



中国认可
检测
INSPECTION
CNAS IB1379

报告编号: 32050013019-24004-25-0105-01



网络安全等级保护 “新点 e 交易”电子交易平台 等级测评报告

被测单位: 苏州国泰新点软件有限公司
测评单位: 苏州如意云网络科技有限公司
报告时间: 2025年10月31日

说明：

一、每个备案系统单独出具测评报告。

二、测评报告编号为四组数据。各组含义和编码规则如下：

第一组为系统备案表编号，由 2 段共 16 位数字组成，可以从公安机关颁发的系统备案证明（或备案回执）上获得。第 1 段即备案证明编号的前 11 位（前 6 位为受理备案公安机关代码，后 5 位为受理备案的公安机关给出的备案单位的顺序编号）；第 2 段即备案证明编号的后 5 位（系统编号）。

第二组为年份，由 2 位数字组成。例如 09 代表 2009 年。

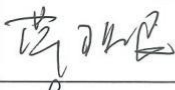
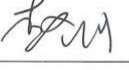
第三组为机构代码，由网络安全等级测评与检测评估机构服务认证证书编号最后四位数字组成。

第四组为本年度系统测评次数，由两位构成。例如 02 表示该系统本年度测评 2 次。

报告编号：32050013019-24004-25-0105-01

【2025 版】

网络安全等级测评基本信息表

被测对象				
被测对象名称	“新点e交易”电子交易平台	安全保护等级	第三级（S3A3）	
备案证明编号	32050013019-24004	统一社会信用代码	91320594060153236B	
被测单位				
单位名称	苏州国泰新点软件有限公司			
单位地址	江苏省苏州市工业园区启泰路66号	邮政编码	215123	
联系人	姓名	蒋铭	职务/职称	经理
	所属部门	信息安全部	办公电话	无
	移动电话	18962289227	电子邮件	jiangm@epoint.com.cn
测评单位				
单位名称	苏州如意云网络科技有限公司		机构代码	SC202127130010105
单位地址	苏州工业园区金鸡湖大道1355号国际科技园A1801室		邮政编码	215000
联系人	姓名	李冬月	职务/职称	总经理
	所属部门	总经办	办公电话	0512-62890636
	移动电话	13771678877	电子邮件	ruiyiyun@seceva.cn
审核批准	编制人		编制日期	2025.10.29
	审核人		审核日期	2025.10.30
	批准人		批准日期	2025.10.31

报告编号：32050013019-24004-25-0105-01

【2025 版】

声明

本报告是“新点 e 交易”电子交易平台（备案证明编号：32050013019-24004）的等级测评报告。

本报告测评结论的有效性建立在被测评单位提供相关证据的真实性基础之上。

本报告中给出的测评结论仅对被测对象当时的安全状态有效。当测评工作完成后，由于被测对象发生变更而涉及到的系统构成组件（或子系统）本报告不再适用。

本报告中给出的测评结论不能作为对被测对象内部部署的相关系统构成组件（或产品）的测评结论。

在任何情况下，若需引用本报告中的测评结果或结论都应保持其原有的意义，不得对相关内容擅自进行增加、修改和伪造或掩盖事实。

苏州如意云网络科技有限公司

2025 年 10 月 31 日



报告编号：32050013019-24004-25-0105-01

【2025 版】

等级测评结论

测评结论和重大风险隐患			
被测对象名称	“新点 e 交易”电子交易平台	安全保护等级	第三级（S3A3）
扩展要求应用情况	☒云计算 ☐移动互联 ☐物联网 ☐工业控制系统 ☐大数据 ☐其他		
被测对象描述	“新点 e 交易”电子交易平台主要提供为招标代理和投标人用于开展招投标活动，同时为代理和评标专家提供使用服务的开评标活动，主要用于代理开标、专家评标等功能。该系统于 2018 年 6 月 5 日由苏州国泰新点软件有限公司立项，系自主研发。系统投入使用时间为 2018 年 7 月 10 日，使用单位为苏州国泰新点软件有限公司。目前该系统由苏州国泰新点软件有限公司信息安全部进行维护，苏州国泰新点软件有限公司为该信息系统等级保护的责任单位。系统部署在华为云，该系统提供 web 应用服务，其中 web 端访问地址为：https://www.etrading.cn。		
安全状况描述	本次安全等级测评采用访谈、核查和测试等测评方法，对“新点 e 交易”电子交易平台的物理机房、网络架构、网络设备、安全设备、系统管理软件、主机操作系统、数据库管理系统、业务应用系统、数据资源、管理制度等具体对象实施了测评。通过测评发现，在安全技术方面具备区域边界隔离、边界访问控制、主机恶意代码查杀、数据定期备份等安全技术措施。在安全管理方面制定了信息安全管理体系及相关制度和流程，信息安全部为职能部门。 本次测评共发现“新点 e 交易”电子交易平台存在安全问题 36 个，其中高风险问题 1 个，中风险问题 31 个，低风险问题 4 个。“新点 e 交易”电子交易平台技术方面尚存问题：如管理用户权限分配、可信验证等需要整改和完善，在管理层面安全方案设计不到位等方面还可以进一步提高。		
等级测评结论	基本符合	重大风险隐患数量	0

重大风险隐患及整改建议

经过单项测评结果判定和整体测评，未发现“新点 e 交易”电子交易平台存在重大风险隐患。

等级测评结论扩展表（云计算安全）

等级测评结论扩展表（云计算安全）			
被测对象 云计算形态	☐ 云计算平台 ☒ 云服务客户业务应用系统(平台报告编号： <u>44030002840-25001-25-0162-01</u>)		
云计算平台名称	华为公有云服务(IaaS)系统	被测对象采用的云计算服务模式	☒ IaaS ☐ PaaS ☐ SaaS
云计算平台服务能力描述			
云计算安全扩展主要要求			符合情况
基础设施位置	a)应保证云计算基础设施位于中国境内。		符合
网络架构	a)应保证云计算平台不承载高于其安全保护等级的业务应用系统；		符合
	b)应实现不同云服务客户虚拟网络之间的隔离；		符合
	c)应具有根据云服务客户业务需求提供通信传输、边界防护、入侵防范等安全机制的能力；		符合
	d)应具有根据云服务客户业务需求自主设置安全策略的能力，包括定义访问路径、选择安全组件、配置安全策略；		符合
	e) 应提供开放接口或开放性安全服务，允许云服务客户接入第三方安全产品或在云计算平台选择第三方安全服务。		符合
访问控制	a) 应在虚拟化网络边界部署访问控制机制，并设置访问控制规则；		符合
	b) 应在不同等级的网络区域边界部署访问控制机制，设置访问控制规则。		符合
入侵防范	a)应能检测到云服务客户发起的网络攻击行为，并能记录攻击类型、攻击时间、攻击流量等；		符合
	b) 应能检测到对虚拟网络节点的网络攻击行为，并能记录攻击类型、攻击时间、攻击流量等；		符合
	c) 应能检测到虚拟机与宿主机、虚拟机与虚拟机之间的异常流量；		符合
	d) 应在检测到网络攻击行为、异常流量情况时进行告警。		符合
安全审计	a) 应对云服务商和云服务客户在远程管理时执行的特权命令进行审计，至少包括虚拟机删除、虚拟机重启；		符合
	b)应保证云服务商对云服务客户系统和数据的操作可被云服务客户审计；		符合

身份鉴别	a) 当远程管理云计算平台中设备时，管理终端和云计算平台之间应建立双向身份验证机制；	符合
访问控制	a) 应保证当虚拟机迁移时，访问控制策略随其迁移；	符合
	b) 应允许云服务客户设置不同虚拟机之间的访问控制策略；	符合
入侵防范	a) 应能检测虚拟机之间的资源隔离失效，并进行告警；	符合
	b) 应能检测非授权新建虚拟机或者重新启用虚拟机，并进行告警；	符合
	c) 应能够检测恶意代码感染及在虚拟机间蔓延的情况，并进行告警；	符合
镜像和快照保护	a) 应针对重要业务系统提供加固的操作系统镜像或操作系统安全加固服务；	符合
	b) 应提供虚拟机镜像、快照完整性校验功能，防止虚拟机镜像被恶意篡改；	符合
	c) 应采取密码技术或其他技术手段防止虚拟机镜像、快照中可能存在的敏感资源被非法访问；	符合
数据完整性和保密性	a) 应确保云服务客户数据、用户个人信息等存储于中国境内，如需出境应遵循国家相关规定；	符合
	b) 应只有在云服务客户授权下，云服务商或第三方才具有云服务客户数据的管理权限；	符合
	c) 应使用校验技术或密码技术保证虚拟机迁移过程中重要数据的完整性，并在检测到完整性受到破坏时采取必要的恢复措施；	符合
	d) 应支持云服务客户部署密钥管理解决方案，保证云服务客户自行实现数据的加解密过程；	符合
数据备份恢复	a) 云服务客户应在本地保存其业务数据的备份；	符合
	b) 应提供查询云服务客户数据及备份存储位置的能力；	符合
	c) 云服务商的云存储服务应保证云服务客户数据存在若干个可用的副本，各副本之间的内容应保持一致；	符合
	d) 应为云服务客户将业务系统及数据迁移到其他云计算平台和本地系统提供技术手段，并协助完成迁移过程；	符合
剩余信息保护	a) 应保证虚拟机所使用的内存和存储空间回收时得到完全清除；	符合
	b) 云服务客户删除业务应用数据时，云计算平台应将云存储中所有副本删除；	符合
集中管控	a) 应能对物理资源和虚拟资源按照策略做统一管理调度与分配；	符合
	b) 应保证云计算平台管理流量与云服务客户业务流量分离；	符合
	c) 应根据云服务商和云服务客户的职责划分，收集各自控制部分的审计数据并实现各自的集中审计；	符合

	d) 应根据云服务商和云服务客户的职责划分，实现各自控制部分，包括虚拟化网络、虚拟机、虚拟化安全设备等的运行状况的集中监测。	符合	
云服务商选择	a)应选择安全合规的云服务商，其所提供的云计算平台应为其所承载的业务应用系统提供相应等级的安全保护能力；	符合	
	b)应在服务水平协议中规定云服务的各项服务内容和具体技术指标；	符合	
	c) 应在服务水平协议中规定云服务商的权限与责任，包括管理范围、职责划分、访问授权、隐私保护、行为准则、违约责任等；	符合	
	d) 应在服务水平协议中规定服务合约到期时，完整提供云服务客户数据，并承诺相关数据在云计算平台上清除；	符合	
	e) 应与选定的云服务商签署保密协议，要求其不得泄露云服务客户数据；	符合	
供应链管理	a) 应确保供应商的选择符合国家有关规定；	符合	
	b)应将供应链安全事件信息或安全威胁信息及时传达到云服务客户；	符合	
	c) 应将供应商的重要变更及时传达到云服务客户，并评估变更带来的安全风险，采取措施对风险进行控制；	符合	
云计算环境管理	a) 云计算平台的运维地点应位于中国境内，境外对境内云计算平台实施运维操作应遵循国家相关规定。	符合	
云计算平台等级测评结论	符合	云计算平台重大风险隐患数量	0

目录

网络安全等级测评基本信息表.....	I
声明	II
等级测评结论.....	III
重大风险隐患及整改建议.....	IV
等级测评结论扩展表（云计算安全）	V
目录	VIII
1 测评项目概述.....	1
1.1 测评目的.....	1
1.2 测评依据.....	1
1.3 测评过程.....	2
1.4 报告分发范围.....	4
2 被测对象描述.....	4
2.1 被测对象概述.....	4
2.1.1 定级结果.....	4
2.1.2 业务和采用的技术.....	4
2.1.3 网络结构.....	5
2.2 测评指标.....	7
2.2.1 安全通用要求指标.....	7
2.2.2 安全扩展要求指标.....	10
2.2.3 其他安全要求指标.....	10
2.2.4 不适用安全要求指标.....	11
2.3 测评对象.....	17
2.3.1 测评对象选择方法.....	17
2.3.2 测评对象选择结果.....	18
3 单项测评结果分析.....	30
3.1 安全物理环境.....	31
3.1.1 已有安全控制措施汇总分析.....	31
3.1.2 主要安全问题汇总分析.....	31

3.2	安全通信网络.....	31
3.2.1	已有安全控制措施汇总分析.....	31
3.2.2	主要安全问题汇总分析.....	32
3.3	安全区域边界.....	32
3.3.1	已有安全控制措施汇总分析.....	32
3.3.2	主要安全问题汇总分析.....	34
3.4	安全计算环境.....	35
3.4.1	网络设备.....	35
3.4.2	安全设备.....	37
3.4.3	服务器和终端.....	40
3.4.4	系统管理软件/平台.....	42
3.4.5	业务应用系统/平台.....	45
3.4.6	数据资源.....	48
3.4.7	其他系统或设备.....	49
3.4.8	安全扩展要求.....	49
3.5	安全管理中心.....	50
3.5.1	已有安全控制措施汇总分析.....	50
3.5.2	主要安全问题汇总分析.....	52
3.6	安全管理制度.....	52
3.6.1	已有安全控制措施汇总分析.....	52
3.6.2	主要安全问题汇总分析.....	53
3.7	安全管理机构.....	53
3.7.1	已有安全控制措施汇总分析.....	53
3.7.2	主要安全问题汇总分析.....	54
3.8	安全管理人员.....	54
3.8.1	已有安全控制措施汇总分析.....	54
3.8.2	主要安全问题汇总分析.....	55
3.9	安全建设管理.....	55
3.9.1	已有安全控制措施汇总分析.....	55

3.9.2	主要安全问题汇总分析	56
3.10	安全运维管理	57
3.10.1	已有安全控制措施汇总分析	57
3.10.2	主要安全问题汇总分析	58
3.11	其他安全要求指标	59
3.12	验证测试	59
3.12.1	漏洞扫描	59
3.12.2	渗透测试	63
3.13	安全问题汇总	65
4	整体测评	85
4.1	安全控制点间安全测评	85
4.2	区域间安全测评	85
4.3	整体测评结果汇总	86
5	安全问题风险分析	86
5.1	低中高风险安全问题分析	86
5.2	重大风险隐患分析	101
6	总体评价	102
7	等级测评结论	105
8	安全问题整改建议	105
8.1	低中高风险安全问题整改建议	105
8.2	重大风险隐患整改建议	122
附录 A	被测对象资产	123
A.1	物理机房	123
A.2	网络设备	123
A.3	安全设备	123
A.4	服务器	129
A.5	终端设备	133
A.6	其他系统或设备	134
A.7	系统管理软件/平台	134

A.8	业务应用系统/平台	134
A.9	数据资源	135
A.10	密码产品	135
A.11	安全相关人员	135
A.12	安全管理文档	136
附录 B	上次测评问题整改情况说明	141
附录 C	单项测评结果汇总	144
C.1	安全物理环境	144
C.2	安全通信网络	145
C.3	安全区域边界	145
C.4	安全计算环境	146
C.4.1	网络设备	146
C.4.2	安全设备	146
C.4.3	服务器和终端	148
C.4.4	系统管理软件/平台	153
C.4.5	业务应用系统/平台	154
C.4.6	数据资源	155
C.4.7	其他系统或设备	155
C.5	安全管理中心	156
C.6	安全管理制度	156
C.7	安全管理机构	157
C.8	安全管理人员	157
C.9	安全建设管理	157
C.10	安全运维管理	158
C.11	其他安全要求指标	159
附录 D	单项测评结果记录	159
D.1	安全物理环境	159
D.1.1	安全通用要求部分	159
D.1.2	安全扩展要求部分	161

D.2 安全通信网络.....162

 D.2.1 安全通用要求部分.....162

 D.2.2 安全扩展要求部分.....164

D.3 安全区域边界.....165

 D.3.1 安全通用要求部分.....165

 D.3.2 安全扩展要求部分.....169

D.4 安全计算环境.....171

 D.4.1 安全通用要求部分.....171

 D.4.2 安全扩展要求部分.....380

D.5 安全管理中心.....383

 D.5.1 安全通用要求部分.....383

 D.5.2 安全扩展要求部分.....386

D.6 安全管理制度.....386

 D.6.1 安全通用要求部分.....386

D.7 安全管理机构.....388

 D.7.1 安全通用要求部分.....388

D.8 安全管理人员.....392

 D.8.1 安全通用要求部分.....393

D.9 安全建设管理.....395

 D.9.1 安全通用要求部分.....395

 D.9.2 安全扩展要求部分.....401

D.10 安全运维管理.....402

 D.10.1 安全通用要求部分.....402

 D.10.2 安全扩展要求部分.....415

D.11 其他安全要求.....416

附录 E 漏洞扫描结果记录.....416

附录 F 渗透测试结果记录.....416

 F.1 暴力破解.....416

附录 G 重大风险隐患触发项参照表.....417

附录 H 重大风险隐患及整改情况.....428

附录 I 威胁列表.....428

附录 J 云计算平台测评及整改情况.....429

1 测评项目概述

1.1 测评目的

安全等级测评的目的是通过对目标系统在安全技术及管理方面的测评,对目标系统的安全技术状态及安全管理状况做出初步判断,给出目标系统在安全技术及安全管理方面与其相应安全等级保护要求之间的差距。测评结论作为委托方进一步完善系统安全策略及安全技术防护措施依据。

为进一步提高信息的保障能力,根据《信息安全等级保护管理办法》(公通字 2007【43】号)的精神,苏州国泰新点软件有限公司委托苏州如意云网络科技有限公司(SC202127130010105)对“新点 e 交易”电子交易平台实施等级测评,以期发现被测评对象和等级保护标准的差距以及存在的安全隐患,为后续的安全整改工作提供参考依据。

1.2 测评依据

- (1) GB/T 22239—2019 《信息安全技术 网络安全等级保护基本要求》;
- (2) GB/T 28448—2019 《信息安全技术 网络安全等级保护测评要求》。

测评过程中参考依据:

- (1) 《中华人民共和国计算机信息系统安全保护等级划分准则》(国务院 147 号令);
- (2) 《信息安全等级保护管理办法》(公通字[2007]43 号);
- (3) GB 17859—1999 《计算机信息系统 安全保护等级划分准则》;
- (4) GB/T 28449—2018 《信息安全技术 网络安全等级保护测评过程指南》;
- (5) GB/T 22240—2020 《信息安全技术 网络安全等级保护定级指南》;

- (6) GB/T 20984—2022 《信息安全技术 信息安全风险评估方法》;
- (7) 信息系统安全等级保护备案材料;
- (8) 《网络安全等级保护测评报告 2025 版模板》;
- (9) 《网络安全等级保护测评高风险判定实施指引(试行)》;
- (10) 《苏州国泰新点软件有限公司网络安全等级保护测评项目合同》。

1.3 测评过程

本次等级测评分为四个过程:测评准备过程、方案编制过程、测评实施过程、分析与报告编制过程。具体如图 1-1 所示。其中,各阶段的时间安排如下:

- 1、2025 年 08 月 20 日~2025 年 08 月 22 日,测评准备过程。
- 2、2025 年 08 月 25 日~2025 年 08 月 28 日,方案编制过程。
- 3、2025 年 09 月 02 日~2025 年 09 月 04 日,现场实施过程。
- 4、2025 年 09 月 05 日~2025 年 10 月 31 日,分析与报告编制过程。

其中,2025 年 09 月 02 日召开了项目现场启动会议,确定了工作方案及项目人员名单;2025 年 09 月 04 日召开了项目末次会议,确认了测评发现的问题。

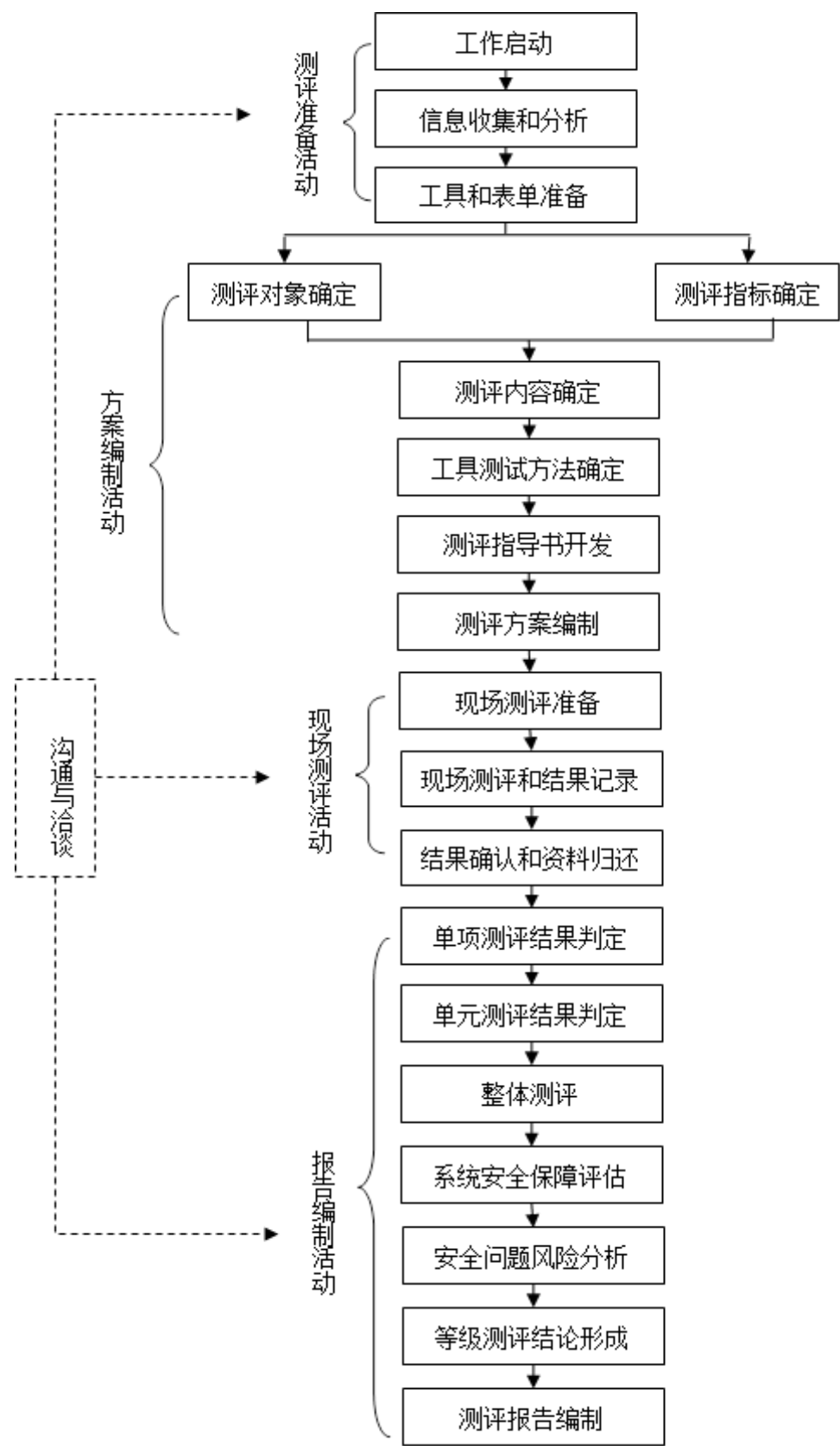


图 1-1 等级保护测评工作流程图

1.4 报告分发范围

本报告一式 3 份，其中，1 份提交苏州国泰新点软件有限公司，1 份提交备案机关，1 份由苏州如意云网络科技有限公司留存。

2 被测对象描述

2.1 被测对象概述

2.1.1 定级结果

表 2-1 定级结果

被测对象名称	安全保护等级	业务信息安全保护等级	系统服务安全保护等级
“新点 e 交易”电子交易平台	3 级	3 级	3 级

2.1.2 业务和采用的技术

“新点 e 交易”电子交易平台主要提供为招标代理和投标人用于开展招投标活动，同时为代理和评标专家提供使用服务的开评标活动，主要用于代理开标、专家评标等功能。该系统于 2018 年 6 月 5 日由苏州国泰新点软件有限公司立项，系自主研发。系统投入使用时间为 2018 年 7 月 10 日，使用单位为苏州国泰新点软件有限公司。目前该系统由苏州国泰新点软件有限公司信息安全部进行维护，苏州国泰新点软件有限公司为该信息系统等级保护的责任单位。该系统服务器所采用的操作系统及版本为 CentOS Linux release 7.4.1708 (Core)，采用了 MySQL-5.7.39 数据库和 Nginx-1.16.1 中间件，该系统主要采用开发语言为 java、c 语言等，应用系统框架使用 spring、springboot 和 mybatisplus 等，同时应用系统采用了 maven 等技术。系统部署在华为云，该系统提供 web 应用服务，其中 web 端访问地址为：<https://www.etrading.cn>。

2.1.3 网络结构

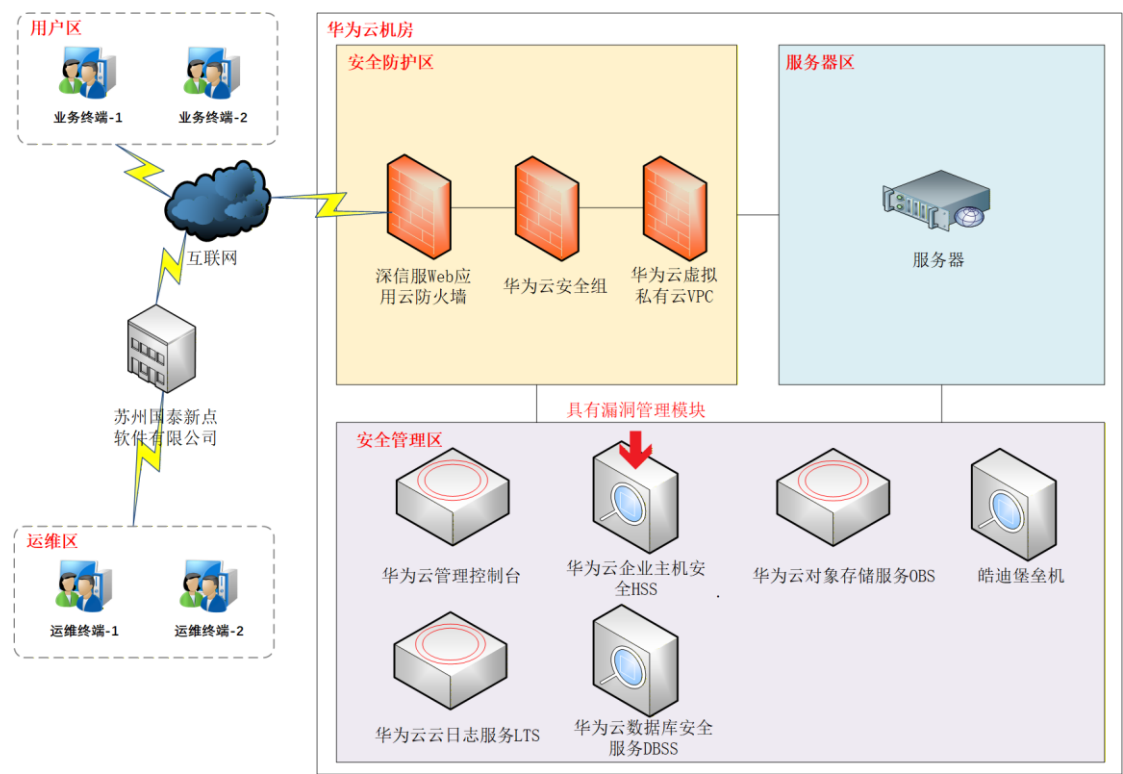


图 2-1 网络拓扑图

如图 2-1 网络结构图所示,“新点 e 交易”电子交易平台的网络结构主要包括：安全防护区、安全管理区、服务器区、用户区、运维区。

1、安全防护区的作用是保证进入网络内部数据流的合法性，防止外部非法数据流的侵入，同时管理内部网络用户的访问权限。部署了深信服 Web 应用云防火墙，深信服 Web 应用云防火墙为华为云授权服务，通过对主干链路上的流量进行检测，对 Web 应用中的各类攻击，防御 OWASP 常见威胁，如 SQL 注入、XSS 注入、跨站请求伪造攻击、Cookie 篡改以及应用层 Web 攻击等，能有效解决网页挂马、敏感信息泄露等安全问题，充分保障 Web 应用安全；部署了华为云安全组，可用于专有网络中的产品实例划分成不同的安全域，并为每个安全域定义不同的访问控制规则；部署了华为云虚拟私有云 VPC，可以将 VPC 网络中的产品实例划分成不同的安全域，并为每个安全域定义不同的访问控制规则。

2、安全管理区的作用是保障“新点 e 交易”电子交易平台安全、稳定的运行。

部署了华为云企业主机安全 HSS，提供了恶意代码查杀、黑客入侵检测、漏洞风险检测和修复等功能；部署了华为云对象存储服务 OBS，提供海量、安全、高可靠、低成本的数据存储能力，可供用户存储任意类型和大小的数据；部署了皓迪堡垒机，提供了内部人员或外联人员的远程访问管理使用，并记录了用户的操作记录；部署了华为云云日志服务 LTS，提供日志收集、实时查询、存储等功能，无需开发即可利用日志做实时决策分析，提升日志处理效率，帮助用户轻松应对日志实时采集、查询分析等日常运营、运维场景；部署了华为云数据库安全服务 DBSS，基于机器学习机制和大数据分析技术，提供数据库审计，SQL 注入攻击检测，风险操作识别等功能，保障云上数据库的安全；部署了华为云管理控制台，虚拟化资源管理、账户管理和服务管理。

3、服务器区的作用是承载了“新点 e 交易”电子交易平台的运行，部署了系统相关的服务器，主要实现业务数据处理和存储。

4、用户区部署了多台业务终端，用于业务用户使用平台功能。

5、运维区部署了多台运维终端，用于系统运维管理、数据备份存储等。

运维人员通过华为云管理控制台对安全组件进行远程管理；重要业务数据和重要个人信息均保存在数据库内，按照数据库备份策略，每天凌晨 6 点通过自研脚本 obs-backup.sh，将前一天的数据库数据备份，备份到华为云对象存储服务 OBS 中，同时每月通过手动备份方式将系统数据备份至运维终端-1 的 D:\备份文件夹中；网络设备和安全设备的配置文件在每次修改配置前后均对配置数据进行一次备份，备份文件保存在运维终端-1 的 D:\备份文件夹中。

2.2 测评指标

2.2.1 安全通用要求指标

表 2-2 安全通用要求指标		
安全类	控制点	测评项数
安全物理环境	物理位置选择	2
	物理访问控制	1
	防盗窃和防破坏	3
	防雷击	2
	防火	3
	防水和防潮	3
	防静电	2
	温湿度控制	1
	电力供应	3
	电磁防护	2
安全通信网络	网络架构	5
	通信传输	2
	可信验证	1
安全区域边界	边界防护	4
	访问控制	5
	入侵防范	4
	恶意代码和垃圾邮件防范	2
	安全审计	4
	可信验证	1
安全计算环境	身份鉴别	4
	访问控制	7
	安全审计	4

安全类	控制点	测评项数
	入侵防范	6
	恶意代码防范	1
	可信验证	1
	数据完整性	2
	数据保密性	2
	数据备份恢复	3
	剩余信息保护	2
	个人信息保护	2
安全管理中心	系统管理	2
	审计管理	2
	安全管理	2
	集中管控	6
安全管理制度	安全策略	1
	管理制度	3
	制定和发布	2
	评审和修订	1
安全管理机构	岗位设置	3
	人员配备	2
	授权和审批	3
	沟通和合作	3
	审核和检查	3
安全管理人员	人员录用	3
	人员离岗	2
	安全意识教育和培训	3
	外部人员访问管理	4

安全类	控制点	测评项数
安全建设管理	定级和备案	4
	安全方案设计	3
	产品采购和使用	3
	自行软件开发	7
	外包软件开发	3
	工程实施	3
	测试验收	2
	系统交付	3
	等级测评	3
	服务供应商选择	3
安全运维管理	环境管理	3
	资产管理	3
	介质管理	2
	设备维护管理	4
	漏洞和风险管理	2
	网络和系统安全管理	10
	恶意代码防范管理	2
	配置管理	2
	密码管理	2
	变更管理	3
	备份与恢复管理	3
	安全事件处置	4
	应急预案管理	4
	外包运维管理	4

安全类	控制点	测评项数
安全通用要求指标数量统计		211

2.2.2 安全扩展要求指标

表 2-3 安全扩展要求指标

扩展类型	安全类	控制点	测评项数
云计算安全扩展要求	安全物理环境	基础设施位置	1
	安全通信网络	网络架构	5
	安全区域边界	访问控制	2
	安全区域边界	入侵防范	4
	安全区域边界	安全审计	2
	安全计算环境	身份鉴别	1
	安全计算环境	访问控制	2
	安全计算环境	入侵防范	3
	安全计算环境	镜像和快照保护	3
	安全计算环境	数据完整性和保密性	4
	安全计算环境	数据备份恢复	4
	安全计算环境	剩余信息保护	2
	安全管理中心	集中管控	4
	安全建设管理	云服务商选择	5
	安全建设管理	供应链管理	3
	安全运维管理	云计算环境管理	1
安全扩展要求指标数量统计			46

2.2.3 其他安全要求指标

本次测评不包含其他安全要求指标。

2.2.4 不适用安全要求指标

表 2-4 不适用安全要求指标

安全类	控制点	不适用项	不适用原因
安全物理环境	物理位置选择	a)机房场地应选择在具有防震、防风和防雨等能力的建筑内；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。
		b)机房场地应避免设在建筑物的顶层或地下室，否则应加强防水和防潮措施。	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。
	物理访问控制	机房出入口应配置电子门禁系统，控制、鉴别和记录进入的人员。	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。
	防盗窃和防破坏	a)应将设备或主要部件进行固定，并设置明显的不易去除的标识；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。
		b)应将通信线缆铺设在隐蔽安全处；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。
		c)应设置机房防盗报警系统或设置有专人值守的视频监控系统。	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。
	防雷击	a)应将各类机柜、设施和设备等通过接地系统安全接地；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。
		b)应采取措施防止感应雷，例如设置防雷保安器或过压保护装置等。	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。
	防火	a)机房应设置火灾自动消防系统，能够自动检测火情、自动报警，并自动灭火；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。
		b)机房及相关的工作房间和辅助房应采用具有耐火等级的建筑材料；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。
		c)应对机房划分区域进行管理，区域和区域之间设置隔离	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云

安全类	控制点	不适用项	不适用原因
		防火措施。	负责，此项标准不适用。
	防水和防潮	a)应采取措施防止雨水通过机房窗户、屋顶和墙壁渗透；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。
		b)应采取措施防止机房内水蒸气结露和地下积水的转移与渗透；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。
		c)应安装对水敏感的检测仪表或元件，对机房进行防水检测和报警。	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。
	防静电	a)应采用防静电地板或地面并采用必要的接地防静电措施；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。
		b)应采取措施防止静电的产生，例如采用静电消除器、佩戴防静电手环等。	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。
	温湿度控制	应设置温湿度自动调节设施，使机房温湿度的变化在设备运行所允许的范围之内。	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。
	电力供应	a)应在机房供电线路上配置稳压器和过电压防护设备；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。
		b)应提供短期的备用电力供应，至少满足设备在断电情况下的正常运行要求；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。
		c)应设置冗余或并行的电力电缆线路为计算机系统供电。	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。
	电磁防护	a)电源线和通信线缆应隔离铺设，避免互相干扰；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。
		b)应对关键设备实施电磁屏蔽。	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。

安全类	控制点	不适用项	不适用原因
安全通信网络	网络架构	a)应保证网络设备的业务处理能力满足业务高峰期需要；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项不适用。
安全区域边界	边界防护	d)应限制无线网络的使用，保证无线网络通过受控的边界设备接入内部网络。	该网络不涉及无线网络使用，此项不适用。
	恶意代码和垃圾邮件防范	b)应在关键网络节点处对垃圾邮件进行检测和防护，并维护垃圾邮件防护机制的升级和更新。	该网络未部署邮件系统，此项不适用。
安全建设管理	产品采购和使用	b)应确保密码产品与服务的采购和使用符合国家密码管理主管部门的要求；	单位未采购和使用密码产品，无该需求，此项不适用。
	外包软件开发	a)应在软件交付前检测其中可能存在的恶意代码；	系统不涉及外包软件开发，故此项不适用。
		b)应保证开发单位提供软件设计文档和使用指南；	系统不涉及外包软件开发，故此项不适用。
		c)应保证开发单位提供软件源代码，并审查软件中可能存在的后门和隐蔽信道。	系统不涉及外包软件开发，故此项不适用。
安全运维管理	环境管理	a)应指定专门的部门或人员负责机房安全，对机房出入进行管理，定期对机房供配电、空调、温湿度控制、消防等设施进行维护管理；	系统部署在华为云，机房物理环境管理由华为云负责，此项不适用。
		b)应建立机房安全管理制度，对有关物理访问、物品带进出和环境安全等方面的管理作出规定；	系统部署在华为云，机房物理环境管理由华为云负责，此项不适用。
	密码管理	a)应遵循密码相关国家标准和行业标准；	当前测评对象未涉及密码产品，无密码产品相关要求，故此项不适用。
		b)应使用国家密码管理主管部门认证核准的密码技术和产品。	当前测评对象未涉及密码产品，无密码产品相关要求，故此项不适用。

安全类	控制点	不适用项	不适用原因
	外包运维管理	a)应确保外包运维服务商的选择符合国家的有关规定；	系统未涉及外包运维服务，此项不适用。
		b)应与选定的外包运维服务商签订相关的协议，明确约定外包运维的范围、工作内容；	系统未涉及外包运维服务，此项不适用。
		c)应保证选择的外包运维服务商在技术和管理方面均应具有按照等级保护要求开展安全运维工作的能力，并将能力要求在签订的协议中明确；	系统未涉及外包运维服务，此项不适用。
		d)应在与外包运维服务商签订的协议中明确所有相关的安全要求，如可能涉及对敏感信息的访问、处理、存储要求，对 IT 基础设施中断服务的应急保障要求等。	系统未涉及外包运维服务，此项不适用。
安全通信网络 (云计算安全扩展要求)	网络架构	b)应实现不同云服务客户虚拟网络之间的隔离；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。
		c)应具有根据云服务客户业务需求提供通信传输、边界防护、入侵防范等安全机制的能力；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。
		d)应具有根据云服务客户业务需求自主设置安全策略的能力，包括定义访问路径、选择安全组件、配置安全策略；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项不适用。
		e)应提供开放接口或开放性安全服务，允许云服务客户接入第三方安全产品或在云计算平台选择第三方安全服务。	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项不适用。
安全区域边界 (云计算安全扩展要求)	访问控制	a)应在虚拟化网络边界部署访问控制机制，并设置访问控制规则；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。

安全类	控制点	不适用项	不适用原因
安全计算环境 (云计算安全扩展要求)		a)应保证当虚拟机迁移时，访问控制策略随其迁移；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。
	入侵防范	a)应能检测虚拟机之间的资源隔离失效，并进行告警；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。
	镜像和快照保护	a)应针对重要业务系统提供加固的操作系统镜像或操作系统安全加固服务；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。
		b)应提供虚拟机镜像、快照完整性校验功能，防止虚拟机镜像被恶意篡改；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。
		c)应采取密码技术或其他技术手段防止虚拟机镜像、快照中可能存在的敏感资源被非法访问。	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。
	数据完整性和保密性	b)应确保只有在云服务客户授权下，云服务商或第三方才具有云服务客户数据的管理权限；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。
		c)应使用校验码或密码技术确保虚拟机迁移过程中重要数据的完整性，并在检测到完整性受到破坏时采取必要的恢复措施；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。
		d)应支持云服务客户部署密钥管理解决方案，保证云服务客户自行实现数据的加解密过程。	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。
	数据备份恢复	b)应提供查询云服务客户数据及备份存储位置的能力；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。
		c)云服务商的云存储服务应保证云服务客户数据存在若干个可用的副本，各副本之间的内容应保持一致；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。

安全类	控制点	不适用项	不适用原因
		d)应为云服务客户将业务系统及数据迁移到其他云计算平台和本地系统提供技术手段，并协助完成迁移过程。	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。
	剩余信息保护	a)应保证虚拟机所使用的内存和存储空间回收时得到完全清除；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。
		b)云服务客户删除业务应用数据时，云计算平台应将云存储中所有副本删除。	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。
安全管理中心（云计算安全扩展要求）	集中管控	a)应能对物理资源和虚拟资源按照策略做统一管理调度与分配；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。
		b)应保证云计算平台管理流量与云服务客户业务流量分离；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。
安全建设管理（云计算安全扩展要求）	供应链管理	a)应确保供应商的选择符合国家有关规定；	该服务由云平台提供，云租户不适用。
		b)应将供应链安全事件信息或安全威胁信息及时传达到云服务客户；	该服务由云平台提供，云租户不适用。
		c)应将供应商的重要变更及时传达到云服务客户，并评估变更带来的安全风险，采取措施对风险进行控制。	该服务由云平台提供，云租户不适用。
安全运维管理（云计算安全扩展要求）	云计算环境管理	云计算平台的运维地点应位于中国境内，境外对境内云计算平台实施运维操作应遵循国家相关规定。	该服务由云平台提供，云租户不适用。
表中不适用指标数量			61

2.3 测评对象

2.3.1 测评对象选择方法

苏州国泰新点软件有限公司“新点 e 交易”电子交易平台为第三级系统。第三级定级对象的等级测评，测评对象种类上基本覆盖、数量进行抽样，重点抽查主要的设备、设施、人员和文档等，抽查的测评对象种类主要考虑以下几个方面：

——主机房（包括其环境、设备和设施等）和部分辅机房，应将放置了服务于定级对象的局部（包括整体）或对定级对象的局部（包括整体）安全性起重要作用的设备、设施的辅机房选取作为测评对象；

——存储被测定级对象重要数据的介质的存放环境；

——办公场地；

——整个系统的网络拓扑结构；

——安全设备，包括防火墙、入侵检测设备和防病毒网关等；

——边界网络设备（可能会包含安全设备），包括路由器、防火墙、认证网关和边界接入设备（如楼层交换机）等；

——对整个定级对象或其局部的安全性起作用的网络互联设备，如核心交换机、汇聚层交换机、路由器等；

——承载被测定级对象主要业务或数据的服务器（包括其操作系统和数据库）；

——管理终端和主要业务应用系统终端；

——虚拟设备，包括虚拟机、虚拟网络设备、虚拟安全设备等；

——云操作系统、云业务管理平台、虚拟机监视器；

——云租户网络控制器；

- 云应用开发平台等；
- 能够完成被测定级对象不同业务使命的业务应用系统；
- 业务备份系统；
- 信息安全主管人员、各方面的负责人员、具体负责安全管理的当事人、业务负责人；
- 涉及到定级对象安全的所有管理制度和记录。

在本级定级对象测评时，定级对象中配置相同的安全设备、边界网络设备、网络互联设备、服务器、终端以及备份设备,每类应至少抽查两台作为测评对象。

2.3.2 测评对象选择结果

2.3.2.1 物理机房

表 2-5 物理机房

序号	机房名称	物理位置	重要程度
1	华为云机房	华北-北京一区	关键

2.3.2.2 网络设备

表 2-6 网络设备

序号	设备名称	是否虚拟设备	系统及版本	品牌及型号	用途	重要程度
1	华为云虚拟私有云 VPC	是	无	华为云	可以将 VPC 网络中的产品实例划分成不同的安全域,并为每个安全域定义不同的访问控制规则。	关键

2.3.2.3 安全设备

表 2-7 安全设备

序号	设备名称	是否虚拟设备	系统及版本	品牌及型号	用途	重要程度
1	深信服 W	是	V8.0.60	深信服 Web	通过对主干链路	关键

序号	设备名称	是否虚拟设备	系统及版本	品牌及型号	用途	重要程度
	eb 应用云防火墙			应用云防火墙	上的流量进行检测，对 Web 应用中的各类攻击，防御OWASP常见威胁，如 SQL 注入、XSS 注入、跨站请求伪造攻击、Cookie 篡改以及应用层 Web 攻击等，能有效解决网页挂马、敏感信息泄露等安全问题，充分保障 Web 应用安全。	
2	华为云安全组	是	基础版	华为云	可用于专有网络中的产品实例划分成不同的安全域，并为每个安全域定义不同的访问控制规则。	关键
3	华为云企业主机安全 HSS	是	企业版	华为云	提供了恶意代码查杀、黑客入侵检测、漏洞风险检测和修复等功能。	重要
4	华为云对象存储服务 OBS	是	无	华为云	提供海量、安全、高可靠、低成本的数据存储能力，可供用户存储任意类型和大小的数据。	重要
5	皓迪堡垒机	否	Version 2.0	皓迪运维管理系统 HD-OAS-500	提供了内部人员或外联人员的远程访问管理使用，并记录了用户的操作记录。	重要
6	华为云云日志服务	是	基础版	华为云	提供日志收集、实时查询、存储等功	重要

序号	设备名称	是否虚拟设备	系统及版本	品牌及型号	用途	重要程度
	LTS				能, 无需开发即可利用日志做实时决策分析, 提升日志处理效率, 帮助用户轻松应对日志实时采集、查询分析等日常运营、运维场景。	
7	华为云数据库安全服务 DBS S	是	基础版	华为云	基于机器学习机制和大数据分析技术, 提供数据库审计, SQL 注入攻击检测, 风险操作识别等功能, 保障云上数据库的安全。	重要

2.3.2.4 服务器

表 2-8 服务器

序号	设备名称	所属业务应用系统/平台	是否虚拟设备	操作系统及版本	数据库管理系统及版本	中间件及版本	重要程度
1	eCloud 相关集成服务器	“新点 e 交易”电子交易平台	是	CentOS Linux release 7.4.1708 (Core)	无	无	关键
2	对外服务器	“新点 e 交易”电子交易平台	是	CentOS Linux release 7.4.1708 (Core)	无	无	关键
3	竞价与产权服务器	“新点 e 交易”电子交易平台	是	CentOS Linux release 7.4.1708 (Core)	无	无	关键
4	数据库服务器	“新点 e 交易”电子交	是	CentOS Linux release	MySQL 5.7.39	无	关键

序号	设备名称	所属业务应用系统/平台	是否虚拟设备	操作系统及版本	数据库管理系统及版本	中间件及版本	重要程度
		易平台		7.4.1708 (Core)			
5	业务框架支撑服务器	“新点 e 交易”电子交易平台	是	CentOS Linux release 7.4.1708 (Core)	无	无	关键
6	电子交易部署服务器	“新点 e 交易”电子交易平台	是	CentOS Linux release 7.4.1708 (Core)	无	无	关键
7	数据推送服务器	“新点 e 交易”电子交易平台	是	CentOS Linux release 7.4.1708 (Core)	无	无	关键
8	应用服务器	“新点 e 交易”电子交易平台	是	CentOS Linux release 7.4.1708 (Core)	无	Nginx 1.16.1	关键
9	中招前置机服务器	“新点 e 交易”电子交易平台	是	CentOS Linux release 7.4.1708 (Core)	无	无	关键
10	网站前台服务器	“新点 e 交易”电子交易平台	是	CentOS Linux release 7.4.1708 (Core)	无	无	关键
11	评标服务器	“新点 e 交易”电子交易平台	是	CentOS Linux release 7.4.1708 (Core)	无	无	关键
12	智能设备与全文检索服务器	“新点 e 交易”电子交易平台	是	CentOS Linux release 7.4.1708 (Core)	无	无	关键

序号	设备名称	所属业务应用系统/平台	是否虚拟设备	操作系统及版本	数据库管理系统及版本	中间件及版本	重要程度
13	限额会员端服务器	“新点 e 交易”电子交易平台	是	CentOS Linux release 7.4.1708 (Core)	无	无	关键
14	评标中间价与诚信库接口服务器	“新点 e 交易”电子交易平台	是	CentOS Linux release 7.4.1708 (Core)	无	无	关键
15	诚信库部署服务器	“新点 e 交易”电子交易平台	是	CentOS Linux release 7.4.1708 (Core)	无	无	关键
16	新点限额集群服务器	“新点 e 交易”电子交易平台	是	CentOS Linux release 7.4.1708 (Core)	无	无	关键
17	江苏限额集群服务器	“新点 e 交易”电子交易平台	是	CentOS Linux release 7.4.1708 (Core)	无	无	关键
18	评标中间服务器	“新点 e 交易”电子交易平台	是	CentOS Linux release 7.4.1708 (Core)	无	无	关键
19	项目 1-不见面大厅服务器	“新点 e 交易”电子交易平台	是	CentOS Linux release 7.4.1708 (Core)	无	无	关键
20	项目 1-新点 e 交易推送服务 2.0 前置机	“新点 e 交易”电子交易平台	是	CentOS Linux release 7.4.1708 (Core)	无	无	关键
21	项目 1-开标大厅服	“新点 e 交易”电子交	是	CentOS Linux release	无	无	关键

序号	设备名称	所属业务应用系统/平台	是否虚拟设备	操作系统及版本	数据库管理系统及版本	中间件及版本	重要程度
	务器	易平台		7.4.1708 (Core)			
22	档案服务器	“新点 e 交易”电子交易平台	是	CentOS Linux release 7.4.1708 (Core)	无	无	关键

2.3.2.5 终端设备

表 2-9 终端设备

序号	设备名称	是否虚拟设备	操作系统及版本	用途	重要程度
1	运维终端-1	否	Windows 7 旗舰版 (内部版本 7601: Service Pack 1)	运维管理，备份网络安全设备配置文件和系统重要数据。	重要
2	运维终端-2	否	Windows 7 旗舰版 (内部版本 7601: Service Pack 1)	运维管理。	一般
3	业务终端-1	否	Windows 7 旗舰版 (内部版本 7601: Service Pack 1)	业务操作。	一般
4	业务终端-2	否	Windows 7 旗舰版 (内部版本 7601: Service Pack 1)	业务操作。	一般

2.3.2.6 其他系统或设备

表 2-10 其他系统或设备

序号	设备名称	是否虚拟设备	系统及版本	设备类别/用途	重要程度	IP 地址	备注
无							

2.3.2.7 系统管理软件/平台

表 2-11 系统管理软件/平台

序号	系统管理软件/平台名称	主要功能	版本	所在设备名称	重要程度
1	华为云管理控制台	虚拟化资源管理、账户管理和服务管理。	无	华为云	重要
2	Nginx 中间件	应用服务代理。	Nginx 1.16.1	应用服务器	关键
3	MySQL 数据库	存储数据。	MySQL 5.7.39	数据库服务器	关键

2.3.2.8 业务应用系统/平台

表 2-12 业务应用系统/平台

序号	业务应用系统/平台名称	主要功能	业务应用软件及版本	开发厂商	重要程度
1	“新点 e 交易”电子交易平台	为招标代理和投标人用于开展招标投标活动,同时为代理和评标专家提供使用服务的开评标活动,主要用于代理开标、专家评标等。	V1.0	苏州国泰新点软件有限公司	关键

2.3.2.9 数据资源

表 2-13 数据资源

序号	数据类别	所属业务应用	安全防护需求	重要程度
1	重要业务数据	“新点 e 交易”电子交易平台	完整性、保密性、可用性	关键
2	重要个人信息	“新点 e 交易”电子交易平台	完整性、保密性、可用性	关键

2.3.2.10 安全相关人员

表 2-14 安全相关人员

序号	姓名	岗位/角色	联系方式	所属单位
1	蒋铭	安全主管	18962289227	苏州国泰新点软件有限公司
2	张鑫	安全管理员	18921952453	苏州国泰新点软件有限公司
3	杨涛	系统管理员/应用管理员/ 数据管理员	18951132006	苏州国泰新点软件有限公司
4	刘波	机房管理员/网络管理员	15150227530	苏州国泰新点软件有限公司
5	屈智	资产管理员/审计管理员	13812995671	苏州国泰新点软件有限公司

2.3.2.11 安全管理文档

表 2-15 安全管理文档

序号	文档名称	主要内容
1	《信息安全管理办法》	明确说明信息安全的总体方针、信息系统管理的原则、信息系统安全工作的总体目标及适用范围等。
2	《信息系统开发程序库修改登记表》	包括变更内容、时间、修改人和批准人等内容。
3	《系统运维巡检记录表》	包括日常巡检记录、运行维护记录、参数的设置和修改等内容。
4	《数据备份恢复测试记录》	包括备份恢复数据名称、备份恢复人员、备份恢复结果等内容。
5	《服务水平协议》	明确云服务商所提供云服务的各项服务内容和具体技术指标，同时规定云服务商的权限与责任，包括管理范围、职责划分、访问授权、隐私保护、行为准则、违约责任等内容。
6	《漏洞扫描记录》	包括时间、漏洞等情况、检测结果和检测结果分析等内容。
7	《代码编写安全规范》	对代码排版要求、注释规范、方法(函数)注释规范

序号	文档名称	主要内容
		以及变量使用等部分进行规范要求。
8	《变更审批记录》	包括变更类型、申报流程、审批部门、批准人等方面内容。
9	《专家评审意见表》	包括评审人员姓名、评审时间、评审对象、评审意见等内容。
10	《介质使用记录表》	内容包含介质名称、借用人、借用时间、归还时间、借用原因等。
11	《系统总体安全建设规划书》	明确系统建设时的各流程以及选择的基本安全措施。
12	《安全设计方案》	根据安全保护等级进行安全整体规划，对风险分析、数据安全需求、运行安全需求、系统结构及部署、系统安全设计和密码技术相关内容进行了详细规划，形成了配套文件。
13	《恶意代码培训记录表》	内容包括培训名称、培训类别、培训人数、培训地点等。
14	《技术维护服务供应商管理》	已对服务供应商变更服务内容进行明确规定。
15	《供应商评价审核制度》	制度中明确了评价指标、考核内容、进入及退出机制等。
16	《数据备份清单》	内容包括备份方式及备份周期等。
17	《应急预案评审记录》	内容包括：应急预案名称、评审人、评审方式、预案评审、评审意见等。
18	《应急预案评审修订记录》	内容包括：应急预案名称、编制人、修订日期、适用单位及地点、层次结构、编制程序、修改意见等。
19	《设备操作手册》	内容包括：设备名称及型号、配置描述、安装说明、维护、设备操作、参数设置等。
20	《设备带离审批记录》	包括设备名称、带离事由、审批人等内容。
21	《培训记录》	内容包括：培训时间、培训内容、培训人员、培训地点等。
22	《用户手册》	明确系统操作方法，确保了用户基础操作的正确性。

序号	文档名称	主要内容
23	《系统使用指南》	明确系统使用方法，包含提高工作效率的方法和 一些实用的小技巧等内容。
24	《系统概要设计说明文档》	明确说明系统设计、开发各阶段的情况。
25	《系统外联申请表》	详细记录了申请部门、申请人、申请事项、审核 申请事项等内容。
26	《系统建设项目实施方案》	对工程的实施过程进行控制与管理，方案内容包 含项目概述、建设依据、组织部署、实施计划、 人员安排等。
27	《培训计划》	包括培训内容、培训次数、培训地点、培训时间 等内容。
28	《授权与审批管理制度》	对单位各事项的授权和审批流程进行明确说明。
29	《系统定级领导意见审批表》	包括定级系统名称、系统等级、审核内容、审核 人员和审核结果等内容。
30	《资产清单》	清单内容包括资产的责任人、所属部门、资产的 名称和资产数量等。
31	《恶意代码查杀表》	详细记录了恶意代码检测记录等内容。
32	《恶意代码库升级记录》	详细记录了恶意代码库升级记录等内容。
33	《日常安全检查记录表》	内容包括检查人员、检查时间、联网情况、系统 运行情况等。
34	《介质盘点清单》	包括介质名称、存储位置、盘点人员（部门）等 内容。
35	《系统测试验收报告》	包括系统测试时间、测试人员、测试公司、测试 模块（功能）和测试结构等内容。
36	《系统测试验收方案》	内容包括：性能测试背景、性能测试目标、性能 测试环境、性能测试计划、测试场景、风险分析 等。
37	《岗位建设管理制度》	明确信息安全岗位建设工作和各类管理人员的职 责。
38	《信息安全管理策略》	对信息安全中的管理策略作出详细规定。
39	《网络安全管理制度》	对单位网络安全进行了明确的规定。

序号	文档名称	主要内容
40	《信息系统安全管理制度》	对单位系统安全进行了明确的规定。
41	《密码管理制度》	对单位密码技术的使用和密码技术产品的使用进行了明确的规范。
42	《安全组织机构》	明确定义单位各部门的组织架构和工作职责。
43	《办公环境管理制度》	对办公室人员的相关行为作出了规定，内容包括不在办公区接待来访人员、工作人员离开座位应确保终端计算机退出登录状态和桌面上没有包含敏感信息的纸档文件等。
44	《产品采购管理制度》	明确安全产品采购的流程、注意事项等内容。
45	《软件开发管理制度》	对软件开发的人员准则、要求规范等进行了明确的要求。
46	《项目实施管理制度》	对项目实施要求、注意事项、最终结果等进行了明确的规定。
47	《信息安全领导小组职责》	明确了安全领导小组各个部门和岗位的职责、分工和技能要求等。
48	《授权和审批管理制度》	明确了系统变更等重要操作事项的审批部门和批准人等。
49	《安全意识教育和培训制度》	对单位各岗位人员的安全意识教育和培训等进行明确说明。
50	《安全检查和通报管理制度》	对重要事项违反相关规定进行检查和惩戒。
51	《人员安全管理制度》	对人员的离职的存储设备、信息文件、资料、图表等其他记载单位秘密信息的财物进行返还等规定。
52	《安全教育和培训管理制度》	对信息安全的教育培训、岗位技能培训、惩戒措施等作出规范。
53	《外部人员管理制度》	明确外来人员的物理访问以及网络、数据库、信息系统时的授权权限规定以及授权程序等。
54	《测试验收管理制度》	对系统的测试验收、验收文件、系统维护等作出描述。
55	《介质安全管理制度》	对介质的存放、存储时间、地点、安全等进行规范。

序号	文档名称	主要内容
56	《资产管理制度》	对信息系统资产的清单、资产的管理、资产标识等作出规范。
57	《设备安全管理制度》	对设备的维护、设备存放安全、设备管理、上门维修等作出规范。
58	《恶意代码防范管理制度》	明确了恶意代码的防范措施、恶意代码库的升级、检测技术以及发现病毒后的分析处理流程。
59	《信息系统变更管理制度》	对系统进行变更时候所应遵循的相关步骤作出规范。
60	《备份与恢复管理制度》	对数据的备份方式、备份频率、存放时间、恢复策略等作出规范。
61	《安全事件报告与处置管理制度》	明确了不同安全事件的报告流程以及不同安全事件的处理流程等内容。
62	《应急响应预案》	描述了应急预案的框架、启动条件、对应措施等内容。
63	《变更管理制度》	明确变更前审批、变更过程记录、变更后通报等方面内容。
64	《安全管理制度评审沟通会议记录》	会议记录包括会议时间、会议地点、主要人员和会议内容等内容。
65	《安全管理制度修订记录》	内容包括文件名称、发文部门、修改内容和修改时间等。
66	《关键活动审批过程表》	内容包括事件编号、事件类型、事件描述、生效时间、申请部门、申请人以及审批意见等。
67	《信息安全管理活动授权和审批表》	包括申请人、所属部门、申请时间、审批事项、审批内容、审批事项具体内容及原因描述、信息安全工作小组审批意见等内容。
68	《信息安全沟通会议记录》	包括会议时间、地点、名称、主要人员和会议内容。
69	《外联单位联系列表》	包括单位名称、地址、联系人、联系方式和合作内容等。
70	《外部人员接入受控网络访问系统的登记记录》	包含了人员信息、接入网络、账户分配、访问权限等内容。

序号	文档名称	主要内容
71	《第三方人员保密协议》	包含了对获得系统访问权限的人员签署保密内容，规定双方责任等内容。
72	《保密协议》	明确了单位员工的姓名、工作岗位和保密内容和泄密后果等内容。
73	《关键区域出入申请表》	详细记录了申请人姓名、申请部门、申请日期、外部人员姓名及单位、申请部门陪同人员姓名、携带设备、工作内容描述等内容。
74	《信息安全培训汇总登记表》	包括时间、地点、培训内容和培训人员等内容。
75	《岗位责任协议》	明确了单位员工的姓名、工作岗位和岗位内容等。
76	《产品采购清单》	包括采购人员、人员所属部门、采购产品、审核人员等内容。
77	《人员考核记录》	包括考核人员姓名、所属部门、考核内容和考核结果等内容。
78	《网络信息安全管理检查表》	包括安全技术措施的有效性、安全配置与安全策略的一致性、安全管理制度的执行情况等内容。
79	《年度信息安全检查情况报告表》	表格中包含了部门基本情况、信息系统基本情况、日常信息安全管理情况、信息安全防护管理情况、信息安全应急管理情况、信息技术产品应用情况、信息安全教育培训情况、信息系统安全建设整改、信息安全经费保障、本年度信息安全事件情况、信息技术外包服务机构情况（包括参与技术检测的外部专业机构）等内容。
80	《应急预案培训记录》	包括时间、地址、人员和培训内容等。
81	《应急预案演练记录》	包括时间、地址、人员和应急演练内容等。
82	《系统安全性测试报告》	包括系统安全性测试时间、安全性测试人员、安全性测试公司、安全性测试模块（功能）和安全性测试结构等内容。
83	《系统变更申请表》	包括变更缘由、变更时间、变更结果等内容。

3 单项测评结果分析

单项测评内容包括“2.2.1 安全通用要求指标”“2.2.2 安全扩展要求指标”和“2.2.3 其他安全要求指标”中涉及的安全类，由已有安全控制措施汇总分析和主要安

全问题汇总分析两部分构成，单项测评结果汇总、单项测评结果记录参见报告附录。

3.1 安全物理环境

3.1.1 已有安全控制措施汇总分析

在云计算安全扩展要求方面采取了以下安全措施：

在基础设施位置方面，系统部署于华为云平台，系统相关服务器、数据库、网络安全防护设备均放置在华为云机房内，该机房位于华北-北京一区，属于中国境内。

3.1.2 主要安全问题汇总分析

在安全物理环境方面，未发现明显的安全问题。

3.2 安全通信网络

3.2.1 已有安全控制措施汇总分析

在安全通信网络方面采取了以下安全措施：

在网络架构方面，互联网出口带宽采用按量收费模式，已满足业务高峰期需求，一年内未出现网络堵塞情况。系统已按照方便管理和控制的原则划分了网络区域，通过华为云虚拟私有云 VPC 划分了服务器网段，重要网络区域未部署在网络边界处，虚拟网络出口部署了深信服 Web 应用云防火墙、华为云安全组，并配置了访问控制策略，可有效避免非授权访问。同时服务器采用华为云弹性服务器部署，可实现系统的高可用性。

在通信传输方面，网络设备、安全设备、华为云管理控制台远程管理方式采用 https，网络设备、安全设备、华为云管理控制台采用 ECDHE-RSA-WITH-AES-128-GCM-SHA256 进行加密，Linux 操作系统采用 ssh 方式（具有 hmac-sha2-

256-ets 技术和 AES_128_GCM 算法) 进行远程管理、应用系统采用 HTTPS 方式(具有 ECDHE-RSA-WITH-AES-256-GCM-SHA256 加密算法)进行远程管理, 数据库开启了 SSL (采用 AES_128_GCM 算法), 可实现通信过程中数据的完整性和保密性。

此外在云计算安全扩展要求方面还采取了以下安全措施:

在网络架构方面, 被测系统部署在华为云, 华为云提供三级等保材料, 被测系统定级为三级, 云计算平台安全保护等级满足被测系统的等级要求。

3.2.2 主要安全问题汇总分析

在安全通信网络方面存在如下安全问题:

(1) 未基于可信根对通信设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。

无可信验证, 无法通过主动免疫可信验证技术提高系统自身安全防护能力, 无法实现积极主动防御。

3.3 安全区域边界

3.3.1 已有安全控制措施汇总分析

在安全区域边界方面采取了以下安全措施:

在边界防护方面, 系统部署在华为云, 通过网络出口边界部署了华为云安全组实现边界访问控制, 默认情况下除允许的通信端口拒绝所有通信。同时通过华为云安全组策略入方向有效限制非授权设备的私自内联行为。

在访问控制方面, 系统通过深信服 Web 应用云防火墙、华为云安全组进行访问控制, 安全组模块配置了严格的访问控制规则, 默认情况下拒绝所有通信。目前策略已实现最优化, 安全策略配置能够基于应用协议和应用内容对进出数据

流进行访问控制。

在入侵防范方面，当前网络环境中部署了深信服 Web 应用云防火墙，当前特征库版本为官方发布的最新版本，可对外部发起的网络攻击行为进行检测和阻断。同时开通了云主机安全服务 HSS 作为内部关键网络节点处的主要安全防护设备，其具有入侵防御功能模块，规则库均已升级至最新版本，并由华为云进行实时更新和维护，可对内部发起的网络攻击行为进行检测和阻断。当前网络环境中部署了深信服 Web 应用云防火墙和华为云企业主机安全 HSS，其具有流量分析功能，规则库版本为最新，可对网络行为进行实时分析，并实现对网络攻击特别是对新型网络攻击行为进行分析，并通过手机短信（138****5671）的方式进行主动报警。

在安全审计方面，当前网络环境中部署了深信服 Web 应用云防火墙和华为云企业主机安全 HSS，其具有流量分析功能，可对所有的用户行为、攻击事件等进行实时分析。深信服 Web 应用云防火墙和华为云企业主机安全 HSS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，华为云管理控制台当前配置策略已创建跟踪列表，并通过本地网络实时保存至华为云对象存储服务 OBS 中，能够对流量日志进行收集、保存、分析，可避免受到未预期的删除、修改或覆盖等。

此外在云计算安全扩展要求方面还采取了以下安全措施：

在访问控制方面，系统部署在华为云上，在不同等级的网络区域边界处部署有深信服 Web 应用云防火墙、华为云安全组，华为云安全组已配置访问控制策略，且策略有效。

在入侵防范方面，系统部署在华为云上，云平台部署有深信服 Web 应用云

防火墙和华为云企业主机安全服务 HSS，已配置监控及报警策略，且策略有效，规则库均已升级至最新版，可对网络入侵行为和虚拟网络节点的网络攻击行为进行防范进行防范、阻断及告警，具备检测记录，记录包括攻击类型、攻击时间、攻击流量等内容。同时华为云企业主机安全服务 HSS 可对虚拟机与宿主机之间、虚拟机与虚拟机之间的异常流量进行检测，并通过手机短信（138****5671）的方式进行告警。

在安全审计方面，系统部署在华为云上，云平台部署有华为云云日志服务 L TS，可对云服务客户执行的特权命令进行审计，审计记录包括虚拟机删除、虚拟机重启等。系统部署在华为云上，云平台无云服务客户系统和数据管理权限，云服务客户管理员可通过云平台查看系统和数据审计记录，云服务商操作可被云服务客户审计。

3.3.2 主要安全问题汇总分析

在安全区域边界方面存在如下安全问题：

(1) 未采用技术手段对内部用户非授权联到外部网络的行为进行检查或限制。

未采取技术措施对非授权的内部用户私自连接外部网络的行为进行检查、限制，存在未授权的内部网络用户私自连接外部网络容易导致数据泄露。

(2) 网络中未部署恶意代码防范系统，无法对恶意代码进行检测和清除。

无法检测潜在的恶意代码，可能会造成恶意代码流入系统造成破坏的风险。

(3) 未采取措施对访问互联网的用户行为进行审计。

无法对访问互联网的用户行文进行管理和记录，不能及时对相关的未授权操作或访问行为进行及时有效的追溯等。

(4) 未基于可信根对边界设备的系统引导程序、系统程序、重要配置参数和通信应用程序等进行动态可信验证。

无可信验证，无法通过主动免疫可信验证技术提高系统自身安全防护能力，无法实现积极主动防御。

3.4 安全计算环境

3.4.1 网络设备

3.4.1.1 已有安全控制措施汇总分析

在网络设备方面采取了以下安全措施：

在身份鉴别方面，系统登录需要输入用户名和口令+手机短信验证码的方式进行身份鉴别，用户标识具有唯一性。设置了口令复杂度和定期更换策略，系统启用了登录失败处理功能。远程管理系统采用 https 协议，使用 ECDHE-RSA-WITH-AES-128-GCM-SHA256 进行数据传输加密，鉴别信息在网络中加密传输，能够防止鉴别信息在传输过程中被窃听和篡改。

在访问控制方面，系统为登录的用户分配了账户，且为每个账户分配了所需的权限。系统中无默认账户，所有账户均为手动创建，并设置了具有一定复杂度的口令。系统中的账户均为在用账户，无多余的或过期的账户，管理员账户与系统账户一一对应，无共享账户存在。系统配置了安全管理员对访问控制策略进行配置。设备的访问控制粒度可达到主体为用户级，客体为功能级。

在安全审计方面，系统提供了审计功能，审计记录实时通过华为云云日志服务 LTS 进行审计，并通过本地网络实时保存至华为云对象存储服务 OBS 中，日志留存 6 个月以上，能够对审计记录进行收集、保存，避免受到未预期的删除、修改或覆盖等。同时未提供审计进程关闭功能，用户无法通过登录界面对审计进

程进行关闭。

在数据完整性方面，远程管理系统采用 https 协议，采用 ECDHE-RSA-WITH-AES-128-GCM-SHA256 进行数据传输加密，可对鉴别信息和配置数据在网络传输过程中的完整性进行校验。

在数据保密性方面，远程管理系统采用 https 协议，使用 ECDHE-RSA-WITH-AES-128-GCM-SHA256 进行数据传输加密，可对鉴别信息和配置数据在网络传输过程中进行数据传输加密。

3.4.1.2 主要安全问题汇总分析

在网络设备方面存在如下安全问题：

(1) 登录连接超时过长。

系统易被非授权人员恶意操作，存在非授权访问的风险。

(2) 未采用两种或两种以上组合的鉴别技术对用户进行身份鉴别，其中一种鉴别技术至少应使用密码技术来实现。

单一鉴别技术安全强度有限，如果未采用双因素认证，一旦被嗅探和泄露，将再没有其它技术进行身份鉴别，存在非授权访问的风险。

(3) 未对重要主体和客体设置安全标记，未实现通过安全标记控制主体对信息资源的访问。

恶意用户可能通过修改用户权限等方法，非授权访问重要信息资源，存在安全隐患。

(4) 系统未采用可信计算技术对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。

无可信验证，不能通过主动免疫可信验证技术提高系统自身安全防护能力，

不能实现积极主动防御。

(5) 未采用校验技术或密码技术保证重要配置数据和鉴别数据在存储过程中的完整性。

可能导致重要配置数据和鉴别数据在存储过程中被恶意篡改，影响信息系统的正常运行。

(6) 未采用密码技术实现鉴别数据和重要配置数据在存储过程中的保密性。

可能导致重要配置数据和鉴别数据在存储过程中被攻击者直接盗用，使重要配置数据和鉴别数据遭遇泄漏。

(7) 未对备份文件进行过恢复性测试。

一旦出现故障，可能由于各种原因无法利用备份数据进行恢复，造成重要数据丢失。

3.4.2 安全设备

3.4.2.1 已有安全控制措施汇总分析

在安全设备方面采取了以下安全措施：

在身份鉴别方面，系统登录需要进行身份鉴别，用户标识具有唯一性。设置了口令复杂度和定期更换策略，系统启用了登录失败处理功能。远程管理系统采用 https 协议，使用 ECDHE-RSA-WITH-AES-128-GCM-SHA256 进行数据传输加密，鉴别信息在网络中加密传输，能够防止鉴别信息在传输过程中被窃听和篡改。

在访问控制方面，系统为登录的用户分配了账户，且为每个账户分配了所需的权限。系统中无默认账户，所有账户均为手动创建，并设置了具有一定复杂度的口令。系统中的账户均为在用账户，无多余的或过期的账户，管理员账户与系统账户一一对应，无共享账户存在。系统配置了安全管理员对访问控制策略进行

配置。设备的访问控制粒度可达到主体为用户级，客体为功能级。

在安全审计方面，系统提供了审计功能，审计记录实时通过华为云云日志服务 LTS 进行审计，并通过本地网络实时保存至华为云对象存储服务 OBS 中，日志留存 6 个月以上，能够对审计记录进行收集、保存，避免受到未预期的删除、修改或覆盖等。同时未提供审计进程关闭功能，用户无法通过登录界面对审计进程进行关闭。

在数据完整性方面，远程管理系统采用 https 协议，采用 ECDHE-RSA-WITH-AES-128-GCM-SHA256 进行数据传输加密，可对鉴别信息和配置数据在网络传输过程中的完整性进行校验。

在数据保密性方面，远程管理系统采用 https 协议，使用 ECDHE-RSA-WITH-AES-128-GCM-SHA256 进行数据传输加密，可对鉴别信息和配置数据在网络传输过程中进行数据传输加密。

3.4.2.2 主要安全问题汇总分析

在安全设备方面存在如下安全问题：

(1) 口令有效周期过长。

账户口令可能被长时间使用，恶意人员可通过猜解的方式获取账户口令，存在非授权访问的风险。

(2) 登录连接超时过长。

系统易被非授权人员恶意操作，存在非授权访问的风险。

(3) 未采用两种或两种以上组合的鉴别技术对用户进行身份鉴别，其中一种鉴别技术至少应使用密码技术来实现。

单一鉴别技术安全强度有限，如果未采用双因素认证，一旦被嗅探和泄露，

将再没有其它技术进行身份鉴别，存在非授权访问的风险。

(4) 采用默认账户进行管理。

恶意人员可能利用默认账户对系统进行试探攻击，存在安全隐患。

(5) 未授予不同账户为了完成各自承担任务所需的最小权限。

无法实现不同权限角色间的监督，存在管理账户越权管理或滥用权限的风险。

(6) 未配置安全管理员账户对访问控制策略进行配置。

无法有效的对访问控制策略进行管控，可能出现不必要的访问控制策略，存在潜在的安全隐患，但采取系统仅在内部网络访问或采用在后台对访问控制策略进行配置，能够降低系统被攻击的风险，整体风险可控，可降低风险。

(7) 未对重要主体和客体设置安全标记，未实现通过安全标记控制主体对信息资源的访问。

恶意用户可能通过修改用户权限等方法，非授权访问重要信息资源，存在安全隐患。

(8) 审计记录仅保存在本机，未进行定期备份。

日志记录容易受到恶意篡改、删除，不便于对安全事件进行追踪和分析。

(9) 未严格限制终端登录地址范围。

恶意用户可从任意地址尝试对设备进行访问、攻击，存在非授权访问的风险。

(10) 系统未采用可信计算技术对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。

无可信验证，不能通过主动免疫可信验证技术提高系统自身安全防护能力，不能实现积极主动防御。

3.4.3 服务器和终端

3.4.3.1 已有安全控制措施汇总分析

在服务器和终端方面采取了以下安全措施：

在身份鉴别方面，系统已启用登录模块，采用账户名和口令的方式对登录的用户进行身份鉴别，账户名具有唯一性。服务器采用 SSH 协议进行远程管理，采用 AES_128_GCM 技术进行加密，可实现鉴别信息在网络中加密传输。

在访问控制方面，已为用户登录系统分配了相应的账户，并对账户分配了相应的权限，操作系统所有账户均为使用中账户，不存在多余、过期的账户。

在安全审计方面，系统开启了审计功能，对用户操作和重要安全事件提供审计，审计范围覆盖到所有系统账户。服务器审计日志已通过配置上传至华为云云日志服务 LTS 中，可对审计记录进行保护，日志保存时间为 6 个月以上，可避免审计记录受到未预期的删除、修改或覆盖等。

在入侵防范方面，系统实现了最小化安装，仅安装了与业务相关的程序，Linux 系统未开启不需要的系统服务、默认共享和高危端口。租户购买了华为云企业主机安全 HSS 企业版，华为云提供了漏洞自动检测并提供了修复方案；租户已每天对系统进行漏洞扫描并修补了漏洞。当前已部署华为云企业主机安全 HSS 企业版，可对服务器入侵行为进行检测，规则库版本为最新，并通过手机短信（138****5671）的方式进行主动报警。系统安装了火绒安全软件，能够及时检测到对重要节点进行入侵的行为，并通过弹窗进行报警。

在恶意代码防范方面，服务器已部署华为云企业主机安全 HSS 企业版，终端安装了火绒安全软件，规则库版本为最新，能够及时识别入侵和病毒行为，并将其有效阻断。

在数据完整性方面，服务器使用 SSH 协议进行加密传输，采用 hmac-sha2-256-etm 技术，可以实现鉴别数据、重要配置数据在传输过程中的完整性。

在数据保密性方面，服务器使用 SSH 协议进行加密传输，采用 AES_128_GCM 算法，可以实现鉴别数据、重要配置数据在传输过程中的保密性。

在数据备份恢复方面，服务器为虚拟化集群部署，并配置了虚拟机资源的自动分配，能够提供系统的高可用性保障。

在剩余信息保护方面，系统鉴别信息和敏感数据所在的存储空间被释放或重新分配前得到了完全清除。

3.4.3.2 主要安全问题汇总分析

在服务器和终端方面存在如下安全问题：

(1) 未配置口令复杂度策略和口令有效期策略。

账户口令可能被设置为弱口令，且长时间使用，恶意人员可通过猜解的方式获取账户口令，存在非授权访问的风险。

(2) 未配置登录失败处理策略及登录连接超时自动退出策略。

恶意人员可通过暴力破解的方式获取账户口令，且设备易被非授权人员恶意操作，存在非授权访问的风险。

(3) 未采用两种或两种以上组合的鉴别技术对用户进行身份鉴别，其中一种鉴别技术至少应使用密码技术来实现。

单一鉴别技术安全强度有限，如果未采用双因素认证，一旦被嗅探和泄露，将再没有其它技术进行身份鉴别，存在非授权访问的风险。

(4) 采用默认账户进行管理。

利用存在默认账户，容易被恶意用户猜测破解造成非授权访问，但未使用默

认口令，能够降低系统被攻击的风险，整体风险可控，可降低风险。

(5) 未授予不同账户为了完成各自承担任务所需的最小权限。

无法实现不同权限角色间的监督，存在管理账户越权管理或滥用权限的风险。

(6) 未配置安全管理员账户对访问控制策略进行配置。

无法有效的对访问控制策略进行管控，可能出现不必要的访问控制策略，存在潜在的安全隐患，但采取系统仅在内部网络访问或采用在后台对访问控制策略进行配置，能够降低系统被攻击的风险，整体风险可控，可降低风险。

(7) 未对重要主体和客体设置安全标记，未实现通过安全标记控制主体对信息资源的访问。

恶意用户可能通过修改用户权限等方法，非授权访问重要信息资源，存在潜在的安全隐患。

(8) 审计范围未覆盖所有重要的用户行为和安全事件。

不便于对安全事件进行追溯和分析，同时无法及时了解设备实际运行状况以及可能存在的安全隐患。

(9) 审计记录仅保存在本机，未进行定期备份。

日志记录容易受到恶意篡改、删除，不便于对安全事件进行追踪和分析。

(10) 未采取措施对系统审计进程进行保护。

审计进程容易受到未预期的中断，造成日志记录缺失，不便于对安全事件进行追踪和分析。

3.4.4 系统管理软件/平台

3.4.4.1 已有安全控制措施汇总分析

在系统管理软件/平台方面采取了以下安全措施：

在身份鉴别方面，华为云管理控制台采用 HTTPS 协议，使用 ECDHE-RSA-WITH-AES-128-GCM-SHA256 进行数据传输加密，数据库开启了 SSL，采用 AES_128_GCM 技术进行加密，可有效防止鉴别信息在传输过程中被窃听。

在访问控制方面，系统对登录的用户分配账户和权限，系统未设置多余账号，不存在过期账号和共享账号。

在安全审计方面，系统启用了安全审计功能，审计覆盖到每个用户，可以对重要安全事件和重要的用户行为进行审计。配置了华为云云日志服务 LTS，设备日志实时保存至华为云云日志服务 LTS，能够对审计记录进行收集、保存，避免受到未预期的删除、修改或覆盖等。

在入侵防范方面，系统对人机接口或通信接口输入的内容提供了数据有效性检验功能，经漏洞扫描未发现 SQL 注入、跨站脚本、远程命令执行等漏洞。租户购买了华为云企业主机安全 HSS 企业版，华为云提供了漏洞自动检测并提供了修复方案；租户已每天对系统进行漏洞扫描并修补了漏洞。

在数据完整性方面，远程管理华为云管理控制台采用 https 协议，采用 ECDHE-RSA-WITH-AES-128-GCM-SHA256 进行数据传输加密，数据库采用 SSL 协议进行管理，采用 AES_128_GCM 技术进行加密，能够实现鉴别数据、重要配置数据在传输过程中的完整性。

在数据保密性方面，远程管理华为云管理控制台采用 https 协议，使用 ECDHE-RSA-WITH-AES-128-GCM-SHA256 进行数据传输加密，数据库采用 SSL 协议进行管理，采用 AES_128_GCM 技术进行加密，能够保证鉴别数据、重要配置数据在传输过程中的保密性。

在剩余信息保护方面，系统未保存用户的鉴别信息，重新登录时需要再次对

用户名、口令进行验证。系统登录时不自动保存和显示历史账号和口令，在用户退出后及时清空会话，无法通过回退操作访问退出前界面，用户的鉴别信息所在的存储空间被释放或重新分配前能够得到完全清除。

3.4.4.2 主要安全问题汇总分析

在系统管理软件/平台方面存在如下安全问题：

(1) 未配置口令有效期策略。

账户口令可能被长时间使用，存在口令被长时间非法盗用的风险。

(2) 登录连接超时过长。

系统易被非授权人员恶意操作，存在非授权访问的风险。

(3) 未配置登录失败处理策略，未配置合理的登录连接超时自动退出策略。

恶意人员可通过暴力破解的方式获取账户口令，且设备易被非授权人员恶意操作，存在非授权访问的风险。

(4) 未采用两种或两种以上组合的鉴别技术对用户进行身份鉴别，其中一种鉴别技术至少应使用密码技术来实现。

单一鉴别技术安全强度有限，如果未采用双因素认证，一旦被嗅探和泄露，将再没有其它技术进行身份鉴别，存在非授权访问的风险。

(5) 采用默认账户进行管理。

恶意人员可能利用默认账户对系统进行试探攻击，存在潜在的安全隐患，但未使用默认口令，能够降低系统被攻击的风险，整体风险可控，可降低风险。

(6) 未授予不同账户为了完成各自承担任务所需的最小权限。

无法实现不同权限角色间的监督，存在管理账户越权管理或滥用权限的风险。

(7) 未配置安全管理员账户对访问控制策略进行配置。

无法有效的对访问控制策略进行管控，可能出现不必要的访问控制策略，存在潜在的安全隐患，但采取系统仅在内部网络访问或采用在后台对访问控制策略进行配置，能够降低系统被攻击的风险，整体风险可控，可降低风险。

(8) 未对重要主体和客体设置安全标记，未实现通过安全标记控制主体对信息资源的访问。

恶意用户可能通过修改用户权限等方法，非授权访问重要信息资源，存在潜在的安全隐患。

(9) 未采取措施对系统审计进程进行保护。

审计进程容易受到未预期的中断，造成日志记录缺失，不便于对安全事件进行追踪和分析。

(10) 未严格限制终端登录地址范围。

恶意用户可从任意地址尝试对设备进行访问、攻击，存在非授权访问的风险。

3.4.5 业务应用系统/平台

3.4.5.1 已有安全控制措施汇总分析

在业务应用系统/平台方面采取了以下安全措施：

在身份鉴别方面，系统已提供登录失败处理功能，限制了连续口令错误 5 次，账户锁定 1 分钟；已配置登录连接超时自动退出时长为 30 分钟。系统远程管理采用 HTTPS 协议，具有 ECDHE-RSA-WITH-AES-256-GCM-SHA256 加密算法，用户鉴别信息以加密方式进行传输。

在访问控制方面，系统对登录的用户分配账户和权限，系统内账户均为在用账户，不存在共享账户，不存在多余的、过期的账户。经渗透测试未发现越权访问漏洞。应用系统的访问控制粒度可达到主体为用户级，可以实现客体为功能模

块级、菜单级或 API 级。

在安全审计方面，系统已启用安全审计功能，对用户的重要行为进行了审计与记录，审计范围覆盖所有的用户，应用系统日志通过应用无法删除、修改。审计进程作为应用系统的功能模块，无独立进程，无法单独中断，审计功能无法关闭。

在入侵防范方面，系统已对人机接口和通讯接口输入的内容进行检验，提供了数据有效性检验功能。租户购买了华为云企业主机安全 HSS 企业版，华为云提供了漏洞自动检测并提供了修复方案；租户已每天对系统进行漏洞扫描并修补了漏洞。当前提供了《漏洞扫描记录》，包括时间、漏洞等情况、检测结果和检测结果分析等内容。

在数据完整性方面，系统采用 HTTPS 进行传输，使用 ECDHE-RSA-WITH-AES-256-GCM-SHA256 加密算法对鉴别数据、配置数据进行完整性校验，能够保证通信传输过程中鉴别数据、配置数据的完整性。

在数据保密性方面，系统采用 HTTPS 进行传输，使用 ECDHE-RSA-WITH-AES-256-GCM-SHA256 加密算法对鉴别数据、配置数据进行加密，能够保证通信传输过程中鉴别数据、配置数据的保密性。当前针对鉴别数据和配置数据采用 SM4 算法，可保证重要配置数据和鉴别数据在存储过程中的保密性。

在剩余信息保护方面，鉴别信息保存在本地 Cookie 中，用户关闭页面或长时间无数据请求，Cookie 自动失效，且服务器自动删除对应的 Session 信息。系统访问采用 WEB 方式，本地除访问必须的框架文件（如 html, js, css, img 等）外，不保存业务相关的敏感数据。

3.4.5.2 主要安全问题汇总分析

在业务应用系统/平台方面存在如下安全问题：

(1) 未配置口令有效期策略。

账户口令可能被长时间使用存在口令被长时间非法盗用的风险。

(2) 未采用两种或两种以上组合的鉴别技术对用户进行身份鉴别，其中一种鉴别技术至少应使用密码技术来实现。

用户名和口令安全强度有限，如果未采用双因素认证，一旦用户名和口令被嗅探和泄露，将再没有其它技术进行身份鉴别，存在非授权访问的风险，但系统仅在单位内部可控网络中访问，总体风险相对可控，可降低风险。

(3) 未授予不同账户为了完成各自承担任务所需的最小权限。

无法实现不同权限角色间的监督，存在管理账户越权管理或滥用权限的风险。

(4) 未配置安全管理员账户对访问控制策略进行配置。

无法有效的对访问控制策略进行管控，可能出现不必要的访问控制策略，存在潜在的安全隐患，但采取系统仅在内部网络访问或采用在后台对访问控制策略进行配置，能够降低系统被攻击的风险，整体风险可控，可降低风险。

(5) 未对重要主体和客体设置安全标记，未实现通过安全标记控制主体对信息资源的访问。

恶意用户可能通过修改用户权限等方法，非授权访问重要信息资源，存在潜在的安全隐患。

(6) 系统未采用可信计算技术对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。

无可信验证，不能通过主动免疫可信验证技术提高系统自身安全防护能力，

不能实现积极主动防御。

(7) 未提供重要配置数据和鉴别数据存储完整性被破坏时的检查和报警机制。

无法第一时间知晓重要配置数据和鉴别数据在存储过程中被破坏,可能会影响信息系统的正常运行。

3.4.6 数据资源

3.4.6.1 已有安全控制措施汇总分析

在数据资源方面采取了以下安全措施：

在数据完整性方面，系统远程管理采用 https 协议进行传输，采用 ECDHE-RSA-WITH-AES-256-GCM-SHA256 加密算法进行加密和身份验证，可以保证重要业务数据和重要个人信息在传输过程中的完整性。

在数据保密性方面，系统远程管理采用 https 协议进行传输，采用 ECDHE-RSA-WITH-AES-256-GCM-SHA256 加密算法进行加密和身份验证，可以保证重要业务数据和重要个人信息在传输过程中的保密性。

在数据备份恢复方面，系统的重要业务数据和重要个人信息保存在数据库中，按照数据库备份策略，每天凌晨 6 点通过自研脚本 obs-backup.sh，将前一天的数据库备份，备份到华为云对象存储服务 OBS，在系统进行重大升级时对备份文件进行备份恢复测试，具备《数据备份恢复测试记录》。

在个人信息保护方面，系统采集的用户个人信息包括姓名、身份证号、手机号等，均为业务所需的个人信息，未发现超范围采集情况；且被测单位已具备个人信息保护的相关管理要求和流程规定。系统中保存的个人信息仅授权用户可访问，非授权用户无法访问及使用，且具备个人信息保护的相关管理要求和流程规

定，且通过华为云数据库安全服务 DBSS 对数据进行安全审计，防止非法查询操作。

3.4.6.2 主要安全问题汇总分析

在数据资源方面存在如下安全问题：

(1) 未提供重要个人信息存储完整性被破坏时的检查和报警机制。

无法第一时间知晓重要个人信息在存储过程中被破坏，可能会影响信息系统的正常运行。

(2) 未提供重要业务数据存储完整性被破坏时的检查和报警机制。

无法第一时间知晓重要业务数据在存储过程中被破坏，可能会影响信息系统的正常运行。

(3) 未将重要数据实时备份至异地。

如发生火灾、重大自然灾害等，可能导致数据完全丢失，但因已采取数据本地备份措施，且系统所在环境发生地震等灾难的可能性较低，整体风险可控。

3.4.7 其他系统或设备

3.4.7.1 已有安全控制措施汇总分析

本次测评不包含安全计算环境其他系统或设备的测评内容。

3.4.7.2 主要安全问题汇总分析

本次测评不包含安全计算环境其他系统或设备的测评内容。

3.4.8 安全扩展要求

3.4.8.1 已有安全控制措施汇总分析

在云计算安全扩展要求方面采取了以下安全措施：

在访问控制方面，云服务客户可通过华为云安全组设置不同虚拟机之间的访

访问控制策略，且访问控制策略可生效。

在入侵防范方面，云计算平台部署华为云企业主机安全服务 HSS，可对非授权新建虚拟机或者重新启用虚拟机进行检测，对恶意代码感染及在虚拟机间蔓延的情况进行检测，并通过手机短信（138****5671）的方式进行告警。

在数据完整性和保密性方面，被测系统部署于华为云平台，系统服务器、数据库等设备均放置于华为云机房，机房位于华北-北京一区，属于中国境内。

在数据备份恢复方面，云服务客户每月通过手动备份方式将系统重要数据备份至运维终端-1 的 D:\备份文件夹中。

3.4.8.2 主要安全问题汇总分析

在云计算安全扩展要求方面存在如下安全问题：

(1) 未在远程管理云平台中设备时，在管理终端和云平台间建立双向身份验证机制。

可能导致攻击者不可信管理终端接入，或者攻击者通过钓鱼或伪造云计算平台服务界面的形式诱骗管理员提供敏感数据，导致管理终端和云计算平台间通信被劫持或伪造。

3.5 安全管理中心

3.5.1 已有安全控制措施汇总分析

在安全管理中心方面采取了以下安全措施：

在系统管理方面，系统管理员通过华为云管理控制台（用户名和口令+手机短信验证码）和皓迪堡垒机（用户名和口令）提供的登录模块进行身份鉴别并登录系统，可对全网资源进行统一管理，系统开启事件审核策略，可对系统管理员的操作进行审计，同时对系统的资源和运行进行配置、控制和管理，包括用户身

份、资源配置、系统加载和启动、系统运行的异常处理、数据和设备的备份与恢复等。

在审计管理方面，审计管理员通过用户名口令+手机短信验证码的方式登录华为云管理控制台，通过华为云管理控制台的华为云对象存储服务 OBS 和华为云日志服务 LTS 能够进行安全审计操作，并对审计管理员的行为进行审计记录。华为云对象存储服务 OBS 和华为云日志服务 LTS 对各个节点的日志记录进行集中收集、统一查询、管理和分析，可对审计数据完整性进行保护。

在安全管理方面，安全管理员可通过华为云管理控制台（用户名和口令+手机短信验证码）提供的登录模块进行身份鉴别，登录系统后可限制其通过特定的命令或操作界面进行系统管理操作。可对系统中的安全策略进行统一配置，并包括安全参数的设置，主体、客体进行统一安全标记，对主体进行授权，配置可信验证策略等。

在集中管控方面，系统划分了特定的服务器管理区域，仅可通过华为云管理控制台进行安全管理。系统的主要设备可通过华为云管理控制台采用 https 等协议进行远程管理。云租户开通了华为云企业主机安全 HSS，可对网络链路、服务器、安全组件的运行状况进行集中监测。系统中部署了华为云日志服务 LTS 对日志进行收集保护，并通过创建跟踪列表实例实时将审计记录传输至云对象存储服务 OBS 进行存储，日志保存时间 6 个月以上，可对审计记录的完整性进行保护，避免受到未预期的删除、修改和覆盖等。租户已购买华为云企业主机安全 HSS 企业版功能，能够对主机漏洞进行统一检测和修复，对云环境的安全策略进行统一管理，包括 IP 白名单、访问控制防护模式、主动防御模式等，同时华为云企业主机安全 HSS 企业版提供了恶意代码查杀功能。当前配置的深信服 Web 应用云

防火墙和华为云企业主机安全 HSS 具有流量分析功能，能够对各类安全事件进行分析，并通并通过手机短信（138****5671）的方式进行报警。

此外在云计算安全扩展要求方面还采取了以下安全措施：

在集中管控方面，云服务客户的审计记录通过华为云云日志服务 LTS 进行收集，可根据云服务商和云服务客户的职责划分，分别收集各自控制部分审计记录，并实现各自的集中审计。通过华为云管理控制台对虚拟化网络、虚拟机、虚拟化安全设备的运行状况的集中监测，云服务商和云服务客户根据职责划分，对各自控制部分进行集中监测。

3.5.2 主要安全问题汇总分析

在安全管理中心方面，未发现明显的安全问题。

3.6 安全管理制度

3.6.1 已有安全控制措施汇总分析

在安全管理制度方面采取了以下安全措施：

在安全策略方面，单位提供了《信息安全管理办法》，内容包含有总则、信息安全方针和目标、信息安全管理策略等内容，阐明了网络信息系统安全管理工作的总体目标、范围、原则和安全框架等。

在管理制度方面，已对安全管理活动中的各类管理内容建立了安全的管理制度。提供了《信息安全管理策略》其中对每个岗位管理员的日常操作进行了规范。并对系统建设管理和系统运维管理的相关内容进行了规范，建立具体的建设、运维操作规程。已形成由信息安全管理办法、信息安全管理策略、信息安全各项操作规程、记录表单等构成的全面的安全管理制度体系。

在制定和发布方面，指定信息安全工作小组负责安全管理制度的制定。安全

管理制度通过 OA 系统进行正式、有效的发布，同时进行了版本控制。

在评审和修订方面，《信息安全管理办法》明确说明信息安全管理组织需要定期（至少每年一次）开展信息安全管理体制和安全管理制度的评审工作，以确保整个信息安全管理体制和安全管理制度的合理性、适用性和有效性；当前已提供了《安全管理制度评审沟通会议记录》和《安全管理制度修订记录》。

3.6.2 主要安全问题汇总分析

在安全管理制度方面，未发现明显的安全问题。

3.7 安全管理机构

3.7.1 已有安全控制措施汇总分析

在安全管理机构方面采取了以下安全措施：

在岗位设置方面，当前成立了信息安全领导小组，其最高领导为信息安全部经理。已定义了相关的负责人以及各个岗位职责，并设立了信息安全部为网络安全管理工作职能部门。

在人员配备方面，当前配备了网络管理员、安全管理员、系统管理员和审计管理员等管理员，可以满足业务需求。当前由张鑫担任安全管理员，未兼任其他管理员职务。

在授权和审批方面，提供的《授权和审批管理制度》已针对系统变更、重要操作、物理访问和系统接入等事项建立审批程序，按照审批程序执行审批过程，对重要活动建立逐级审批制度。

在沟通和合作方面，每月进行网络安全例会，同时单位提供了外联单位联系表。

在审核和检查方面，已每天对系统联网情况、系统运行情况、系统漏洞等进

行日常检查，同时每半年对系统进行全面检查，检查内容包括安全配置和策略是否一致、安全管理制度是否执行到位。单位制定了安全检查情况报告表，对检查内容以及检查方法进行了说明，对安全检查数据进行汇总分析并形成安全检查报告。

3.7.2 主要安全问题汇总分析

在安全管理机构方面，未发现明显的安全问题。

3.8 安全管理人员

3.8.1 已有安全控制措施汇总分析

在安全管理人员方面采取了以下安全措施：

在人员录用方面，由苏州国泰新点软件有限公司人力资源部负责人员的录用工作。在人员录用前均会对其作严格的身份背景、技能掌握程度等相关的考核，特别对于关键岗位、关键职务人员，以及其他会大量接触敏感信息的人员会重点审查；相关审查记录保存在人力资源部。当前与被录用人员签署《保密协议》，同时提供了与关键岗位人员签署的《岗位责任协议》。

在人员离岗方面，人员调岗时，已删除该员工的所有信息系统访问账号和权限，相关部门会及时收回其在职期间钥匙、工作证等。

在安全意识教育培训方面，提供的《安全教育和培训管理制度》内容包括培训对象、培训周期、培训内容等，其中明确应对各类人员进行安全意识教育，明确安全责任和惩戒措施。

在外部人员访问管理方面，已制定《外部人员管理制度》，明确了相关访问控制程序，访问受控区域需提前申请，进入必须由单位相关人员全程陪同，不允许第三方人员单独滞留于上述场所，且提供《关键区域出入申请表》；同时对外

部人员访问受控网络的申请流程进行了说明，并提供了《外部人员接入受控网络访问系统的登记记录》。

3.8.2 主要安全问题汇总分析

在安全管理人员方面，未发现明显的安全问题。

3.9 安全建设管理

3.9.1 已有安全控制措施汇总分析

在安全建设管理方面采取了以下安全措施：

在定级和备案方面，编制了信息系统定级报告，明确了信息系统的边界和安全保护等级（S3A3G3），说明了信息系统定级方法和理由。系统定级结果已经过信息安全部经理批准。已将系统备案材料递交至苏州市公安局进行备案，具备备案证明。

在产品采购和使用方面，业务部门或个人需要购买计算机设备或软件，首先须由本部门领导审批同意，然后向单位领导提出申请，由单位领导统一规划和综合评估后，如确实需要购买，由采购部门在向供货商询价后，申请部门或个人根据此价格完成财务审批手续，并提供了《产品采购清单》。每年均会审定和更新候选产品名单。

在工程实施方面，指定信息安全部负责工程的实施。已制定安全工程实施方案控制工程实施过程。

在测试验收方面，当前已提供系统的测试验收方案和测试验收报告。上线前已进行安全性测试，提供了安全性测试报告。

在系统交付方面，系统交付时，已提供交付清单。同时项目实施人员对系统运维人员进行了培训。已提供建设过程文档和运行维护文档。

在等级测评方面，在确定该信息系统的安全保护等级后，系统级别未发生变化。已在《变更管理制度》中规定系统发生重大变更或级别发生变化时及时进行等级测评。前次选择的测评单位为苏州如意云网络科技有限公司，可在“网络安全等级保护测评机构服务认证获证机构名录”查看到该公司名称，该名录的发布单位是“公安部第三研究所（认证中心）”；符合国家有关规定。

在服务供应商选择方面，当前选择苏州如意云网络科技有限公司作为测评认证服务商，选择华为云计算技术有限公司作为云服务商，选择的安全服务商具备相应的安全资质，符合国家的有关规定。与上述公司签署的服务合同明确了服务内容、服务期限和服务承诺等内容。

此外在云计算安全扩展要求方面还采取了以下安全措施：

在云服务商选择方面，选择的云服务商为华为云计算技术有限公司，其具备相关服务资质，且此次测评系统托管的华为公有云服务(IaaS)系统已通过三级等保测评，提供了等保测评报告，云服务商所提供的云计算平台能够为其所承载的业务应用系统提供相应等级的安全保护能力。当前单位与云服务商-华为云计算技术有限公司签署了《服务水平协议》，在合同中规定了云服务的各项服务内容和具体技术指标，明确了服务商的权限与责任，包括管理的范围、人员职责划分、访问授权、隐私保护、行为准则、违约责任等。合同明确说明服务水平协议中规定服务合约到期时，云服务商要完整提供云服务客户数据，并承诺相关数据在云计算平台上清除。同时合同明确说明云服务商对云服务客户数据的保密规定。

3.9.2 主要安全问题汇总分析

在安全建设管理方面存在如下安全问题：

(1) 系统安全设计方案的论证和审定管理不完善，缺少对系统安全策略相

关配套文件的合理性和正确性的论证和审定记录。

可能存在安全策略缺乏合理性和可行性，导致信息系统安全防御能力缺乏完整性、系统性，不足以满足业务发展需要。

(2) 该系统建设期未邀请第三方公司担任项目监理工作，无法通过第三方工程监理控制项目的实施过程。

可能导致工程实施缺少组织性，工程实施管理不到位。

3.10 安全运维管理

3.10.1 已有安全控制措施汇总分析

在安全运维管理方面采取了以下安全措施：

在环境管理方面，建立的《机房安全管理制度》已对有关物理访问、物品带进出和环境安全等方面的管理作出规定。当前未在重要区域内接待来访人员，未随意放置含有敏感信息的纸档文件和移动介质等。

在资产管理方面，建立了资产清单，提供的《资产管理制度》已明确根据资产的重要程度对资产进行标识管理，根据资产的价值选择相应的管理措施；并对信息分类与标识方法作出规定，并对信息的使用、传输和存储等进行规范化管理。

在设备维护管理方面，对设备的软硬件维护行为进行了制度化规范。

在漏洞和风险管理方面，租户购买了华为云企业主机安全 HSS 企业版，华为云提供了漏洞自动检测并提供了修复方案；租户已每天对系统进行漏洞扫描并修补了漏洞。当前已每年进行一次等级保护测评工作。

在网络和系统安全管理方面，划分了网络管理员、系统管理员、审计管理员和安全管理员等职务，并在《岗位建设管理制度》中明确了各个管理员的岗位职责。系统的账号管理由信息安全部负责，包括账户的删除和创建等。

在恶意代码防范管理方面，已明确说明在员工安全意识培训中对防恶意代码知识进行宣讲，宣讲内容包括防病毒知识和防恶意代码的方法等，并提供了恶意代码防范知识培训的培训记录。

在配置管理方面，当前已提供网络拓扑结构、各个设备安装的软件组件的版本和补丁信息、各个设备或软件组件的配置参数等。

在变更管理方面，已建立中止变更并从失败变更中恢复的程序，明确过程控制方法和人员职责。

在备份与恢复管理方面，明确数据备份方式及备份周期，同时对数据的备份策略和恢复策略、备份程序和恢复程序等方面做出规定。

在安全事件处置方面，已通过会议形式告知用户在发生安全弱点和可疑事件时应及时向安全管理部门汇报；目前尚无安全事件发生。已建立《安全事件报告与处置管理制度》，明确了与安全事件有关的工作职责与安全事件的类型，并在制度中对事件报告和后期恢复的管理职责进行了说明。

在应急预案管理方面，建立了《应急响应预案》，对应急响应的流程、应急演练的步骤、应急响应总结进行了规定和说明，当前每年会进行一次应急预案演练和培训。每年对原有的应急预案进行评估和修订。

3.10.2 主要安全问题汇总分析

在安全运维管理方面存在如下安全问题：

(1) 未指定专门部门或人员对系统进行巡检，未对日志、监测和报警数据等进行分析、统计。

可能存在无法及早发现并处置安全隐患的风险。

3.11 其他安全要求指标

本次测评不包含其他安全要求指标。

3.12 验证测试

表 3-1 测试工具情况表

设备名称	系统/插件版本/是否最新版本/哈希值	测试时间
锐讯漏洞扫描系统	3.0.11.1156/1.0.0.8180/是/7d3fc61c72e0acab2e842fd6574cf4db	2025 年 09 月 04 日
Burpsuite 社区版	BurpSuite Communityv2025_4/是/SHA256:84cb161af592aa37c3ab672a3fe05775d241499153aab525e87ff60eb8c662b0	2025 年 09 月 04 日
NMAP	NMAP7.95/是/SHA256: c59b51d15b5965f27db4c5bbd21793ad6b492c8c751836ba8bd43829d791146e	2025 年 09 月 04 日
科来网络分析系统（技术交流版）	CSNAS 技术交流版 15.2.0.15292/是/SHA256: 5a2f5144e35194cbe58e2cc9b82e97a227f1d6bd70e1edad9a152830fff0b965	2025 年 09 月 04 日

3.12.1 漏洞扫描

3.12.1.1 漏洞扫描结果统计

对“新点 e 交易”电子交易平台进行测评，涉及到测试工具。为了发挥测试工具的作用，达到测评的目的，各种测试工具需要接入到被测系统网络中，并配置合法的网路 IP 地址。

针对被测系统的网络设备、安全设备、服务器、终端和业务应用系统的情况，需要在被测系统网络中设置测试接入点，数据库和中间件漏洞通过其所在服务器进行发现，不单独作为扫描对象，扫描接入点如图 3-1 所示：

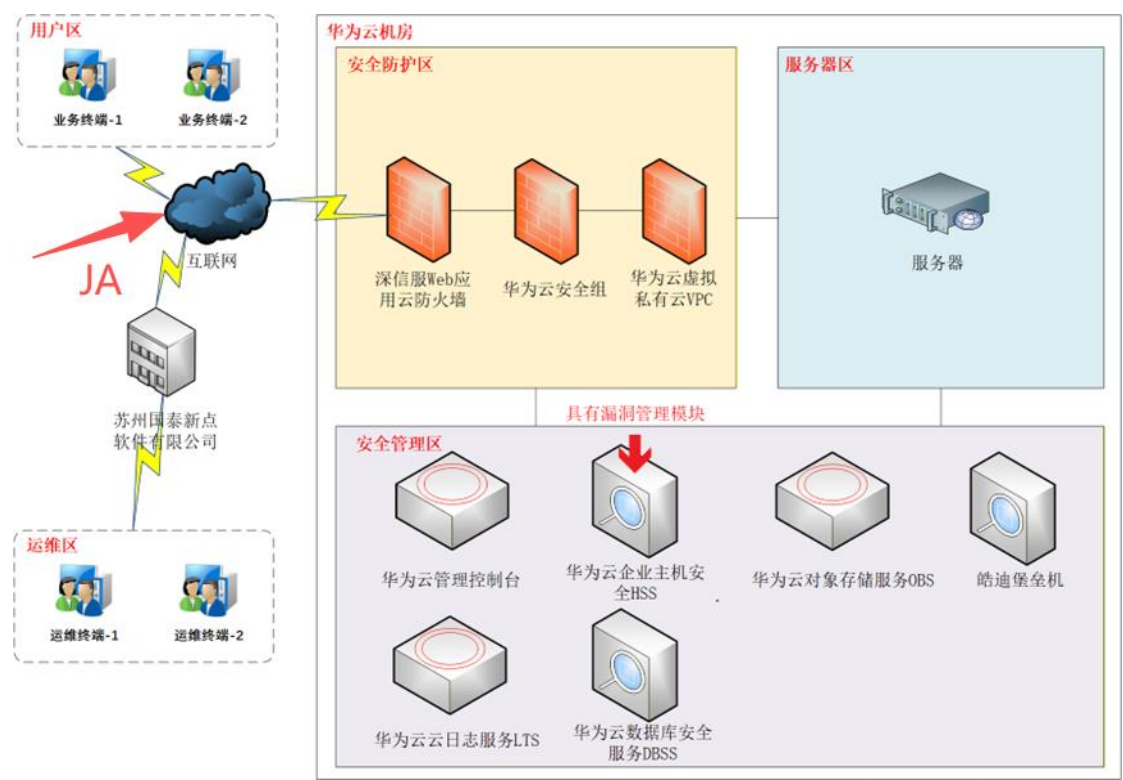


图 3-1 工具扫描接入测试示意图

通过华为云企业安全 HSS 每天从内部对系统服务器和应用系统等进行漏洞扫描。

接入点 JA：在互联网接入，探测目标为“新点 e 交易”电子交易平台的应用系统、系统相关服务器和终端等，漏扫主要目的是模拟外部恶意用户发现 Web 应用系统等安全漏洞的过程，并尝试利用以上漏洞实施诸如获取系统控制权、获得大量敏感信息等模拟攻击行为。在这里选取接入点，是参考“由较低重要程度区域向较高重要程度区域探测、由外联接口向系统内部探测、跨网络隔离设备要分段探测、同一系统同等重要程度功能区域之间要相互探测”这四条原则。

(1) 接入点 JA 漏洞扫描结果统计

接入点 JA 的漏洞扫描结果汇总如下表所示。

表 3-2 接入点 JA 漏洞扫描结果汇总表

序号	设备名称	系统及版本	安全漏洞数量			
			高	中	低	小计
1	eCloud 相关集成服务器	CentOS Linux release 7.4.1708 (Core)	0	0	0	0
2	对外服务器	CentOS Linux release 7.4.1708 (Core)	0	0	0	0
3	竞价与产权服务器	CentOS Linux release 7.4.1708 (Core)	0	0	0	0
4	数据库服务器	CentOS Linux release 7.4.1708 (Core)	0	0	0	0
5	业务框架支撑服务器	CentOS Linux release 7.4.1708 (Core)	0	0	0	0
6	电子交易部署服务器	CentOS Linux release 7.4.1708 (Core)	0	0	0	0
7	数据推送服务器	CentOS Linux release 7.4.1708 (Core)	0	0	0	0
8	应用服务器	CentOS Linux release 7.4.1708 (Core)	0	0	0	0
9	中招前置机服务器	CentOS Linux release 7.4.1708 (Core)	0	0	0	0
10	网站前台服务器	CentOS Linux release 7.4.1708 (Core)	0	0	0	0
11	评标服务器	CentOS Linux release 7.4.1708 (Core)	0	0	0	0
12	智能设备与全文检索服务器	CentOS Linux release 7.4.1708 (Core)	0	0	0	0
13	限额会员端服务器	CentOS Linux release 7.4.1708 (Core)	0	0	0	0
14	评标中间价与诚信库接口服务器	CentOS Linux release 7.4.1708 (Core)	0	0	0	0
15	诚信库部署服务器	CentOS Linux release 7.4.1708 (Core)	0	0	0	0
16	新点限额集群服务器	CentOS Linux release 7.4.1708 (Core)	0	0	0	0
17	江苏限额集群服务	CentOS Linux release 7.4.	0	0	0	0

序号	设备名称	系统及版本	安全漏洞数量			
			高	中	低	小计
	器	1708 (Core)				
18	评标中间服务器	CentOS Linux release 7.4.1708 (Core)	0	0	0	0
19	项目 1-不见面大厅服务器	CentOS Linux release 7.4.1708 (Core)	0	0	0	0
20	项目 1-新点 e 交易推送服务 2.0 前置机	CentOS Linux release 7.4.1708 (Core)	0	0	0	0
21	项目 1-开标大厅服务器	CentOS Linux release 7.4.1708 (Core)	0	0	0	0
22	档案服务器	CentOS Linux release 7.4.1708 (Core)	0	0	0	0
23	运维终端-1	Windows 7 旗舰版 (内部版本 7601: Service Pack 1)	0	0	0	0
24	运维终端-2	Windows 7 旗舰版 (内部版本 7601: Service Pack 1)	0	0	0	0
25	业务终端-1	Windows 7 旗舰版 (内部版本 7601: Service Pack 1)	0	0	0	0
26	业务终端-2	Windows 7 旗舰版 (内部版本 7601: Service Pack 1)	0	0	0	0
27	“新点 e 交易”电子交易平台	V1.0	0	0	0	0
28	深信服 Web 应用云防火墙	V8.0.60	0	0	0	0
29	皓迪堡垒机	Version 2.0	0	0	0	0

3.12.1.2 漏洞扫描问题描述

通过对漏洞扫描结果进行分析,“新点 e 交易”电子交易平台存在的主要安全漏洞汇总如下表所示。

表 3-3 主要安全漏洞汇总表

序号	安全漏洞名称	关联资产/域名	严重程度
本次漏扫未发现安全漏洞			

3.12.2 渗透测试

3.12.2.1 渗透测试过程说明

测试方法

基于“新点 e 交易”电子交易平台安全测试的性质和目的，渗透测试中漏洞利用手段包括但不限于：持久化、权限提升、防御绕过、凭据访问、发现、横向移动、收集、命令与控制等。

为了不对测试目标造成破坏、损害或篡改，对于某些可能会对测试对象造成负面影响的攻击方法和手段在本次安全测试中没有使用，具体包括：社会工程学、分布式拒绝服务攻击、散布病毒（包括木马、恶意代码等）、对即时通讯工具的攻击、网络钓鱼等。

测试过程

1、收集目标系统信息

渗透测试目标收集包括方案中选定的：

网络设备（互联 IP 地址、端口使用情况）；

安全设备（工作状态：透明、路由模式等；IP 地址等）；

主机各设备的类型（操作系统类型、主要应用、IP 地址等）；

目标系统网络拓扑结构等相关信息（各区域网络地址段划分情况等）。

2、规划工具测试接入点

渗透测试接入点采用漏洞扫描工具接入点进行测试，如图 3-1 工具扫描接入测试示意图。

接入点的规划，考虑网络结构、访问控制、服务器部署情况等，现场测试时，参考以下原则：

由低级别系统向高级别系统探测；

同一系统同等重要程度功能区域之间要相互探测；

由非核心区域向核心区域探测；

由外联接口向系统内部探测；

跨网络隔离设备（包括网络设备和安全设备）要分段探测。

3、现场测试

在获取到了现场测试的授权之后，进入现场，根据《工具测试作业指导书》中的测试步骤，进行现场测试。测试过程中，详细记录每一接入点测试的起止时间、接入 IP 地址（包括接入设备的 IP 地址配置，掩码、网管配置等）。

如果测试过程中出现异常情况，及时记录。重要验证步骤抓图取证，为测试结果的整理准备充足必要的证据。

在现场测试过程中，可能要对某些扫描报告中的漏洞进行验证，验证测试之前会先对扫描出的漏洞进行分析、判断，其目的是验证漏洞的真实性以为之后的报告提供测试证据。

进行验证测试和工具测试时，避开业务高峰期，在系统资源处于空闲状态时进行；上机验证测试由测评人员提出需要验证的内容，系统运营、使用单位的技术人员进行实际操作。整个现场测评过程系统运营、使用单位全程监督。

4、测试结果整理分析

依据报告统一格式对现场测评中取得的各种测试数据进行整理统计。从整理的结果中，可以分析出被测系统中各个被测个体存在的漏洞情况，也可以根据各

个接入点测试结果的统计整理，分析出各个区域之间的访问控制策略配置情况。

3.12.2.2 渗透测试问题描述

通过渗透测试发现,“新点 e 交易”电子交易平台存在的安全问题汇总如下表所示。

表 3-4 渗透测试结果汇总表							
序号	安全问题	关联资产/域名	严重程度	通用/扩展	安全类	控制点	测评项
1	暴力破解	“新点 e 交易”电子交易平台/ https://www.etrading.cn	中	通用	安全计算环境	身份鉴别	b)应具有登录失败处理功能，应配置并启用结束会话、限制非法登录次数和当登录连接超时自动退出等相关措施；

3.13 安全问题汇总

针对单项测评结果中存在的部分符合项和不符合项进行汇总，形成安全问题如下表所示。

表 3-5 安全问题汇总表						
问题编号	安全问题	测评对象	通用/扩展	安全类	控制点	测评项
T1	未基于可信根对通信设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。	安全通信网络	安全通用要求	安全通信网络	可信验证	可基于可信根对通信设备的系统引导程序、系统程序、重要配置参数和通信应用程序等进行可信验证，并在应用程序的关键执行环节进行动态可信验证，在检测到其可信性受到破坏后进行报

问题编号	安全问题	测评对象	通用/扩展	安全类	控制点	测评项
						警，并将验证结果形成审计记录送至安全管理中心。
T2	未采用技术手段对内部用户非授权联到外部网络的行为进行检查或限制。	安全区域边界	安全通用要求	安全区域边界	边界防护	c)应能够对内部用户非授权联到外部网络的行为进行检查或限制；
T3	网络中未部署恶意代码防范系统，无法对恶意代码进行检测和清除。	安全区域边界	安全通用要求	安全区域边界	恶意代码和垃圾邮件防范	a)应在关键网络节点处对恶意代码进行检测和清除，并维护恶意代码防护机制的升级和更新；
T4	未采取措施对访问互联网的用户行为进行审计。	安全区域边界	安全通用要求	安全区域边界	安全审计	d)应能对远程访问的用户行为、访问互联网的用户行为等单独进行行为审计和数据分析。
T5	未基于可信根对边界设备的系统引导程序、系统程序、重要配置参数和通信应用程序等进行动态可信验证。	安全区域边界	安全通用要求	安全区域边界	可信验证	可基于可信根对边界设备的系统引导程序、系统程序、重要配置参数和边界防护应用程序等进行可信验证，并在应用程序的关键执行环节进行动态可信验证，在检测到其可信性受到破坏后进行报警，并将验证结果形成审计记录送至安全管理中心。
T6	未配置口令有效期策略。	MySQL 数据库、“新点e 交易”电子	安全通用要求	安全计算环境	身份鉴别	a)应对登录的用户进行身份标识和鉴别，身份标识具有唯一

问题编号	安全问题	测评对象	通用/扩展	安全类	控制点	测评项
		交易平台				性，身份鉴别信息具有复杂度要求并定期更换；
T7	口令有效周期过长。	皓迪堡垒机	安全通用要求	安全计算环境	身份鉴别	
T8	未配置口令复杂度策略和口令有效期策略。	运维终端-1、运维终端-2、业务终端-1、业务终端-2	安全通用要求	安全计算环境	身份鉴别	
T9	登录连接超时过长。	华为云虚拟私有云 VPC、华为云安全组、华为云企业主机安全 HSS、华为云对象存储服务 OBS、皓迪堡垒机、华为云云日志服务 LTS、华为云数据库安全服务 DBSS、华为云管理控制台	安全通用要求	安全计算环境	身份鉴别	b)应具有登录失败处理功能，应配置并启用结束会话、限制非法登录次数和当登录连接超时自动退出等相关措施；
T10	未配置登录失败处理策略，未配置合理的登录连接超时自动退出策略。	MySQL 数据库	安全通用要求	安全计算环境	身份鉴别	
T11	未配置登录失败处理策略及登录连接超时自动退出策略。	运维终端-1、运维终端-2、业务终端-1、业务终端-2	安全通用要求	安全计算环境	身份鉴别	
T12	未采用两种	华为云虚拟	安全通	安全计	身份鉴	d)应采用口令、密码

问题编号	安全问题	测评对象	通用/扩展	安全类	控制点	测评项
	或两种以上组合的鉴别技术对用户进行身份鉴别，其中一种鉴别技术至少应使用密码技术来实现。	私有云 VP C、深信服 Web 应用云防火墙、华为云安全组、华为云企业主机安全 H SS、华为云对象存储服务 OBS、皓迪堡垒机、华为云云日志服务 LTS、华为云数据库安全服务 DBSS、e Cloud 相关集成服务器、对外服务器、竞价与产权服务器、数据库服务器、业务框架支撑服务器、电子交易部署服务器、数据推送服务器、应用服务器、中招前置机服务器、网站前台服务器、评标服务器、智能设备与全文检索服务器、限额会员端服务器、评标中间价与诚信库接口	用要求	算环境	别	技术、生物技术等两种或两种以上组合的鉴别技术对用户进行身份鉴别，且其中一种鉴别技术至少应使用密码技术来实现。

问题编号	安全问题	测评对象	通用/扩展	安全类	控制点	测评项
		服务器、诚信库部署服务器、新点限额集群服务器、江苏限额集群服务器、评标中间服务器、项目 1-不见面大厅服务器、项目 1-新点 e 交易推送服务 2.0 前置机、项目 1-开标大厅服务器、档案服务器、运维终端-1、运维终端-2、业务终端-1、业务终端-2、华为云管理控制台、MySQL 数据库、“新点 e 交易”电子交易平台				
T13	采用默认账户进行管理。	深信服 Web 应用云防火墙、皓迪堡垒机、eCloud 相关集成服务器、对外服务器、竞价与产权服务器、数据库服务器、业务框架支撑服务	安全通用要求	安全计算环境	访问控制	b)应重命名或删除默认账户，修改默认账户的默认口令；

问题编号	安全问题	测评对象	通用/扩展	安全类	控制点	测评项
		器、电子交易部署服务器、数据推送服务器、应用服务器、中招前置机服务器、网站前台服务器、评标服务器、智能设备与全文检索服务器、限额会员端服务器、评标中间价与诚信库接口服务器、诚信库部署服务器、新点限额集群服务器、江苏限额集群服务器、评标中间服务器、项目 1-不见面大厅服务器、项目 1-新点 e 交易推送服务 2.0 前置机、项目 1-开标大厅服务器、档案服务器、运维终端-1、运维终端-2、业务终端-1、业务终端-2、MySQL 数据库				

问题编号	安全问题	测评对象	通用/扩展	安全类	控制点	测评项
T14	未授予不同账户为了完成各自承担任务所需的最小权限。	深信服 Web 应用云防火墙、皓迪堡垒机、eCloud 相关集成服务器、对外服务器、竞价与产权服务器、数据库服务器、业务框架支撑服务器、电子交易部署服务器、数据推送服务器、应用服务器、中招前置机服务器、网站前台服务器、评标服务器、智能设备与全文检索服务器、限额会员端服务器、评标中间价与诚信库接口服务器、诚信库部署服务器、新点限额集群服务器、江苏限额集群服务器、评标中间服务器、项目 1-不见面大厅服务器、项目 1-新点 e	安全通用要求	安全计算环境	访问控制	d)应授予管理用户所需的最小权限，实现管理用户的权限分离；

问题编号	安全问题	测评对象	通用/扩展	安全类	控制点	测评项
		交易推送服务 2.0 前置机、项目 1-开标大厅服务器、档案服务器、运维终端-1、运维终端-2、业务终端-1、业务终端-2、MySQL 数据库、“新点 e 交易”电子交易平台				
T15	未配置安全管理员账户对访问控制策略进行配置。	深信服 Web 应用云防火墙、皓迪堡垒机、eCloud 相关集成服务器、对外服务器、竞价与产权服务器、数据库服务器、业务框架支撑服务器、电子交易部署服务器、数据推送服务器、应用服务器、中招前置机服务器、网站前台服务器、评标服务器、智能设备与全文检索服务器、	安全通用要求	安全计算环境	访问控制	e)应由授权主体配置访问控制策略，访问控制策略规定主体对客体的访问规则；

问题编号	安全问题	测评对象	通用/扩展	安全类	控制点	测评项
		限额会员端服务器、评标中间价与诚信库接口服务器、诚信库部署服务器、新点限额集群服务器、江苏限额集群服务器、评标中间服务器、项目 1-不见面大厅服务器、项目 1-新点 e 交易推送服务 2.0 前置机、项目 1-开标大厅服务器、档案服务器、运维终端-1、运维终端-2、业务终端-1、业务终端-2、MySQL 数据库、“新点 e 交易”电子交易平台				
T16	未对重要主体和客体设置安全标记，未实现通过安全标记控制主体对信息资源的访问。	华为云虚拟私有云 VPC、深信服 Web 应用云防火墙、华为云安全组、华为云企业主机安全 HSS、华为云	安全通用要求	安全计算环境	访问控制	g)应对重要主体和客体设置安全标记，并控制主体对有安全标记信息资源的访问。

问题 编号	安全问题	测评对象	通用/扩 展	安全类	控制点	测评项
		对象存储服务 OBS、皓迪堡垒机、华为云云日志服务 LTS、华为云数据库安全服务 DBSS、eCloud 相关集成服务器、对外服务器、竞价与产权服务器、数据库服务器、业务框架支撑服务器、电子交易部署服务器、数据推送服务器、应用服务器、中招前置机服务器、网站前台服务器、评标服务器、智能设备与全文检索服务器、限额会员端服务器、评标中间价与诚信库接口服务器、诚信库部署服务器、新点限额集群服务器、江苏限额集群服务器、评标中间服务				

问题编号	安全问题	测评对象	通用/扩展	安全类	控制点	测评项
		器、项目 1-不见面大厅服务器、项目 1-新点 e 交易推送服务 2.0 前置机、项目 1-开标大厅服务器、档案服务器、运维终端-1、运维终端-2、业务终端-1、业务终端-2、华为云管理控制台、MySQL 数据库、“新点 e 交易”电子交易平台				
T17	审计范围未覆盖所有重要的用户行为和安全事件。	运维终端-1、运维终端-2、业务终端-1、业务终端-2	安全通用要求	安全计算环境	安全审计	a)应启用安全审计功能，审计覆盖到每个用户，对重要的用户行为和重要安全事件进行审计；
T18	审计记录仅保存在本机，未进行定期备份。	皓迪堡垒机、运维终端-1、运维终端-2、业务终端-1、业务终端-2	安全通用要求	安全计算环境	安全审计	c)应对审计记录进行保护，定期备份，避免受到未预期的删除、修改或覆盖等；
T19	未采取措施对系统审计进程进行保护。	eCloud 相关集成服务器、对外服务器、竞价与产权服务器、数据库服务器、业务框架支撑	安全通用要求	安全计算环境	安全审计	d)应对审计进程进行保护，防止未经授权的中断。

问题编号	安全问题	测评对象	通用/扩展	安全类	控制点	测评项
		服务器、电子交易部署服务器、数据推送服务器、应用服务器、中招前置机服务器、网站前台服务器、评标服务器、智能设备与全文检索服务器、限额会员端服务器、评标中间价与诚信库接口服务器、诚信库部署服务器、新点限额集群服务器、江苏限额集群服务器、评标中间服务器、项目 1-不见面大厅服务器、项目 1-新点 e 交易推送服务 2.0 前置机、项目 1-开标大厅服务器、档案服务器、My SQL 数据库				
T20	开启了不必要的服务、不必要的默认共享和高	运维终端 -1、运维终端 -2、业务终端 -1、业务	安全通用要求	安全计算环境	入侵防范	b)应关闭不需要的系统服务、默认共享和高危端口；

问题编号	安全问题	测评对象	通用/扩展	安全类	控制点	测评项
	危端口。	终端-2				
T21	未严格限制终端登录地址范围。	深信服 Web 应用云防火墙、皓迪堡垒机、eCloud 相关集成服务器、对外服务器、竞价与产权服务器、数据库服务器、业务框架支撑服务器、电子交易部署服务器、数据推送服务器、应用服务器、中招前置机服务器、网站前台服务器、评标服务器、智能设备与全文检索服务器、限额会员端服务器、评标中间价与诚信库接口服务器、诚信库部署服务器、新点限额集群服务器、江苏限额集群服务器、评标中间服务器、项目 1-不见面大厅	安全通用要求	安全计算环境	入侵防范	c)应通过设定终端接入方式或网络地址范围对通过网络进行管理的管理终端进行限制；

问题编号	安全问题	测评对象	通用/扩展	安全类	控制点	测评项
		服务器、项目 1-新点 e 交易推送服务 2.0 前置机、项目 1-开标大厅服务器、档案服务器、MySQL 数据库				
T22	未定期进行漏洞扫描。	运维终端 -1、运维终端 -2、业务终端 -1、业务终端 -2	安全通用要求	安全计算环境	入侵防范	e)应能发现可能存在的已知漏洞，并在经过充分测试评估后，及时修补漏洞；
T23	系统未采用可信计算技术对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。	华为云私有云 VPC、深信服 Web 应用云防火墙、华为云安全组、华为云企业主机安全 HSS、华为云对象存储服务 OBS、皓迪堡垒机、华为云云日志服务 LTS、华为云数据库安全服务 DBSS、eCloud 相关集成服务器、对外服务器、竞价与产权服务器、数据库服务器、业务框架支撑	安全通用要求	安全计算环境	可信验证	可基于可信根对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行可信验证，并在应用程序的关键执行环节进行动态可信验证，在检测到其可信性受到破坏后进行报警，并将验证结果形成审计记录送至安全管理中心。

问题 编号	安全问题	测评对象	通用/扩 展	安全类	控制点	测评项
		服务器、电 子交易部署 服务器、数 据推送服务 器、应用服 务器、中招 前置机服务 器、网站前 台服务器、 评标服务 器、智能设 备与全文检 索服务器、 限额会员端 服务器、评 标中间价与 诚信库接口 服务器、诚 信库部署服 务器、新点 限额集群服 务器、江苏 限额集群服 务器、评标 中间服务 器、项目 1- 不见面大厅 服务器、项 目 1-新点 e 交易推送服 务 2.0 前置 机、项目 1- 开标大厅服 务器、档案 服务器、运 维终端-1、 运维终端- 2、业务终 端-1、业务 终端-2、华 为云管理控制				

问题编号	安全问题	测评对象	通用/扩展	安全类	控制点	测评项
		台、Nginx 中间件、MySQL 数据库、“新点 e 交易”电子交易平台				
T24	未提供重要配置数据和鉴别数据存储完整性被破坏时的检查和报警机制。	“新点 e 交易”电子交易平台	安全通用要求	安全计算环境	数据完整性	b)应采用校验技术或密码技术保证重要数据在存储过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等。
T25	未采用校验技术或密码技术保证重要配置数据和鉴别数据在存储过程中的完整性。	华为云私有云 VPC、深信服 Web 应用云防火墙、华为云安全组、华为云企业主机安全 HSS、华为云对象存储服务 OBS、皓迪堡垒机、华为云云日志服务 LTS、华为云数据库安全服务 DBSS、eCloud 相关集成服务器、对外服务器、竞价与产权服务器、数据库服务器、业务框架支撑服务器、电	安全通用要求	安全计算环境	数据完整性	

问题 编号	安全问题	测评对象	通用/扩 展	安全类	控制点	测评项
		子交易部署 服务器、数 据推送服务 器、应用服 务器、中招 前置机服务 器、网站前 台服务器、 评标服务 器、智能设 备与全文检 索服务器、 限额会员端 服务器、评 标中间价与 诚信库接口 服务器、诚 信库部署服 务器、新点 限额集群服 务器、江苏 限额集群服 务器、评标 中间服务 器、项目 1- 不见面大厅 服务器、项 目 1-新点 e 交易推送服 务 2.0 前置 机、项目 1- 开标大厅服 务器、档案 服务器、运 维终端-1、 运维终端 - 2、业务终端 -1、业务终 端-2、华为 云管理控制 台、MySQL				

问题编号	安全问题	测评对象	通用/扩展	安全类	控制点	测评项
		数据库				
T26	未提供重要个人信息存储完整性被破坏时的检查和报警机制。	重要个人信息	安全通用要求	安全计算环境	数据完整性	
T27	未提供重要业务数据存储完整性被破坏时的检查和报警机制。	重要业务数据	安全通用要求	安全计算环境	数据完整性	
T28	未采用校验技术或密码技术保证重要配置数据在存储过程中的完整性。	Nginx 中间件	安全通用要求	安全计算环境	数据完整性	
T29	未采用密码技术实现鉴别数据和重要配置数据在存储过程中的保密性。	华为云虚拟私有云 VPC、深信服 Web 应用云防火墙、华为云安全组、华为云企业主机安全 HSS、华为云对象存储服务 OBS、皓迪堡垒机、华为云云日志服务 LTS、华为云数据库安全服务 DBSS、华为云管理控	安全通用要求	安全计算环境	数据保密性	b)应采用密码技术保证重要数据在存储过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等。

问题编号	安全问题	测评对象	通用/扩展	安全类	控制点	测评项
		制台				
T30	未采用密码技术保证重要配置数据在存储过程中的保密性。	eCloud 相关集成服务器、对外服务器、竞价与产权服务器、数据库服务器、业务框架支撑服务器、电子交易部署服务器、数据推送服务器、应用服务器、中招前置机服务器、网站前台服务器、评标服务器、智能设备与全文检索服务器、限额会员端服务器、评标中间价与诚信库接口服务器、诚信库部署服务器、新点限额集群服务器、江苏限额集群服务器、评标中间服务器、项目 1-不见面大厅服务器、项目 1-新点 e 交易推送服务 2.0 前置	安全通用要求	安全计算环境	数据保密性	

问题编号	安全问题	测评对象	通用/扩展	安全类	控制点	测评项
		机、项目 1-开标大厅服务器、档案服务器、运维终端-1、运维终端-2、业务终端-1、业务终端-2、Nginx 中间件、MySQL 数据库				
T31	未对备份文件进行过恢复性测试。	华为云虚拟私有云 VPC、深信服 Web 应用云防火墙、华为云安全组、华为云企业主机安全 HSS、华为云对象存储服务 OBS、皓迪堡垒机、华为云云日志服务 LTS、华为云数据库安全服务 DBSS	安全通用要求	安全计算环境	数据备份恢复	a)应提供重要数据的本地数据备份与恢复功能；
T32	未将重要数据实时备份至异地。	重要业务数据、重要个人信息	安全通用要求	安全计算环境	数据备份恢复	b)应提供异地实时备份功能，利用通信网络将重要数据实时备份至备份场地；
T33	未在远程管理云平台中设备时，在管理终端和云平台间建立双向身份验证机制。	云租户安全扩展要求	云计算安全扩展要求	安全计算环境	身份鉴别	当远程管理云计算平台中设备时，管理终端和云计算平台之间应建立双向身份验证机制。

问题编号	安全问题	测评对象	通用/扩展	安全类	控制点	测评项
T34	系统安全设计方案的论证和审定管理不完善，缺少对系统安全策略相关配套文件的合理性和正确性的论证和审定记录。	制度或记录类文档	安全通用要求	安全建设管理	安全方案设计	c)应组织相关部门和有关安全专家对安全整体规划及其配套文件的合理性和正确性进行论证和审定，经过批准后才能正式实施。
T35	该系统建设期未邀请第三方公司担任项目监理工作，无法通过第三方工程监理控制项目的实施过程。	制度或记录类文档	安全通用要求	安全建设管理	工程实施	c)应通过第三方工程监理控制项目的实施过程。
T36	未指定专门部门或人员对系统进行巡检，未对日志、监测和报警数据等进行分析、统计。	制度或记录类文档	安全通用要求	安全运维管理	网络 and 系统安全管理	f)应指定专门的部门或人员对日志、监测和报警数据等进行分析、统计，及时发现可疑行为；

4 整体测评

4.1 安全控制点间安全测评

本次测评不包含本类安全检测调整项。

4.2 区域间安全测评

安全计算环境-恶意代码防范对安全区域边界-恶意代码和垃圾邮件防范 a)

功能补偿

在安全区域边界中，未部署恶意代码防护系统，无法对网络中的恶意代码攻击进行检测和防护，可能会造成恶意代码流入系统造成破坏的风险，但在安全计算环境的恶意代码防范中，服务器操作系统安装了华为云企业主机安全 HSS 企业版，终端操作系统安装了火绒安全软件，并及时更新病毒库，能够对恶意代码攻击行为进行检测和清除，在一定程度上降低了恶意代码带来的风险，对安全问题起到一定的补偿作用。因此可降低该项问题的安全风险。

4.3 整体测评结果汇总

经整体测评后安全问题严重程度变化情况如下表所示。

表 4-1 整体测评结果汇总表

问题编号	安全问题	测评对象	整体测评描述	严重程度变化
T3	网络中未部署恶意代码防范系统，无法对恶意代码进行检测和清除。	安全区域边界	在安全区域边界中，未部署恶意代码防护系统，无法对网络中的恶意代码攻击进行检测和防护，可能会造成恶意代码流入系统造成破坏的风险，但在安全计算环境的恶意代码防范中，服务器操作系统安装了华为云企业主机安全 HSS 企业版，终端操作系统安装了火绒安全软件，并及时更新病毒库，能够对恶意代码攻击行为进行检测和清除，在一定程度上降低了恶意代码带来的风险，对安全问题起到一定的补偿作用。	高→中

5 安全问题风险分析

5.1 低中高风险安全问题分析

针对等级测评结果中存在的所有安全问题，结合关联资产和威胁分别分析安全问题可能产生的危害结果，找出可能对系统、单位、社会及国家造成的最大安

全危害（损失），并根据最大安全危害（损失）的严重程度进一步确定安全问题的风险等级，结果为“高”“中”或“低”。最大安全危害（损失）结果应结合安全问题所影响业务的重要程度、相关系统组件的重要程度、安全问题严重程度以及安全事件影响范围等进行综合分析。

风险分析结果为“高”“中”或“低”风险等级的问题如表 5-1 所示。

表 5-1 安全问题风险分析

序号	安全类	安全问题	关联资产	关联威胁	危害分析结果	风险等级
1	安全通信网络	未基于可信根对通信设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。	安全通信网络	篡改	无可信验证，无法通过主动免疫可信验证技术提高系统自身安全防护能力，无法实现积极主动防御。	低
2	安全区域边界	未采用技术手段对内部用户非授权联到外部网络的行为进行检查或限制。	安全区域边界	恶意攻击	未采取技术措施对非授权的内部用户私自连接外部网络的行为进行检查、限制，存在未授权的内部网络用户私自连接外部网络容易导致数据泄露。	中
3		网络中未部署恶意代码防范系统，无法对恶意代码进行检测和清除。	安全区域边界	恶意攻击	无法检测潜在的恶意代码，可能会造成恶意代码流入系统造成破坏的风险。	中
4		未采取措施对访问互联网的用户行为进行审计。	安全区域边界	抵赖	无法对访问互联网的用户行文进行管理和记录，不能及时对相关的未授权操作或访问行为进行及时有效的追溯等。	中

序号	安全类	安全问题	关联资产	关联威胁	危害分析结果	风险等级
5		未基于可信根对边界设备的系统引导程序、系统程序、重要配置参数和通信应用程序等进行动态可信验证。	安全区域边界	篡改	无可信验证,无法通过主动免疫可信验证技术提高系统自身安全防护能力,无法实现积极主动防御。	低
6	安全计算环境	未配置口令有效期策略。	MySQL 数据库、“新点 e 交易”电子交易平台	恶意攻击	账户口令可能被长时间使用存在口令被长时间非法盗用的风险。	中
7		口令有效周期过长。	皓迪堡垒机	恶意攻击	账户口令可能被长时间使用,恶意人员可通过猜解的方式获取账户口令,存在非授权访问的风险。	中
8		未配置口令复杂度策略和口令有效期策略。	运维终端-1、运维终端-2、业务终端-1、业务终端-2	恶意攻击	账户口令可能被设置为弱口令,且长时间使用,恶意人员可通过猜解的方式获取账户口令,存在非授权访问的风险。	中
9		登录连接超时过长。	华为云虚拟私有云 VPC、华为云安全组、华为云企业主机安全 HSS、华为云对象存储服务 OBS、皓迪堡垒机、华为云云日志服务 LTS、华为云数据库安全服务 DBSS、华为云管理控制台	恶意攻击	系统易被非授权人员恶意操作,存在非授权访问的风险。	中
10		未配置登录失	MySQL 数据库	恶意	恶意人员可通过	中

序号	安全类	安全问题	关联资产	关联威胁	危害分析结果	风险等级
	11	败处理策略，未配置合理的登录连接超时自动退出策略。		攻击	暴力破解的方式获取账户口令，且设备易被非授权人员恶意操作，存在非授权访问的风险。	
11		未配置登录失败处理策略及登录连接超时自动退出策略。	运维终端-1、运维终端-2、业务终端-1、业务终端-2	恶意攻击	恶意人员可通过暴力破解的方式获取账户口令，且设备易被非授权人员恶意操作，存在非授权访问的风险。	中
12		未采用两种或两种以上组合的鉴别技术对用户进行身份鉴别，其中一种鉴别技术至少应使用密码技术来实现。	华为云虚拟私有云 VPC、深信服 Web 应用云防火墙、华为云安全组、华为云企业主机安全 HSS、华为云对象存储服务 OBS、皓迪堡垒机、华为云云日志服务 LTS、华为云数据库安全服务 DBSS、eCloud 相关集成服务器、对外服务器、竞价与产权服务器、数据库服务器、业务框架支撑服务器、电子交易部署服务器、数据推送服务器、应用服务器、中招前置机服务器、网站前台服务器、评标服务器、智能设备与全文检索服务器、限额会员端服务器、评标中间价与诚信库接	恶意攻击	单一鉴别技术安全强度有限，如果未采用双因素认证，一旦被嗅探和泄露，将再没有其它技术进行身份鉴别，存在非授权访问的风险。	高

序号	安全类	安全问题	关联资产	关联威胁	危害分析结果	风险等级
			口服务器、诚信库部署服务器、新点限额集群服务器、江苏限额集群服务器、评标中间服务器、项目 1-不见面大厅服务器、项目 1-新点 e 交易推送服务 2.0 前置机、项目 1-开标大厅服务器、档案服务器、运维终端-1、运维终端-2、业务终端-1、业务终端-2、华为云管理控制台、MySQL 数据库、“新点 e 交易”电子交易平台			
13		采用默认账户进行管理。	深信服 Web 应用云防火墙、皓迪堡垒机、eCloud 相关集成服务器、对外服务器、竞价与产权服务器、数据库服务器、业务框架支撑服务器、电子交易部署服务器、数据推送服务器、应用服务器、中招前置机服务器、网站前台服务器、评标服务器、智能设备与全文检索服务器、限额会员端服务器、评标中间价与诚信库接口服务器、诚信库部署服务器、新点限额集群服务器、江苏限额集群服务器、评	恶意攻击	恶意人员可能利用默认账户对系统进行试探攻击，存在潜在的安全隐患，但未使用默认口令，能够降低系统被攻击的风险，整体风险可控，可降低风险。	中

序号	安全类	安全问题	关联资产	关联威胁	危害分析结果	风险等级
			标中间服务器、项目 1-不见面大厅服务器、项目 1-新点 e 交易推送服务 2.0 前置机、项目 1-开标大厅服务器、档案服务器、运维终端-1、运维终端-2、业务终端-1、业务终端-2、MySQL 数据库			
14		未授予不同账户为了完成各自承担任务所需的最小权限。	深信服 Web 应用云防火墙、皓迪堡垒机、eCloud 相关集成服务器、对外服务器、竞价与产权服务器、数据库服务器、业务框架支撑服务器、电子交易部署服务器、数据推送服务器、应用服务器、中招前置机服务器、网站前台服务器、评标服务器、智能设备与全文检索服务器、限额会员端服务器、评标中间价与诚信库接口服务器、诚信库部署服务器、新点限额集群服务器、江苏限额集群服务器、评标中间服务器、项目 1-不见面大厅服务器、项目 1-新点 e 交易推送服务 2.0 前置机、项目 1-开标大厅服务器、档案服务器、运维终	越权或滥用	无法实现不同权限角色间的监督，存在管理账户越权管理或滥用权限的风险。	中

序号	安全类	安全问题	关联资产	关联威胁	危害分析结果	风险等级
			端-1、运维终端-2、业务终端-1、业务终端-2、MySQL数据库、“新点e交易”电子交易平台			
15		未配置安全管理员账户对访问控制策略进行配置。	深信服 Web 应用云防火墙、皓迪堡垒机、eCloud 相关集成服务器、对外服务器、竞价与产权服务器、数据库服务器、业务框架支撑服务器、电子交易部署服务器、数据推送服务器、应用服务器、中招前置机服务器、网站前台服务器、评标服务器、智能设备与全文检索服务器、限额会员端服务器、评标中间价与诚信库接口服务器、诚信库部署服务器、新点限额集群服务器、江苏限额集群服务器、评标中间服务器、项目 1-不见面大厅服务器、项目 1-新点 e 交易推送服务 2.0 前置机、项目 1-开标大厅服务器、档案服务器、运维终端-1、运维终端-2、业务终端-1、业务终端-2、MySQL数据库、“新点e交易”电子交易平台	越权或滥用	无法有效的对访问控制策略进行管控,可能出现不必要的访问控制策略,存在潜在的安全隐患,但采取系统仅在内部网络访问或采用在后台对访问控制策略进行配置,能够降低系统被攻击的风险,整体风险可控,可降低风险。	中

序号	安全类	安全问题	关联资产	关联威胁	危害分析结果	风险等级
16		未对重要主体和客体设置安全标记，未实现通过安全标记控制主体对信息资源的访问。	华为云虚拟私有云 VPC、深信服 Web 应用云防火墙、华为云安全组、华为云企业主机安全 HSS、华为云对象存储服务 OBS、皓迪堡垒机、华为云云日志服务 LTS、华为云数据库安全服务 DBSS、eCloud 相关集成服务器、对外服务器、竞价与产权服务器、数据库服务器、业务框架支撑服务器、电子交易部署服务器、数据推送服务器、应用服务器、中招前置机服务器、网站前台服务器、评标服务器、智能设备与全文检索服务器、限额会员端服务器、评标中间价与诚信库接口服务器、诚信库部署服务器、新点限额集群服务器、江苏限额集群服务器、评标中间服务器、项目 1-不见面大厅服务器、项目 1-新点 e 交易推送服务 2.0 前置机、项目 1-开标大厅服务器、档案服务器、运维终端-1、运维终端-2、业务终端-1、业务终端-2、华为云管理控	越权或滥用	恶意用户可能通过修改用户权限等方法，非授权访问重要信息资源，存在潜在的安全隐患。	低

序号	安全类	安全问题	关联资产	关联威胁	危害分析结果	风险等级
			制台、MySQL 数据库、“新点 e 交易”电子交易平台			
17		审计范围未覆盖所有重要的用户行为和安全事件。	运维终端-1、运维终端-2、业务终端-1、业务终端-2	抵赖	不便于对安全事件进行追溯和分析,同时无法及时了解设备实际运行状况以及可能存在的安全隐患。	中
18		审计记录仅保存在本机,未进行定期备份。	皓迪堡垒机、运维终端-1、运维终端-2、业务终端-1、业务终端-2	抵赖	日志记录容易受到恶意篡改、删除,不便于对安全事件进行追踪和分析。	中
19		未采取措施对系统审计进程进行保护。	eCloud 相关集成服务器、对外服务器、竞价与产权服务器、数据库服务器、业务框架支撑服务器、电子交易部署服务器、数据推送服务器、应用服务器、中招前置机服务器、网站前台服务器、评标服务器、智能设备与全文检索服务器、限额会员端服务器、评标中间价与诚信库接口服务器、诚信库部署服务器、新点限额集群服务器、江苏限额集群服务器、评标中间服务器、项目 1-不见面大厅服务器、项目 1-新点 e 交易推送服务 2.0 前置机、项目 1-开	抵赖	审计进程容易受到未预期的中断,造成日志记录缺失,不便于对安全事件进行追踪和分析。	中

序号	安全类	安全问题	关联资产	关联威胁	危害分析结果	风险等级
			标大厅服务器、档案服务器、MySQL 数据库			
20		开启了不必要的服务、不必要的默认共享和高危端口。	运维终端-1、运维终端-2、业务终端-1、业务终端-2	恶意攻击	恶意人员可能利用默认服务中的漏洞、默认共享或高危端口对系统进行攻击。	中
21		未严格限制终端登录地址范围。	深信服 Web 应用云防火墙、皓迪堡垒机、eCloud 相关集成服务器、对外服务器、竞价与产权服务器、数据库服务器、业务框架支撑服务器、电子交易部署服务器、数据推送服务器、应用服务器、中招前置机服务器、网站前台服务器、评标服务器、智能设备与全文检索服务器、限额会员端服务器、评标中间价与诚信库接口服务器、诚信库部署服务器、新点限额集群服务器、江苏限额集群服务器、评标中间服务器、项目 1-不见面大厅服务器、项目 1-新点 e 交易推送服务 2.0 前置机、项目 1-开标大厅服务器、档案服务器、MySQL 数据库	恶意攻击	恶意用户可从任意地址尝试对设备进行访问、攻击,存在非授权访问的风险。	中
22		未定期进行漏	运维终端-1、运维	恶意	不能及时发现系	中

序号	安全类	安全问题	关联资产	关联威胁	危害分析结果	风险等级
		洞扫描。	终端-2、业务终端-1、业务终端-2	攻击	统中存在的漏洞，并对漏洞进行修补，可能导致恶意人员利用系统漏洞对系统进行攻击。	
23		系统未采用可信计算技术对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。	华为云虚拟私有云 VPC、深信服 Web 应用云防火墙、华为云安全组、华为云企业主机安全 HSS、华为云对象存储服务 OBS、皓迪堡垒机、华为云云日志服务 LTS、华为云数据库安全服务 DBSS、eCloud 相关集成服务器、对外服务器、竞价与产权服务器、数据库服务器、业务框架支撑服务器、电子交易部署服务器、数据推送服务器、应用服务器、中招前置机服务器、网站前台服务器、评标服务器、智能设备与全文检索服务器、限额会员端服务器、评标中间价与诚信库接口服务器、诚信库部署服务器、新点限额集群服务器、江苏限额集群服务器、评标中间服务器、项目 1-不见面大厅服务器、项目 1-新点 e 交易推送	篡改	无可信验证，不能通过主动免疫可信验证技术提高系统自身安全防护能力，不能实现积极主动防御。	低

序号	安全类	安全问题	关联资产	关联威胁	危害分析结果	风险等级
			服务 2.0 前置机、项目 1-开标大厅服务器、档案服务器、运维终端-1、运维终端-2、业务终端-1、业务终端-2、华为云管理控制台、Nginx 中间件、MySQL 数据库、“新点 e 交易”电子交易平台			
24		未提供重要配置数据和鉴别数据存储完整性被破坏时的检查和报警机制。	“新点 e 交易”电子交易平台	篡改	无法第一时间知晓重要配置数据和鉴别数据在存储过程中被破坏，可能会影响信息系统的正常运行。	中
25		未采用校验技术或密码技术保证重要配置数据和鉴别数据在存储过程中的完整性。	华为云虚拟私有云 VPC、深信服 Web 应用云防火墙、华为云安全组、华为云企业主机安全 HSS、华为云对象存储服务 OBS、皓迪堡垒机、华为云云日志服务 LTS、华为云数据库安全服务 DBSS、eCloud 相关集成服务器、对外服务器、竞价与产权服务器、数据库服务器、业务框架支撑服务器、电子交易部署服务器、数据推送服务器、应用服务器、中招前置机服务器、网站前台服务器、评标服务器、	篡改	可能导致重要配置数据和鉴别数据在存储过程中被恶意篡改，影响信息系统的正常运行。	中

序号	安全类	安全问题	关联资产	关联威胁	危害分析结果	风险等级
			智能设备与全文检索服务器、限额会员端服务器、评标中间价与诚信库接口服务器、诚信库部署服务器、新点限额集群服务器、江苏限额集群服务器、评标中间服务器、项目 1-不见面大厅服务器、项目 1-新点 e 交易推送服务 2.0 前置机、项目 1-开标大厅服务器、档案服务器、运维终端-1、运维终端-2、业务终端-1、业务终端-2、华为云管理控制台、MySQL 数据库			
26		未提供重要个人信息存储完整性被破坏时的检查和报警机制。	重要个人信息	篡改	无法第一时间知晓重要个人信息在存储过程中被破坏,可能会影响信息系统的正常运行。	中
27		未提供重要业务数据存储完整性被破坏时的检查和报警机制。	重要业务数据	篡改	无法第一时间知晓重要业务数据在存储过程中被破坏,可能会影响信息系统的正常运行。	中
28		未采用校验技术或密码技术保证重要配置数据在存储过程中的完整性。	Nginx 中间件	篡改	可能导致重要配置数据在存储过程中被恶意篡改,影响信息系统的正常运行。	中

序号	安全类	安全问题	关联资产	关联威胁	危害分析结果	风险等级
29		未采用密码技术实现鉴别数据和重要配置数据在存储过程中的保密性。	华为云虚拟私有云 VPC、深信服 Web 应用云防火墙、华为云安全组、华为云企业主机安全 HSS、华为云对象存储服务 OBS、皓迪堡垒机、华为云云日志服务 LTS、华为云数据库安全服务 DBSS、华为云管理控制台	敏感信息泄露	可能导致重要配置数据和鉴别数据在存储过程中被攻击者直接盗用,使重要配置数据和鉴别数据遭遇泄漏。	中
30		未采用密码技术保证重要配置数据在存储过程中的保密性。	eCloud 相关集成服务器、对外服务器、竞价与产权服务器、数据库服务器、业务框架支撑服务器、电子交易部署服务器、数据推送服务器、应用服务器、中招前置机服务器、网站前台服务器、评标服务器、智能设备与全文检索服务器、限额会员端服务器、评标中间价与诚信库接口服务器、诚信库部署服务器、新点限额集群服务器、江苏限额集群服务器、评标中间服务器、项目 1-不见面大厅服务器、项目 1-新点 e 交易推送服务 2.0 前置机、项目 1-开标大厅服务器、档案服务器、运维终端-1、运维终端-	敏感信息泄露	存在重要配置数据在存储过程中被攻击者嗅探并盗用,使重要配置数据遭遇泄露。	中

序号	安全类	安全问题	关联资产	关联威胁	危害分析结果	风险等级
			2、业务终端-1、业务终端-2、Nginx 中间件、MySQL 数据库			
31		未对备份文件进行过恢复性测试。	华为云虚拟私有云 VPC、深信服 Web 应用云防火墙、华为云安全组、华为云企业主机安全 HSS、华为云对象存储服务 OBS、皓迪堡垒机、华为云云日志服务 LTS、华为云数据库安全服务 DBSS	管理不到位	一旦出现故障，可能由于各种原因无法利用备份数据进行恢复，造成重要数据丢失。	中
32		未将重要数据实时备份至异地。	重要业务数据、重要个人信息	物理环境影响	如发生火灾、重大自然灾害等，可能导致数据完全丢失，但因已采取数据本地备份措施，且系统所在环境发生地震等灾难的可能性较低，整体风险可控。	中
33		未在远程管理云平台中设备时，在管理终端和云平台间建立双向身份验证机制。	云租户安全扩展要求	恶意攻击	可能导致攻击者不可信管理终端接入，或者攻击者通过钓鱼或伪造云计算平台服务界面的形式诱骗管理员提供敏感数据，导致管理终端和云计算平台间通信被劫持或伪造。	中
34	安全建设管理	系统安全设计方案的论证和审定管理不完	制度或记录类文档	管理不到位	可能存在安全策略缺乏合理性和可行性，导致信息	中

序号	安全类	安全问题	关联资产	关联威胁	危害分析结果	风险等级
		善，缺少对系统安全策略相关配套文件的合理性和正确性的论证和审定记录。			系统安全防御能力缺乏完整性、系统性，不足以满足业务发展需要。	
35		该系统建设期未邀请第三方公司担任项目监理工作，无法通过第三方工程监理控制项目的实施过程。	制度或记录类文档	管理不到位	可能导致工程实施缺少组织性，工程实施管理不到位。	中
36	安全运维管理	未指定专门部门或人员对系统进行巡检，未对日志、监测和报警数据等进行分析、统计。	制度或记录类文档	管理不到位	可能存在无法及早发现并处置安全隐患的风险。	中

5.2 重大风险隐患分析

根据重大风险隐患判定原则(相关性原则、严重性原则、高发性原则)进行综合分析，判断是否为重大风险隐患。重大风险隐患可能由一个高风险问题直接引发，还可能是多个高、中、低安全问题的叠加。

针对等级测评结果中存在的所有高风险安全问题，从安全问题导致的影响程度、安全问题被利用的可能性等方面进一步确认重大风险隐患。其中高风险安全问题导致的安全事件发生概率较大，且一旦发生后将造成业务中断、敏感数据泄露或被篡改、获得系统管理权限或业务权限等严重后果的应当确定为重大风险隐患。

其中，以下高风险问题不满足重大风险隐患判定原则：

(1) 安全计算环境的“未采用两种或两种以上组合的鉴别技术对用户进行身份鉴别，其中一种鉴别技术至少应使用密码技术来实现”高风险问题，不满足高发性原则：经测试验证与分析，渗透人员与测评人员未能通过利用该高风险对系统造成完全控制账户，致数据泄露、业务瘫痪，并诱发勒索攻击等严重后果。

经过单项测评结果判定和整体测评，未发现“新点 e 交易”电子交易平台存在重大风险隐患。

6 总体评价

在安全物理环境通用和云计算安全扩展要求方面，本次共测评 23 项，其中符合项 1 项，部分符合项 0 项，不符合项 0 项，不适用项 22 项。

在安全通信网络通用和云计算安全扩展要求方面，本次共测评 13 项，其中符合项 7 项，部分符合项 0 项，不符合项 1 项，不适用项 5 项。

在安全区域边界通用和云计算安全扩展要求方面，本次共测评 28 项，其中符合项 21 项，部分符合项 0 项，不符合项 4 项，不适用项 3 项。

在安全计算环境通用和云计算安全扩展要求方面，本次共测评 53 项，其中符合项 21 项，部分符合项 14 项，不符合项 5 项，不适用项 13 项。

在安全管理中心通用和云计算安全扩展要求方面，本次共测评 16 项，其中符合项 14 项，部分符合项 0 项，不符合项 0 项，不适用项 2 项。

在安全管理制度通用方面，本次共测评 7 项，其中符合项 7 项，部分符合项 0 项，不符合项 0 项，不适用项 0 项。

在安全管理机构通用方面，本次共测评 14 项，其中符合项 14 项，部分符合项 0 项，不符合项 0 项，不适用项 0 项。

在安全管理人员通用方面，本次共测评 12 项，其中符合项 12 项，部分符合

项 0 项，不符合项 0 项，不适用项 0 项。

在安全建设管理通用和云计算安全扩展要求方面，本次共测评 42 项，其中符合项 33 项，部分符合项 0 项，不符合项 2 项，不适用项 7 项。

在安全运维管理通用和云计算安全扩展要求方面，本次共测评 49 项，其中符合项 39 项，部分符合项 0 项，不符合项 1 项，不适用项 9 项。

依据 GB/T 22239—2019《信息安全技术 网络安全等级保护基本要求》和 GB/T 28448—2019《信息安全技术 网络安全等级保护测评要求》的第三级要求，在本次测评中共测评 257 项，其中符合项 169 项，部分符合项 14 项，不符合项 13 项，不适用项 61 项。

根据单项测评结果汇总要求项符合情况如下表所示。

表 6-1 要求项符合情况汇总表

序号	安全类	要求项总数	要求项符合情况			
			符合	部分符合	不符合	不适用
1	安全物理环境	23	1	0	0	22
2	安全通信网络	13	7	0	1	5
3	安全区域边界	28	21	0	4	3
4	安全计算环境	53	21	14	5	13
5	安全管理中心	16	14	0	0	2
6	安全管理制度	7	7	0	0	0
7	安全管理机构	14	14	0	0	0

序号	安全类	要求项总数	要求项符合情况			
			符合	部分符合	不符合	不适用
8	安全管理人员	12	12	0	0	0
9	安全建设管理	42	33	0	2	7
10	安全运维管理	49	39	0	1	9
要求项符合情况数量统计		257	169	14	13	61
要求项符合率统计			86.22%			

注：符合率=单项符合总项数/（该级别要求总项数-不适用项数）*100%

7 等级测评结论

等级测评结论主要由被测系统单项符合性进行判定,符合性判定根据被测系统各层面安全保护情况与相应等级安全保护要求的符合程度进行确定。具体判定依据如下表所示。

表 7-1 等级测评结论判定依据

等级测评结论	判定依据
符合	被测系统符合率高于 90%，且无重大风险隐患。
基本符合	被测系统符合率高于 60%，低于 90%；或者符合率为[90%，100%]且存在重大风险隐患。
不符合	被测系统符合率低于 60%。

依据 GB/T 22239—2019《信息安全技术 网络安全等级保护基本要求》和 GB/T 28448—2019《信息安全技术 网络安全等级保护测评要求》的第三级要求，经对“新点 e 交易”电子交易平台的安全保护状况进行综合分析评价后，等级测评结论如下：

“新点 e 交易”电子交易平台本次等级测评的符合率为 86.22%，等级测评结论判定为基本符合。

8 安全问题整改建议

8.1 低中高风险安全问题整改建议

表 8-1 安全问题整改建议

序号	安全类	安全问题	关联资产	整改建议
1	安全通信网络	未基于可信根对通信设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。	安全通信网络	建议采用可信技术的度量验证的技术手段对通信设备的引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证，并在应用程序的关键执行环节进行动态可信验证，在检测到其可信性受到破坏后进行报

序号	安全类	安全问题	关联资产	整改建议
				警，并将验证结果形成审计记录送至安全管理中心。
2	安全区域边界	未采用技术手段对内部用户非授权联到外部网络的行为进行检查或限制。	安全区域边界	建议部署终端安全管控系统等措施对非法外联行为进行检查或限制。
3		网络中未部署恶意代码防范系统，无法对恶意代码进行检测和清除。	安全区域边界	建议部署恶意代码防范产品对恶意代码进行检测和清除，并维护恶意代码产品的升级和更新。
4		未采取措施对访问互联网的用户行为进行审计。	安全区域边界	建议采取措施或部署相关组件对互联网访问的用户行为进行审计和数据分析。
5		未基于可信根对边界设备的系统引导程序、系统程序、重要配置参数和通信应用程序等进行动态可信验证。	安全区域边界	建议基于可信根对边界设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证，并在应用程序的关键执行环节进行动态可信验证，在检测到其可信性受到破坏后进行报警，并将验证结果形成审计记录送至安全管理中心。
6	安全计算环境	未配置口令有效期策略。	MySQL 数据库、“新点 e 交易”电子交易平台	建议配置口令的有效期限策略，至少 90 天更换一次口令，防止口令被轻易破解。
7		口令有效周期过长。	皓迪堡垒机	建议缩短口令的有效期限，至少 90 天更换一次口令，防止口令被轻易破解。
8		未配置口令复杂度策略和口令有效期策略。	运维终端-1、运维终端-2、业务终端-1、业务终端-2	建议配置口令的复杂度策略及有效期策略，如采用 8 位及以上且包含字母、数字、特殊字符中两

序号	安全类	安全问题	关联资产	整改建议
				种及两种以上组合，并至少 90 天定期更换口令，防止口令被轻易破解。
9		登录连接超时过长。	华为云虚拟私有云 VPC、华为云安全组、华为云企业主机安全 HSS、华为云对象存储服务 OBS、皓迪堡垒机、华为云云日志服务 LTS、华为云数据库安全服务 DBSS、华为云管理控制台	建议配置合理的登录连接超时自动退出策略，如 15 分钟无操作后自动退出系统，降低设备被非授权访问的风险。
10		未配置登录失败处理策略，未配置合理的登录连接超时自动退出策略。	MySQL 数据库	建议配置登录失败处理策略，如登录失败 5 次锁定账户 10 分钟，防止恶意人员暴力破解账户口令，并配置合理的登录连接超时自动退出策略，如 15 分钟无操作后自动退出系统，降低设备被非授权访问的风险。
11		未配置登录失败处理策略及登录连接超时自动退出策略。	运维终端-1、运维终端-2、业务终端-1、业务终端-2	建议配置登录失败处理策略，如登录失败 5 次锁定账户 10 分钟，防止恶意人员暴力破解账户口令，并配置登录连接超时自动退出策略，如 15 分钟无操作后自动退出系统，降低设备被非授权访问的风险。
12		未采用两种或两种以上组合的鉴别技术对用户进行身份鉴别，其中一种鉴别技术至	华为云虚拟私有云 VPC、深信服 Web 应用云防火墙、华	建议采用两种或两种以上组合的鉴别技术对用户进行身份鉴别，并且其中一种鉴别技术为密码

序号	安全类	安全问题	关联资产	整改建议
		少应使用密码技术来实现。	为云安全组、华为云企业主机安全 HSS、华为云对象存储服务 OBS、皓迪堡垒机、华为云云日志服务 LTS、华为云数据库安全服务 DBSS、eCloud 相关集成服务器、对外服务器、竞价与产权服务器、数据库服务器、业务框架支撑服务器、电子交易部署服务器、数据推送服务器、应用服务器、中招前置机服务器、网站前台服务器、评标服务器、智能设备与全文检索服务器、限额会员端服务器、评标中间价与诚信库接口服务器、诚信库部署服务器、新点限额集群服务器、江苏限额集群服务器、评标中间服务器、项目 1-不见面大厅服务器、项目 1-新点 e 交易推送服务 2.0 前置	技术，如：数字证书等。

序号	安全类	安全问题	关联资产	整改建议
			机、项目 1-开标大厅服务器、档案服务器、运维终端-1、运维终端-2、业务终端-1、业务终端-2、华为云管理控制台、MySQL 数据库、“新点 e 交易”电子交易平台	
13		采用默认账户进行管理。	深信服 Web 应用云防火墙、皓迪堡垒机、e Cloud 相关集成服务器、对外服务器、竞价与产权服务器、数据库服务器、业务框架支撑服务器、电子交易部署服务器、数据推送服务器、应用服务器、中招前置机服务器、网站前台服务器、评标服务器、智能设备与全文检索服务器、限额会员端服务器、评标中间价与诚信库接口服务器、诚信库部署服务器、新点限额集群服务器、江苏限额集群服务	建议锁定或删除默认账户，若存在无法删除情况，可将默认账户进行重命名，同时限制访问地址、加强口令强度等。

序号	安全类	安全问题	关联资产	整改建议
			器、评标中间服务器、项目 1-不见面大厅服务器、项目 1-新点 e 交易推送服务 2.0 前置机、项目 1-开标大厅服务器、档案服务器、运维终端-1、运维终端-2、业务终端-1、业务终端-2、MySQL 数据库	
14		未授予不同账户为了完成各自承担任务所需的最小权限。	深信服 Web 应用云防火墙、皓迪堡垒机、e Cloud 相关集成服务器、对外服务器、竞价与产权服务器、数据库服务器、业务框架支撑服务器、电子交易部署服务器、数据推送服务器、应用服务器、中招前置机服务器、网站前台服务器、评标服务器、智能设备与全文检索服务器、限额会员端服务器、评标中间价与诚信库接口服务器、诚信库部署服务器、	建议健全安全管理员、审计管理员、系统管理员等管理账户，并根据业务需要设置各账户的权限，实现所有管理用户的管理权限最小化。

序号	安全类	安全问题	关联资产	整改建议
			新点限额集群服务器、江苏限额集群服务器、评标中间服务器、项目 1-不见面大厅服务器、项目 1-新点 e 交易推送服务 2.0 前置机、项目 1-开标大厅服务器、档案服务器、运维终端-1、运维终端-2、业务终端-1、业务终端-2、MySQL 数据库、“新点 e 交易”电子交易平台	
15		未配置安全管理员账户对访问控制策略进行配置。	深信服 Web 应用云防火墙、皓迪堡垒机、e Cloud 相关集成服务器、对外服务器、竞价与产权服务器、数据库服务器、业务框架支撑服务器、电子交易部署服务器、数据推送服务器、应用服务器、中招前置机服务器、网站前台服务器、评标服务器、智能设备与全文检索服务器、限额会	建议配备专职的安全管理员账户，由安全管理员账户配置访问控制策略，并规定主体对客体的访问规则。

序号	安全类	安全问题	关联资产	整改建议
			员端服务器、 评标中间价与 诚信库接口服 务器、诚信库 部署服务器、 新点限额集群 服务器、江苏 限额集群服务 器、评标中间 服务器、项目 1 -不见面大厅服 务器、项目 1- 新点 e 交易推 送服务 2.0 前置 机、项目 1-开 标大厅服务 器、档案服务 器、运维终端- 1、运维终端- 2、业务终端- 1、业务终端- 2、MySQL 数 据库、“新点 e 交易”电子交易 平台	
16		未对重要主体和客体 设置安全标记，未实 现通过安全标记控制 主体对信息资源的访 问。	华为云虚拟私有云 VPC、深信服 Web 应用 云防火墙、华为云安全组、华为云企业主 机安全 HSS、华为云对象存储服务 OBS、 皓迪堡垒机、华为云云日志 服务 LTS、华为云数据库安全服务 DBSS、 eCloud 相关集成服务器、对	建议对资源进行严格划分，并对重要主体和客体 进行分级标记，形成完整的资源分级和访问权限 控制结构体系，依据安全 标记控制主体对信息资源 的访问。

序号	安全类	安全问题	关联资产	整改建议
			外服务器、竞价与产权服务器、数据库服务器、业务框架支撑服务器、电子交易部署服务器、数据推送服务器、应用服务器、中招前置机服务器、网站前台服务器、评标服务器、智能设备与全文检索服务器、限额会员端服务器、评标中间价与诚信库接口服务器、诚信库部署服务器、新点限额集群服务器、江苏限额集群服务器、评标中间服务器、项目 1-不见面大厅服务器、项目 1-新点 e 交易推送服务 2.0 前置机、项目 1-开标大厅服务器、档案服务器、运维终端-1、运维终端-2、业务终端-1、业务终端-2、华为云管理控制台、MySQL 数据库、“新点 e 交易”电子交易平台	

序号	安全类	安全问题	关联资产	整改建议
17		审计范围未覆盖所有重要的用户行为和安全事件。	运维终端-1、运维终端-2、业务终端-1、业务终端-2	建议完善审计日志策略，对重要的用户行为和重要安全事件进行审计。
18		审计记录仅保存在本机，未进行定期备份。	皓迪堡垒机、运维终端-1、运维终端-2、业务终端-1、业务终端-2	建议部署日志服务器对日志进行集中存放，并确保保存时间能够达到半年以上。
19		未采取措施对系统审计进程进行保护。	eCloud 相关集成服务器、对外服务器、竞价与产权服务器、数据库服务器、业务框架支撑服务器、电子交易部署服务器、数据推送服务器、应用服务器、中招前置机服务器、网站前台服务器、评标服务器、智能设备与全文检索服务器、限额会员端服务器、评标中间价与诚信库接口服务器、诚信库部署服务器、新点限额集群服务器、江苏限额集群服务器、评标中间服务器、项目 1-不见面大厅服务器、项目 1-新点 e 交易推	建议对审计进程进行保护，避免受到未预期的中断。

序号	安全类	安全问题	关联资产	整改建议
			送服务 2.0 前置机、项目 1-开标大厅服务器、档案服务器、MySQL 数据库	
20		开启了不必要的服务、不必要的默认共享和高危端口。	运维终端-1、运维终端-2、业务终端-1、业务终端-2	建议关闭不必要的服务，关闭不必要的默认共享，关闭高危端口。
21		未严格限制终端登录地址范围。	深信服 Web 应用云防火墙、皓迪堡垒机、e Cloud 相关集成服务器、对外服务器、竞价与产权服务器、数据库服务器、业务框架支撑服务器、电子交易部署服务器、数据推送服务器、应用服务器、中招前置机服务器、网站前台服务器、评标服务器、智能设备与全文检索服务器、限额会员端服务器、评标中间价与诚信库接口服务器、诚信库部署服务器、新点限额集群服务器、江苏限额集群服务器、评标中间	建议对管理员的登录地址进行限制（如：配置可信主机、允许访问的地址、ACL 策略、登录掩码、地址限制、IP 安全策略等）。

序号	安全类	安全问题	关联资产	整改建议
			服务器、项目 1-不见面大厅服务器、项目 1-新点 e 交易推送服务 2.0 前置机、项目 1-开标大厅服务器、档案服务器、MySQL 数据库	
22		未定期进行漏洞扫描。	运维终端-1、运维终端-2、业务终端-1、业务终端-2	建议定期进行漏洞扫描，并在测试通过的前提下，及时修复漏洞。
23		系统未采用可信计算技术对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。	华为云虚拟私有云 VPC、深信服 Web 应用云防火墙、华为云安全组、华为云企业主机安全 HSS、华为云对象存储服务 OBS、皓迪堡垒机、华为云云日志服务 LTS、华为云数据库安全服务 DBSS、eCloud 相关集成服务器、对外服务器、竞价与产权服务器、数据库服务器、业务框架支撑服务器、电子交易部署服务器、数据推送服务器、应用服务器、中招前置	建议采用可信技术的度量 and 验证的技术手段对计算设备的引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证，在检测到其可信性受到破坏后进行报警，并将验证结果形成审计记录送至安全管理中心。

序号	安全类	安全问题	关联资产	整改建议
			机服务器、网站前台服务器、评标服务器、智能设备与全文检索服务器、限额会员端服务器、评标中间价与诚信库接口服务器、诚信库部署服务器、新点限额集群服务器、江苏限额集群服务器、评标中间服务器、项目 1-不见面大厅服务器、项目 1-新点 e 交易推送服务 2.0 前置机、项目 1-开标大厅服务器、档案服务器、运维终端-1、运维终端-2、业务终端-1、业务终端-2、华为云管理控制台、Nginx 中间件、MySQL 数据库、“新点 e 交易”电子交易平台	
24		未提供重要配置数据和鉴别数据存储完整性被破坏时的检查和报警机制。	“新点 e 交易”电子交易平台	建议提供重要配置数据和鉴别数据存储完整性被破坏时的检查和报警机制。
25		未采用校验技术或密码技术保证重要配置数据和鉴别数据在存	华为云虚拟私有云 VPC、深信服 Web 应用	建议在重要配置数据和鉴别数据存储时，采用经国家密码主管部门认可

序号	安全类	安全问题	关联资产	整改建议
		储过程中的完整性。	云防火墙、华为云安全组、华为云企业主机安全 HSS、华为云对象存储服务 OBS、皓迪堡垒机、华为云云日志服务 LTS、华为云数据库安全服务 DBSS、eCloud 相关集成服务器、对外服务器、竞价与产权服务器、数据库服务器、业务框架支撑服务器、电子交易部署服务器、数据推送服务器、应用服务器、中招前置机服务器、网站前台服务器、评标服务器、智能设备与全文检索服务器、限额会员端服务器、评标中间价与诚信库接口服务器、诚信库部署服务器、新点限额集群服务器、江苏限额集群服务器、评标中间服务器、项目 1-不见面大厅服务器、项目 1-新点 e 交易推	的校验技术或密码技术，保证其在存储过程中数据的完整性。

序号	安全类	安全问题	关联资产	整改建议
			送服务 2.0 前置机、项目 1-开标大厅服务器、档案服务器、运维终端-1、运维终端-2、业务终端-1、业务终端-2、华为云管理控制台、MySQL 数据库	
26		未提供重要个人信息存储完整性被破坏时的检查和报警机制。	重要个人信息	建议提供重要个人信息存储完整性被破坏时的检查和报警机制。
27		未提供重要业务数据存储完整性被破坏时的检查和报警机制。	重要业务数据	建议提供重要业务数据存储完整性被破坏时的检查和报警机制。
28		未采用校验技术或密码技术保证重要配置数据在存储过程中的完整性。	Nginx 中间件	建议在重要配置数据存储时，采用经国家密码主管部门认可的校验技术或密码技术，保证其在存储过程中数据的完整性。
29		未采用密码技术实现鉴别数据和重要配置数据在存储过程中的保密性。	华为云虚拟私有云 VPC、深信服 Web 应用云防火墙、华为云安全组、华为云企业主机安全 HSS、华为云对象存储服务 OBS、皓迪堡垒机、华为云云日志服务 LTS、华为云数据库安全服务 DBSS、华为云管理控制台	建议对系统重要配置数据和鉴别数据采用经国家密码主管部门认可的密码技术，实现其在存储过程中数据的保密性。

序号	安全类	安全问题	关联资产	整改建议
30		未采用密码技术保证重要配置数据在存储过程中的保密性。	eCloud 相关集成服务器、对外服务器、竞价与产权服务器、数据库服务器、业务框架支撑服务器、电子交易部署服务器、数据推送服务器、应用服务器、中招前置机服务器、网站前台服务器、评标服务器、智能设备与全文检索服务器、限额会员端服务器、评标中间价与诚信库接口服务器、诚信库部署服务器、新点限额集群服务器、江苏限额集群服务器、评标中间服务器、项目 1-不见面大厅服务器、项目 1-新点 e 交易推送服务 2.0 前置机、项目 1-开标大厅服务器、档案服务器、运维终端-1、运维终端-2、业务终端-1、业务终端-2、Nginx 中间件、MySQL 数据库	建议对重要配置数据采用经国家密码主管部门认可的密码技术，保证其在存储过程中数据的保密性。

序号	安全类	安全问题	关联资产	整改建议
31		未对备份文件进行过恢复性测试。	华为云虚拟私有云 VPC、深信服 Web 应用云防火墙、华为云安全组、华为云企业主机安全 HSS、华为云对象存储服务 OBS、皓迪堡垒机、华为云云日志服务 LTS、华为云数据库安全服务 DBSS	建议定期对重要数据的备份进行恢复测试，确保在出现数据破坏时，可利用备份数据进行恢复，并妥善保存相关记录。
32		未将重要数据实时备份至异地。	重要业务数据、重要个人信息	建议确定安全的数据备份场地，并利用通信网络将重要数据实时传送至备用场地。
33		未在远程管理云平台中设备时，在管理终端和云平台间建立双向身份验证机制。	云租户安全扩展要求	建议在远程管理云平台中设备时，在管理终端和云平台间建立双向身份验证机制。
34	安全建设管理	系统安全设计方案的论证和审定管理不完善，缺少对系统安全策略相关配套文件的合理性和正确性的论证和审定记录。	制度或记录类文档	建议组织相关部门和有关安全技术专家对总体安全策略、安全技术框架、安全管理策略、总体规划、详细设计方案等相关配套文件的合理性和正确性进行论证和审定，并且经过批准后，才能正式实施。
35		该系统建设期未邀请第三方公司担任项目监理工作，无法通过第三方工程监理控制项目的实施过程。	制度或记录类文档	建议通过聘请第三方工程监理的方式控制项目的实施过程，保障项目质量。
36	安全运维管理	未指定专门部门或人员对系统进行巡检，	制度或记录类文档	建议指定专门部门或人员对系统进行巡检，对日

序号	安全类	安全问题	关联资产	整改建议
		未对日志、监测和报警数据等进行分析、统计。		志、监测和报警数据等进行分析、统计并出具相关报告。

8.2 重大风险隐患整改建议

经过单项测评结果判定和整体测评，未发现“新点 e 交易”电子交易平台存在重大风险隐患。

【正文结束】

附录A 被测对象资产

A.1 物理机房

附录 A 表-1 物理机房

序号	机房名称	物理位置	重要程度	备注
1	华为云机房	华北-北京一区	关键	数量：1

A.2 网络设备

附录 A 表-2 网络设备

序号	设备名称	是否虚拟设备	系统及版本	品牌及型号	用途	重要程度	IP 地址	备注
1	华为云虚拟私有云 VPC	是	无	华为云	可以将 VPC 网络中的产品实例划分成不同的安全域，并为每个安全域定义不同的访问控制规则。	关键	无	数量：1

A.3 安全设备

附录 A 表-3 安全设备

序号	设备名称	是否虚拟设备	系统及版本	品牌及型号	用途	重要程度	IP 地址	备注
1	深信服 Web 应用云防火墙	是	V8.0.60	深信服 Web 应用云防火墙	通过对主干链路上的流量进行检	关键	无	数量：1

序号	设备名称	是否虚拟设备	系统及版本	品牌及型号	用途	重要程度	IP 地址	备注
					测，对 Web 应用中的各类攻击，防御 OWASP 常见威胁，如 SQL 注入、XSS 注入、跨站请求伪造攻击、Cookie 篡改以及应用层 Web 攻击等，能有效解决网页挂马、敏感信息泄露等安全问			

序号	设备名称	是否虚拟设备	系统及版本	品牌及型号	用途	重要程度	IP 地址	备注
					题，充分保障 Web 应用安全。			
2	华为云安全组	是	基础版	华为云	可用于专有网络中的产品实例划分成不同的安全域，并为每个安全域定义不同的访问控制规则。	关键	无	数量：1
3	华为云企业主机安全 HSS	是	企业版	华为云	提供了恶意代码查杀、黑客入侵检测、	重要	无	数量：1

序号	设备名称	是否虚拟设备	系统及版本	品牌及型号	用途	重要程度	IP 地址	备注
					漏洞风险检测和修复等功能。			
4	华为云对象存储服务 OBS	是	无	华为云	提供海量、安全、高可靠、低成本的数据存储能力，可供用户存储任意类型和大小的数据。	重要	无	数量：1
5	皓迪堡垒机	否	Version 2.0	皓迪运维管理系统 H D-OAS-500	提供了内部人员或外联人员的远程访问管	重要	192.168.*.150	数量：1

序号	设备名称	是否虚拟设备	系统及版本	品牌及型号	用途	重要程度	IP 地址	备注
					理使用，并记录了用户的操作记录。			
6	华为云云日志服务 LTS	是	基础版	华为云	提供日志收集、实时查询、存储等功能，无需开发即可利用日志做实时决策分析，提升日志处理效率，帮助用户轻松应对日志实时	重要	无	数量：1

序号	设备名称	是否虚拟设备	系统及版本	品牌及型号	用途	重要程度	IP 地址	备注
					采集、查询分析等日常运营、运维场景。			
7	华为云数据库安全服务 DBSS	是	基础版	华为云	基于机器学习机制和大数据分析技术，提供数据库审计，SQL 注入攻击检测，风险操作识别等功能，保障云上数据库的安全。	重要	无	数量：1

A.4 服务器

附录 A 表-4 服务器

序号	设备名称	所属业务应用系统/平台名称	是否虚拟设备	操作系统及版本	数据库管理系统及版本	中间件及版本	重要程度	IP地址	备注
1	eCloud 相关集成服务器	“新点e交易”电子交易平台	是	CentOS Linux release 7.4.1708 (Core)	无	无	关键	192.168.*.167	数量：1
2	对外服务器	“新点e交易”电子交易平台	是	CentOS Linux release 7.4.1708 (Core)	无	无	关键	192.168.*.11	数量：1
3	竞价与产权服务器	“新点e交易”电子交易平台	是	CentOS Linux release 7.4.1708 (Core)	无	无	关键	192.168.*.182	数量：1
4	数据库服务器	“新点e交易”电子交易平台	是	CentOS Linux release 7.4.1708 (Core)	MySQL 5.7.39	无	关键	192.168.*.216	数量：1
5	业务框架支撑服务器	“新点e交易”电子交易平台	是	CentOS Linux release 7.4.1708 (Core)	无	无	关键	192.168.*.117	数量：1
6	电子	“新点e交	是	CentOS	无	无	关键	192.	数

序号	设备名称	所属业务应用系统/平台名称	是否虚拟设备	操作系统及版本	数据库管理系统及版本	中间件及版本	重要程度	IP地址	备注
	交易部署服务器	易”电子交易平台		Linux release 7.4.1708 (Core)				168.*.58	量：1
7	数据推送服务器	“新点 e 交易”电子交易平台	是	CentOS Linux release 7.4.1708 (Core)	无	无	关键	192.168.*.125	数量：1
8	应用服务器	“新点 e 交易”电子交易平台	是	CentOS Linux release 7.4.1708 (Core)	无	Nginx 1.16.1	关键	192.168.*.147	数量：1
9	中招前置机服务器	“新点 e 交易”电子交易平台	是	CentOS Linux release 7.4.1708 (Core)	无	无	关键	192.168.*.69	数量：1
10	网站前台服务器	“新点 e 交易”电子交易平台	是	CentOS Linux release 7.4.1708 (Core)	无	无	关键	192.168.*.29	数量：1
11	评标服务器	“新点 e 交易”电子交易平台	是	CentOS Linux release 7.4.1708 (Core)	无	无	关键	192.168.*.223	数量：1

序号	设备名称	所属业务应用系统/平台名称	是否虚拟设备	操作系统及版本	数据库管理系统及版本	中间件及版本	重要程度	IP地址	备注
				e)					
12	智能设备与全文检索服务器	“新点e交易”电子交易平台	是	CentOS Linux release 7.4.1708 (Core)	无	无	关键	192.168.*.153	数量：1
13	限额会员端服务器	“新点e交易”电子交易平台	是	CentOS Linux release 7.4.1708 (Core)	无	无	关键	192.168.*.17	数量：1
14	评标中间价与诚信库接口服务器	“新点e交易”电子交易平台	是	CentOS Linux release 7.4.1708 (Core)	无	无	关键	192.168.*.157	数量：1
15	诚信库部署服务器	“新点e交易”电子交易平台	是	CentOS Linux release 7.4.1708 (Core)	无	无	关键	192.168.*.238	数量：1
16	新点限额集群服务器	“新点e交易”电子交易平台	是	CentOS Linux release 7.4.1708 (Core)	无	无	关键	192.168.*.192	数量：1
17	江苏限额	“新点e交易”电子交	是	CentOS Linux re	无	无	关键	192.168.	数量

序号	设备名称	所属业务应用系统/平台名称	是否虚拟设备	操作系统及版本	数据库管理系统及版本	中间件及版本	重要程度	IP地址	备注
	集群服务器	易平台		lease 7.4.1708 (Core)				*.170	: 1
18	评标中间服务器	“新点e交易”电子交易平台	是	CentOS Linux release 7.4.1708 (Core)	无	无	关键	192.168.*.91	数量：1
19	项目1-不见面大厅服务器	“新点e交易”电子交易平台	是	CentOS Linux release 7.4.1708 (Core)	无	无	关键	192.168.*.107	数量：1
20	项目1-新点e交易推送服务2.0前置机	“新点e交易”电子交易平台	是	CentOS Linux release 7.4.1708 (Core)	无	无	关键	192.168.*.54	数量：1
21	项目1-开标大厅服务器	“新点e交易”电子交易平台	是	CentOS Linux release 7.4.1708 (Core)	无	无	关键	192.168.*.152	数量：1
22	档案服务器	“新点e交易”电子交易平台	是	CentOS Linux release 7.4.1708 (Cor	无	无	关键	192.168.*.222	数量：1

序号	设备名称	所属业务应用系统/平台名称	是否虚拟设备	操作系统及版本	数据库管理系统及版本	中间件及版本	重要程度	IP地址	备注
				e)					

A.5 终端设备

附录 A 表-5 终端设备

序号	设备名称	是否虚拟设备	操作系统及版本	用途	重要程度	IP地址	备注
1	运维终端-1	否	Windows 7 旗舰版（内部版本 7601: Service Pack 1）	运维管理，备份网络安全设备配置文件和系统重要数据。	重要	192.168.*.24	数量：1
2	运维终端-2	否	Windows 7 旗舰版（内部版本 7601: Service Pack 1）	运维管理。	一般	192.168.*.3、192.168.*.1、192.168.*.22	数量：3
3	业务终端-1	否	Windows 7 旗舰版（内部版本 7601: Service Pack 1）	系统管理。	一般	192.168.*.4	数量：1
4	业务终端-2	否	Windows 7 旗舰版（内部版本 7601: Service Pack 1）	系统管理。	一般	192.168.*.6、192.168.*.38、192.168.*.52	数量：3

A.6 其他系统或设备

附录 A 表-6 其他系统或设备

序号	设备名称	是否虚拟设备	系统及版本	设备类别/用途	重要程度	IP 地址	备注
无							

A.7 系统管理软件/平台

附录 A 表-7 系统管理软件/平台

序号	系统管理软件/平台名称	所在设备名称	版本	主要功能	重要程度	IP 地址	备注
1	华为云管理控制台	华为云	无	虚拟化资源管理、账户管理和服务管理。	重要	无	数量：1
2	Nginx 中间件	应用服务器	Nginx 1.16.1	应用服务代理。	关键	192.168.*.147	数量：1
3	MySQL 数据库	数据库服务器	MySQL 5.7.39	存储数据。	关键	192.168.*.216	数量：1

A.8 业务应用系统/平台

附录 A 表-8 业务应用系统/平台

序号	业务应用系统/平台名称	主要功能	业务应用软件及版本	开发厂商	重要程度	IP 地址	备注
1	“新点 e 交易”电子交易平台	为招标代理和投标人用于开展招投标活动，同时为代理和评标专家提供使用服务的开评标活动，主要用于	V1.0	苏州国泰新点软件有限公司	关键	http://www.e-trading.cn	数量：1

序号	业务应用系统/ 平台名称	主要功能	业务应用软件 及版本	开发厂商	重要 程度	IP 地址	备注
		代理开标、专 家评标等。					

A.9 数据资源

附录 A 表-9 数据资源

序号	数据类别	所属业务应用	安全防护需求	重要程 度
1	重要业务数据	“新点 e 交易”电子交易平 台	完整性、保密性、可用 性	关键
2	重要个人信息	“新点 e 交易”电子交易平 台	完整性、保密性、可用 性	关键
3	重要配置数据	“新点 e 交易”电子交易平 台	完整性、保密性、可用 性	重要
4	重要审计数据	“新点 e 交易”电子交易平 台	完整性、可用性	重要
5	鉴别数据	“新点 e 交易”电子交易平 台	完整性、保密性、可用 性	重要

A.10 密码产品

附录 A 表-10 密码产品

序号	产品/模块名称	生产厂商	证书编 号	密码算法	用途	重要程 度
无						

A.11 安全相关人员

附录 A 表-11 安全相关人员

序号	姓名	岗位/角色	联系方式	所属单位
1	蒋铭	安全主管	18962289227	苏州国泰新点软件 有限公司
2	张鑫	安全管理员	18921952453	苏州国泰新点软件 有限公司

序号	姓名	岗位/角色	联系方式	所属单位
3	杨涛	系统管理员/应用管理员/ 数据管理员	18951132006	苏州国泰新点软件 有限公司
4	刘波	机房管理员/网络管理员	15150227530	苏州国泰新点软件 有限公司
5	屈智	资产管理员/审计管理员	13812995671	苏州国泰新点软件 有限公司

A.12安全管理文档

附录 A 表-12 安全管理文档

序号	文档名称	主要内容
1	《信息安全管理办法》	明确说明信息安全的总体方针、信息系统管理的原则、信息系统安全工作的总体目标及适用范围等。
2	《信息系统开发程序库修改登记表》	包括变更内容、时间、修改人和批准人等内容。
3	《系统运维巡检记录表》	包括日常巡检记录、运行维护记录、参数的设置和修改等内容。
4	《数据备份恢复测试记录》	包括备份恢复数据名称、备份恢复人员、备份恢复结果等内容。
5	《服务水平协议》	明确云服务商所提供云服务的各项服务内容和具体技术指标，同时规定云服务商的权限与责任，包括管理范围、职责划分、访问授权、隐私保护、行为准则、违约责任等内容。
6	《漏洞扫描记录》	包括时间、漏洞等情况、检测结果和检测结果分析等内容。
7	《代码编写安全规范》	对代码排版要求、注释规范、方法(函数)注释规范以及变量使用等部分进行规范要求。
8	《变更审批记录》	包括变更类型、申报流程、审批部门、批准人等方面内容。
9	《专家评审意见表》	包括评审人员姓名、评审时间、评审对象、评审意见等内容。

序号	文档名称	主要内容
10	《介质使用记录表》	内容包含介质名称、借用人、借用时间、归还时间、借用原因等。
11	《系统总体安全建设规划书》	明确系统建设时的各流程以及选择的基本安全措施。
12	《安全设计方案》	根据安全保护等级进行安全整体规划，对风险分析、数据安全需求、运行安全需求、系统结构及部署、系统安全设计和密码技术相关内容进行了详细规划，形成了配套文件。
13	《恶意代码培训记录表》	内容包括培训名称、培训类别、培训人数、培训地点等。
14	《技术维护服务供应商管理》	已对服务供应商变更服务内容进行明确规定。
15	《供应商评价审核制度》	制度中明确了评价指标、考核内容、进入及退出机制等。
16	《数据备份清单》	内容包括备份方式及备份周期等。
17	《应急预案评审记录》	内容包括：应急预案名称、评审人、评审方式、预案评审、评审意见等。
18	《应急预案评审修订记录》	内容包括：应急预案名称、编制人、修订日期、适用单位及地点、层次结构、编制程序、修改意见等。
19	《设备操作手册》	内容包括：设备名称及型号、配置描述、安装说明、维护、设备操作、参数设置等。
20	《设备带离审批记录》	包括设备名称、带离事由、审批人等内容。
21	《培训记录》	内容包括：培训时间、培训内容、培训人员、培训地点等。
22	《用户手册》	明确系统操作方法，确保了用户基础操作的正确性。
23	《系统使用指南》	明确系统使用方法，包含提高工作效率的方法和一些实用的小技巧等内容。
24	《系统概要设计说明文档》	明确说明系统设计、开发各阶段的情况。
25	《系统外联申请表》	详细记录了申请部门、申请人、申请事项、审核

序号	文档名称	主要内容
		申请事项等内容。
26	《系统建设项目实施方案》	对工程的实施过程进行控制与管理，方案内容包括项目概述、建设依据、组织部署、实施计划、人员安排等。
27	《培训计划》	包括培训内容、培训次数、培训地点、培训时间等内容。
28	《授权与审批管理制度》	对单位各事项的授权和审批流程进行明确说明。
29	《系统定级领导意见审批表》	包括定级系统名称、系统等级、审核内容、审核人员和审核结果等内容。
30	《资产清单》	清单内容包括资产的责任人、所属部门、资产的名称和资产数量等。
31	《恶意代码查杀表》	详细记录了恶意代码检测记录等内容。
32	《恶意代码库升级记录》	详细记录了恶意代码库升级记录等内容。
33	《日常安全检查记录表》	内容包括检查人员、检查时间、联网情况、系统运行情况等。
34	《介质盘点清单》	包括介质名称、存储位置、盘点人员（部门）等内容。
35	《系统测试验收报告》	包括系统测试时间、测试人员、测试公司、测试模块（功能）和测试结构等内容。
36	《系统测试验收方案》	内容包括：性能测试背景、性能测试目标、性能测试环境、性能测试计划、测试场景、风险分析等。
37	《岗位建设管理制度》	明确信息安全岗位建设工作和各类管理人员的职责。
38	《信息安全管理策略》	对信息安全中的管理策略作出详细规定。
39	《网络安全管理制度》	对单位网络安全进行了明确的规定。
40	《信息系统安全管理制度》	对单位系统安全进行了明确的规定。
41	《密码管理制度》	对单位密码技术的使用和密码技术产品的使用进行了明确的规范。

序号	文档名称	主要内容
42	《安全组织机构》	明确定义单位各部门的组织架构和工作职责。
43	《办公环境管理制度》	对办公室人员的相关行为作出了规定，内容包括不在办公区接待来访人员、工作人员离开座位应确保终端计算机退出登录状态和桌面上没有包含敏感信息的纸档文件等。
44	《产品采购管理制度》	明确安全产品采购的流程、注意事项等内容。
45	《软件开发管理制度》	对软件开发的人员准则、要求规范等进行了明确的要求。
46	《项目实施管理制度》	对项目实施要求、注意事项、最终结果等进行了明确的规定。
47	《信息安全领导小组职责》	明确了安全领导小组各个部门和岗位的职责、分工和技能要求等。
48	《授权和审批管理制度》	明确了系统变更等重要操作事项的审批部门和批准人等。
49	《安全意识教育和培训制度》	对单位各岗位人员的安全意识教育和培训等进行明确说明。
50	《安全检查和通报管理制度》	对重要事项违反相关规定进行检查和惩戒。
51	《人员安全管理制度》	对人员的离职的存储设备、信息文件、资料、图表等其他记载单位秘密信息的财物进行返还等规定。
52	《安全教育和培训管理制度》	对信息安全的教育培训、岗位技能培训、惩戒措施等作出规范。
53	《外部人员管理制度》	明确外来人员的物理访问以及网络、数据库、信息系统时的授权权限规定以及授权程序等。
54	《测试验收管理制度》	对系统的测试验收、验收文件、系统维护等作出描述。
55	《介质安全管理制度》	对介质的存放、存储时间、地点、安全等进行规范。
56	《资产管理制度》	对信息系统资产的清单、资产的管理、资产标识等作出规范。

序号	文档名称	主要内容
57	《设备安全管理制度》	对设备的维护、设备存放安全、设备管理、上门维修等作出规范。
58	《恶意代码防范管理制度》	明确了恶意代码的防范措施、恶意代码库的升级、检测技术以及发现病毒后的分析处理流程。
59	《信息系统变更管理制度》	对系统进行变更时候所应遵循的相关步骤作出规范。
60	《备份与恢复管理制度》	对数据的备份方式、备份频率、存放时间、恢复策略等作出规范。
61	《安全事件报告与处置管理制度》	明确了不同安全事件的报告流程以及不同安全事件的处理流程等内容。
62	《应急响应预案》	描述了应急预案的框架、启动条件、对应措施等内容。
63	《变更管理制度》	明确变更前审批、变更过程记录、变更后通报等方面内容。
64	《安全管理制度评审沟通会议记录》	会议记录包括会议时间、会议地点、主要人员和会议内容等内容。
65	《安全管理制度修订记录》	内容包括文件名称、发文部门、修改内容和修改时间等。
66	《关键活动审批过程表》	内容包括事件编号、事件类型、事件描述、生效时间、申请部门、申请人以及审批意见等。
67	《信息安全管理活动授权和审批表》	包括申请人、所属部门、申请时间、审批事项、审批内容、审批事项具体内容及原因描述、信息安全小组审批意见等内容。
68	《信息安全沟通会议记录》	包括会议时间、地点、名称、主要人员和会议内容。
69	《外联单位联系列表》	包括单位名称、地址、联系人、联系方式和合作内容等。
70	《外部人员接入受控网络访问系统的登记记录》	包含了人员信息、接入网络、账户分配、访问权限等内容。
71	《第三方人员保密协议》	包含了对获得系统访问权限的人员签署保密内容，规定双方责任等内容。

序号	文档名称	主要内容
72	《保密协议》	明确了单位员工的姓名、工作岗位和保密内容和泄密后果等内容。
73	《关键区域出入申请表》	详细记录了申请人姓名、申请部门、申请日期、外部人员姓名及单位、申请部门陪同人员姓名、携带设备、工作内容描述等内容。
74	《信息安全培训汇总登记表》	包括时间、地点、培训内容和培训人员等内容。
75	《岗位责任协议》	明确了单位员工的姓名、工作岗位和岗位内容等。
76	《产品采购清单》	包括采购人员、人员所属部门、采购产品、审核人员等内容。
77	《人员考核记录》	包括考核人员姓名、所属部门、考核内容和考核结果等内容。
78	《网络信息安全管理检查表》	包括安全技术措施的有效性、安全配置与安全策略的一致性、安全管理制度的执行情况等内容。
79	《年度信息安全检查情况报告表》	表格中包含了部门基本情况、信息系统基本情况、日常信息安全管理情况、信息安全防护管理情况、信息安全应急管理情况、信息技术产品应用情况、信息安全教育培训情况、信息系统安全建设整改、信息安全经费保障、本年度信息安全事件情况、信息技术外包服务机构情况（包括参与技术检测的外部专业机构）等内容。
80	《应急预案培训记录》	包括时间、地址、人员和培训内容等。
81	《应急预案演练记录》	包括时间、地址、人员和应急演练内容等。
82	《系统安全性测试报告》	包括系统安全性测试时间、安全性测试人员、安全性测试公司、安全性测试模块（功能）和安全性测试结构等内容。
83	《系统变更申请表》	包括变更缘由、变更时间、变更结果等内容。

附录B 上次测评问题整改情况说明

系统前次测评在 2024 年 12 月，由苏州如意云网络科技有限公司进行测评，系统等级测评结论为中，综合得分为 87.18 分，报告编号为 32050013019-24004-

24-0105-01。本表内容引用 2024 年度的《网络安全等级保护常熟市环卫综合信息
系统等级测评报告》，对部分问题进行了合并。

附录 B 表-1 上次测评问题整改情况

序号	安全问题	整改结果	情况说明
1	未基于可信根对通信设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。	☐ 已整改 ☒ 未整改	未整改
2	未基于可信根对边界设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。	☐ 已整改 ☒ 未整改	未整改
3	未基于可信根对安全计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。	☐ 已整改 ☒ 未整改	未整改
4	未采用技术措施对非授权设备私自联到内部网络的行为进行检查或限制。	☒ 已整改 ☐ 未整改	系统部署在华为云，通过华为云安全组策略入方向允许 22、1883、9535 等端口进行通信，可有效限制非授权设备的私自内联行为。
5	未采取技术措施对非授权的内部用户私自连接外部网络的行为进行检查或限制。	☐ 已整改 ☒ 未整改	未整改
6	数据库和应用系统未配置口令有效期策略。	☐ 已整改 ☒ 未整改	未整改
7	堡垒机口令有效周期过长。	☐ 已整改 ☒ 未整改	未整改
8	华为云管理控制台及其安全组件的登录连接超时过长。	☐ 已整改 ☒ 未整改	未整改

序号	安全问题	整改结果	情况说明
9	数据库未配置登录失败处理策略。	☐ 已整改 ☒ 未整改	未整改
10	各类系统（设备）未采用两种或两种以上组合的鉴别技术对用户进行身份鉴别。	☐ 已整改 ☒ 未整改	未整改
11	服务器和数据库采用默认账户进行管理。	☐ 已整改 ☒ 未整改	未整改
12	各类系统（设备）未实现管理用户的权限分离。	☐ 已整改 ☒ 未整改	未整改
13	未对重要主体和客体设置安全标记，未实现通过安全标记控制主体对信息资源的访问。	☐ 已整改 ☒ 未整改	未整改
14	各类系统（设备）未严格限制终端登录地址范围。	☐ 已整改 ☒ 未整改	未整改
15	堡垒机和终端审计记录仅保存在本机，未将日志传输至日志审计系统进行定期备份。	☐ 已整改 ☒ 未整改	未整改
16	未采用校验技术或密码技术保证服务器和数据库的重要配置数据和鉴别数据在存储过程中的完整性。	☐ 已整改 ☒ 未整改	未整改
17	未采用密码技术保证网络安全设备的重要配置数据和鉴别数据在存储过程中的保密性。	☐ 已整改 ☒ 未整改	未整改
18	未采用任何机制对管理终端及云平台之间进行双向身份验证。	☐ 已整改 ☒ 未整改	未整改

序号	安全问题	整改结果	情况说明
19	该系统建设期未邀请第三方公司担任项目监理工作，无法通过第三方工程监理控制项目的实施过程。	☐ 已整改 ☒ 未整改	未整改
20	未定期对系统进行安全测评。	☒ 已整改 ☐ 未整改	该系统已每年至少进行一次等级保护测评工作，并提供了 2024 年度的测评报告，前次测评由苏州如意云网络科技有限公司负责，系统等级测评结论为良，综合得分为 87.18 分，报告编号为 32050013019-24004-24-0105-01，同时已根据发现的问题进行了加固，有整改记录。
21	未提供内部人员日常操作行为记录表以及是否违反上网策略的行为检查表。	☒ 已整改 ☐ 未整改	当前制定了《网络安全管理制度》，网络外联需提交《系统外联申请表》，详细记录了申请部门、申请人、申请事项、审核申请事项等内容，同时提供了检查用户违反网络安全策略行为的工作记录（每年一次）。

附录C 单项测评结果汇总

C.1 安全物理环境

附录 C 表-1 安全物理环境单项测评结果汇总表（安全通用要求部分）

序号	测评对象	符合情况	安全通用要求									
			物理位置选择	物理访问控制	防盗窃和防破坏	防雷击	防火	防水和防潮	防静电	温湿度控制	电力供应	电磁防护
1	华为云机房	符合	0	0	0	0	0	0	0	0	0	0
		部分符合	0	0	0	0	0	0	0	0	0	0
		不符合	0	0	0	0	0	0	0	0	0	0
		不适用	2	1	3	2	3	3	2	1	3	2

附录 C 表-2 安全物理环境单项测评结果汇总表（安全扩展要求部分）

序号	测评对象	符合情况	安全扩展要求
			基础设施位置（云计算）
1	云计算安全扩展要求	符合	1
		部分符合	0
		不符合	0
		不适用	0

C.2 安全通信网络

附录 C 表-3 安全通信网络单项测评结果汇总表（安全通用要求部分）

序号	测评对象	符合情况	安全通用要求		
			网络架构	通信传输	可信验证
1	安全通信网络	符合	4	2	0
		部分符合	0	0	0
		不符合	0	0	1
		不适用	1	0	0

附录 C 表-4 安全通信网络单项测评结果汇总表（安全扩展要求部分）

序号	测评对象	符合情况	安全扩展要求
			网络架构（云计算）
1	云租户安全扩展要求	符合	1
		部分符合	0
		不符合	0
		不适用	4

C.3 安全区域边界

附录 C 表-5 安全区域边界单项测评结果汇总表（安全通用要求部分）

序号	测评对象	符合情况	安全通用要求					
			边界防护	访问控制	入侵防范	恶意代码和垃圾邮件防范	安全审计	可信验证
1	安全	符合	2	5	4	0	3	0

序号	测评对象	符合情况	安全通用要求					
			边界防护	访问控制	入侵防范	恶意代码和垃圾邮件防范	安全审计	可信验证
	区域边界	部分符合	0	0	0	0	0	0
		不符合	1	0	0	1	1	1
		不适用	1	0	0	1	0	0

附录 C 表-6 安全区域边界单项测评结果汇总表（安全扩展要求部分）

序号	测评对象	符合情况	安全扩展要求		
			访问控制（云计算）	入侵防范（云计算）	安全审计（云计算）
1	云租户安全扩展要求	符合	1	4	2
		部分符合	0	0	0
		不符合	0	0	0
		不适用	1	0	0

C.4 安全计算环境

C.4.1 网络设备

附录 C 表-7 安全计算环境单项测评结果汇总表（安全通用要求部分）

序号	测评对象	符合情况	安全通用要求										
			身份鉴别	访问控制	安全审计	入侵防范	恶意代码防范	可信验证	数据完整性	数据保密性	数据备份恢复	剩余信息保护	个人信息保护
1	华为云虚拟私有云VPC	符合	2	6	4	0	0	0	1	1	0	1	0
		部分符合	1	0	0	0	0	0	0	0	1	0	0
		不符合	1	1	0	0	0	1	1	1	0	0	0
		不适用	0	0	0	6	1	0	0	0	2	1	2

C.4.2 安全设备

序号	测评对象	符合情况	安全通用要求										
			身份鉴别	访问控制	安全审计	入侵防范	恶意代码防范	可信验证	数据完整性	数据保密性	数据备份恢复	剩余信息保护	个人信息保护
6	华为云日志服务 LTS	符合	2	6	4	0	0	0	1	1	0	1	0
		部分符合	1	0	0	0	0	0	0	0	1	0	0
		不符合	1	1	0	0	0	1	1	1	0	0	0
		不适用	0	0	0	6	1	0	0	0	2	1	2
7	华为云数据库安全服务 DBS S	符合	2	6	4	0	0	0	1	1	0	1	0
		部分符合	1	0	0	0	0	0	0	0	1	0	0
		不符合	1	1	0	0	0	1	1	1	0	0	0
		不适用	0	0	0	6	1	0	0	0	2	1	2

C.4.3 服务器和终端

附录 C 表-9 安全计算环境单项测评结果汇总表（安全通用要求部分）

序号	测评对象	符合情况	安全通用要求										
			身份鉴别	访问控制	安全审计	入侵防范	恶意代码防范	可信验证	数据完整性	数据保密性	数据备份恢复	剩余信息保护	个人信息保护
1	eCloud 相关集成服务器	符合	3	3	3	4	1	0	1	1	1	2	0
		部分符合	0	1	0	0	0	0	0	1	0	0	0
		不符合	1	3	1	1	0	1	1	0	0	0	0
		不适用	0	0	0	1	0	0	0	0	2	0	2
2	对外服务	符合	3	3	3	4	1	0	1	1	1	2	0
		部分符合	0	1	0	0	0	0	0	1	0	0	0

序号	测评对象	符合情况	安全通用要求										
			身份鉴别	访问控制	安全审计	入侵防范	恶意代码防范	可信验证	数据完整性	数据保密性	数据备份恢复	剩余信息保护	个人信息保护
	交易” 电子交易平台	不符合	1	2	0	0	0	1	0	0	0	0	0
		不适用	0	0	0	4	1	0	0	0	3	0	2

C.4.6 数据资源

附录 C 表-12 安全计算环境单项测评结果汇总表（安全通用要求部分）

序号	测评对象	符合情况	安全通用要求				
			数据完整性	数据保密性	数据备份恢复	剩余信息保护	个人信息保护
1	重要业务数据	符合	1	2	1	0	0
		部分符合	1	0	0	0	0
		不符合	0	0	1	0	0
		不适用	0	0	1	2	2
2	重要个人信息	符合	1	2	1	0	2
		部分符合	1	0	0	0	0
		不符合	0	0	1	0	0
		不适用	0	0	1	2	0

C.4.7 其他系统或设备

本次测评此系统不涉及其他系统或设备。

附录 C 表-13 安全计算环境单项测评结果汇总表（安全扩展要求部分）

序号	测评对象	符合情况	安全扩展要求						
			身份鉴别（云计算）	访问控制（云计算）	入侵防范（云计算）	镜像和快照保护（云计算）	数据完整性和保密性（云计算）	数据备份恢复（云计算）	剩余信息保护（云计算）
1	云租户安全扩展要求	符合	0	1	2	0	1	1	0
		部分符合	0	0	0	0	0	0	0
		不符合	1	0	0	0	0	0	0
		不适用	0	1	1	3	3	3	2

C.5 安全管理中心

附录 C 表-14 安全管理中心单项测评结果汇总表（安全通用要求部分）

序号	测评对象	符合情况	安全通用要求			
			系统管理	审计管理	安全管理	集中管控
1	安全管理中心	符合	2	2	2	6
		部分符合	0	0	0	0
		不符合	0	0	0	0
		不适用	0	0	0	0

附录 C 表-15 安全管理中心单项测评结果汇总表（安全扩展要求部分）

序号	测评对象	符合情况	安全扩展要求
			集中管控（云计算）
1	云租户安全扩展要求	符合	2
		部分符合	0
		不符合	0
		不适用	2

C.6 安全管理制度

附录 C 表-16 安全管理制度单项测评结果汇总表（安全通用要求部分）

序号	测评对象	符合情况	安全通用要求			
			安全策略	管理制度	制定和发布	评审和修订
1	制度或记录类文档	符合	1	3	2	1
		部分符合	0	0	0	0
		不符合	0	0	0	0
		不适用	0	0	0	0

C.7 安全管理机构

附录 C 表-17 安全管理机构单项测评结果汇总表（安全通用要求部分）

序号	测评对象	符合情况	安全通用要求				
			岗位设置	人员配备	授权和审批	沟通和合作	审核和检查
1	制度或记录类文档	符合	3	2	3	3	3
		部分符合	0	0	0	0	0
		不符合	0	0	0	0	0
		不适用	0	0	0	0	0

C.8 安全管理人员

附录 C 表-18 安全管理人员单项测评结果汇总表（安全通用要求部分）

序号	测评对象	符合情况	安全通用要求			
			人员录用	人员离岗	安全意识教育和培训	外部人员访问管理
1	制度或记录类文档	符合	3	2	3	4
		部分符合	0	0	0	0
		不符合	0	0	0	0
		不适用	0	0	0	0

C.9 安全建设管理

序号	测评对象	符合情况	安全通用要求													
			环境管理	资产管理	介质管理	设备维护管理	漏洞和风险管理	网络和系统安全管理	恶意代码防范管理	配置管理	密码管理	变更管理	备份与恢复管理	安全事件处置	应急预案管理	外包运维管理
	类文档	部分符合	0	0	0	0	0	0	0	0	0	0	0	0	0	0
		不符合	0	0	0	0	0	1	0	0	0	0	0	0	0	0
		不适用	2	0	0	0	0	0	0	0	2	0	0	0	0	4

附录 C 表-22 安全运维管理单项测评结果汇总表（安全扩展要求部分）

序号	测评对象	符合情况	安全扩展要求
			云计算环境管理（云计算）
1	云租户安全扩展要求	符合	0
		部分符合	0
		不符合	0
		不适用	1

C.11其他安全要求指标

本次测评不包含其他安全要求指标。

附录D 单项测评结果记录

D.1 安全物理环境

D.1.1 安全通用要求部分

D.1.1.1华为云机房

控制点	测评项	结果记录	符合情况
物理位	a)机房场地应选择在具有防震、	被测系统采用 IaaS 服务，针对此	不适用

控制点	测评项	结果记录	符合情况
置选择	防风 and 防雨等能力的建筑内；	项的安全保护责任由华为云负责，此项标准不适用。	
	b)机房场地应避免设在建筑物的顶层或地下室，否则应加强防水和防潮措施。	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
物理访问控制	机房出入口应配置电子门禁系统，控制、鉴别和记录进入的人员。	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
防盗窃和防破坏	a)应将设备或主要部件进行固定，并设置明显的不易除去的标识；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
	b)应将通信线缆铺设在隐蔽安全处；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
	c)应设置机房防盗报警系统或设置有专人值守的视频监控系统。	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
防雷击	a)应将各类机柜、设施和设备等通过接地系统安全接地；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
	b)应采取措施防止感应雷，例如设置防雷保安器或过压保护装置等。	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
防火	a)机房应设置火灾自动消防系统，能够自动检测火情、自动报警，并自动灭火；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
	b)机房及相关的工作房间和辅助房应采用具有耐火等级的建筑材料；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
	c)应对机房划分区域进行管理，区域和区域之间设置隔离防火措施。	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
防水和	a)应采取措施防止雨水通过机房	被测系统采用 IaaS 服务，针对此	不适用

控制点	测评项	结果记录	符合情况
防潮	窗户、屋顶和墙壁渗透；	项的安全保护责任由华为云负责，此项标准不适用。	
	b)应采取措施防止机房内水蒸气结露和地下积水的转移与渗透；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
	c)应安装对水敏感的检测仪表或元件，对机房进行防水检测和报警。	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
防静电	a)应采用防静电地板或地面并采用必要的接地防静电措施；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
	b)应采取措施防止静电的产生，例如采用静电消除器、佩戴防静电手环等。	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
温湿度控制	应设置温湿度自动调节设施，使机房温湿度的变化在设备运行所允许的范围之内。	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
电力供应	a)应在机房供电线路上配置稳压器和过电压防护设备；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
	b)应提供短期的备用电力供应，至少满足设备在断电情况下的正常运行要求；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
	c)应设置冗余或并行的电力电缆线路为计算机系统供电。	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
电磁防护	a)电源线和通信线缆应隔离铺设，避免互相干扰；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
	b)应对关键设备实施电磁屏蔽。	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用

D.1.2 安全扩展要求部分

D.1.2.1 云计算安全扩展要求

测评指标	控制点	测评项	结果记录	符合情况
云计算安全扩展要求	基础设施位置	应保证云计算基础设施位于中国境内。	经查看，系统部署于华为云平台，系统相关服务器、数据库、网络安全防护设备均放置在华为云机房内，该机房位于华北-北京一区，属于中国境内。	符合

D.2 安全通信网络

D.2.1 安全通用要求部分

D.2.1.1 安全通信网络

控制点	测评项	结果记录	符合情况
网络架构	a)应保证网络设备的业务处理能力满足业务高峰期需要；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项不适用。	不适用
	b)应保证网络各个部分的带宽满足业务高峰期需要；	经访谈及查看，系统部署在华为云上，且互联网出口带宽采用按量收费模式，并通过华为云云防火墙检测到近 30 天进出方向的流量趋势：响应峰值 150 Mbps、请求峰值 75 Mbps，不存在带宽受限制的情况，近一年内未出现网络堵塞情况，能够满足业务高峰期需求。	符合
	c)应划分不同的网络区域，并按照方便管理和控制的原则为各网络区域分配地址；	经访谈及查看，系统部署在华为云上，根据业务不同的需求，通过华为云管理控制台-华为云虚拟私有云 VPC-交换机查看服务器部署在 192.168.*.0/24，已根据不同区域分配不同地址段。	符合
	d)应避免将重要网络区域部署在边界处，重要网络区域与其他网络区域之间应采取可靠的技术	经访谈及查看，系统部署在华为云上，重要网段未部署在网络边界，并在深信服 Web 应用云防火	符合

控制点	测评项	结果记录	符合情况
	隔离手段；	墙、华为云安全组上配置了访问控制策略，可有效避免非授权访问。	
	e)应提供通信线路、关键网络设备和关键计算设备的硬件冗余，保证系统的可用性。	经查看，系统部署在华为云，通信线路、关键网络设备和关键计算设备均由华为云负责，服务器采用华为云弹性服务器部署，可实现系统的高可用性。	符合
通信传输	a)应采用校验技术或密码技术保证通信过程中数据的完整性；	经查看，网络设备、安全设备、华为云管理控制台远程管理方式采用 https，网络设备、安全设备、华为云管理控制台采用 ECDHE-RSA-WITH-AES-128-GCM-SHA256 进行加密，Linux 操作系统采用 ssh 方式（具有 hmac-sha 2-256-etm 技术）进行远程管理、应用系统采用 HTTPS 方式（具有 ECDHE-RSA-WITH-AES-256-GCM-SHA256 加密算法）进行远程管理，数据库开启了 SSL（采用 AES_128_GCM 算法），可实现通信过程中数据的完整性校验。	符合
	b)应采用密码技术保证通信过程中数据的保密性。	经查看，网络设备、安全设备、华为云管理控制台远程管理方式采用 https，网络设备、安全设备、华为云管理控制台采用 ECDHE-RSA-WITH-AES-128-GCM-SHA256 进行加密，Linux 操作系统采用 ssh 方式（采用 AES_128_GCM 算法）进行远程管理、应用系统采用 HTTPS 方式（具有 ECDHE-RSA-WITH-AES-256-GCM-SHA256 加密算法）进行远程管理，数据库开启了 SSL（采用 AES_128_GCM 算法），可实现通信过程中数据的保密性。	符合

控制点	测评项	结果记录	符合情况
可信验证	可基于可信根对通信设备的系统引导程序、系统程序、重要配置参数和通信应用程序等进行可信验证，并在应用程序的关键执行环节进行动态可信验证，在检测到其可信性受到破坏后进行报警，并将验证结果形成审计记录送至安全管理中心。	未基于可信根对通信设备的系统引导程序、系统程序等进行动态可信验证。	不符合

D.2.2 安全扩展要求部分

D.2.2.1 云租户安全扩展要求

测评指标	控制点	测评项	结果记录	符合情况
云计算安全扩展要求	网络架构	a)应保证云计算平台不承载高于其安全保护等级的业务应用系统；	经查看，被测系统部署在华为云，华为云提供三级等保材料，被测系统定级为三级，云计算平台安全保护等级满足被测系统的等级要求。	符合
		b)应实现不同云服务客户虚拟网络之间的隔离；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
		c)应具有根据云服务客户业务需求提供通信传输、边界防护、入侵防范等安全机制的能力；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
		d)应具有根据云服务客户业务需求自主设置安全策略的能力，包括定义访问路径、选择安全组件、配置安全策略；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项不适用。	不适用
		e)应提供开放接口或开放性安全服务，允许云服务客户接入第三方安全产品或在云计算平台选择第三方安全服务。	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项不适用。	不适用

D.3 安全区域边界

D.3.1 安全通用要求部分

D.3.1.1安全区域边界

控制点	测评项	结果记录	符合情况
边界防护	a)应保证跨越边界的访问和数据流通过边界设备提供的受控接口进行通信；	经查看，系统部署在华为云，网络出口边界部署了华为云安全组，在安全策略中配置了严格的访问控制策略，入方向仅允许 22、1883、9535、9098、123、85、3306 等通信端口，默认策略动作为拒绝所有通信。	符合
	b)应能够对非授权设备私自联到内部网络的行为进行检查或限制；	经查看，系统部署在华为云，通过华为云安全组策略入方向允许 22、1883、9535 等端口进行通信，可有效限制非授权设备的私自内联行为。	符合
	c)应能够对内部用户非授权联到外部网络的行为进行检查或限制；	经查看，未采取部署终端管控系统等措施对单位内部用户外联到外部网络的行为进行检查和限制。	不符合
	d)应限制无线网络的使用，保证无线网络通过受控的边界设备接入内部网络。	该网络不涉及无线网络使用，此项不适用。	不适用
访问控制	a)应在网络边界或区域之间根据访问控制策略设置访问控制规则，默认情况下除允许通信外受控接口拒绝所有通信；	经查看，网络出口边界部署了深信服 Web 应用云防火墙、华为云安全组，安全策略中配置了严格的访问控制策略，策略明确源地址、目的地址、源端口和目的端口配置等参数，默认情况下除允许通信外受控接口拒绝所有通信。	符合
	b)应删除多余或无效的访问控制规则，优化访问控制列表，并保证访问控制规则数量最小化；	经查看，网络出口边界部署了深信服 Web 应用云防火墙、华为云安全组，安全策略中配置了严格的访问控制策略，安全策略中不	符合

控制点	测评项	结果记录	符合情况
		存在子网重复、策略重复和策略无效等情况，目前系统策略已实现最优化。	
	c)应对源地址、目的地址、源端口、目的端口和协议等进行检查，以允许/拒绝数据包进出；	经查看，网络出口边界部署了深信服 Web 应用云防火墙、华为云安全组，安全策略中配置了严格的访问控制策略，策略中设置了源地址、目的地址、源端口、目的端口和协议，以允许/拒绝数据包进出。	符合
	d)应能根据会话状态信息为进出数据流提供明确的允许/拒绝访问的能力；	经查看，华为云安全组的策略功能和配置，其采用会话认证等机制为进出数据流提供明确的允许/拒绝访问的能力，且策略有效。	符合
	e)应对进出网络的数据流实现基于应用协议和应用内容的访问控制。	经查看，网络出口边界部署了深信服 Web 应用云防火墙，安全策略中配置了严格的访问控制策略，实现了基于应用协议（如：HTTP、HTTPS、NTP、DNS 等协议）和应用内容（如：关键字、敏感字等内容）的访问控制。	符合
入侵防范	a)应在关键网络节点处检测、防止或限制从外部发起的网络攻击行为；	经查看，当前网络环境中部署了深信服 Web 应用云防火墙，作为当前网络环境中外部关键网络节点处的主要安全防护设备，其具有漏洞攻击特征识别功能模块，当前漏洞攻击特征识别库版本：2025.9.2，更新时间：2025.9.2，当前特征库版本为官方发布的最新版本，设备特征库采用实时通过互联网进行在线升级和维护；当前网络环境中部署了华为云企业主机安全 HSS，作为当前网络环境中关键网络节点处的主要安全防护设备，其具有入侵防御功能模块，当前入侵防御	符合

控制点	测评项	结果记录	符合情况
		特征库版本：2025.9.2，更新时间：2025.9.2，当前特征库版本为官方发布的最新版本，更新维护由华为云负责，可对外部发起的网络攻击行为进行检测和阻断。	
	b)应在关键网络节点处检测、防止或限制从内部发起的网络攻击行为；	经查看，当前网络环境中部署了华为云企业主机安全 HSS，作为当前网络环境中内部关键网络节点处的主要安全防护设备，其具有入侵防御功能模块，当前入侵防御特征库版本：2025.9.2，更新时间：2025.9.2，更新维护由华为云负责，可对从内部发起的网络攻击行为进行检测和阻断。	符合
	c)应采取技术措施对网络行为进行分析，实现对网络攻击特别是新型网络攻击行为的分析；	经查看，当前网络环境中部署了深信服 Web 应用云防火墙和华为云企业主机安全 HSS，其具有流量分析功能，当前规则库版本：2025.9.2，版本发布日期：2025.9.2，当前规则库版本为官方发布的最新版本，深信服 Web 应用云防火墙的规则库采用实时通过互联网进行在线升级和维护，华为云企业主机安全 HSS 的规则库更新由华为云负责，可对网络行为进行实时分析，并实现对网络攻击特别是对新型网络攻击行为进行分析。	符合
	d)当检测到攻击行为时，记录攻击源 IP、攻击类型、攻击目标、攻击时间，在发生严重入侵事件时应提供报警。	经查看，当前网络环境中部署了深信服 Web 应用云防火墙和华为云企业主机安全 HSS，已配置相应安全策略，且策略有效，能够对网络中的各种攻击行为进行检测、识别、分析和记录，并通过手机短信（138****5671）的方式进行主动报警。	符合
恶意代	a)应在关键网络节点处对恶意代	经查看，网络层面未部署恶意代	不符合

控制点	测评项	结果记录	符合情况
码和垃圾邮件防范	码进行检测和清除，并维护恶意代码防护机制的升级和更新；	码防护系统，无法对网络中的恶意代码攻击进行检测和防护。	
	b)应在关键网络节点处对垃圾邮件进行检测和防护，并维护垃圾邮件防护机制的升级和更新。	该网络未部署邮件系统，此项不适用。	不适用
安全审计	a)应在网络边界、重要网络节点进行安全审计，审计覆盖到每个用户，对重要的用户行为和重要安全事件进行审计；	经查看，当前网络环境中部署了深信服 Web 应用云防火墙和华为云企业主机安全 HSS，其具有流量分析功能，可对所有的用户行为、攻击事件等进行实时分析。	符合
	b)审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息；	经查看，深信服 Web 应用云防火墙和华为云企业主机安全 HSS 的审计记录主要包括：事件 ID、时间、告警类型、告警内容、装填、优先级、操作等相关信息。	符合
	c)应对审计记录进行保护，定期备份，避免受到未预期的删除、修改或覆盖等；	经查看，深信服 Web 应用云防火墙和华为云企业主机安全 HSS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，华为云管理控制台当前配置策略已创建跟踪列表，并通过本地网络实时保存至华为云对象存储服务 OBS 中，可查询最早日志时间为 2025.3.1-2025.9.2，日志保存时间在 6 个月以上，能够对流量日志进行收集、保存、分析，可避免受到未预期的删除、修改或覆盖等。	符合
	d)应能对远程访问的用户行为、访问互联网的用户行为等单独进行行为审计和数据分析。	经查看，当前网络环境中部署了皓迪堡垒机，远程管理用户通过皓迪堡垒机对其用户行为进行单独审计和分析，但未对访问互联网的用户行为进行行为审计和数据分析。	不符合
可信验	可基于可信根对边界设备的系	未基于可信根对边界设备的系	不符合

控制点	测评项	结果记录	符合情况
证	统引导程序、系统程序、重要配置参数和边界防护应用程序等进行可信验证，并在应用程序的关键执行环节进行动态可信验证，在检测到其可信性受到破坏后进行报警，并将验证结果形成审计记录送至安全管理中心。	统引导程序、系统程序、重要配置参数和通信应用程序等进行动态可信验证。	

D.3.2 安全扩展要求部分

D.3.2.1云租户安全扩展要求

测评指标	控制点	测评项	结果记录	符合情况
云计算安全扩展要求	访问控制	a)应在虚拟化网络边界部署访问控制机制，并设置访问控制规则；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
		b)应在不同等级的网络区域边界部署访问控制机制，设置访问控制规则。	经查看及访谈，系统部署在华为云上，在不同等级的网络区域边界处部署有深信服 Web 应用云防火墙、华为云安全组，华为云安全组已配置访问控制策略，且策略有效。	符合
	入侵防范	a)应能检测到云服务客户发起的网络攻击行为，并能记录攻击类型、攻击时间、攻击流量等；	经查看，系统部署在华为云上，云平台部署有深信服 Web 应用云防火墙和华为云企业主机安全服务 HSS，已配置监控及报警策略，且策略有效，深信服 Web 应用云防火墙的规则库采用实时通过互联网进行在线升级和维护，华为云企业主机安全 HSS 的规则库更新由华为云负责，均已升级至最新版，可对网络入侵行为进行防范、阻断及告警，具备检测记录，记录包括攻击类型、攻击时间、攻击流量等内容。	符合

测评指标	控制点	测评项	结果记录	符合情况
		b)应能检测到对虚拟网络节点的网络攻击行为,并能记录攻击类型、攻击时间、攻击流量等;	经查看,系统部署在华为云上,云平台部署有华为云企业主机安全服务 HSS,已配置监控及报警策略,且策略有效,设备规则库由华为云进行实时更新和维护,均已升级至最新版,可对虚拟网络节点的网络攻击行为进行防范,具备检测记录,记录包括攻击类型、攻击时间、攻击流量等内容。	符合
		c)应能检测到虚拟机与宿主机、虚拟机与虚拟机之间的异常流量;	经查看,系统部署在华为云上,云平台部署有华为云企业主机安全服务 HSS,已配置监控及报警策略,且策略有效,设备规则库由华为云进行实时更新和维护,均已升级至最新版,可对虚拟机与宿主机之间、虚拟机与虚拟机之间的异常流量进行检测。	符合
		d)应在检测到网络攻击行为、异常流量情况进行告警。	经查看,系统部署在华为云上,云平台部署有华为云企业主机安全服务 HSS,已配置相应安全策略,且策略有效,设备规则库由华为云进行实时更新和维护,规则库均已升级至最新版本,可对网络攻击行为、异常流量情况进行检测,并通过手机短信(138****5671)的方式进行告警。	符合
	安全审计	a)应对云服务商和云服务客户在远程管理时执行的特权命令进行审计,至少包括虚拟机删除、虚拟机重启;	经查看,系统部署在华为云上,云平台部署有华为云日志服务 LTS,可对云服务客户执行的特权命令进行审计,审计记录包括虚拟机删除、虚拟机重启等。	符合
		b)应保证云服务商对云	经查看,系统部署在华为云上,	符合

测评指标	控制点	测评项	结果记录	符合情况
		服务客户系统和数据的操作可被云服务客户审计。	云平台无云服务客户系统和数据管理权限，云服务客户管理员可通过云平台查看系统和数据审计记录，云服务商操作可被云服务客户审计。	

D.4 安全计算环境

D.4.1 安全通用要求部分

D.4.1.1网络设备

D.4.1.1.1 华为云虚拟私有云 VPC

控制点	测评项	结果记录	符合情况
身份鉴别	a)应对登录的用户进行身份标识和鉴别，身份标识具有唯一性，身份鉴别信息具有复杂度要求并定期更换；	经查看，华为云虚拟私有云 VPC 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，华为云管理控制台登录需要输入用户名和口令+手机短信验证码的方式进行身份鉴别，用户标识具有唯一性，查看访问管理-安全设置-密码安全策略，当前配置策略账户口令长度为 8 个字符及以上，且包含大写字母、小写字母、数字和特殊符号 4 种，当前口令配置与系统配置策略一致，满足口令复杂度要求，口令有效期 30 天。	符合
	b)应具有登录失败处理功能，应配置并启用结束会话、限制非法登录次数和当登录连接超时自动退出等相关措施；	经查看，华为云虚拟私有云 VPC 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，系统配置了登录失败处理功能和网络登录连接超时自动退出功能，查看访问管理-安全设置-登录验证策略，15 分钟内登录失败 5 次，账户锁定 15 分钟，网络登录连接超时超时	部分符合

控制点	测评项	结果记录	符合情况
		60 分钟自动退出，但登录连接超时过长。	
	c)当进行远程管理时，应采取必要措施防止鉴别信息在网络传输过程中被窃听；	经查看，华为云虚拟私有云 VPC 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，远程管理系统采用 https 协议,使用 ECDHE-RSA-WITH-AES-128-GCM-SHA256 进行数据传输加密，鉴别信息在网络中加密传输，能够防止鉴别信息在传输过程中被窃听和篡改。	符合
	d)应采用口令、密码技术、生物技术等两种或两种以上组合的鉴别技术对用户进行身份鉴别，且其中一种鉴别技术至少应使用密码技术来实现。	经查看，华为云虚拟私有云 VPC 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，华为云管理控制台登录系统时采用用户名和口令，同时通过手机验证码进行身份鉴别，但系统未采用密码技术对用户进行身份鉴别。	不符合
访问控制	a)应对登录的用户分配账户和权限；	经查看，华为云虚拟私有云 VPC 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，查看华为云管理控制台-统一身份认证服务-用户，系统对登录的用户分配了账户 zhangxin 系统管理员、admin_shenji 审计管理员、admin_safe 安全管理员，并为每个登录的账户分配了相应的系统管理权限。	符合
	b)应重命名或删除默认账户，修改默认账户的默认口令；	经查看，华为云虚拟私有云 VPC 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，查看华为云管理控制台-统一身份认证服务-用户，系统对登录的用户分配了账户 zhangxin 系统管理员、admin_shenji 审计管理员、admin_safe 安全	符合

控制点	测评项	结果记录	符合情况
		管理员，系统中无默认账户，所有账户均为手动创建，口令满足复杂度要求。	
	c)应及时删除或停用多余的、过期的账户，避免共享账户的存在；	经查看，华为云虚拟私有云 VPC 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，系统对登录的用户分配了账户 zhangxin 系统管理员、admin_shenji 审计管理员、admin_safe 安全管理员，不存在其他多余、过期和共享账户。	符合
	d)应授予管理用户所需的最小权限，实现管理用户的权限分离；	经查看，华为云虚拟私有云 VPC 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，查看华为云管理控制台-统一身份认证服务-用户，系统对登录的用户分配了账户 zhangxin 系统管理员、admin_shenji 审计管理员、admin_safe 安全管理员，实现了管理用户的权限分离和用户所需的最小化权限。	符合
	e)应由授权主体配置访问控制策略，访问控制策略规定主体对客体的访问规则；	经查看，华为云虚拟私有云 VPC 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，系统配置了安全管理员对访问控制策略进行配置。	符合
	f)访问控制的粒度应达到主体为用户级或进程级，客体为文件、数据库表级；	经查看，设备的访问控制粒度可达到主体为用户级，客体为功能级。	符合
	g)应对重要主体和客体设置安全标记，并控制主体对有安全标记信息资源的访问。	经查看，系统不支持基于安全标记的访问控制。	不符合
安全审计	a)应启用安全审计功能，审计覆盖到每个用户，对重要的用户行为和重要安全事件进行审计；	经查看，华为云虚拟私有云 VPC 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，华为云管理控制台	符合

控制点	测评项	结果记录	符合情况
		开启了华为云云日志服务 LTS，审计范围覆盖所有用户，可对用户的操作行为、系统运行状态等进行审计记录。	
	b)审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息；	经查看，审计记录的主要内容包括：操作时间、操作者、事件名称、资源类型、资源名称等相关信息。	符合
	c)应对审计记录进行保护，定期备份，避免受到未预期的删除、修改或覆盖等；	经查看，华为云虚拟私有云 VPC 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，华为云管理控制台通过华为云云日志服务 LTS 进行审计，当前配置策略已创建跟踪列表，并通过本地网络实时保存至华为云对象存储服务 OBS 中，可查询最早日志时间为 2025.3.1-2025.9.2，日志保存时间在 6 个月以上，能够对审计记录进行收集、保存、分析，可避免受到未预期的删除、修改或覆盖等。	符合
	d)应对审计进程进行保护，防止未经授权的中断。	经查看，华为云虚拟私有云 VPC 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，华为云管理控制台未提供审计进程关闭功能，用户无法通过登录界面对审计进程进行关闭。	符合
入侵防范	a)应遵循最小安装的原则，仅安装需要的组件和应用程序；	因《信息安全技术 网络安全等级保护测评要求》（GB/T 28448-2019）中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
	b)应关闭不需要的系统服务、默认共享和高危端口；	因《信息安全技术 网络安全等级保护测评要求》（GB/T 28448-2019）中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用

控制点	测评项	结果记录	符合情况
	c)应通过设定终端接入方式或网络地址范围对通过网络进行管理的管理终端进行限制；	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
	d)应提供数据有效性检验功能，保证通过人机接口输入或通过通信接口输入的内容符合系统设定要求；	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前设备，故此项不适用。	不适用
	e)应能发现可能存在的已知漏洞，并在经过充分测试评估后，及时修补漏洞；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
	f)应能够检测到对重要节点进行入侵的行为，并在发生严重入侵事件时提供报警。	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
恶意代码防范	应采用免受恶意代码攻击的技术措施或主动免疫可信验证机制及时识别入侵和病毒行为，并将其有效阻断。	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
可信验证	可基于可信根对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行可信验证，并在应用程序的关键执行环节进行动态可信验证，在检测到其可信性受到破坏后进行报警，并将验证结果形成审计记录送至安全管理中心。	未采用可信计算技术对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。	不符合
数据完整性	a)应采用校验技术或密码技术保证重要数据在传输过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等；	经查看，华为云虚拟私有云 VPC 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，远程管理系统采用 https 协议，采用 ECDHE-RSA-WITH-AES-128-GCM-SHA256 进行数据传输加密，可对鉴别信息和配置数据在网络传输过程中的完整性进行校验。	符合

控制点	测评项	结果记录	符合情况
	b)应采用校验技术或密码技术保证重要数据在存储过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等。	经查看，系统未采用校验技术或密码技术实现鉴别数据、重要配置数据在存储过程中的完整性。	不符合
数据保密性	a)应采用密码技术保证重要数据在传输过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等；	经查看，华为云虚拟私有云 VPC 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，远程管理系统采用 https 协议，使用 ECDHE-RSA-WITH-AES-128-GCM-SHA256 进行数据传输加密，可对鉴别信息和配置数据在网络传输过程中进行数据传输加密。	符合
	b)应采用密码技术保证重要数据在存储过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等。	经查看，系统未采用密码技术保证鉴别数据、重要配置数据在存储过程中的保密性。	不符合
数据备份恢复	a)应提供重要数据的本地数据备份与恢复功能；	经核查，系统提供了配置数据的备份功能，每次修改配置前后均对配置数据进行一次备份，备份文件保存在运维终端-1 的 D:\备份文件夹中，但未进行备份恢复性测试。	部分符合
	b)应提供异地实时备份功能，利用通信网络将重要数据实时备份至备份场地；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
	c)应提供重要数据处理系统的热冗余，保证系统的高可用性。	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
剩余信息保护	a)应保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除；	经查看，华为云虚拟私有云 VPC 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，华为云管理控制台	符合

控制点	测评项	结果记录	符合情况
		的鉴别信息保存在本地 Cookie 中，用户关闭页面或长时间无数据请求，Cookie 自动失效，且服务器自动删除对应的 Session 信息。	
	b)应保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
个人信息保护	a)应仅采集和保存业务必需的用户个人信息；	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
	b)应禁止未授权访问和非法使用用户个人信息。	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用

D.4.1.2安全设备

D.4.1.2.1 深信服 Web 应用云防火墙

控制点	测评项	结果记录	符合情况
身份鉴别	a)应对登录的用户进行身份标识和鉴别，身份标识具有唯一性，身份鉴别信息具有复杂度要求并定期更换；	经查看，系统登录需要输入用户名和口令进行身份鉴别，用户标识具有唯一性，查看系统管理-管理员账号-密码安全策略，账户口令长度为 8 个字符以上，且包含大写字母、小写字母、数字和特殊符号 4 种，口令定期更换时间 30 天，当前口令配置与系统配置策略一致，满足口令复杂度要求。	符合
	b)应具有登录失败处理功能，应配置并启用结束会话、限制非法登录次数和当登录连接超时自动退出等相关措施；	经查看，系统配置了登录失败处理功能和网络登录连接超时自动退出功能，查看系统管理-通用配置-控制台配置，登录失败 5	符合

控制点	测评项	结果记录	符合情况
		次，账户锁定 60 分钟，网络登录页面连接空闲 10 分钟自动退出。	
	c)当进行远程管理时，应采取必要措施防止鉴别信息在网络传输过程中被窃听；	经查看，远程管理系统采用 https 协议，使用 TLS 1.0、RSA、AES_128_CBC with HMAC-SHA1 进行数据传输加密，鉴别信息在网络中加密传输，能够防止鉴别信息在传输过程中被窃听和篡改。	符合
	d)应采用口令、密码技术、生物技术等两种或两种以上组合的鉴别技术对用户进行身份鉴别，且其中一种鉴别技术至少应使用密码技术来实现。	经查看，登录系统仅采用用户名和口令进行身份鉴别，未采用双因子认证对用户身份进行鉴别。	不符合
访问控制	a)应对登录的用户分配账户和权限；	经查看，查看系统管理-管理员账号，系统对登录的用户分配了账户 admin 系统管理员，并分配了相应的系统管理权限。	符合
	b)应重命名或删除默认账户，修改默认账户的默认口令；	经查看，系统未重命名或删除默认账户 admin，用户已自行设置了账户登录口令。	部分符合
	c)应及时删除或停用多余的、过期的账户，避免共享账户的存在；	经查看，查看系统管理-管理员账号，系统对登录的用户分配了账户 admin 系统管理员，不存在其他多余、过期、共享账户。	符合
	d)应授予管理用户所需的最小权限，实现管理用户的权限分离；	经查看，查看系统管理-管理员账号，系统对登录的用户分配了账户 admin 系统管理员，未设置系统管理员、安全管理员、审计管理员账户，无法实现管理用户的权限分离。	不符合
	e)应由授权主体配置访问控制策略，访问控制策略规定主体对客体的访问规则；	经查看，系统未配置安全管理员对访问控制策略进行配置。	不符合
	f)访问控制的粒度应达到主体为	经查看，设备的访问控制粒度可	符合

控制点	测评项	结果记录	符合情况
	用户级或进程级，客体为文件、数据库表级；	达到主体为用户级，客体为功能级。	
	g)应对重要主体和客体设置安全标记，并控制主体对有安全标记信息资源的访问。	经查看，系统不支持基于安全标记的访问控制。	不符合
安全审计	a)应启用安全审计功能，审计覆盖到每个用户，对重要的用户行为和重要安全事件进行审计；	经查看，查看日志管理-系统日志，系统启用日志审计功能，范围覆盖所有用户，可对用户的操作行为、系统运行状态等进行记录。	符合
	b)审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息；	经查看，查看日志管理-系统日志，审计记录主要包括：序号、用户名、主机 IP、操作对象、操作、日期时间、详细等相关的信息。	符合
	c)应对审计记录进行保护，定期备份，避免受到未预期的删除、修改或覆盖等；	经查看，深信服 Web 应用云防火墙为华为云授权服务，通过华为云云日志服务 LTS 进行审计，当前配置策略已创建跟踪列表，并通过本地网络实时保存至华为云对象存储服务 OBS 中，可查询最早日志时间为 2025.3.1-2025.9.2，日志保存时间在 6 个月以上，能够对审计记录进行收集、保存、分析，可避免受到未预期的删除、修改或覆盖等。	符合
	d)应对审计进程进行保护，防止未经授权的中断。	经查看，系统审计进程为系统内置服务进程，管理员无法关闭，可防止审计进程未经授权的中断。	符合
入侵防范	a)应遵循最小安装的原则，仅安装需要的组件和应用程序；	经查看，该安全设备为嵌入式系统，系统组件均为业务需要，系统中未安装不必要的组件。	符合
	b)应关闭不需要的系统服务、默认共享和高危端口；	经查看，系统开启了 https、syslog 等管理需要的服务和端口，未	符合

控制点	测评项	结果记录	符合情况
		开启其他不需要的系统服务，默认共享和高危端口。	
	c)应通过设定终端接入方式或网络地址范围对通过网络进行管理的管理终端进行限制；	经查看，当前未对管理员的登录地址进行限制。	不符合
	d)应提供数据有效性检验功能，保证通过人机接口输入或通过通信接口输入的内容符合系统设定要求；	因《信息安全技术 网络安全等级保护测评要求》（GB/T 28448-2019）中该项测评对象的选择不涉及当前设备，故此项不适用。	不适用
	e)应能发现可能存在的已知漏洞，并在经过充分测试评估后，及时修补漏洞；	深信服 Web 应用云防火墙为购买的华为云授权服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
	f)应能够检测到对重要节点进行入侵的行为，并在发生严重入侵事件时提供报警。	经查看，系统具有漏洞攻击特征识别功能模块，当前漏洞攻击特征识别库版本：2025.9.2，更新时间：2025.9.2，当前特征库版本为官方发布的最新版本，设备特征库采用实时通过互联网进行在线升级和维护，能够对重要节点的入侵行为进行分析和检测，并通过手机短信（138****5671）的方式进行主动报警。	符合
恶意代码防范	应采用免受恶意代码攻击的技术措施或主动免疫可信验证机制及时识别入侵和病毒行为，并将其有效阻断。	因《信息安全技术 网络安全等级保护测评要求》（GB/T 28448-2019）中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
可信验证	可基于可信根对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行可信验证，并在应用程序的关键执行环节进行动态可信验证，在检测到其可信性受到破坏后进行报警，并将验证结果形成审计记录送至安全管理中心。	未采用可信计算技术对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。	不符合

控制点	测评项	结果记录	符合情况
数据完整性	a)应采用校验技术或密码技术保证重要数据在传输过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等；	经查看，远程管理系统采用 https 协议，采用 TLS 1.0、RSA、AES_128_CBC with HMAC-SHA1 进行数据传输加密，可对鉴别信息和配置数据在网络传输过程中的完整性进行校验。	符合
	b)应采用校验技术或密码技术保证重要数据在存储过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等。	经查看，系统未采用校验技术或密码技术实现鉴别数据、重要配置数据在存储过程中的完整性。	不符合
数据保密性	a)应采用密码技术保证重要数据在传输过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等；	经查看，远程管理系统采用 https 协议，使用 TLS 1.0、RSA、AES_128_CBC with HMAC-SHA1 进行数据传输加密，可对鉴别信息和配置数据在网络传输过程中进行数据传输加密。	符合
	b)应采用密码技术保证重要数据在存储过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等。	经查看，系统未采用密码技术保证鉴别数据、重要配置数据在存储过程中的保密性。	不符合
数据备份恢复	a)应提供重要数据的本地数据备份与恢复功能；	经核查，系统提供了配置数据的备份功能，每次修改配置前后均对配置数据进行一次备份，备份文件保存在运维终端-1 的 D:\备份文件夹中，但未进行备份恢复性测试。	部分符合
	b)应提供异地实时备份功能，利用通信网络将重要数据实时备份至备份场地；	安全设备配置文件无需异地备份，此项不适用。	不适用
	c)应提供重要数据处理系统的热冗余，保证系统的高可用性。	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用

控制点	测评项	结果记录	符合情况
剩余信息保护	a)应保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除；	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
	b)应保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
个人信息保护	a)应仅采集和保存业务必需的用户个人信息；	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
	b)应禁止未授权访问和非法使用用户个人信息。	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用

D.4.1.2.2 华为云安全组

控制点	测评项	结果记录	符合情况
身份鉴别	a)应对登录的用户进行身份标识和鉴别，身份标识具有唯一性，身份鉴别信息具有复杂度要求并定期更换；	经查看，华为云安全组为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，华为云管理控制台登录需要输入用户名和口令+手机短信验证码的方式进行身份鉴别，用户标识具有唯一性，查看访问管理-安全设置-密码安全策略，当前配置策略账户口令长度为 8 个字符及以上，且包含大写字母、小写字母、数字和特殊符号 4 种，当前口令配置与系统配置策略一致，满足口令复杂度要求，口令有效期 30 天。	符合
	b)应具有登录失败处理功能，应配置并启用结束会话、限制非法登录次数和当登录连接超时自	经查看，华为云安全组为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管	部分符合

控制点	测评项	结果记录	符合情况
	动退出等相关措施;	理, 系统配置了登录失败处理功能和网络登录连接超时自动退出功能, 查看访问管理-安全设置-登录验证策略, 15 分钟内登录失败 5 次, 账户锁定 15 分钟, 网络登录连接超时 60 分钟自动退出, 但登录连接超时过长。	
	c)当进行远程管理时, 应采取必要措施防止鉴别信息在网络传输过程中被窃听;	经查看, 华为云安全组为华为云管理控制台的功能模块, 并通过华为云管理控制台进行操作管理, 远程管理系统采用 https 协议, 使用 ECDHE-RSA-WITH-AES-128-GCM-SHA256 进行数据传输加密, 鉴别信息在网络中加密传输, 能够防止鉴别信息在传输过程中被窃听和篡改。	符合
	d)应采用口令、密码技术、生物技术等两种或两种以上组合的鉴别技术对用户进行身份鉴别, 且其中一种鉴别技术至少应使用密码技术来实现。	经查看, 华为云安全组为华为云管理控制台的功能模块, 并通过华为云管理控制台进行操作管理, 华为云管理控制台登录系统时采用用户名和口令, 同时通过手机验证码进行身份鉴别, 但系统未采用密码技术对用户进行身份鉴别。	不符合
访问控制	a)应对登录的用户分配账户和权限;	经查看, 华为云安全组为华为云管理控制台的功能模块, 并通过华为云管理控制台进行操作管理, 查看华为云管理控制台-统一身份认证服务-用户, 系统对登录的用户分配了账户 zhangxin 系统管理员、admin_shenji 审计管理员、admin_safe 安全管理员, 并为每个登录的账户分配了相应的系统管理权限。	符合
	b)应重命名或删除默认账户, 修改默认账户的默认口令;	经查看, 华为云安全组为华为云管理控制台的功能模块, 并通过华为云管理控制台进行操作管	符合

控制点	测评项	结果记录	符合情况
		理,查看华为云管理控制台-统一身份认证服务-用户,系统对登录的用户分配了账户 zhangxin 系统管理员、admin_shenji 审计管理员、admin_safe 安全管理员,系统中无默认账户,所有账户均为手动创建,口令满足复杂度要求。	
	c)应及时删除或停用多余的、过期的账户,避免共享账户的存在;	经查看,华为云安全组为华为云管理控制台的功能模块,并通过华为云管理控制台进行操作管理,系统对登录的用户分配了账户 zhangxin 系统管理员、admin_shenji 审计管理员、admin_safe 安全管理员,不存在其他多余、过期和共享账户。	符合
	d)应授予管理用户所需的最小权限,实现管理用户的权限分离;	经查看,华为云安全组为华为云管理控制台的功能模块,并通过华为云管理控制台进行操作管理,查看华为云管理控制台-统一身份认证服务-用户,系统对登录的用户分配了账户 zhangxin 系统管理员、admin_shenji 审计管理员、admin_safe 安全管理员,实现了管理用户的权限分离和用户所需的最小化权限。	符合
	e)应由授权主体配置访问控制策略,访问控制策略规定主体对客体的访问规则;	经查看,华为云安全组为华为云管理控制台的功能模块,并通过华为云管理控制台进行操作管理,系统配置了安全管理员对访问控制策略进行配置。	符合
	f)访问控制的粒度应达到主体为用户级或进程级,客体为文件、数据库表级;	经查看,设备的访问控制粒度可达到主体为用户级,客体为功能级。	符合
	g)应对重要主体和客体设置安全标记,并控制主体对有安全标记信息资源的访问。	经查看,系统不支持基于安全标记的访问控制。	不符合

控制点	测评项	结果记录	符合情况
安全审计	a)应启用安全审计功能，审计覆盖到每个用户，对重要的用户行为和重要安全事件进行审计；	经查看，华为云安全组为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，华为云管理控制台开启了华为云云日志服务 LTS，审计范围覆盖所有用户，可对用户的操作行为、系统运行状态等进行审计记录。	符合
	b)审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息；	经查看，审计记录的主要内容包 括：操作时间、操作者、事件名称、资源类型、资源名称等相关信息。	符合
	c)应对审计记录进行保护，定期备份，避免受到未预期的删除、修改或覆盖等；	经查看，华为云安全组为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，华为云管理控制台通过华为云云日志服务 LTS 进行审计，当前配置策略已创建跟踪列表，并通过本地网络实时保存至华为云对象存储服务 OBS 中，可查询最早日志时间为 2025.3.1-2025.9.2，日志保存时间在 6 个月以上，能够对审计记录进行收集、保存、分析，可避免受到未预期的删除、修改或覆盖等。	符合
	d)应对审计进程进行保护，防止未经授权的中断。	经查看，华为云安全组为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，华为云管理控制台未提供审计进程关闭功能，用户无法通过登录界面对审计进程进行关闭。	符合
入侵防范	a)应遵循最小安装的原则，仅安装需要的组件和应用程序；	因《信息安全技术 网络安全等级保护测评要求》（GB/T 28448-2019）中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
	b)应关闭不需要的系统服务、默认共享和高危端口；	因《信息安全技术 网络安全等级保护测评要求》（GB/T 28448-	不适用

控制点	测评项	结果记录	符合情况
		2019) 中该项测评对象的选择不涉及当前系统, 故此项不适用。	
	c)应通过设定终端接入方式或网络地址范围对通过网络进行管理的管理终端进行限制;	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统, 故此项不适用。	不适用
	d)应提供数据有效性检验功能, 保证通过人机接口输入或通过通信接口输入的内容符合系统设定要求;	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前设备, 故此项不适用。	不适用
	e)应能发现可能存在的已知漏洞, 并在经过充分测试评估后, 及时修补漏洞;	被测系统采用 IaaS 服务, 针对此项的安全保护责任由华为云负责, 此项标准不适用。	不适用
	f)应能够检测到对重要节点进行入侵的行为, 并在发生严重入侵事件时提供报警。	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统, 故此项不适用。	不适用
恶意代码防范	应采用免受恶意代码攻击的技术措施或主动免疫可信验证机制及时识别入侵和病毒行为, 并将其有效阻断。	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统, 故此项不适用。	不适用
可信验证	可基于可信根对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行可信验证, 并在应用程序的关键执行环节进行动态可信验证, 在检测到其可信性受到破坏后进行报警, 并将验证结果形成审计记录送至安全管理中心。	未采用可信计算技术对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。	不符合
数据完整性	a)应采用校验技术或密码技术保证重要数据在传输过程中的完整性, 包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等;	经查看, 华为云安全组为华为云管理控制台的功能模块, 并通过华为云管理控制台进行操作管理, 远程管理系统采用 https 协议, 采用 ECDHE-RSA-WITH-AES-128-GCM-SHA256 进行数据	符合

控制点	测评项	结果记录	符合情况
		传输加密，可对鉴别信息和配置数据在网络传输过程中的完整性进行校验。	
	b)应采用校验技术或密码技术保证重要数据在存储过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等。	经查看，系统未采用校验技术或密码技术实现鉴别数据、重要配置数据在存储过程中的完整性。	不符合
数据保密性	a)应采用密码技术保证重要数据在传输过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等；	经查看，华为云安全组为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，远程管理系统采用 https 协议，使用 ECDHE-RSA-WITH-AES-128-GCM-SHA256 进行数据传输加密，可对鉴别信息和配置数据在网络传输过程中进行数据传输加密。	符合
	b)应采用密码技术保证重要数据在存储过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等。	经查看，系统未采用密码技术保证鉴别数据、重要配置数据在存储过程中的保密性。	不符合
数据备份恢复	a)应提供重要数据的本地数据备份与恢复功能；	经核查，系统提供了配置数据的备份功能，每次修改配置前后均对配置数据进行一次备份，备份文件保存在运维终端-1 的 D:\备份文件夹中，但未进行备份恢复性测试。	部分符合
	b)应提供异地实时备份功能，利用通信网络将重要数据实时备份至备份场地；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
	c)应提供重要数据处理系统的热冗余，保证系统的高可用性。	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用

控制点	测评项	结果记录	符合情况
剩余信息保护	a)应保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除；	经查看，华为云安全组为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，华为云管理控制台的鉴别信息保存在本地 Cookie 中，用户关闭页面或长时间无数据请求，Cookie 自动失效，且服务器自动删除对应的 Session 信息。	符合
	b)应保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
个人信息保护	a)应仅采集和保存业务必需的用户个人信息；	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
	b)应禁止未授权访问和非法使用用户个人信息。	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用

D.4.1.2.3 华为云企业主机安全 HSS

控制点	测评项	结果记录	符合情况
身份鉴别	a)应对登录的用户进行身份标识和鉴别，身份标识具有唯一性，身份鉴别信息具有复杂度要求并定期更换；	经查看，华为云企业主机安全 HSS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，华为云管理控制台登录需要输入用户名和口令+手机短信验证码的方式进行身份鉴别，用户标识具有唯一性，查看访问管理-安全设置-密码安全策略，当前配置策略账户口令长度为 8 个字符及以上，且包含大写字母、小写字母、数字和特殊符号 4 种，当前口令配置与系统配置策略一致，满足口令复杂	符合

控制点	测评项	结果记录	符合情况
		度要求，口令有效期 30 天。	
	b)应具有登录失败处理功能，应配置并启用结束会话、限制非法登录次数和当登录连接超时自动退出等相关措施；	经查看，华为云企业主机安全 HSS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，系统配置了登录失败处理功能和网络登录连接超时自动退出功能，查看访问管理-安全设置-登录验证策略，15 分钟内登录失败 5 次，账户锁定 15 分钟，网络登录连接超时 60 分钟自动退出，但登录连接超时过长。	部分符合
	c)当进行远程管理时，应采取必要措施防止鉴别信息在网络传输过程中被窃听；	经查看，华为云企业主机安全 HSS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，远程管理系统采用 https 协议，使用 ECDHE-RSA-WITH-AES-128-GCM-SHA256 进行数据传输加密，鉴别信息在网络中加密传输，能够防止鉴别信息在传输过程中被窃听和篡改。	符合
	d)应采用口令、密码技术、生物技术等两种或两种以上组合的鉴别技术对用户进行身份鉴别，且其中一种鉴别技术至少应使用密码技术来实现。	经查看，华为云企业主机安全 HSS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，华为云管理控制台登录系统时采用用户名和口令，同时通过手机验证码进行身份鉴别，但系统未采用密码技术对用户进行身份鉴别。	不符合
访问控制	a)应对登录的用户分配账户和权限；	经查看，华为云企业主机安全 HSS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，查看华为云管理控制台-统一身份认证服务-用户，系统对登录的用户分配了账户 zhangxin 系统管理员、admin_	符合

控制点	测评项	结果记录	符合情况
		shenji 审计管理员、admin_safe 安全管理员，并为每个登录的账户分配了相应的系统管理权限。	
	b)应重命名或删除默认账户，修改默认账户的默认口令；	经查看，华为云企业主机安全 HSS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，查看华为云管理控制台-统一身份认证服务-用户，系统对登录的用户分配了账户 zhangxin 系统管理员、admin_shenji 审计管理员、admin_safe 安全管理员，系统中无默认账户，所有账户均为手动创建，口令满足复杂度要求。	符合
	c)应及时删除或停用多余的、过期的账户，避免共享账户的存在；	经查看，华为云企业主机安全 HSS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，系统对登录的用户分配了账户 zhangxin 系统管理员、admin_shenji 审计管理员、admin_safe 安全管理员，不存在其他多余、过期和共享账户。	符合
	d)应授予管理用户所需的最小权限，实现管理用户的权限分离；	经查看，华为云企业主机安全 HSS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，查看华为云管理控制台-统一身份认证服务-用户，系统对登录的用户分配了账户 zhangxin 系统管理员、admin_shenji 审计管理员、admin_safe 安全管理员，实现了管理用户的权限分离和用户所需的最小化权限。	符合
	e)应由授权主体配置访问控制策略，访问控制策略规定主体对客体的访问规则；	经查看，华为云企业主机安全 HSS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，系统配置了安全	符合

控制点	测评项	结果记录	符合情况
		管理员对访问控制策略进行配置。	
	f)访问控制的粒度应达到主体为用户级或进程级，客体为文件、数据库表级；	经查看，设备的访问控制粒度可达到主体为用户级，客体为功能级。	符合
	g)应对重要主体和客体设置安全标记，并控制主体对有安全标记信息资源的访问。	经查看，系统不支持基于安全标记的访问控制。	不符合
安全审计	a)应启用安全审计功能，审计覆盖到每个用户，对重要的用户行为和重要安全事件进行审计；	经查看，华为云企业主机安全 HSS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，华为云管理控制台开启了华为云云日志服务 LTS，审计范围覆盖所有用户，可对用户的操作行为、系统运行状态等进行审计记录。	符合
	b)审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息；	经查看，审计记录的主要内容包括：操作时间、操作者、事件名称、资源类型、资源名称等相关信息。	符合
	c)应对审计记录进行保护，定期备份，避免受到未预期的删除、修改或覆盖等；	经查看，华为云企业主机安全 HSS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，华为云管理控制台通过华为云云日志服务 LTS 进行审计，当前配置策略已创建跟踪列表，并通过本地网络实时保存至华为云对象存储服务 OBS 中，可查询最早日志时间为 2025.3.1-2025.9.2，日志保存时间在 6 个月以上，能够对审计记录进行收集、保存、分析，可避免受到未预期的删除、修改或覆盖等。	符合
	d)应对审计进程进行保护，防止未经授权的中断。	经查看，华为云企业主机安全 HSS 为华为云管理控制台的功能	符合

控制点	测评项	结果记录	符合情况
		模块，并通过华为云管理控制台进行操作管理，华为云管理控制台未提供审计进程关闭功能，用户无法通过登录界面对审计进程进行关闭。	
入侵防范	a)应遵循最小安装的原则，仅安装需要的组件和应用程序；	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
	b)应关闭不需要的系统服务、默认共享和高危端口；	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
	c)应通过设定终端接入方式或网络地址范围对通过网络进行管理的管理终端进行限制；	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
	d)应提供数据有效性检验功能，保证通过人机接口输入或通过通信接口输入的内容符合系统设定要求；	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前设备，故此项不适用。	不适用
	e)应能发现可能存在的已知漏洞，并在经过充分测试评估后，及时修补漏洞；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
	f)应能够检测到对重要节点进行入侵的行为，并在发生严重入侵事件时提供报警。	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
恶意代码防范	应采用免受恶意代码攻击的技术措施或主动免疫可信验证机制及时识别入侵和病毒行为，并将其有效阻断。	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
可信验证	可基于可信根对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行可信	未采用可信计算技术对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进	不符合

控制点	测评项	结果记录	符合情况
	验证，并在应用程序的关键执行环节进行动态可信验证，在检测到其可信性受到破坏后进行报警，并将验证结果形成审计记录送至安全管理中心。	行动态可信验证。	
数据完整性	a)应采用校验技术或密码技术保证重要数据在传输过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等；	经查看，华为云企业主机安全 HSS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，远程管理系统采用 https 协议，采用 ECDHE-RSA-WITH-AES-128-GCM-SHA256 进行数据传输加密，可对鉴别信息和配置数据在网络传输过程中的完整性进行校验。	符合
	b)应采用校验技术或密码技术保证重要数据在存储过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等。	经查看，系统未采用校验技术或密码技术实现鉴别数据、重要配置数据在存储过程中的完整性。	不符合
数据保密性	a)应采用密码技术保证重要数据在传输过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等；	经查看，华为云企业主机安全 HSS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，远程管理系统采用 https 协议，使用 ECDHE-RSA-WITH-AES-128-GCM-SHA256 进行数据传输加密，可对鉴别信息和配置数据在网络传输过程中进行数据传输加密。	符合
	b)应采用密码技术保证重要数据在存储过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等。	经查看，系统未采用密码技术保证鉴别数据、重要配置数据在存储过程中的保密性。	不符合
数据备份恢复	a)应提供重要数据的本地数据备份与恢复功能；	经核查，系统提供了配置数据的备份功能，每次修改配置前后均对配置数据进行一次备份，备份文件保存在运维终端-1 的 D:\备	部分符合

控制点	测评项	结果记录	符合情况
		份文件夹中，但未进行备份恢复性测试。	
	b)应提供异地实时备份功能，利用通信网络将重要数据实时备份至备份场地；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
	c)应提供重要数据处理系统的热冗余，保证系统的高可用性。	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
剩余信息保护	a)应保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除；	经查看，华为云企业主机安全 HSS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，华为云管理控制台的鉴别信息保存在本地 Cookie 中，用户关闭页面或长时间无数据请求，Cookie 自动失效，且服务器自动删除对应的 Session 信息。	符合
	b)应保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
个人信息保护	a)应仅采集和保存业务必需的用户个人信息；	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
	b)应禁止未授权访问和非法使用用户个人信息。	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用

D.4.1.2.4 华为云对象存储服务 OBS

控制点	测评项	结果记录	符合情况
身份鉴	a)应对登录的用户进行身份标识	经查看，华为云对象存储服务 O	符合

控制点	测评项	结果记录	符合情况
别	和鉴别，身份标识具有唯一性，身份鉴别信息具有复杂度要求并定期更换；	BS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，华为云管理控制台登录需要输入用户名和口令+手机短信验证码的方式进行身份鉴别，用户标识具有唯一性，查看访问管理-安全设置-密码安全策略，当前配置策略账户口令长度为 8 个字符及以上，且包含大写字母、小写字母、数字和特殊符号 4 种，当前口令配置与系统配置策略一致，满足口令复杂度要求，口令有效期 30 天。	
	b)应具有登录失败处理功能，应配置并启用结束会话、限制非法登录次数和当登录连接超时自动退出等相关措施；	经查看，华为云对象存储服务 O BS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，系统配置了登录失败处理功能和网络登录连接超时自动退出功能，查看访问管理-安全设置-登录验证策略，15 分钟内登录失败 5 次，账户锁定 15 分钟，网络登录连接超时超时 60 分钟自动退出，但登录连接超时过长。	部分符合
	c)当进行远程管理时，应采取必要措施防止鉴别信息在网络传输过程中被窃听；	经查看，华为云对象存储服务 O BS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，远程管理系统采用 https 协议，使用 ECDHE-RSA -WITH-AES-128-GCM-SHA256 进行数据传输加密，鉴别信息在网络中加密传输，能够防止鉴别信息在传输过程中被窃听和篡改。	符合
	d)应采用口令、密码技术、生物技术等两种或两种以上组合的鉴别技术对用户进行身份鉴别，且其中一种鉴别技术至少应使	经查看，华为云对象存储服务 O BS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，华为云管理控制	不符合

控制点	测评项	结果记录	符合情况
	用密码技术来实现。	台登录系统时采用用户名和口令，同时通过手机验证码进行身份鉴别，但系统未采用密码技术对用户进行身份鉴别。	
访问控制	a)应对登录的用户分配账户和权限；	经查看，华为云对象存储服务 OBS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，查看华为云管理控制台-统一身份认证服务-用户，系统对登录的用户分配了账户 zhangxin 系统管理员、admin_shenji 审计管理员、admin_safe 安全管理员，并为每个登录的账户分配了相应的系统管理权限。	符合
	b)应重命名或删除默认账户，修改默认账户的默认口令；	经查看，华为云对象存储服务 OBS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，查看华为云管理控制台-统一身份认证服务-用户，系统对登录的用户分配了账户 zhangxin 系统管理员、admin_shenji 审计管理员、admin_safe 安全管理员，系统中无默认账户，所有账户均为手动创建，口令满足复杂度要求。	符合
	c)应及时删除或停用多余的、过期的账户，避免共享账户的存在；	经查看，华为云对象存储服务 OBS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，系统对登录的用户分配了账户 zhangxin 系统管理员、admin_shenji 审计管理员、admin_safe 安全管理员，不存在其他多余、过期和共享账户。	符合
	d)应授予管理用户所需的最小权限，实现管理用户的权限分离；	经查看，华为云对象存储服务 OBS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，查看华为云管理	符合

控制点	测评项	结果记录	符合情况
		控制台-统一身份认证服务-用户，系统对登录的用户分配了账户 zhangxin 系统管理员、admin_shenji 审计管理员、admin_safe 安全管理员，实现了管理用户的权限分离和用户所需的最小化权限。	
	e)应由授权主体配置访问控制策略，访问控制策略规定主体对客体的访问规则；	经查看，华为云对象存储服务 OBS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，系统配置了安全管理员对访问控制策略进行配置。	符合
	f)访问控制的粒度应达到主体为用户级或进程级，客体为文件、数据库表级；	经查看，设备的访问控制粒度可达到主体为用户级，客体为功能级。	符合
	g)应对重要主体和客体设置安全标记，并控制主体对有安全标记信息资源的访问。	经查看，系统不支持基于安全标记的访问控制。	不符合
安全审计	a)应启用安全审计功能，审计覆盖到每个用户，对重要的用户行为和重要安全事件进行审计；	经查看，华为云对象存储服务 OBS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，华为云管理控制台开启了华为云云日志服务 LTS，审计范围覆盖所有用户，可对用户的操作行为、系统运行状态等进行审计记录。	符合
	b)审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息；	经查看，审计记录的主要内容包括：操作时间、操作者、事件名称、资源类型、资源名称等相关信息。	符合
	c)应对审计记录进行保护，定期备份，避免受到未预期的删除、修改或覆盖等；	经查看，华为云对象存储服务 OBS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，华为云管理控制台通过华为云云日志服务 LTS 进	符合

控制点	测评项	结果记录	符合情况
		行审计，当前配置策略已创建跟踪列表，并通过本地网络实时保存至华为云对象存储服务 OBS 中，可查询最早日志时间为 2025.3.1-2025.9.2，日志保存时间在 6 个月以上，能够对审计记录进行收集、保存、分析，可避免受到未预期的删除、修改或覆盖等。	
	d)应对审计进程进行保护，防止未经授权的中断。	经查看，华为云对象存储服务 OBS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，华为云管理控制台未提供审计进程关闭功能，用户无法通过登录界面对审计进程进行关闭。	符合
入侵防范	a)应遵循最小安装的原则，仅安装需要的组件和应用程序；	因《信息安全技术 网络安全等级保护测评要求》（GB/T 28448-2019）中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
	b)应关闭不需要的系统服务、默认共享和高危端口；	因《信息安全技术 网络安全等级保护测评要求》（GB/T 28448-2019）中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
	c)应通过设定终端接入方式或网络地址范围对通过网络进行管理的管理终端进行限制；	因《信息安全技术 网络安全等级保护测评要求》（GB/T 28448-2019）中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
	d)应提供数据有效性检验功能，保证通过人机接口输入或通过通信接口输入的内容符合系统设定要求；	因《信息安全技术 网络安全等级保护测评要求》（GB/T 28448-2019）中该项测评对象的选择不涉及当前设备，故此项不适用。	不适用
	e)应能发现可能存在的已知漏洞，并在经过充分测试评估后，及时修补漏洞；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用

控制点	测评项	结果记录	符合情况
	f)应能够检测到对重要节点进行入侵的行为，并在发生严重入侵事件时提供报警。	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
恶意代码防范	应采用免受恶意代码攻击的技术措施或主动免疫可信验证机制及时识别入侵和病毒行为，并将其有效阻断。	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
可信验证	可基于可信根对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行可信验证，并在应用程序的关键执行环节进行动态可信验证，在检测到其可信性受到破坏后进行报警，并将验证结果形成审计记录送至安全管理中心。	未采用可信计算技术对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。	不符合
数据完整性	a)应采用校验技术或密码技术保证重要数据在传输过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等；	经查看，华为云对象存储服务 O BS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，远程管理系统采用 https 协议，采用 ECDHE-RSA -WITH-AES-128-GCM-SHA256 进行数据传输加密，可对鉴别信息和配置数据在网络传输过程中的完整性进行校验。	符合
	b)应采用校验技术或密码技术保证重要数据在存储过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等。	经查看，系统未采用校验技术或密码技术实现鉴别数据、重要配置数据在存储过程中的完整性。	不符合
数据保密性	a)应采用密码技术保证重要数据在传输过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等；	经查看，华为云对象存储服务 O BS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，远程管理系统采用 https 协议，使用 ECDHE-RSA -WITH-AES-128-GCM-SHA256	符合

控制点	测评项	结果记录	符合情况
		进行数据传输加密，可对鉴别信息和配置数据在网络传输过程中进行数据传输加密。	
	b)应采用密码技术保证重要数据在存储过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等。	经查看，系统未采用密码技术保证鉴别数据、重要配置数据在存储过程中的保密性。	不符合
数据备份恢复	a)应提供重要数据的本地数据备份与恢复功能；	经核查，系统提供了配置数据的备份功能，每次修改配置前后均对配置数据进行一次备份，备份文件保存在运维终端-1 的 D:\备份文件夹中，但未进行备份恢复性测试。	部分符合
	b)应提供异地实时备份功能，利用通信网络将重要数据实时备份至备份场地；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
	c)应提供重要数据处理系统的热冗余，保证系统的高可用性。	因《信息安全技术 网络安全等级保护测评要求》（GB/T 28448-2019）中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
剩余信息保护	a)应保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除；	经查看，华为云对象存储服务 OBS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，华为云管理控制台的鉴别信息保存在本地 Cookie 中，用户关闭页面或长时间无数据请求，Cookie 自动失效，且服务器自动删除对应的 Session 信息。	符合
	b)应保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	因《信息安全技术 网络安全等级保护测评要求》（GB/T 28448-2019）中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
个人信息保护	a)应仅采集和保存业务必需的用户个人信息；	因《信息安全技术 网络安全等级保护测评要求》（GB/T 28448-	不适用

控制点	测评项	结果记录	符合情况
		2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	
	b)应禁止未授权访问和非法使用用户个人信息。	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用

D.4.1.2.5 皓迪堡垒机

控制点	测评项	结果记录	符合情况
身份鉴别	a)应对登录的用户进行身份标识和鉴别，身份标识具有唯一性，身份鉴别信息具有复杂度要求并定期更换；	经查看，系统登录需要输入用户名和口令进行身份鉴别，用户标识具有唯一性，查看密码策略列表-密码策略信息，当前配置策略账户口令长度为 8 个字符及以上，且包含大小写字母、数字和特殊字符，当前口令配置与系统配置策略一致，但当前口令有效期策略配置不合理，配置时间过长，口令有效期为 180 天，到期后强制修改口令。	部分符合
	b)应具有登录失败处理功能，应配置并启用结束会话、限制非法登录次数和当登录连接超时自动退出等相关措施；	经查看，系统配置了登录失败处理功能和网络登录连接超时自动退出功能，查看系统管理-通用配置-控制台配置，60 分钟内登录失败 5 次，账户锁定 60 分钟，网络登录连接超时为 60 分钟自动退出，但连接超时策略配置时间过长。	部分符合
	c)当进行远程管理时，应采取必要措施防止鉴别信息在网络传输过程中被窃听；	经查看，远程管理系统采用 https 协议，使用 AES-256-CBC-WITH-SHA256 进行数据传输加密，鉴别信息在网络中加密传输，能够防止鉴别信息在传输过程中被窃听和篡改。	符合
	d)应采用口令、密码技术、生物技术等两种或两种以上组合的	经查看，登录系统仅采用用户名和口令进行身份鉴别，未采用双	不符合

控制点	测评项	结果记录	符合情况
	鉴别技术对用户进行身份鉴别，且其中一种鉴别技术至少应使用密码技术来实现。	因子认证对用户身份进行鉴别。	
访问控制	a)应对登录的用户分配账户和权限；	经查看，查看系统管理-管理员账号，系统对登录的用户分配了账户 Admin 系统管理员，并分配了相应的系统管理权限。	符合
	b)应重命名或删除默认账户，修改默认账户的默认口令；	经查看，系统未重命名或删除默认账户 Admin，用户已自行设置了账户登录口令。	部分符合
	c)应及时删除或停用多余的、过期的账户，避免共享账户的存在；	经查看，查看系统管理-管理员账号，系统对登录的用户分配了账户 Admin 系统管理员，不存在其他多余、过期、共享账户。	符合
	d)应授予管理用户所需的最小权限，实现管理用户的权限分离；	经查看，查看系统管理-管理员账号，系统对登录的用户分配了账户 Admin 系统管理员，未设置系统管理员、安全管理员、审计管理员账户，无法实现管理用户的权限分离。	不符合
	e)应由授权主体配置访问控制策略，访问控制策略规定主体对客体的访问规则；	经查看，系统未配置安全管理员对访问控制策略进行配置。	不符合
	f)访问控制的粒度应达到主体为用户级或进程级，客体为文件、数据库表级；	经查看，设备的访问控制粒度可达到主体为用户级，客体为功能级。	符合
	g)应对重要主体和客体设置安全标记，并控制主体对有安全标记信息资源的访问。	经查看，系统不支持基于安全标记的访问控制。	不符合
安全审计	a)应启用安全审计功能，审计覆盖到每个用户，对重要的用户行为和重要安全事件进行审计；	经查看，查看审计管理，系统启用日志审计功能，范围覆盖所有用户，可对用户的操作行为、系统运行状态等进行记录。	符合
	b)审计记录应包括事件的日期和	经查看，查看审计管理，审计记	符合

控制点	测评项	结果记录	符合情况
	时间、用户、事件类型、事件是否成功及其他与审计相关的信息；	录主要包括访问者、资源名称、审计节点、协议账号、登录时间、市场流量进度、状态、功能等相关的信息。	
	c)应对审计记录进行保护，定期备份，避免受到未预期的删除、修改或覆盖等；	经查看，在可控的网络环境下，当前配置策略中审计记录仅本地保存，无法实现对审计数据进行保护或避免受到删除、修改或覆盖等。	不符合
	d)应对审计进程进行保护，防止未经授权的中断。	经查看，系统审计进程为系统内置服务进程，管理员无法关闭，可防止审计进程未经授权的中断。	符合
入侵防范	a)应遵循最小安装的原则，仅安装需要的组件和应用程序；	经查看，该安全设备为嵌入式系统，系统组件均为业务需要，系统中未安装不必要的组件。	符合
	b)应关闭不需要的系统服务、默认共享和高危端口；	经查看，系统开启了 https 等管理需要的服务和端口，未开启其他不需要的系统服务，默认共享和高危端口。	符合
	c)应通过设定终端接入方式或网络地址范围对通过网络进行管理的管理终端进行限制；	经查看，当前未对终端接入地址或接入方式进行限制。	不符合
	d)应提供数据有效性检验功能，保证通过人机接口输入或通过通信接口输入的内容符合系统设定要求；	因《信息安全技术 网络安全等级保护测评要求》（GB/T 28448-2019）中该项测评对象的选择不涉及当前设备，故此项不适用。	不适用
	e)应能发现可能存在的已知漏洞，并在经过充分测试评估后，及时修补漏洞；	经访谈和查看，由苏州国泰新点软件有限公司管理员每个季度进行一次漏洞扫描，并提供了漏洞扫描记录，在发现漏洞时，经过充分测试评估后，修复漏洞。	符合
	f)应能够检测到对重要节点进行入侵的行为，并在发生严重入侵事件时提供报警。	此项不适用，该项要求一般在入侵防护系统上实现。	不适用

控制点	测评项	结果记录	符合情况
恶意代码防范	应采用免受恶意代码攻击的技术措施或主动免疫可信验证机制及时识别入侵和病毒行为，并将其有效阻断。	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
可信验证	可基于可信根对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行可信验证，并在应用程序的关键执行环节进行动态可信验证，在检测到其可信性受到破坏后进行报警，并将验证结果形成审计记录送至安全管理中心。	未采用可信计算技术对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。	不符合
数据完整性	a)应采用校验技术或密码技术保证重要数据在传输过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等；	经查看，远程管理系统采用 https 协议，采用 AES-256-CBC-WITH-SHA256 进行数据传输加密，可对鉴别信息和配置数据在网络传输过程中的完整性进行校验。	符合
	b)应采用校验技术或密码技术保证重要数据在存储过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等。	经查看，系统未采用校验技术或密码技术实现鉴别数据、重要配置数据在存储过程中的完整性。	不符合
数据保密性	a)应采用密码技术保证重要数据在传输过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等；	经查看，远程管理系统采用 https 协议，使用 AES-256-CBC-WITH-SHA256 进行数据传输加密，可对鉴别信息和配置数据在网络传输过程中进行数据传输加密。	符合
	b)应采用密码技术保证重要数据在存储过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等。	经查看，系统未采用密码技术保证鉴别数据、重要配置数据在存储过程中的保密性。	不符合
数据备份恢复	a)应提供重要数据的本地数据备份与恢复功能；	经核查，系统提供了配置数据的备份功能，每次修改配置前后均对配置数据进行一次备份，备份	部分符合

控制点	测评项	结果记录	符合情况
		文件保存在运维终端-1 的 D:\备份文件夹中，但未进行备份恢复性测试。	
	b)应提供异地实时备份功能，利用通信网络将重要数据实时备份至备份场地；	安全设备配置文件无需异地备份，此项不适用。	不适用
	c)应提供重要数据处理系统的冗余，保证系统的高可用性。	系统为旁路部署的运维审计分析设备，无需热冗余部署，此项不适用。	不适用
剩余信息保护	a)应保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除；	因《信息安全技术 网络安全等级保护测评要求》（GB/T 28448-2019）中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
	b)应保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	因《信息安全技术 网络安全等级保护测评要求》（GB/T 28448-2019）中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
个人信息保护	a)应仅采集和保存业务必需的用户个人信息；	因《信息安全技术 网络安全等级保护测评要求》（GB/T 28448-2019）中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
	b)应禁止未授权访问和非法使用用户个人信息。	因《信息安全技术 网络安全等级保护测评要求》（GB/T 28448-2019）中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用

D.4.1.2.6 华为云云日志服务 LTS

控制点	测评项	结果记录	符合情况
身份鉴别	a)应对登录的用户进行身份标识和鉴别，身份标识具有唯一性，身份鉴别信息具有复杂度要求并定期更换；	经查看，华为云云日志服务 LTS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，华为云管理控制台登录需要输入用户名和口令+手机短信验证码的方式进行身份	符合

控制点	测评项	结果记录	符合情况
		鉴别，用户标识具有唯一性，查看访问管理-安全设置-密码安全策略，当前配置策略账户口令长度为 8 个字符及以上，且包含大写字母、小写字母、数字和特殊符号 4 种，当前口令配置与系统配置策略一致，满足口令复杂度要求，口令有效期 30 天。	
	b)应具有登录失败处理功能，应配置并启用结束会话、限制非法登录次数和当登录连接超时自动退出等相关措施；	经查看，华为云云日志服务 LTS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，系统配置了登录失败处理功能和网络登录连接超时自动退出功能，查看访问管理-安全设置-登录验证策略，15 分钟内登录失败 5 次，账户锁定 15 分钟，网络登录连接超时超时 60 分钟自动退出，但登录连接超时过长。	部分符合
	c)当进行远程管理时，应采取必要措施防止鉴别信息在网络传输过程中被窃听；	经查看，华为云云日志服务 LTS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，远程管理系统采用 https 协议，使用 ECDHE-RSA-WITH-AES-128-GCM-SHA256 进行数据传输加密，鉴别信息在网络中加密传输，能够防止鉴别信息在传输过程中被窃听和篡改。	符合
	d)应采用口令、密码技术、生物技术等两种或两种以上组合的鉴别技术对用户进行身份鉴别，且其中一种鉴别技术至少应使用密码技术来实现。	经查看，华为云云日志服务 LTS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，华为云管理控制台登录系统时采用用户名和口令，同时通过手机验证码进行身份鉴别，但系统未采用密码技术对用户进行身份鉴别。	不符合
访问控	a)应对登录的用户分配账户和权	经查看，华为云云日志服务 LTS	符合

控制点	测评项	结果记录	符合情况
制	限；	为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，查看华为云管理控制台-统一身份认证服务-用户，系统对登录的用户分配了账户 zhangxin 系统管理员、admin_shenji 审计管理员、admin_safe 安全管理员，并为每个登录的账户分配了相应的系统管理权限。	
	b)应重命名或删除默认账户，修改默认账户的默认口令；	经查看，华为云云日志服务 LTS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，查看华为云管理控制台-统一身份认证服务-用户，系统对登录的用户分配了账户 zhangxin 系统管理员、admin_shenji 审计管理员、admin_safe 安全管理员，系统中无默认账户，所有账户均为手动创建，口令满足复杂度要求。	符合
	c)应及时删除或停用多余的、过期的账户，避免共享账户的存在；	经查看，华为云云日志服务 LTS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，系统对登录的用户分配了账户 zhangxin 系统管理员、admin_shenji 审计管理员、admin_safe 安全管理员，不存在其他多余、过期和共享账户。	符合
	d)应授予管理用户所需的最小权限，实现管理用户的权限分离；	经查看，华为云云日志服务 LTS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，查看华为云管理控制台-统一身份认证服务-用户，系统对登录的用户分配了账户 zhangxin 系统管理员、admin_shenji 审计管理员、admin_safe 安全管理员，实现了管理用户的权限分离和用户所需的最小化权限。	符合

控制点	测评项	结果记录	符合情况
	e)应由授权主体配置访问控制策略，访问控制策略规定主体对客体的访问规则；	经查看，华为云云日志服务 LTS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，系统配置了安全管理员对访问控制策略进行配置。	符合
	f)访问控制的粒度应达到主体为用户级或进程级，客体为文件、数据库表级；	经查看，设备的访问控制粒度可达到主体为用户级，客体为功能级。	符合
	g)应对重要主体和客体设置安全标记，并控制主体对有安全标记信息资源的访问。	经查看，系统不支持基于安全标记的访问控制。	不符合
安全审计	a)应启用安全审计功能，审计覆盖到每个用户，对重要的用户行为和重要安全事件进行审计；	经查看，华为云云日志服务 LTS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，华为云管理控制台开启了华为云云日志服务 LTS，审计范围覆盖所有用户，可对用户的操作行为、系统运行状态等进行审计记录。	符合
	b)审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息；	经查看，审计记录的主要内容包括：操作时间、操作者、事件名称、资源类型、资源名称等相关信息。	符合
	c)应对审计记录进行保护，定期备份，避免受到未预期的删除、修改或覆盖等；	经查看，华为云云日志服务 LTS 审计记录本地保存，当前配置策略已创建跟踪列表，并通过本地网络实时保存至华为云对象存储服务 OBS 中，可查询最早日志时间为 2025.3.1-2025.9.2，日志保存时间在 6 个月以上，能够对审计记录进行收集、保存、分析，可避免受到未预期的删除、修改或覆盖等。	符合
	d)应对审计进程进行保护，防止未经授权的中断。	经查看，华为云云日志服务 LTS 为华为云管理控制台的功能模块，并通过华为云管理控制台进	符合

控制点	测评项	结果记录	符合情况
		行操作管理，华为云管理控制台未提供审计进程关闭功能，用户无法通过登录界面对审计进程进行关闭。	
入侵防范	a)应遵循最小安装的原则，仅安装需要的组件和应用程序；	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
	b)应关闭不需要的系统服务、默认共享和高危端口；	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
	c)应通过设定终端接入方式或网络地址范围对通过网络进行管理的管理终端进行限制；	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
	d)应提供数据有效性检验功能，保证通过人机接口输入或通过通信接口输入的内容符合系统设定要求；	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前设备，故此项不适用。	不适用
	e)应能发现可能存在的已知漏洞，并在经过充分测试评估后，及时修补漏洞；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
	f)应能够检测到对重要节点进行入侵的行为，并在发生严重入侵事件时提供报警。	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
恶意代码防范	应采用免受恶意代码攻击的技术措施或主动免疫可信验证机制及时识别入侵和病毒行为，并将其有效阻断。	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
可信验证	可基于可信根对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行可信验证，并在应用程序的关键执行	未采用可信计算技术对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。	不符合

控制点	测评项	结果记录	符合情况
	环节进行动态可信验证，在检测到其可信性受到破坏后进行报警，并将验证结果形成审计记录送至安全管理中心。		
数据完整性	a)应采用校验技术或密码技术保证重要数据在传输过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等；	经查看，华为云云日志服务 LTS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，远程管理系统采用 https 协议，采用 ECDHE-RSA-WITH-AES-128-GCM-SHA256 进行数据传输加密，可对鉴别信息和配置数据在网络传输过程中的完整性进行校验。	符合
	b)应采用校验技术或密码技术保证重要数据在存储过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等。	经查看，系统未采用校验技术或密码技术实现鉴别数据、重要配置数据在存储过程中的完整性。	不符合
数据保密性	a)应采用密码技术保证重要数据在传输过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等；	经查看，华为云云日志服务 LTS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，远程管理系统采用 https 协议，使用 ECDHE-RSA-WITH-AES-128-GCM-SHA256 进行数据传输加密，可对鉴别信息和配置数据在网络传输过程中进行数据传输加密。	符合
	b)应采用密码技术保证重要数据在存储过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等。	经查看，系统未采用密码技术保证鉴别数据、重要配置数据在存储过程中的保密性。	不符合
数据备份恢复	a)应提供重要数据的本地数据备份与恢复功能；	经核查，系统提供了配置数据的备份功能，每次修改配置前后均对配置数据进行一次备份，备份文件保存在运维终端-1 的 D:\备份文件夹中，但未进行备份恢复	部分符合

控制点	测评项	结果记录	符合情况
		性测试。	
	b)应提供异地实时备份功能，利用通信网络将重要数据实时备份至备份场地；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
	c)应提供重要数据处理系统的热冗余，保证系统的高可用性。	因《信息安全技术 网络安全等级保护测评要求》（GB/T 28448-2019）中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
剩余信息保护	a)应保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除；	经查看，华为云云日志服务 LTS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，华为云管理控制台的鉴别信息保存在本地 Cookie 中，用户关闭页面或长时间无数据请求，Cookie 自动失效，且服务器自动删除对应的 Session 信息。	符合
	b)应保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	因《信息安全技术 网络安全等级保护测评要求》（GB/T 28448-2019）中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
个人信息保护	a)应仅采集和保存业务必需的用户个人信息；	因《信息安全技术 网络安全等级保护测评要求》（GB/T 28448-2019）中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
	b)应禁止未授权访问和非法使用用户个人信息。	因《信息安全技术 网络安全等级保护测评要求》（GB/T 28448-2019）中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用

D.4.1.2.7 华为云数据库安全服务 DBSS

控制点	测评项	结果记录	符合情况
身份鉴别	a)应对登录的用户进行身份标识和鉴别，身份标识具有唯一性，	经查看，华为云数据库安全服务 DBSS 为华为云管理控制台的功	符合

控制点	测评项	结果记录	符合情况
	身份鉴别信息具有复杂度要求并定期更换；	能模块，并通过华为云管理控制台进行操作管理，华为云管理控制台登录需要输入用户名和口令+手机短信验证码的方式进行身份鉴别，用户标识具有唯一性，查看访问管理-安全设置-密码安全策略，当前配置策略账户口令长度为 8 个字符及以上，且包含大写字母、小写字母、数字和特殊符号 4 种，当前口令配置与系统配置策略一致，满足口令复杂度要求，口令有效期 30 天。	
	b)应具有登录失败处理功能，应配置并启用结束会话、限制非法登录次数和当登录连接超时自动退出等相关措施；	经查看，华为云数据库安全服务 DBSS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，系统配置了登录失败处理功能和网络登录连接超时自动退出功能，查看访问管理-安全设置-登录验证策略，15 分钟内登录失败 5 次，账户锁定 15 分钟，网络登录连接超时 60 分钟自动退出，但登录连接超时过长。	部分符合
	c)当进行远程管理时，应采取必要措施防止鉴别信息在网络传输过程中被窃听；	经查看，华为云数据库安全服务 DBSS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，远程管理系统采用 https 协议，使用 ECDHE-RSA-WITH-AES-128-GCM-SHA256 进行数据传输加密，鉴别信息在网络中加密传输，能够防止鉴别信息在传输过程中被窃听和篡改。	符合
	d)应采用口令、密码技术、生物技术等两种或两种以上组合的鉴别技术对用户进行身份鉴别，且其中一种鉴别技术至少应使用密码技术来实现。	经查看，华为云数据库安全服务 DBSS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，华为云管理控制台登录系统时采用用户名和	不符合

控制点	测评项	结果记录	符合情况
		口令，同时通过手机验证码进行身份鉴别，但系统未采用密码技术对用户进行身份鉴别。	
访问控制	a)应对登录的用户分配账户和权限；	经查看，华为云数据库安全服务 DBSS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，查看华为云管理控制台-统一身份认证服务-用户，系统对登录的用户分配了账户 zhangxin 系统管理员、admin_shenji 审计管理员、admin_safe 安全管理员，并为每个登录的账户分配了相应的系统管理权限。	符合
	b)应重命名或删除默认账户，修改默认账户的默认口令；	经查看，华为云数据库安全服务 DBSS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，查看华为云管理控制台-统一身份认证服务-用户，系统对登录的用户分配了账户 zhangxin 系统管理员、admin_shenji 审计管理员、admin_safe 安全管理员，系统中无默认账户，所有账户均为手动创建，口令满足复杂度要求。	符合
	c)应及时删除或停用多余的、过期的账户，避免共享账户的存在；	经查看，华为云数据库安全服务 DBSS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，系统对登录的用户分配了账户 zhangxin 系统管理员、admin_shenji 审计管理员、admin_safe 安全管理员，不存在其他多余、过期和共享账户。	符合
	d)应授予管理用户所需的最小权限，实现管理用户的权限分离；	经查看，华为云数据库安全服务 DBSS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，查看华为云管理控制台-统一身份认证服务-用	符合

控制点	测评项	结果记录	符合情况
		户，系统对登录的用户分配了账户 zhangxin 系统管理员、admin_shenji 审计管理员、admin_safe 安全管理员，实现了管理用户的权限分离和用户所需的最小化权限。	
	e)应由授权主体配置访问控制策略，访问控制策略规定主体对客体的访问规则；	经查看，华为云数据库安全服务 DBSS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，系统配置了安全管理员对访问控制策略进行配置。	符合
	f)访问控制的粒度应达到主体为用户级或进程级，客体为文件、数据库表级；	经查看，设备的访问控制粒度可达到主体为用户级，客体为功能级。	符合
	g)应对重要主体和客体设置安全标记，并控制主体对有安全标记信息资源的访问。	经查看，系统不支持基于安全标记的访问控制。	不符合
安全审计	a)应启用安全审计功能，审计覆盖到每个用户，对重要的用户行为和重要安全事件进行审计；	经查看，华为云数据库安全服务 DBSS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，华为云管理控制台开启了华为云云日志服务 LTS，审计范围覆盖所有用户，可对用户的操作行为、系统运行状态等进行审计记录。	符合
	b)审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息；	经查看，审计记录的主要内容包 括：操作时间、操作者、事件名称、资源类型、资源名称等相关信息。	符合
	c)应对审计记录进行保护，定期备份，避免受到未预期的删除、修改或覆盖等；	经查看，华为云数据库安全服务 DBSS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，华为云管理控制台通过华为云云日志服务 LTS 进行审计，当前配置策略已创建	符合

控制点	测评项	结果记录	符合情况
		跟踪列表，并通过本地网络实时保存至华为云对象存储服务 OBS 中，可查询最早日志时间为 2025.3.1-2025.9.2，日志保存时间在 6 个月以上，能够对审计记录进行收集、保存、分析，可避免受到未预期的删除、修改或覆盖等。	
	d)应对审计进程进行保护，防止未经授权的中断。	经查看，华为云数据库安全服务 DBSS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，华为云管理控制台未提供审计进程关闭功能，用户无法通过登录界面对审计进程进行关闭。	符合
入侵防范	a)应遵循最小安装的原则，仅安装需要的组件和应用程序；	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
	b)应关闭不需要的系统服务、默认共享和高危端口；	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
	c)应通过设定终端接入方式或网络地址范围对通过网络进行管理的管理终端进行限制；	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
	d)应提供数据有效性检验功能，保证通过人机接口输入或通过通信接口输入的内容符合系统设定要求；	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前设备，故此项不适用。	不适用
	e)应能发现可能存在的已知漏洞，并在经过充分测试评估后，及时修补漏洞；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
	f)应能够检测到对重要节点进行	因《信息安全技术 网络安全等	不适用

控制点	测评项	结果记录	符合情况
	入侵的行为，并在发生严重入侵事件时提供报警。	级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	
恶意代码防范	应采用免受恶意代码攻击的技术措施或主动免疫可信验证机制及时识别入侵和病毒行为，并将其有效阻断。	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
可信验证	可基于可信根对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行可信验证，并在应用程序的关键执行环节进行动态可信验证，在检测到其可信性受到破坏后进行报警，并将验证结果形成审计记录送至安全管理中心。	未采用可信计算技术对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。	不符合
数据完整性	a)应采用校验技术或密码技术保证重要数据在传输过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等；	经查看，华为云数据库安全服务 DBSS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，远程管理系统采用 https 协议，采用 ECDHE-RSA-WITH-AES-128-GCM-SHA256 进行数据传输加密，可对鉴别信息和配置数据在网络传输过程中的完整性进行校验。	符合
	b)应采用校验技术或密码技术保证重要数据在存储过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等。	经查看，系统未采用校验技术或密码技术实现鉴别数据、重要配置数据在存储过程中的完整性。	不符合
数据保密性	a)应采用密码技术保证重要数据在传输过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等；	经查看，华为云数据库安全服务 DBSS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，远程管理系统采用 https 协议，使用 ECDHE-RSA-WITH-AES-128-GCM-SHA256 进行数据传输加密，可对鉴别	符合

控制点	测评项	结果记录	符合情况
		信息和配置数据在网络传输过程中进行数据传输加密。	
	b)应采用密码技术保证重要数据在存储过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等。	经查看，系统未采用密码技术保证鉴别数据、重要配置数据在存储过程中的保密性。	不符合
数据备份恢复	a)应提供重要数据的本地数据备份与恢复功能；	经核查，系统提供了配置数据的备份功能，每次修改配置前后均对配置数据进行一次备份，备份文件保存在运维终端-1 的 D:\备份文件夹中，但未进行备份恢复性测试。	部分符合
	b)应提供异地实时备份功能，利用通信网络将重要数据实时备份至备份场地；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
	c)应提供重要数据处理系统的热冗余，保证系统的高可用性。	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
剩余信息保护	a)应保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除；	经查看，华为云数据库安全服务 DBSS 为华为云管理控制台的功能模块，并通过华为云管理控制台进行操作管理，华为云管理控制台的鉴别信息保存在本地 Cookie 中，用户关闭页面或长时间无数据请求，Cookie 自动失效，且服务器自动删除对应的 Session 信息。	符合
	b)应保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
个人信息保护	a)应仅采集和保存业务必需的用户个人信息；	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不	不适用

控制点	测评项	结果记录	符合情况
		涉及当前系统，故此项不适用。	
	b)应禁止未授权访问和非法使用用户个人信息。	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用

D.4.1.3服务器和终端

D.4.1.3.1 eCloud 相关集成服务器

控制点	测评项	结果记录	符合情况
身份鉴别	a)应对登录的用户进行身份标识和鉴别，身份标识具有唯一性，身份鉴别信息具有复杂度要求并定期更换；	经核查，Linux 系统提供了登录模块，采用用户名和口令的方式对用户进行身份鉴别；通过 <code>cat /etc/passwd</code> 查看用户列表，用户名具有唯一性，系统用户使用 <code>root</code> 进行管理，通过 <code>/etc/login.defs</code> 查看，口令策略如下：密码过期时间：90 天；最小密码长度：5 个字符；密码最短存留期：0 天；密码过期提示：7 天；通过 <code>cat /etc/security/pwquality.conf</code> 命令查看， <code>minlen = 8、lcredit=-1、ucrcedit=-1、dcredit=-1、ocredit=-1</code> ，口令最小长度为 8 位，且口令至少包含一个大写字母、一个小写字母、一个数字、一个特殊字符，已配置口令复杂度策略；系统已禁用 <code>chage</code> 命令，访谈系统管理员，管理员已每 3 个月更换一次口令。	符合
	b)应具有登录失败处理功能，应配置并启用结束会话、限制非法登录次数和当登录连接超时自动退出等相关措施；	经核查，通过查看 <code>/etc/pam.d/system-auth</code> 和 <code>/etc/pam.d/sshd</code> 配置文件， <code>auth required pam_tally2.so deny=3 unlock_time=300 even_deny_root root_unlock_time=300</code> ，账户登录失败 3 次锁定 300 秒，系统已配置登录失败处理策略；	符合

控制点	测评项	结果记录	符合情况
		通过 cat /etc/profile 命令查看，TMOUT=600，系统已配置登录连接超时 600 秒自动退出策略。	
	c)当进行远程管理时，应采取必要措施防止鉴别信息在网络传输过程中被窃听；	通过systemctl grep running 命令，查看当前正在运行的服务，系统未开启 Telnet 服务，开启了 sshd.service 服务，仅允许使用 SSH 协议进行远程管理,服务器采用 AES_128_GCM 技术进行加密，可实现鉴别信息在网络中加密传输。	符合
	d)应采用口令、密码技术、生物技术等两种或两种以上组合的鉴别技术对用户进行身份鉴别，且其中一种鉴别技术至少应使用密码技术来实现。	经查看，登录系统仅采用用户名和口令进行身份鉴别，未采用双因子认证对用户身份进行鉴别。	不符合
访问控制	a)应对登录的用户分配账户和权限；	经核查/etc/passwd 和/etc/shadow 文件，已对登录系统的用户分配了 root 等账户，并分配了相应的权限。	符合
	b)应重命名或删除默认账户，修改默认账户的默认口令；	经查看，系统采用 root 账户进行管理，未重命名默认账户，但对默认账户自行设置了口令。	部分符合
	c)应及时删除或停用多余的、过期的账户，避免共享账户的存在；	经核查/etc/shadow 文件，系统账户中不存在多余的、过期的账户，账户由专人管理，不存在共享账户。	符合
	d)应授予管理用户所需的最小权限，实现管理用户的权限分离；	经查看，系统采用 root 账户进行管理，未配置安全管理员、审计管理员等账户，未实现管理用户的权限分离。	不符合
	e)应由授权主体配置访问控制策略，访问控制策略规定主体对客体的访问规则；	经查看，系统未配置安全管理员对访问控制策略进行配置。	不符合
	f)访问控制的粒度应达到主体为	经查看，服务器访问控制粒度可	符合

控制点	测评项	结果记录	符合情况
	用户级或进程级，客体为文件、数据库表级；	达到主体为用户级，客体为文件级别。	
	g)应对重要主体和客体设置安全标记，并控制主体对有安全标记信息资源的访问。	经核查，系统未采取技术措施实现基于安全标记的强制访问控制功能。	不符合
安全审计	a)应启用安全审计功能，审计覆盖到每个用户，对重要的用户行为和重要安全事件进行审计；	通过命令 <code>service auditd status</code> 、 <code>service rsyslog status</code> 查看审计功能状态，服务器系统本身已开启了 <code>auditd</code> 服务和 <code>rsyslog</code> 服务，为用户操作和重要安全事件提供审计，审计范围覆盖到所有系统账户。	符合
	b)审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息；	查看 <code>var/logs</code> 下的审计日志文件，审计记录内容包括用户操作时间、操作进程 ID、操作内容、操作结果等信息。	符合
	c)应对审计记录进行保护，定期备份，避免受到未预期的删除、修改或覆盖等；	经核查，服务器审计日志已通过配置上传至华为云云日志服务 L TS 中，可对审计记录进行保护，能够查看 2025 年 3 月 1 日到 2025 年 9 月 2 日的审计记录，日志保存时间为 6 个月以上，可避免审计记录受到未预期的删除、修改或覆盖等。	符合
	d)应对审计进程进行保护，防止未经授权的中断。	经查看，系统启未采取措施对 <code>rsyslog</code> 进程进行保护，无法防止未经授权的中断。	不符合
入侵防范	a)应遵循最小安装的原则，仅安装需要的组件和应用程序；	经查看，操作系统为 CentOS Linux release 7.4.1708 (Core)，通过 <code>rpm -qa sort</code> 命令查看，系统实现了最小化安装，仅安装了与业务相关的组件和应用程序。	符合
	b)应关闭不需要的系统服务、默认共享和高危端口；	通过 <code>service</code> 命令和 <code>netstat -nlt</code> 命令查看，开启的服务和端口均为业务需要，通过 <code>show mount -</code>	符合

控制点	测评项	结果记录	符合情况
		e 命令查看，Linux 无共享文件。	
	c)应通过设定终端接入方式或网络地址范围对通过网络进行管理的管理终端进行限制；	查看/etc/hosts.allow 和/etc/hosts.deny 系统配置文件，服务器本地未对接入方式或远程网络访问地址进行限制，但系统仅在内部可控网络进行管理。	不符合
	d)应提供数据有效性检验功能，保证通过人机接口输入或通过通信接口输入的内容符合系统设定要求；	依据 GB/T 28448-2019 《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
	e)应能发现可能存在的已知漏洞，并在经过充分测试评估后，及时修补漏洞；	经访谈和查看，租户购买了华为云企业主机安全 HSS 企业版，华为云提供了漏洞自动检测并提供了修复方案；租户已每天对系统进行漏洞扫描并修补了漏洞。当前提供了《漏洞扫描记录》，包括时间、漏洞等情况、检测结果和检测结果分析等内容。	符合
	f)应能够检测到对重要节点进行入侵的行为，并在发生严重入侵事件时提供报警。	经核查，当前已部署华为云企业主机安全 HSS 企业版，可对服务器入侵行为进行检测，该设备入侵防御特征库版本为最新版本，更新时间为 2025-09-02，更新维护由华为云负责，能够检测到对重要节点进行入侵的行为，并通过手机短信（138****5671）的方式进行主动报警。	符合
恶意代码防范	应采用免受恶意代码攻击的技术措施或主动免疫可信验证机制及时识别入侵和病毒行为，并将其有效阻断。	经核查，当前已部署华为云企业主机安全 HSS 企业版，病毒库版本为最新版本，更新时间为 2025-09-02，更新维护由华为云负责，可及时发现入侵和病毒行为，并将其有效阻断。	符合
可信验证	可基于可信根对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行可信	未采用可信计算技术对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进	不符合

控制点	测评项	结果记录	符合情况
	验证，并在应用程序的关键执行环节进行动态可信验证，在检测到其可信性受到破坏后进行报警，并将验证结果形成审计记录送至安全管理中心。	行动态可信验证。	
数据完整性	a)应采用校验技术或密码技术保证重要数据在传输过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等；	经查看，服务器使用 SSH 协议进行加密传输，采用 hmac-sha2-256-ctm 技术，可以实现鉴别数据、重要配置数据在传输过程中的完整性。	符合
	b)应采用校验技术或密码技术保证重要数据在存储过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等。	经查看，系统未采用校验技术或密码技术实现鉴别数据、重要配置数据在存储过程中的完整性。	不符合
数据保密性	a)应采用密码技术保证重要数据在传输过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等；	经查看，服务器使用 SSH 协议进行加密传输，采用 AES_128_GCM 算法，可以实现鉴别数据、重要配置数据在传输过程中的保密性。	符合
	b)应采用密码技术保证重要数据在存储过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等。	通过 cat /etc/shadow 命令查看，服务器采用 SHA512 加盐加密技术将鉴别数据进行加密存储，实现鉴别数据在存储过程中的保密性，未采用密码技术实现配置数据在存储过程中的保密性。	部分符合
数据备份恢复	a)应提供重要数据的本地数据备份与恢复功能；	操作系统本身无需备份的业务数据和配置数据，此项不适用。	不适用
	b)应提供异地实时备份功能，利用通信网络将重要数据实时备份至备份场地；	操作系统本身无需备份的业务数据和配置数据，此项不适用。	不适用
	c)应提供重要数据处理系统的热冗余，保证系统的高可用性。	经访谈及核查，服务器为虚拟化集群部署，并配置了虚拟机资源	符合

控制点	测评项	结果记录	符合情况
		的自动分配，能够提供系统的高可用性保障。	
剩余信息保护	a)应保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除；	经查看，系统采用命令行方式进行管理，用户退出后会删除原来的用户目录，下次登录再重新生成，能够保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除。	符合
	b)应保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	经查看，系统采用命令行方式进行管理，操作生成的缓存文件关机自动删除，能够保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	符合
个人信息保护	a)应仅采集和保存业务必需的用户个人信息；	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
	b)应禁止未授权访问和非法使用用户个人信息。	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用

D.4.1.3.2 对外服务器

控制点	测评项	结果记录	符合情况
身份鉴别	a)应对登录的用户进行身份标识和鉴别，身份标识具有唯一性，身份鉴别信息具有复杂度要求并定期更换；	经核查，Linux 系统提供了登录模块，采用用户名和口令的方式对用户进行身份鉴别；通过 cat / etc/passwd 查看用户列表，用户名具有唯一性，系统用户使用 root 进行管理，通过/etc/login.defs 查看，口令策略如下：密码过期时间：90 天；最小密码长度：5 个字符；密码最短存留期：0 天；密码过期提示：7 天；通过 cat / etc/security/pwquality.conf 命令查看，minlen = 8、lcredit=-1、ucr	符合

控制点	测评项	结果记录	符合情况
		edit=-1、dcredit=-1、ocredit=-1，口令最小长度为 8 位，且口令至少包含一个大写字母、一个小写字母、一个数字、一个特殊字符，已配置口令复杂度策略；系统已禁用 chage 命令，访谈系统管理员，管理员已每 3 个月更换一次口令。	
	b)应具有登录失败处理功能，应配置并启用结束会话、限制非法登录次数和当登录连接超时自动退出等相关措施；	经核查，通过查看/etc/pam.d/system-auth 和/etc/pam.d/sshd 配置文件，auth required pam_tally2.sodeny=3 unlock_time=300 even_deny_root root_unlock_time=300，账户登录失败 3 次锁定 300 秒，系统已配置登录失败处理策略；通过 cat /etc/profile 命令查看，TMOUT=600，系统已配置登录连接超时 600 秒自动退出策略。	符合
	c)当进行远程管理时，应采取必要措施防止鉴别信息在网络传输过程中被窃听；	通过systemctl grep running 命令，查看当前正在运行的服务，系统未开启 Telnet 服务，开启了sshd.service 服务，仅允许使用SSH 协议进行远程管理,服务器采用 AES_128_GCM 技术进行加密，可实现鉴别信息在网络中加密传输。	符合
	d)应采用口令、密码技术、生物技术等两种或两种以上组合的鉴别技术对用户进行身份鉴别，且其中一种鉴别技术至少应使用密码技术来实现。	经查看，登录系统仅采用用户名和口令进行身份鉴别，未采用双因子认证对用户身份进行鉴别。	不符合
访问控制	a)应对登录的用户分配账户和权限；	经核查/etc/passwd 和/etc/shadow 文件，已对登录系统的用户分配了 root 等账户，并分配了相应的权限。	符合
	b)应重命名或删除默认账户，修改默认账户的默认口令；	经查看，系统采用 root 账户进行管理，未重命名默认账户，但对	部分符合

控制点	测评项	结果记录	符合情况
		默认账户自行设置了口令。	
	c)应及时删除或停用多余的、过期的账户，避免共享账户的存在；	经核查/etc/shadow 文件，系统账户中不存在多余的、过期的账户，账户由专人管理，不存在共享账户。	符合
	d)应授予管理用户所需的最小权限，实现管理用户的权限分离；	经查看，系统采用 root 账户进行管理，未配置安全管理员、审计管理员等账户，未实现管理用户的权限分离。	不符合
	e)应由授权主体配置访问控制策略，访问控制策略规定主体对客体的访问规则；	经查看，系统未配置安全管理员对访问控制策略进行配置。	不符合
	f)访问控制的粒度应达到主体为用户级或进程级，客体为文件、数据库表级；	经查看，服务器访问控制粒度可达到主体为用户级，客体为文件级别。	符合
	g)应对重要主体和客体设置安全标记，并控制主体对有安全标记信息资源的访问。	经核查，系统未采取技术措施实现基于安全标记的强制访问控制功能。	不符合
安全审计	a)应启用安全审计功能，审计覆盖到每个用户，对重要的用户行为和重要安全事件进行审计；	通过命令 service auditd status、service rsyslog status 查看审计功能状态，服务器系统本身已开启了 auditd 服务和 rsyslog 服务，为用户操作和重要安全事件提供审计，审计范围覆盖到所有系统账户。	符合
	b)审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息；	查看 var/logs 下的审计日志文件，审计记录内容包括用户操作时间、操作进程 ID、操作内容、操作结果等信息。	符合
	c)应对审计记录进行保护，定期备份，避免受到未预期的删除、修改或覆盖等；	经核查，服务器审计日志已通过配置上传至华为云云日志服务 LTS 中，可对审计记录进行保护，能够查看 2025 年 3 月 1 日到 2025 年 9 月 2 日的审计记录，日志保存时间为 6 个月以上，可避免	符合

控制点	测评项	结果记录	符合情况
		审计记录受到未预期的删除、修改或覆盖等。	
	d)应对审计进程进行保护,防止未经授权的中断。	经查看,系统启未采取措施对 rsyslog 进程进行保护,无法防止未经授权的中断。	不符合
入侵防范	a)应遵循最小安装的原则,仅安装需要的组件和应用程序;	经查看,操作系统为 CentOS Linux release 7.4.1708 (Core),通过 rpm -qa sort 命令查看,系统实现了最小化安装,仅安装了与业务相关的组件和应用程序。	符合
	b)应关闭不需要的系统服务、默认共享和高危端口;	通过 service 命令和 netstat -nltp 命令查看,开启的服务和端口均为业务需要,通过 show mount -e 命令查看,Linux 无共享文件。	符合
	c)应通过设定终端接入方式或网络地址范围对通过网络进行管理的管理终端进行限制;	查看/etc/hosts.allow 和/etc/hosts.deny 系统配置文件,服务器本地未对接入方式或远程网络访问地址进行限制,但系统仅在内部可控网络进行管理。	不符合
	d)应提供数据有效性检验功能,保证通过人机接口输入或通过通信接口输入的内容符合系统设定要求;	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》,该项的测评对象选择不涉及当前对象,故此项目不适用。	不适用
	e)应能发现可能存在的已知漏洞,并在经过充分测试评估后,及时修补漏洞;	经访谈和查看,租户购买了华为云企业主机安全 HSS 企业版,华为云提供了漏洞自动检测并提供了修复方案;租户已每天对系统进行漏洞扫描并修补了漏洞。当前提供了《漏洞扫描记录》,包括时间、漏洞等情况、检测结果和检测结果分析等内容。	符合
	f)应能够检测到对重要节点进行入侵的行为,并在发生严重入侵事件时提供报警。	经核查,当前已部署华为云企业主机安全 HSS 企业版,可对服务器入侵行为进行检测,该设备入侵防御特征库版本为最新版本,	符合

控制点	测评项	结果记录	符合情况
		更新时间为 2025-09-02，更新维护由华为云负责，能够检测到对重要节点进行入侵的行为，并通过手机短信（138****5671）的方式进行主动报警。	
恶意代码防范	应采用免受恶意代码攻击的技术措施或主动免疫可信验证机制及时识别入侵和病毒行为，并将其有效阻断。	经核查，当前已部署华为云企业主机安全 HSS 企业版，病毒库版本为最新版本，更新时间为 2025-09-02，更新维护由华为云负责，可及时发现入侵和病毒行为，并将其有效阻断。	符合
可信验证	可基于可信根对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行可信验证，并在应用程序的关键执行环节进行动态可信验证，在检测到其可信性受到破坏后进行报警，并将验证结果形成审计记录送至安全管理中心。	未采用可信计算技术对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。	不符合
数据完整性	a)应采用校验技术或密码技术保证重要数据在传输过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等；	经查看，服务器使用 SSH 协议进行加密传输，采用 hmac-sha2-256-ctm 技术，可以实现鉴别数据、重要配置数据在传输过程中的完整性。	符合
	b)应采用校验技术或密码技术保证重要数据在存储过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等。	经查看，系统未采用校验技术或密码技术实现鉴别数据、重要配置数据在存储过程中的完整性。	不符合
数据保密性	a)应采用密码技术保证重要数据在传输过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等；	经查看，服务器使用 SSH 协议进行加密传输，采用 AES_128_GCM 算法，可以实现鉴别数据、重要配置数据在传输过程中的保密性。	符合

控制点	测评项	结果记录	符合情况
	b)应采用密码技术保证重要数据在存储过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等。	通过 cat /etc/shadow 命令查看，服务器采用 SHA512 加盐加密技术将鉴别数据进行加密存储，实现鉴别数据在存储过程中的保密性，未采用密码技术实现配置数据在存储过程中的保密性。	部分符合
数据备份恢复	a)应提供重要数据的本地数据备份与恢复功能；	操作系统本身无需备份的业务数据和配置数据，此项不适用。	不适用
	b)应提供异地实时备份功能，利用通信网络将重要数据实时备份至备份场地；	操作系统本身无需备份的业务数据和配置数据，此项不适用。	不适用
	c)应提供重要数据处理系统的热冗余，保证系统的高可用性。	经访谈及核查，服务器为虚拟化集群部署，并配置了虚拟机资源的自动分配，能够提供系统的高可用性保障。	符合
剩余信息保护	a)应保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除；	经查看，系统采用命令行方式进行管理，用户退出后会删除原来的用户目录，下次登录再重新生成，能够保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除。	符合
	b)应保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	经查看，系统采用命令行方式进行管理，操作生成的缓存文件关机自动删除，能够保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	符合
个人信息保护	a)应仅采集和保存业务必需的用户个人信息；	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
	b)应禁止未授权访问和非法使用用户个人信息。	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用

D.4.1.3.3 竞价与产权服务器

控制点	测评项	结果记录	符合情况
身份鉴别	a)应对登录的用户进行身份标识和鉴别，身份标识具有唯一性，身份鉴别信息具有复杂度要求并定期更换；	经核查，Linux 系统提供了登录模块，采用用户名和口令的方式对用户进行身份鉴别；通过 cat / etc/passwd 查看用户列表，用户名具有唯一性，系统用户使用 root 进行管理，通过/etc/login.defs 查看，口令策略如下：密码过期时间：90 天；最小密码长度：5 个字符；密码最短存留期：0 天；密码过期提示：7 天；通过 cat / etc/security/pwquality.conf 命令查看，minlen = 8、lcredit=-1、ucrcedit=-1、dcredit=-1、ocredit=-1，口令最小长度为 8 位，且口令至少包含一个大写字母、一个小写字母、一个数字、一个特殊字符，已配置口令复杂度策略；系统已禁用 chage 命令，访谈系统管理员，管理员已每 3 个月更换一次口令。	符合
	b)应具有登录失败处理功能，应配置并启用结束会话、限制非法登录次数和当登录连接超时自动退出等相关措施；	经核查，通过查看/etc/pam.d/system-auth 和/etc/pam.d/sshd 配置文件，auth required pam_tally2.soden deny=3 unlock_time=300 even_deny_root root_unlock_time=300，账户登录失败 3 次锁定 300 秒，系统已配置登录失败处理策略；通过 cat /etc/profile 命令查看，TMOUT=600，系统已配置登录连接超时 600 秒自动退出策略。	符合
	c)当进行远程管理时，应采取必要措施防止鉴别信息在网络传输过程中被窃听；	通过systemctl grep running 命令，查看当前正在运行的服务，系统未开启 Telnet 服务，开启了 sshd.service 服务，仅允许使用 SSH 协议进行远程管理,服务器采用 AES_128_GCM 技术进行加密，可实现鉴别信息在网络中加密传输。	符合

控制点	测评项	结果记录	符合情况
	d)应采用口令、密码技术、生物技术等两种或两种以上组合的鉴别技术对用户进行身份鉴别,且其中一种鉴别技术至少应使用密码技术来实现。	经查看,登录系统仅采用用户名和口令进行身份鉴别,未采用双因子认证对用户身份进行鉴别。	不符合
访问控制	a)应对登录的用户分配账户和权限;	经核查/etc/passwd 和/etc/shadow 文件,已对登录系统的用户分配了 root 等账户,并分配了相应的权限。	符合
	b)应重命名或删除默认账户,修改默认账户的默认口令;	经查看,系统采用 root 账户进行管理,未重命名默认账户,但对默认账户自行设置了口令。	部分符合
	c)应及时删除或停用多余的、过期的账户,避免共享账户的存在;	经核查/etc/shadow 文件,系统账户中不存在多余的、过期的账户,账户由专人管理,不存在共享账户。	符合
	d)应授予管理用户所需的最小权限,实现管理用户的权限分离;	经查看,系统采用 root 账户进行管理,未配置安全管理员、审计管理员等账户,未实现管理用户的权限分离。	不符合
	e)应由授权主体配置访问控制策略,访问控制策略规定主体对客体的访问规则;	经查看,系统未配置安全管理员对访问控制策略进行配置。	不符合
	f)访问控制的粒度应达到主体为用户级或进程级,客体为文件、数据库表级;	经查看,服务器访问控制粒度可达到主体为用户级,客体为文件级别。	符合
	g)应对重要主体和客体设置安全标记,并控制主体对有安全标记信息资源的访问。	经核查,系统未采取技术措施实现基于安全标记的强制访问控制功能。	不符合
安全审计	a)应启用安全审计功能,审计覆盖到每个用户,对重要的用户行为和重要安全事件进行审计;	通过命令 service auditd status、service rsyslog status 查看审计功能状态,服务器系统本身已开启了 auditd 服务和 rsyslog 服务,为用户操作和重要安全事件提供审计,审计范围覆盖到所有系	符合

控制点	测评项	结果记录	符合情况
		统账户。	
	b)审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息；	查看 var/logs 下的审计日志文件，审计记录内容包括用户操作时间、操作进程 ID、操作内容、操作结果等信息。	符合
	c)应对审计记录进行保护，定期备份，避免受到未预期的删除、修改或覆盖等；	经核查，服务器审计日志已通过配置上传至华为云云日志服务 LTS 中，可对审计记录进行保护，能够查看 2025 年 3 月 1 日到 2025 年 9 月 2 日的审计记录，日志保存时间为 6 个月以上，可避免审计记录受到未预期的删除、修改或覆盖等。	符合
	d)应对审计进程进行保护，防止未经授权的中断。	经查看，系统启未采取措施对 rsyslog 进程进行保护，无法防止未经授权的中断。	不符合
入侵防范	a)应遵循最小安装的原则，仅安装需要的组件和应用程序；	经查看，操作系统为 CentOS Linux release 7.4.1708 (Core)，通过 rpm -qa sort 命令查看，系统实现了最小化安装，仅安装了与业务相关的组件和应用程序。	符合
	b)应关闭不需要的系统服务、默认共享和高危端口；	通过 service 命令和 netstat -nltp 命令查看，开启的服务和端口均为业务需要，通过 show mount -e 命令查看，Linux 无共享文件。	符合
	c)应通过设定终端接入方式或网络地址范围对通过网络进行管理的管理终端进行限制；	查看/etc/hosts.allow 和/etc/hosts.deny 系统配置文件，服务器本地未对接入方式或远程网络访问地址进行限制，但系统仅在内部可控网络进行管理。	不符合
	d)应提供数据有效性检验功能，保证通过人机接口输入或通过通信接口输入的内容符合系统设定要求；	依据 GB/T 28448-2019 《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
	e)应能发现可能存在的已知漏	经访谈和查看，租户购买了华为	符合

控制点	测评项	结果记录	符合情况
	洞，并在经过充分测试评估后，及时修补漏洞；	云企业主机安全 HSS 企业版，华为云提供了漏洞自动检测并提供了修复方案；租户已每天对系统进行漏洞扫描并修补了漏洞。当前提供了《漏洞扫描记录》，包括时间、漏洞等情况、检测结果和检测结果分析等内容。	
	f)应能够检测到对重要节点进行入侵的行为，并在发生严重入侵事件时提供报警。	经核查，当前已部署华为云企业主机安全 HSS 企业版，可对服务器入侵行为进行检测，该设备入侵防御特征库版本为最新版本，更新时间为 2025-09-02，更新维护由华为云负责，能够检测到对重要节点进行入侵的行为，并通过手机短信（138****5671）的方式进行主动报警。	符合
恶意代码防范	应采用免受恶意代码攻击的技术措施或主动免疫可信验证机制及时识别入侵和病毒行为，并将其有效阻断。	经核查，当前已部署华为云企业主机安全 HSS 企业版，病毒库版本为最新版本，更新时间为 2025-09-02，更新维护由华为云负责，可及时发现入侵和病毒行为，并将其有效阻断。	符合
可信验证	可基于可信根对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行可信验证，并在应用程序的关键执行环节进行动态可信验证，在检测到其可信性受到破坏后进行报警，并将验证结果形成审计记录送至安全管理中心。	未采用可信计算技术对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。	不符合
数据完整性	a)应采用校验技术或密码技术保证重要数据在传输过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等；	经查看，服务器使用 SSH 协议进行加密传输，采用 hmac-sha2-256-etm 技术，可以实现鉴别数据、重要配置数据在传输过程中的完整性。	符合
	b)应采用校验技术或密码技术保	经查看，系统未采用校验技术或	不符合

控制点	测评项	结果记录	符合情况
	证重要数据在存储过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等。	密码技术实现鉴别数据、重要配置数据在存储过程中的完整性。	
数据保密性	a)应采用密码技术保证重要数据在传输过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等；	经查看，服务器使用 SSH 协议进行加密传输，采用 AES_128_GCM 算法，可以实现鉴别数据、重要配置数据在传输过程中的保密性。	符合
	b)应采用密码技术保证重要数据在存储过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等。	通过 cat /etc/shadow 命令查看，服务器采用 SHA512 加盐加密技术将鉴别数据进行加密存储，实现鉴别数据在存储过程中的保密性，未采用密码技术实现配置数据在存储过程中的保密性。	部分符合
数据备份恢复	a)应提供重要数据的本地数据备份与恢复功能；	操作系统本身无需备份的业务数据和配置数据，此项不适用。	不适用
	b)应提供异地实时备份功能，利用通信网络将重要数据实时备份至备份场地；	操作系统本身无需备份的业务数据和配置数据，此项不适用。	不适用
	c)应提供重要数据处理系统的热冗余，保证系统的高可用性。	经访谈及核查，服务器为虚拟化集群部署，并配置了虚拟机资源的自动分配，能够提供系统的高可用性保障。	符合
剩余信息保护	a)应保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除；	经查看，系统采用命令行方式进行管理，用户退出后会删除原来的用户目录，下次登录再重新生成，能够保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除。	符合
	b)应保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	经查看，系统采用命令行方式进行管理，操作生成的缓存文件关机自动删除，能够保证存有敏感数据的存储空间被释放或重新	符合

控制点	测评项	结果记录	符合情况
		分配前得到完全清除。	
个人信息保护	a)应仅采集和保存业务必需的用户个人信息；	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
	b)应禁止未授权访问和非法使用用户个人信息。	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用

D.4.1.3.4 数据库服务器

控制点	测评项	结果记录	符合情况
身份鉴别	a)应对登录的用户进行身份标识和鉴别，身份标识具有唯一性，身份鉴别信息具有复杂度要求并定期更换；	经核查，Linux 系统提供了登录模块，采用用户名和口令的方式对用户进行身份鉴别；通过 cat /etc/passwd 查看用户列表，用户名具有唯一性，系统用户使用 root 进行管理，通过/etc/login.defs 查看，口令策略如下：密码过期时间：90 天；最小密码长度：5 个字符；密码最短存留期：0 天；密码过期提示：7 天；通过 cat /etc/security/pwquality.conf 命令查看，minlen = 8、lcredit=-1、ucrcedit=-1、dcredit=-1、ocredit=-1，口令最小长度为 8 位，且口令至少包含一个大写字母、一个小写字母、一个数字、一个特殊字符，已配置口令复杂度策略；系统已禁用 chage 命令，访谈系统管理员，管理员已每 3 个月更换一次口令。	符合
	b)应具有登录失败处理功能，应配置并启用结束会话、限制非法登录次数和当登录连接超时自动退出等相关措施；	经核查，通过查看/etc/pam.d/system-auth 和/etc/pam.d/sshd 配置文件，auth required pam_tally2.sodeny=3 unlock_time=300 even_d	符合

控制点	测评项	结果记录	符合情况
		eny_root root_unlock_time=300, 账户登录失败 3 次锁定 300 秒, 系统已配置登录失败处理策略; 通过 cat /etc/profile 命令查看, TMOUT=600, 系统已配置登录连接超时 600 秒自动退出策略。	
	c)当进行远程管理时,应采取必要措施防止鉴别信息在网络传输过程中被窃听;	通过systemctl grep running 命令,查看当前正在运行的服务,系统未开启 Telnet 服务,开启了 sshd.service 服务,仅允许使用 SSH 协议进行远程管理,服务器采用 AES_128_GCM 技术进行加密,可实现鉴别信息在网络中加密传输。	符合
	d)应采用口令、密码技术、生物技术等两种或两种以上组合的鉴别技术对用户进行身份鉴别,且其中一种鉴别技术至少应使用密码技术来实现。	经查看,登录系统仅采用用户名和口令进行身份鉴别,未采用双因子认证对用户身份进行鉴别。	不符合
访问控制	a)应对登录的用户分配账户和权限;	经核查/etc/passwd 和/etc/shadow 文件,已对登录系统的用户分配了 root 等账户,并分配了相应的权限。	符合
	b)应重命名或删除默认账户,修改默认账户的默认口令;	经查看,系统采用 root 账户进行管理,未重命名默认账户,但对默认账户自行设置了口令。	部分符合
	c)应及时删除或停用多余的、过期的账户,避免共享账户的存在;	经核查/etc/shadow 文件,系统账户中不存在多余的、过期的账户,账户由专人管理,不存在共享账户。	符合
	d)应授予管理用户所需的最小权限,实现管理用户的权限分离;	经查看,系统采用 root 账户进行管理,未配置安全管理员、审计管理员等账户,未实现管理用户的权限分离。	不符合
	e)应由授权主体配置访问控制策	经查看,系统未配置安全管理员	不符合

控制点	测评项	结果记录	符合情况
	略，访问控制策略规定主体对客体的访问规则；	对访问控制策略进行配置。	
	f)访问控制的粒度应达到主体为用户级或进程级，客体为文件、数据库表级；	经查看，服务器访问控制粒度可达到主体为用户级，客体为文件级别。	符合
	g)应对重要主体和客体设置安全标记，并控制主体对有安全标记信息资源的访问。	经核查，系统未采取技术措施实现基于安全标记的强制访问控制功能。	不符合
安全审计	a)应启用安全审计功能，审计覆盖到每个用户，对重要的用户行为和重要安全事件进行审计；	通过命令 <code>service auditd status</code> 、 <code>service rsyslog status</code> 查看审计功能状态，服务器系统本身已开启了 <code>auditd</code> 服务和 <code>rsyslog</code> 服务，为用户操作和重要安全事件提供审计，审计范围覆盖到所有系统账户。	符合
	b)审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息；	查看 <code>var/logs</code> 下的审计日志文件，审计记录内容包括用户操作时间、操作进程 ID、操作内容、操作结果等信息。	符合
	c)应对审计记录进行保护，定期备份，避免受到未预期的删除、修改或覆盖等；	经核查，服务器审计日志已通过配置上传至华为云云日志服务 L TS 中，可对审计记录进行保护，能够查看 2025 年 3 月 1 日到 2025 年 9 月 2 日的审计记录，日志保存时间为 6 个月以上，可避免审计记录受到未预期的删除、修改或覆盖等。	符合
	d)应对审计进程进行保护，防止未经授权的中断。	经查看，系统启未采取措施对 <code>rsyslog</code> 进程进行保护，无法防止未经授权的中断。	不符合
入侵防范	a)应遵循最小安装的原则，仅安装需要的组件和应用程序；	经查看，操作系统为 CentOS Linux release 7.4.1708 (Core)，通过 <code>rpm -qa sort</code> 命令查看，系统实现了最小化安装，仅安装了与业务相关的组件和应用程序。	符合

控制点	测评项	结果记录	符合情况
	b)应关闭不需要的系统服务、默认共享和高危端口；	通过 service 命令和 netstat -nltp 命令查看，开启的服务和端口均为业务需要，通过 show mount -e 命令查看，Linux 无共享文件。	符合
	c)应通过设定终端接入方式或网络地址范围对通过网络进行管理的管理终端进行限制；	查看/etc/hosts.allow 和/etc/hosts.deny 系统配置文件，服务器本地未对接入方式或远程网络访问地址进行限制，但系统仅在内部可控网络进行管理。	不符合
	d)应提供数据有效性检验功能，保证通过人机接口输入或通过通信接口输入的内容符合系统设定要求；	依据 GB/T 28448-2019 《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
	e)应能发现可能存在的已知漏洞，并在经过充分测试评估后，及时修补漏洞；	经访谈和查看，租户购买了华为云企业主机安全 HSS 企业版，华为云提供了漏洞自动检测并提供了修复方案；租户已每天对系统进行漏洞扫描并修补了漏洞。当前提供了《漏洞扫描记录》，包括时间、漏洞等情况、检测结果和检测结果分析等内容。	符合
	f)应能够检测到对重要节点进行入侵的行为，并在发生严重入侵事件时提供报警。	经核查，当前已部署华为云企业主机安全 HSS 企业版，可对服务器入侵行为进行检测，该设备入侵防御特征库版本为最新版本，更新时间为 2025-09-02，更新维护由华为云负责，能够检测到对重要节点进行入侵的行为，并通过手机短信（138****5671）的方式进行主动报警。	符合
恶意代码防范	应采用免受恶意代码攻击的技术措施或主动免疫可信验证机制及时识别入侵和病毒行为，并将其有效阻断。	经核查，当前已部署华为云企业主机安全 HSS 企业版，病毒库版本为最新版本，更新时间为 2025-09-02，更新维护由华为云负责，可及时发现入侵和病毒行为，并将其有效阻断。	符合

控制点	测评项	结果记录	符合情况
可信验证	可基于可信根对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行可信验证，并在应用程序的关键执行环节进行动态可信验证，在检测到其可信性受到破坏后进行报警，并将验证结果形成审计记录送至安全管理中心。	未采用可信计算技术对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。	不符合
数据完整性	a)应采用校验技术或密码技术保证重要数据在传输过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等；	经查看，服务器使用 SSH 协议进行加密传输，采用 hmac-sha2-256-ctm 技术，可以实现鉴别数据、重要配置数据在传输过程中的完整性。	符合
	b)应采用校验技术或密码技术保证重要数据在存储过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等。	经查看，系统未采用校验技术或密码技术实现鉴别数据、重要配置数据在存储过程中的完整性。	不符合
数据保密性	a)应采用密码技术保证重要数据在传输过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等；	经查看，服务器使用 SSH 协议进行加密传输，采用 AES_128_GCM 算法，可以实现鉴别数据、重要配置数据在传输过程中的保密性。	符合
	b)应采用密码技术保证重要数据在存储过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等。	通过 cat /etc/shadow 命令查看，服务器采用 SHA512 加盐加密技术将鉴别数据进行加密存储，实现鉴别数据在存储过程中的保密性，未采用密码技术实现配置数据在存储过程中的保密性。	部分符合
数据备份恢复	a)应提供重要数据的本地数据备份与恢复功能；	操作系统本身无需备份的业务数据和配置数据，此项不适用。	不适用
	b)应提供异地实时备份功能，利用通信网络将重要数据实时备份至备份场地；	操作系统本身无需备份的业务数据和配置数据，此项不适用。	不适用

控制点	测评项	结果记录	符合情况
	c)应提供重要数据处理系统的热冗余，保证系统的高可用性。	经访谈及核查，服务器为虚拟化集群部署，并配置了虚拟机资源的自动分配，能够提供系统的高可用性保障。	符合
剩余信息保护	a)应保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除；	经查看，系统采用命令行方式进行管理，用户退出后会删除原来的用户目录，下次登录再重新生成，能够保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除。	符合
	b)应保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	经查看，系统采用命令行方式进行管理，操作生成的缓存文件关机自动删除，能够保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	符合
个人信息保护	a)应仅采集和保存业务必需的用户个人信息；	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
	b)应禁止未授权访问和非法使用用户个人信息。	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用

D.4.1.3.5 业务框架支撑服务器

控制点	测评项	结果记录	符合情况
身份鉴别	a)应对登录的用户进行身份标识和鉴别，身份标识具有唯一性，身份鉴别信息具有复杂度要求并定期更换；	经核查，Linux 系统提供了登录模块，采用用户名和口令的方式对用户进行身份鉴别；通过 cat /etc/passwd 查看用户列表，用户名具有唯一性，系统用户使用 ro ot 进行管理，通过/etc/login.defs 查看，口令策略如下：密码过期时间：90 天；最小密码长度：5 个字符；密码最短存留期：0 天；密码过期提示：7 天；通过 cat /	符合

控制点	测评项	结果记录	符合情况
		etc/security/pwquality.conf 命令查看，minlen = 8、lcredit=-1、ucrcedit=-1、dcredit=-1、ocredit=-1，口令最小长度为 8 位，且口令至少包含一个大写字母、一个小写字母、一个数字、一个特殊字符，已配置口令复杂度策略；系统已禁用 chage 命令，访谈系统管理员，管理员已每 3 个月更换一次口令。	
	b)应具有登录失败处理功能，应配置并启用结束会话、限制非法登录次数和当登录连接超时自动退出等相关措施；	经核查，通过查看/etc/pam.d/system-auth 和/etc/pam.d/sshd 配置文件，auth required pam_tally2.sodeny=3 unlock_time=300 even_deny_root root_unlock_time=300，账户登录失败 3 次锁定 300 秒，系统已配置登录失败处理策略；通过 cat /etc/profile 命令查看，TMOUT=600，系统已配置登录连接超时 600 秒自动退出策略。	符合
	c)当进行远程管理时，应采取必要措施防止鉴别信息在网络传输过程中被窃听；	通过systemctl grep running 命令，查看当前正在运行的服务，系统未开启 Telnet 服务，开启了sshd.service 服务，仅允许使用SSH 协议进行远程管理,服务器采用 AES_128_GCM 技术进行加密，可实现鉴别信息在网络中加密传输。	符合
	d)应采用口令、密码技术、生物技术等两种或两种以上组合的鉴别技术对用户进行身份鉴别，且其中一种鉴别技术至少应使用密码技术来实现。	经查看，登录系统仅采用用户名和口令进行身份鉴别，未采用双因子认证对用户身份进行鉴别。	不符合
访问控制	a)应对登录的用户分配账户和权限；	经核查/etc/passwd 和/etc/shadow 文件，已对登录系统的用户分配了 root 等账户，并分配了相应的权限。	符合

控制点	测评项	结果记录	符合情况
	b)应重命名或删除默认账户，修改默认账户的默认口令；	经查看，系统采用 root 账户进行管理，未重命名默认账户，但对默认账户自行设置了口令。	部分符合
	c)应及时删除或停用多余的、过期的账户，避免共享账户的存在；	经核查/etc/shadow 文件，系统账户中不存在多余的、过期的账户，账户由专人管理，不存在共享账户。	符合
	d)应授予管理用户所需的最小权限，实现管理用户的权限分离；	经查看，系统采用 root 账户进行管理，未配置安全管理员、审计管理员等账户，未实现管理用户的权限分离。	不符合
	e)应由授权主体配置访问控制策略，访问控制策略规定主体对客体的访问规则；	经查看，系统未配置安全管理员对访问控制策略进行配置。	不符合
	f)访问控制的粒度应达到主体为用户级或进程级，客体为文件、数据库表级；	经查看，服务器访问控制粒度可达到主体为用户级，客体为文件级别。	符合
	g)应对重要主体和客体设置安全标记，并控制主体对有安全标记信息资源的访问。	经核查，系统未采取技术措施实现基于安全标记的强制访问控制功能。	不符合
安全审计	a)应启用安全审计功能，审计覆盖到每个用户，对重要的用户行为和重要安全事件进行审计；	通过命令 service auditd status、service rsyslog status 查看审计功能状态，服务器系统本身已开启了 auditd 服务和 rsyslog 服务，为用户操作和重要安全事件提供审计，审计范围覆盖到所有系统账户。	符合
	b)审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息；	查看 var/logs 下的审计日志文件，审计记录内容包括用户操作时间、操作进程 ID、操作内容、操作结果等信息。	符合
	c)应对审计记录进行保护，定期备份，避免受到未预期的删除、修改或覆盖等；	经核查，服务器审计日志已通过配置上传至华为云云日志服务 L TS 中，可对审计记录进行保护，能够查看 2025 年 3 月 1 日到 20	符合

控制点	测评项	结果记录	符合情况
		25 年 9 月 2 日的审计记录，日志保存时间为 6 个月以上，可避免审计记录受到未预期的删除、修改或覆盖等。	
	d)应对审计进程进行保护，防止未经授权的中断。	经查看，系统启未采取措施对 rsyslog 进程进行保护，无法防止未经授权的中断。	不符合
入侵防范	a)应遵循最小安装的原则，仅安装需要的组件和应用程序；	经查看，操作系统为 CentOS Linux release 7.4.1708 (Core)，通过 rpm -qa sort 命令查看，系统实现了最小化安装，仅安装了与业务相关的组件和应用程序。	符合
	b)应关闭不需要的系统服务、默认共享和高危端口；	通过 service 命令和 netstat -nltp 命令查看，开启的服务和端口均为业务需要，通过 show mount -e 命令查看，Linux 无共享文件。	符合
	c)应通过设定终端接入方式或网络地址范围对通过网络进行管理的管理终端进行限制；	查看/etc/hosts.allow 和/etc/hosts.deny 系统配置文件，服务器本地未对接入方式或远程网络访问地址进行限制，但系统仅在内部可控网络进行管理。	不符合
	d)应提供数据有效性检验功能，保证通过人机接口输入或通过通信接口输入的内容符合系统设定要求；	依据 GB/T 28448-2019 《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
	e)应能发现可能存在的已知漏洞，并在经过充分测试评估后，及时修补漏洞；	经访谈和查看，租户购买了华为云企业主机安全 HSS 企业版，华为云提供了漏洞自动检测并提供了修复方案；租户已每天对系统进行漏洞扫描并修补了漏洞。当前提供了《漏洞扫描记录》，包括时间、漏洞等情况、检测结果和检测结果分析等内容。	符合
	f)应能够检测到对重要节点进行入侵的行为，并在发生严重入侵	经核查，当前已部署华为云企业主机安全 HSS 企业版，可对服务	符合

控制点	测评项	结果记录	符合情况
	事件时提供报警。	器入侵行为进行检测，该设备入侵防御特征库版本为最新版本，更新时间为 2025-09-02，更新维护由华为云负责，能够检测到对重要节点进行入侵的行为，并通过手机短信（138****5671）的方式进行主动报警。	
恶意代码防范	应采用免受恶意代码攻击的技术措施或主动免疫可信验证机制及时识别入侵和病毒行为，并将其有效阻断。	经核查，当前已部署华为云企业主机安全 HSS 企业版，病毒库版本为最新版本，更新时间为 2025-09-02，更新维护由华为云负责，可及时发现入侵和病毒行为，并将其有效阻断。	符合
可信验证	可基于可信根对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行可信验证，并在应用程序的关键执行环节进行动态可信验证，在检测到其可信性受到破坏后进行报警，并将验证结果形成审计记录送至安全管理中心。	未采用可信计算技术对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。	不符合
数据完整性	a)应采用校验技术或密码技术保证重要数据在传输过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等；	经查看，服务器使用 SSH 协议进行加密传输，采用 hmac-sha2-256-etm 技术，可以实现鉴别数据、重要配置数据在传输过程中的完整性。	符合
	b)应采用校验技术或密码技术保证重要数据在存储过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等。	经查看，系统未采用校验技术或密码技术实现鉴别数据、重要配置数据在存储过程中的完整性。	不符合
数据保密性	a)应采用密码技术保证重要数据在传输过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等；	经查看，服务器使用 SSH 协议进行加密传输，采用 AES_128_GCM 算法，可以实现鉴别数据、重要配置数据在传输过程中的保	符合

控制点	测评项	结果记录	符合情况
		密性。	
	b)应采用密码技术保证重要数据在存储过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等。	通过 cat /etc/shadow 命令查看，服务器采用 SHA512 加盐加密技术将鉴别数据进行加密存储，实现鉴别数据在存储过程中的保密性，未采用密码技术实现配置数据在存储过程中的保密性。	部分符合
数据备份恢复	a)应提供重要数据的本地数据备份与恢复功能；	操作系统本身无需备份的业务数据和配置数据，此项不适用。	不适用
	b)应提供异地实时备份功能，利用通信网络将重要数据实时备份至备份场地；	操作系统本身无需备份的业务数据和配置数据，此项不适用。	不适用
	c)应提供重要数据处理系统的热冗余，保证系统的高可用性。	经访谈及核查，服务器为虚拟化集群部署，并配置了虚拟机资源的自动分配，能够提供系统的高可用性保障。	符合
剩余信息保护	a)应保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除；	经查看，系统采用命令行方式进行管理，用户退出后会删除原来的用户目录，下次登录再重新生成，能够保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除。	符合
	b)应保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	经查看，系统采用命令行方式进行管理，操作生成的缓存文件关机自动删除，能够保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	符合
个人信息保护	a)应仅采集和保存业务必需的用户个人信息；	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
	b)应禁止未授权访问和非法使用用户个人信息。	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用

D.4.1.3.6 电子交易部署服务器

控制点	测评项	结果记录	符合情况
身份鉴别	a)应对登录的用户进行身份标识和鉴别，身份标识具有唯一性，身份鉴别信息具有复杂度要求并定期更换；	经核查，Linux 系统提供了登录模块，采用用户名和口令的方式对用户进行身份鉴别；通过 cat /etc/passwd 查看用户列表，用户名具有唯一性，系统用户使用 root 进行管理，通过/etc/login.defs 查看，口令策略如下：密码过期时间：90 天；最小密码长度：5 个字符；密码最短存留期：0 天；密码过期提示：7 天；通过 cat /etc/security/pwquality.conf 命令查看，minlen = 8、lcredit=-1、ucrcedit=-1、dcredit=-1、ocredit=-1，口令最小长度为 8 位，且口令至少包含一个大写字母、一个小写字母、一个数字、一个特殊字符，已配置口令复杂度策略；系统已禁用 chage 命令，访谈系统管理员，管理员已每 3 个月更换一次口令。	符合
	b)应具有登录失败处理功能，应配置并启用结束会话、限制非法登录次数和当登录连接超时自动退出等相关措施；	经核查，通过查看/etc/pam.d/system-auth 和/etc/pam.d/sshd 配置文件，auth required pam_tally2.sodeny=3 unlock_time=300 even_denyn_root root_unlock_time=300，账户登录失败 3 次锁定 300 秒，系统已配置登录失败处理策略；通过 cat /etc/profile 命令查看，TMOUT=600，系统已配置登录连接超时 600 秒自动退出策略。	符合
	c)当进行远程管理时，应采取必要措施防止鉴别信息在网络传输过程中被窃听；	通过systemctl grep running 命令，查看当前正在运行的服务，系统未开启 Telnet 服务，开启了sshd.service 服务，仅允许使用SSH 协议进行远程管理,服务器采用 AES_128_GCM 技术进行加	符合

控制点	测评项	结果记录	符合情况
		密, 可实现鉴别信息在网络中加密传输。	
	d)应采用口令、密码技术、生物技术等两种或两种以上组合的鉴别技术对用户进行身份鉴别, 且其中一种鉴别技术至少应使用密码技术来实现。	经查看, 登录系统仅采用用户名和口令进行身份鉴别, 未采用双因子认证对用户身份进行鉴别。	不符合
访问控制	a)应对登录的用户分配账户和权限;	经核查/etc/passwd 和/etc/shadow 文件, 已对登录系统的用户分配了 root 等账户, 并分配了相应的权限。	符合
	b)应重命名或删除默认账户, 修改默认账户的默认口令;	经查看, 系统采用 root 账户进行管理, 未重命名默认账户, 但对默认账户自行设置了口令。	部分符合
	c)应及时删除或停用多余的、过期的账户, 避免共享账户的存在;	经核查/etc/shadow 文件, 系统账户中不存在多余的、过期的账户, 账户由专人管理, 不存在共享账户。	符合
	d)应授予管理用户所需的最小权限, 实现管理用户的权限分离;	经查看, 系统采用 root 账户进行管理, 未配置安全管理员、审计管理员等账户, 未实现管理用户的权限分离。	不符合
	e)应由授权主体配置访问控制策略, 访问控制策略规定主体对客体的访问规则;	经查看, 系统未配置安全管理员对访问控制策略进行配置。	不符合
	f)访问控制的粒度应达到主体为用户级或进程级, 客体为文件、数据库表级;	经查看, 服务器访问控制粒度可达到主体为用户级, 客体为文件级别。	符合
	g)应对重要主体和客体设置安全标记, 并控制主体对有安全标记信息资源的访问。	经核查, 系统未采取技术措施实现基于安全标记的强制访问控制功能。	不符合
安全审计	a)应启用安全审计功能, 审计覆盖到每个用户, 对重要的用户行为和重要安全事件进行审计;	通过命令 service auditd status、service rsyslog status 查看审计功能状态, 服务器系统本身已开	符合

控制点	测评项	结果记录	符合情况
		启了 auditd 服务和 rsyslog 服务，为用户操作和重要安全事件提供审计，审计范围覆盖到所有系统账户。	
	b)审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息；	查看 var/logs 下的审计日志文件，审计记录内容包括用户操作时间、操作进程 ID、操作内容、操作结果等信息。	符合
	c)应对审计记录进行保护，定期备份，避免受到未预期的删除、修改或覆盖等；	经核查，服务器审计日志已通过配置上传至华为云云日志服务 LTS 中，可对审计记录进行保护，能够查看 2025 年 3 月 1 日到 2025 年 9 月 2 日的审计记录，日志保存时间为 6 个月以上，可避免审计记录受到未预期的删除、修改或覆盖等。	符合
	d)应对审计进程进行保护，防止未经授权的中断。	经查看，系统启未采取措施对 rsyslog 进程进行保护，无法防止未经授权的中断。	不符合
入侵防范	a)应遵循最小安装的原则，仅安装需要的组件和应用程序；	经查看，操作系统为 CentOS Linux release 7.4.1708 (Core)，通过 rpm -qa sort 命令查看，系统实现了最小化安装，仅安装了与业务相关的组件和应用程序。	符合
	b)应关闭不需要的系统服务、默认共享和高危端口；	通过 service 命令和 netstat -nltp 命令查看，开启的服务和端口均为业务需要，通过 show mount -e 命令查看，Linux 无共享文件。	符合
	c)应通过设定终端接入方式或网络地址范围对通过网络进行管理的管理终端进行限制；	查看/etc/hosts.allow 和/etc/hosts.deny 系统配置文件，服务器本地未对接入方式或远程网络访问地址进行限制，但系统仅在内部可控网络进行管理。	不符合
	d)应提供数据有效性检验功能，保证通过人机接口输入或通过	依据 GB/T 28448-2019 《信息安全技术网络安全等级保护测评	不适用

控制点	测评项	结果记录	符合情况
	通信接口输入的内容符合系统设定要求；	要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	
	e)应能发现可能存在的已知漏洞，并在经过充分测试评估后，及时修补漏洞；	经访谈和查看，租户购买了华为云企业主机安全 HSS 企业版，华为云提供了漏洞自动检测并提供了修复方案；租户已每天对系统进行漏洞扫描并修补了漏洞。当前提供了《漏洞扫描记录》，包括时间、漏洞等情况、检测结果和检测结果分析等内容。	符合
	f)应能够检测到对重要节点进行入侵的行为，并在发生严重入侵事件时提供报警。	经核查，当前已部署华为云企业主机安全 HSS 企业版，可对服务器入侵行为进行检测，该设备入侵防御特征库版本为最新版本，更新时间为 2025-09-02，更新维护由华为云负责，能够检测到对重要节点进行入侵的行为，并通过手机短信（138****5671）的方式进行主动报警。	符合
恶意代码防范	应采用免受恶意代码攻击的技术措施或主动免疫可信验证机制及时识别入侵和病毒行为，并将其有效阻断。	经核查，当前已部署华为云企业主机安全 HSS 企业版，病毒库版本为最新版本，更新时间为 2025-09-02，更新维护由华为云负责，可及时发现入侵和病毒行为，并将其有效阻断。	符合
可信验证	可基于可信根对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行可信验证，并在应用程序的关键执行环节进行动态可信验证，在检测到其可信性受到破坏后进行报警，并将验证结果形成审计记录送至安全管理中心。	未采用可信计算技术对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。	不符合
数据完整性	a)应采用校验技术或密码技术保证重要数据在传输过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、	经查看，服务器使用 SSH 协议进行加密传输，采用 hmac-sha2-256-ctm 技术，可以实现鉴别数据、重要配置数据在传输过程中的	符合

控制点	测评项	结果记录	符合情况
	重要配置数据、重要视频数据和重要个人信息等；	完整性。	
	b)应采用校验技术或密码技术保证重要数据在存储过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等。	经查看，系统未采用校验技术或密码技术实现鉴别数据、重要配置数据在存储过程中的完整性。	不符合
数据保密性	a)应采用密码技术保证重要数据在传输过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等；	经查看，服务器使用 SSH 协议进行加密传输，采用 AES_128_GCM 算法，可以实现鉴别数据、重要配置数据在传输过程中的保密性。	符合
	b)应采用密码技术保证重要数据在存储过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等。	通过 cat /etc/shadow 命令查看，服务器采用 SHA512 加盐加密技术将鉴别数据进行加密存储，实现鉴别数据在存储过程中的保密性，未采用密码技术实现配置数据在存储过程中的保密性。	部分符合
数据备份恢复	a)应提供重要数据的本地数据备份与恢复功能；	操作系统本身无需备份的业务数据和配置数据，此项不适用。	不适用
	b)应提供异地实时备份功能，利用通信网络将重要数据实时备份至备份场地；	操作系统本身无需备份的业务数据和配置数据，此项不适用。	不适用
	c)应提供重要数据处理系统的冗余，保证系统的高可用性。	经访谈及核查，服务器为虚拟化集群部署，并配置了虚拟机资源的自动分配，能够提供系统的高可用性保障。	符合
剩余信息保护	a)应保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除；	经查看，系统采用命令行方式进行管理，用户退出后会删除原来的用户目录，下次登录再重新生成，能够保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除。	符合
	b)应保证存有敏感数据的存储空	经查看，系统采用命令行方式进	符合

控制点	测评项	结果记录	符合情况
	间被释放或重新分配前得到完全清除。	行管理，操作生成的缓存文件关机自动删除，能够保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	
个人信息保护	a)应仅采集和保存业务必需的用户个人信息；	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
	b)应禁止未授权访问和非法使用用户个人信息。	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用

D.4.1.3.7 数据推送服务器

控制点	测评项	结果记录	符合情况
身份鉴别	a)应对登录的用户进行身份标识和鉴别，身份标识具有唯一性，身份鉴别信息具有复杂度要求并定期更换；	经核查，Linux 系统提供了登录模块，采用用户名和口令的方式对用户进行身份鉴别；通过 cat /etc/passwd 查看用户列表，用户名具有唯一性，系统用户使用 root 进行管理，通过/etc/login.defs 查看，口令策略如下：密码过期时间：90 天；最小密码长度：5 个字符；密码最短存留期：0 天；密码过期提示：7 天；通过 cat /etc/security/pwquality.conf 命令查看，minlen = 8、lcredit=-1、ucrcedit=-1、dcredit=-1、ocredit=-1，口令最小长度为 8 位，且口令至少包含一个大写字母、一个小写字母、一个数字、一个特殊字符，已配置口令复杂度策略；系统已禁用 chage 命令，访谈系统管理员，管理员已每 3 个月更换一次口令。	符合
	b)应具有登录失败处理功能，应	经核查，通过查看/etc/pam.d/syst	符合

控制点	测评项	结果记录	符合情况
	配置并启用结束会话、限制非法登录次数和当登录连接超时自动退出等相关措施；	em-auth 和/etc/pam.d/sshd 配置文件, auth required pam_tally2.so deny=3 unlock_time=300 even_deny_root root_unlock_time=300, 账户登录失败 3 次锁定 300 秒, 系统已配置登录失败处理策略; 通过 cat /etc/profile 命令查看, TMOUT=600, 系统已配置登录连接超时 600 秒自动退出策略。	
	c)当进行远程管理时,应采取必要措施防止鉴别信息在网络传输过程中被窃听;	通过systemctl grep running 命令, 查看当前正在运行的服务, 系统未开启 Telnet 服务, 开启了 sshd.service 服务, 仅允许使用 SSH 协议进行远程管理,服务器采用 AES_128_GCM 技术进行加密, 可实现鉴别信息在网络中加密传输。	符合
	d)应采用口令、密码技术、生物技术等两种或两种以上组合的鉴别技术对用户进行身份鉴别, 且其中一种鉴别技术至少应使用密码技术来实现。	经查看, 登录系统仅采用用户名和口令进行身份鉴别, 未采用双因子认证对用户身份进行鉴别。	不符合
访问控制	a)应对登录的用户分配账户和权限;	经核查/etc/passwd 和/etc/shadow 文件, 已对登录系统的用户分配了 root 等账户, 并分配了相应的权限。	符合
	b)应重命名或删除默认账户, 修改默认账户的默认口令;	经查看, 系统采用 root 账户进行管理, 未重命名默认账户, 但对默认账户自行设置了口令。	部分符合
	c)应及时删除或停用多余的、过期的账户, 避免共享账户的存在;	经核查/etc/shadow 文件, 系统账户中不存在多余的、过期的账户, 账户由专人管理, 不存在共享账户。	符合
	d)应授予管理用户所需的最小权限, 实现管理用户的权限分离;	经查看, 系统采用 root 账户进行管理, 未配置安全管理员、审计管理员等账户, 未实现管理用户	不符合

控制点	测评项	结果记录	符合情况
		的权限分离。	
	e)应由授权主体配置访问控制策略，访问控制策略规定主体对客体的访问规则；	经查看，系统未配置安全管理员对访问控制策略进行配置。	不符合
	f)访问控制的粒度应达到主体为用户级或进程级，客体为文件、数据库表级；	经查看，服务器访问控制粒度可达到主体为用户级，客体为文件级别。	符合
	g)应对重要主体和客体设置安全标记，并控制主体对有安全标记信息资源的访问。	经核查，系统未采取技术措施实现基于安全标记的强制访问控制功能。	不符合
安全审计	a)应启用安全审计功能，审计覆盖到每个用户，对重要的用户行为和重要安全事件进行审计；	通过命令 <code>service auditd status</code> 、 <code>service rsyslog status</code> 查看审计功能状态，服务器系统本身已开启了 <code>auditd</code> 服务和 <code>rsyslog</code> 服务，为用户操作和重要安全事件提供审计，审计范围覆盖到所有系统账户。	符合
	b)审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息；	查看 <code>var/logs</code> 下的审计日志文件，审计记录内容包括用户操作时间、操作进程 ID、操作内容、操作结果等信息。	符合
	c)应对审计记录进行保护，定期备份，避免受到未预期的删除、修改或覆盖等；	经核查，服务器审计日志已通过配置上传至华为云云日志服务 L TS 中，可对审计记录进行保护，能够查看 2025 年 3 月 1 日到 2025 年 9 月 2 日的审计记录，日志保存时间为 6 个月以上，可避免审计记录受到未预期的删除、修改或覆盖等。	符合
	d)应对审计进程进行保护，防止未经授权的中断。	经查看，系统启未采取措施对 <code>rsyslog</code> 进程进行保护，无法防止未经授权的中断。	不符合
入侵防范	a)应遵循最小安装的原则，仅安装需要的组件和应用程序；	经查看，操作系统为 CentOS Linux release 7.4.1708 (Core)，通过 <code>rpm -qa sort</code> 命令查看，系统	符合

控制点	测评项	结果记录	符合情况
		实现了最小化安装，仅安装了与业务相关的组件和应用程序。	
	b)应关闭不需要的系统服务、默认共享和高危端口；	通过 service 命令和 netstat -nltp 命令查看，开启的服务和端口均为业务需要，通过 show mount -e 命令查看，Linux 无共享文件。	符合
	c)应通过设定终端接入方式或网络地址范围对通过网络进行管理的管理终端进行限制；	查看/etc/hosts.allow 和/etc/hosts.deny 系统配置文件，服务器本地未对接入方式或远程网络访问地址进行限制，但系统仅在内部可控网络进行管理。	不符合
	d)应提供数据有效性检验功能，保证通过人机接口输入或通过通信接口输入的内容符合系统设定要求；	依据 GB/T 28448-2019 《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
	e)应能发现可能存在的已知漏洞，并在经过充分测试评估后，及时修补漏洞；	经访谈和查看，租户购买了华为云企业主机安全 HSS 企业版，华为云提供了漏洞自动检测并提供了修复方案；租户已每天对系统进行漏洞扫描并修补了漏洞。当前提供了《漏洞扫描记录》，包括时间、漏洞等情况、检测结果和检测结果分析等内容。	符合
	f)应能够检测到对重要节点进行入侵的行为，并在发生严重入侵事件时提供报警。	经核查，当前已部署华为云企业主机安全 HSS 企业版，可对服务器入侵行为进行检测，该设备入侵防御特征库版本为最新版本，更新时间为 2025-09-02，更新维护由华为云负责，能够检测到对重要节点进行入侵的行为，并通过手机短信（138****5671）的方式进行主动报警。	符合
恶意代码防范	应采用免受恶意代码攻击的技术措施或主动免疫可信验证机制及时识别入侵和病毒行为，并将其有效阻断。	经核查，当前已部署华为云企业主机安全 HSS 企业版，病毒库版本为最新版本，更新时间为 2025-09-02，更新维护由华为云负责，	符合

控制点	测评项	结果记录	符合情况
		可及时发现入侵和病毒行为，并将其有效阻断。	
可信验证	可基于可信根对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行可信验证，并在应用程序的关键执行环节进行动态可信验证，在检测到其可信性受到破坏后进行报警，并将验证结果形成审计记录送至安全管理中心。	未采用可信计算技术对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。	不符合
数据完整性	a)应采用校验技术或密码技术保证重要数据在传输过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等；	经查看，服务器使用 SSH 协议进行加密传输，采用 hmac-sha2-256-ctm 技术，可以实现鉴别数据、重要配置数据在传输过程中的完整性。	符合
	b)应采用校验技术或密码技术保证重要数据在存储过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等。	经查看，系统未采用校验技术或密码技术实现鉴别数据、重要配置数据在存储过程中的完整性。	不符合
数据保密性	a)应采用密码技术保证重要数据在传输过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等；	经查看，服务器使用 SSH 协议进行加密传输，采用 AES_128_GCM 算法，可以实现鉴别数据、重要配置数据在传输过程中的保密性。	符合
	b)应采用密码技术保证重要数据在存储过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等。	通过 cat /etc/shadow 命令查看，服务器采用 SHA512 加盐加密技术将鉴别数据进行加密存储，实现鉴别数据在存储过程中的保密性，未采用密码技术实现配置数据在存储过程中的保密性。	部分符合
数据备份恢复	a)应提供重要数据的本地数据备份与恢复功能；	操作系统本身无需备份的业务数据和配置数据，此项不适用。	不适用

控制点	测评项	结果记录	符合情况
	b)应提供异地实时备份功能，利用通信网络将重要数据实时备份至备份场地；	操作系统本身无需备份的业务数据和配置数据，此项不适用。	不适用
	c)应提供重要数据处理系统的热冗余，保证系统的高可用性。	经访谈及核查，服务器为虚拟化集群部署，并配置了虚拟机资源的自动分配，能够提供系统的高可用性保障。	符合
剩余信息保护	a)应保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除；	经查看，系统采用命令行方式进行管理，用户退出后会删除原来的用户目录，下次登录再重新生成，能够保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除。	符合
	b)应保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	经查看，系统采用命令行方式进行管理，操作生成的缓存文件关机自动删除，能够保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	符合
个人信息保护	a)应仅采集和保存业务必需的用户个人信息；	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
	b)应禁止未授权访问和非法使用用户个人信息。	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用

D.4.1.3.8 应用服务器

控制点	测评项	结果记录	符合情况
身份鉴别	a)应对登录的用户进行身份标识和鉴别，身份标识具有唯一性，身份鉴别信息具有复杂度要求并定期更换；	经核查，Linux 系统提供了登录模块，采用用户名和口令的方式对用户进行身份鉴别；通过 cat /etc/passwd 查看用户列表，用户名具有唯一性，系统用户使用 root 进行管理，通过/etc/login.defs	符合

控制点	测评项	结果记录	符合情况
		查看，口令策略如下：密码过期时间：90 天；最小密码长度：5 个字符；密码最短存留期：0 天；密码过期提示：7 天；通过 cat /etc/security/pwquality.conf 命令查看，minlen = 8、lcredit=-1、ucrcedit=-1、dcredit=-1、ocredit=-1，口令最小长度为 8 位，且口令至少包含一个大写字母、一个小写字母、一个数字、一个特殊字符，已配置口令复杂度策略；系统已禁用 chage 命令，访谈系统管理员，管理员已每 3 个月更换一次口令。	
	b)应具有登录失败处理功能，应配置并启用结束会话、限制非法登录次数和当登录连接超时自动退出等相关措施；	经核查，通过查看/etc/pam.d/system-auth 和/etc/pam.d/sshd 配置文件，auth required pam_tally2.so deny=3 unlock_time=300 even_deny_root root_unlock_time=300，账户登录失败 3 次锁定 300 秒，系统已配置登录失败处理策略；通过 cat /etc/profile 命令查看，TMOUT=600，系统已配置登录连接超时 600 秒自动退出策略。	符合
	c)当进行远程管理时，应采取必要措施防止鉴别信息在网络传输过程中被窃听；	通过systemctl grep running 命令，查看当前正在运行的服务，系统未开启 Telnet 服务，开启了 sshd.service 服务，仅允许使用 SSH 协议进行远程管理,服务器采用 AES_128_GCM 技术进行加密，可实现鉴别信息在网络中加密传输。	符合
	d)应采用口令、密码技术、生物技术等两种或两种以上组合的鉴别技术对用户进行身份鉴别，且其中一种鉴别技术至少应使用密码技术来实现。	经查看，登录系统仅采用用户名和口令进行身份鉴别，未采用双因子认证对用户身份进行鉴别。	不符合

控制点	测评项	结果记录	符合情况
访问控制	a)应对登录的用户分配账户和权限;	经核查/etc/passwd 和/etc/shadow 文件, 已对登录系统的用户分配了 root 等账户, 并分配了相应的权限。	符合
	b)应重命名或删除默认账户, 修改默认账户的默认口令;	经查看, 系统采用 root 账户进行管理, 未重命名默认账户, 但对默认账户自行设置了口令。	部分符合
	c)应及时删除或停用多余的、过期的账户, 避免共享账户的存在;	经核查/etc/shadow 文件, 系统账户中不存在多余的、过期的账户, 账户由专人管理, 不存在共享账户。	符合
	d)应授予管理用户所需的最小权限, 实现管理用户的权限分离;	经查看, 系统采用 root 账户进行管理, 未配置安全管理员、审计管理员等账户, 未实现管理用户的权限分离。	不符合
	e)应由授权主体配置访问控制策略, 访问控制策略规定主体对客体的访问规则;	经查看, 系统未配置安全管理员对访问控制策略进行配置。	不符合
	f)访问控制的粒度应达到主体为用户级或进程级, 客体为文件、数据库表级;	经查看, 服务器访问控制粒度可达到主体为用户级, 客体为文件级别。	符合
	g)应对重要主体和客体设置安全标记, 并控制主体对有安全标记信息资源的访问。	经核查, 系统未采取技术措施实现基于安全标记的强制访问控制功能。	不符合
安全审计	a)应启用安全审计功能, 审计覆盖到每个用户, 对重要的用户行为和重要安全事件进行审计;	通过命令 service auditd status、service rsyslog status 查看审计功能状态, 服务器系统本身已开启了 auditd 服务和 rsyslog 服务, 为用户操作和重要安全事件提供审计, 审计范围覆盖到所有系统账户。	符合
	b)审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息;	查看 var/logs 下的审计日志文件, 审计记录内容包括用户操作时间、操作进程 ID、操作内容、操作结果等信息。	符合

控制点	测评项	结果记录	符合情况
	c)应对审计记录进行保护，定期备份，避免受到未预期的删除、修改或覆盖等；	经核查，服务器审计日志已通过配置上传至华为云云日志服务 LTS 中，可对审计记录进行保护，能够查看 2025 年 3 月 1 日到 2025 年 9 月 2 日的审计记录，日志保存时间为 6 个月以上，可避免审计记录受到未预期的删除、修改或覆盖等。	符合
	d)应对审计进程进行保护，防止未经授权的中断。	经查看，系统启未采取措施对 rsyslog 进程进行保护,无法防止未经授权的中断。	不符合
入侵防范	a)应遵循最小安装的原则，仅安装需要的组件和应用程序；	经查看，操作系统为 CentOS Linux release 7.4.1708 (Core)，通过 rpm -qa sort 命令查看，系统实现了最小化安装，仅安装了与业务相关的组件和应用程序。	符合
	b)应关闭不需要的系统服务、默认共享和高危端口；	通过 service 命令和 netstat -nltp 命令查看，开启的服务和端口均为业务需要,通过 show mount -e 命令查看，Linux 无共享文件。	符合
	c)应通过设定终端接入方式或网络地址范围对通过网络进行管理的管理终端进行限制；	查看/etc/hosts.allow 和/etc/hosts.deny 系统配置文件，服务器本地未对接入方式或远程网络访问地址进行限制，但系统仅在内部可控网络进行管理。	不符合
	d)应提供数据有效性检验功能，保证通过人机接口输入或通过通信接口输入的内容符合系统设定要求；	依据 GB/T 28448-2019 《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
	e)应能发现可能存在的已知漏洞，并在经过充分测试评估后，及时修补漏洞；	经访谈和查看，租户购买了华为云企业主机安全 HSS 企业版，华为云提供了漏洞自动检测并提供了修复方案；租户已每天对系统进行漏洞扫描并修补了漏洞。当前提供了《漏洞扫描记录》，包括时间、漏洞等情况、检测结果	符合

控制点	测评项	结果记录	符合情况
		和检测结果分析等内容。	
	f)应能够检测到对重要节点进行入侵的行为，并在发生严重入侵事件时提供报警。	经核查，当前已部署华为云企业主机安全 HSS 企业版，可对服务器入侵行为进行检测，该设备入侵防御特征库版本为最新版本，更新时间为 2025-09-02，更新维护由华为云负责，能够检测到对重要节点进行入侵的行为，并通过手机短信（138****5671）的方式进行主动报警。	符合
恶意代码防范	应采用免受恶意代码攻击的技术措施或主动免疫可信验证机制及时识别入侵和病毒行为，并将其有效阻断。	经核查，当前已部署华为云企业主机安全 HSS 企业版，病毒库版本为最新版本，更新时间为 2025-09-02，更新维护由华为云负责，可及时发现入侵和病毒行为，并将其有效阻断。	符合
可信验证	可基于可信根对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行可信验证，并在应用程序的关键执行环节进行动态可信验证，在检测到其可信性受到破坏后进行报警，并将验证结果形成审计记录送至安全管理中心。	未采用可信计算技术对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。	不符合
数据完整性	a)应采用校验技术或密码技术保证重要数据在传输过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等；	经查看，服务器使用 SSH 协议进行加密传输，采用 hmac-sha2-256-etm 技术，可以实现鉴别数据、重要配置数据在传输过程中的完整性。	符合
	b)应采用校验技术或密码技术保证重要数据在存储过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等。	经查看，系统未采用校验技术或密码技术实现鉴别数据、重要配置数据在存储过程中的完整性。	不符合

控制点	测评项	结果记录	符合情况
数据保密性	a)应采用密码技术保证重要数据在传输过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等；	经查看，服务器使用 SSH 协议进行加密传输，采用 AES_128_GCM 算法，可以实现鉴别数据、重要配置数据在传输过程中的保密性。	符合
	b)应采用密码技术保证重要数据在存储过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等。	通过 cat /etc/shadow 命令查看，服务器采用 SHA512 加盐加密技术将鉴别数据进行加密存储，实现鉴别数据在存储过程中的保密性，未采用密码技术实现配置数据在存储过程中的保密性。	部分符合
数据备份恢复	a)应提供重要数据的本地数据备份与恢复功能；	操作系统本身无需备份的业务数据和配置数据，此项不适用。	不适用
	b)应提供异地实时备份功能，利用通信网络将重要数据实时备份至备份场地；	操作系统本身无需备份的业务数据和配置数据，此项不适用。	不适用
	c)应提供重要数据处理系统的热冗余，保证系统的高可用性。	经访谈及核查，服务器为虚拟化集群部署，并配置了虚拟机资源的自动分配，能够提供系统的高可用性保障。	符合
剩余信息保护	a)应保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除；	经查看，系统采用命令行方式进行管理，用户退出后会删除原来的用户目录，下次登录再重新生成，能够保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除。	符合
	b)应保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	经查看，系统采用命令行方式进行管理，操作生成的缓存文件关机自动删除，能够保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	符合
个人信息保护	a)应仅采集和保存业务必需的用户个人信息；	依据 GB/T 28448-2019 《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用

控制点	测评项	结果记录	符合情况
	b)应禁止未授权访问和非法使用用户个人信息。	依据 GB/T 28448-2019 《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用

D.4.1.3.9 中招前置机服务器

控制点	测评项	结果记录	符合情况
身份鉴别	a)应对登录的用户进行身份标识和鉴别，身份标识具有唯一性，身份鉴别信息具有复杂度要求并定期更换；	经核查，Linux 系统提供了登录模块，采用用户名和口令的方式对用户进行身份鉴别；通过 cat /etc/passwd 查看用户列表，用户名具有唯一性，系统用户使用 root 进行管理，通过/etc/login.defs 查看，口令策略如下：密码过期时间：90 天；最小密码长度：5 个字符；密码最短存留期：0 天；密码过期提示：7 天；通过 cat /etc/security/pwquality.conf 命令查看，minlen = 8、lcredit=-1、ucrcedit=-1、dcredit=-1、ocredit=-1，口令最小长度为 8 位，且口令至少包含一个大写字母、一个小写字母、一个数字、一个特殊字符，已配置口令复杂度策略；系统已禁用 chage 命令，访谈系统管理员，管理员已每 3 个月更换一次口令。	符合
	b)应具有登录失败处理功能，应配置并启用结束会话、限制非法登录次数和当登录连接超时自动退出等相关措施；	经核查，通过查看/etc/pam.d/system-auth 和/etc/pam.d/sshd 配置文件，auth required pam_tally2.sodeny=3 unlock_time=300 even_deny_root root_unlock_time=300，账户登录失败 3 次锁定 300 秒，系统已配置登录失败处理策略；通过 cat /etc/profile 命令查看，TMOUT=600，系统已配置登录连接超时 600 秒自动退出策略。	符合

控制点	测评项	结果记录	符合情况
	c)当进行远程管理时，应采取必要措施防止鉴别信息在网络传输过程中被窃听；	通过systemctl grep running 命令，查看当前正在运行的服务，系统未开启 Telnet 服务，开启了 sshd.service 服务，仅允许使用 SSH 协议进行远程管理,服务器采用 AES_128_GCM 技术进行加密，可实现鉴别信息在网络中加密传输。	符合
	d)应采用口令、密码技术、生物技术等两种或两种以上组合的鉴别技术对用户进行身份鉴别，且其中一种鉴别技术至少应使用密码技术来实现。	经查看，登录系统仅采用用户名和口令进行身份鉴别，未采用双因子认证对用户身份进行鉴别。	不符合
访问控制	a)应对登录的用户分配账户和权限；	经核查/etc/passwd 和/etc/shadow 文件，已对登录系统的用户分配了 root 等账户，并分配了相应的权限。	符合
	b)应重命名或删除默认账户，修改默认账户的默认口令；	经查看，系统采用 root 账户进行管理，未重命名默认账户，但对默认账户自行设置了口令。	部分符合
	c)应及时删除或停用多余的、过期的账户，避免共享账户的存在；	经核查/etc/shadow 文件，系统账户中不存在多余的、过期的账户，账户由专人管理，不存在共享账户。	符合
	d)应授予管理用户所需的最小权限，实现管理用户的权限分离；	经查看，系统采用 root 账户进行管理，未配置安全管理员、审计管理员等账户，未实现管理用户的权限分离。	不符合
	e)应由授权主体配置访问控制策略，访问控制策略规定主体对客体的访问规则；	经查看，系统未配置安全管理员对访问控制策略进行配置。	不符合
	f)访问控制的粒度应达到主体为用户级或进程级，客体为文件、数据库表级；	经查看，服务器访问控制粒度可达到主体为用户级，客体为文件级别。	符合
	g)应对重要主体和客体设置安全	经核查，系统未采取技术措施实	不符合

控制点	测评项	结果记录	符合情况
	标记，并控制主体对有安全标记信息资源的访问。	现基于安全标记的强制访问控制功能。	
安全审计	a)应启用安全审计功能，审计覆盖到每个用户，对重要的用户行为和重要安全事件进行审计；	通过命令 service auditd status、service rsyslog status 查看审计功能状态，服务器系统本身已开启了 auditd 服务和 rsyslog 服务，为用户操作和重要安全事件提供审计，审计范围覆盖到所有系统账户。	符合
	b)审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息；	查看 var/logs 下的审计日志文件，审计记录内容包括用户操作时间、操作进程 ID、操作内容、操作结果等信息。	符合
	c)应对审计记录进行保护，定期备份，避免受到未预期的删除、修改或覆盖等；	经核查，服务器审计日志已通过配置上传至华为云云日志服务 L TS 中，可对审计记录进行保护，能够查看 2025 年 3 月 1 日到 2025 年 9 月 2 日的审计记录，日志保存时间为 6 个月以上，可避免审计记录受到未预期的删除、修改或覆盖等。	符合
	d)应对审计进程进行保护，防止未经授权的中断。	经查看，系统启未采取措施对 rsyslog 进程进行保护，无法防止未经授权的中断。	不符合
入侵防范	a)应遵循最小安装的原则，仅安装需要的组件和应用程序；	经查看，操作系统为 CentOS Linux release 7.4.1708 (Core)，通过 rpm -qa sort 命令查看，系统实现了最小化安装，仅安装了与业务相关的组件和应用程序。	符合
	b)应关闭不需要的系统服务、默认共享和高危端口；	通过 service 命令和 netstat -nltp 命令查看，开启的服务和端口均为业务需要，通过 show mount -e 命令查看，Linux 无共享文件。	符合
	c)应通过设定终端接入方式或网络地址范围对通过网络进行管	查看/etc/hosts.allow 和/etc/hosts.deny 系统配置文件，服务器本地	不符合

控制点	测评项	结果记录	符合情况
	理的管理终端进行限制；	未对接入方式或远程网络访问地址进行限制，但系统仅在内部可控网络进行管理。	
	d)应提供数据有效性检验功能，保证通过人机接口输入或通过通信接口输入的内容符合系统设定要求；	依据 GB/T 28448-2019 《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
	e)应能发现可能存在的已知漏洞，并在经过充分测试评估后，及时修补漏洞；	经访谈和查看，租户购买了华为云企业主机安全 HSS 企业版，华为云提供了漏洞自动检测并提供了修复方案；租户已每天对系统进行漏洞扫描并修补了漏洞。当前提供了《漏洞扫描记录》，包括时间、漏洞等情况、检测结果和检测结果分析等内容。	符合
	f)应能够检测到对重要节点进行入侵的行为，并在发生严重入侵事件时提供报警。	经核查，当前已部署华为云企业主机安全 HSS 企业版，可对服务器入侵行为进行检测，该设备入侵防御特征库版本为最新版本，更新时间为 2025-09-02，更新维护由华为云负责，能够检测到对重要节点进行入侵的行为，并通过手机短信 (138****5671) 的方式进行主动报警。	符合
恶意代码防范	应采用免受恶意代码攻击的技术措施或主动免疫可信验证机制及时识别入侵和病毒行为，并将其有效阻断。	经核查，当前已部署华为云企业主机安全 HSS 企业版，病毒库版本为最新版本，更新时间为 2025-09-02，更新维护由华为云负责，可及时发现入侵和病毒行为，并将其有效阻断。	符合
可信验证	可基于可信根对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行可信验证，并在应用程序的关键执行环节进行动态可信验证，在检测到其可信性受到破坏后进行报警，并将验证结果形成审计记录	未采用可信计算技术对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。	不符合

控制点	测评项	结果记录	符合情况
	送至安全管理中心。		
数据完整性	a)应采用校验技术或密码技术保证重要数据在传输过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等；	经查看，服务器使用 SSH 协议进行加密传输，采用 hmac-sha2-256-ctm 技术，可以实现鉴别数据、重要配置数据在传输过程中的完整性。	符合
	b)应采用校验技术或密码技术保证重要数据在存储过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等。	经查看，系统未采用校验技术或密码技术实现鉴别数据、重要配置数据在存储过程中的完整性。	不符合
数据保密性	a)应采用密码技术保证重要数据在传输过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等；	经查看，服务器使用 SSH 协议进行加密传输，采用 AES_128_GCM 算法，可以实现鉴别数据、重要配置数据在传输过程中的保密性。	符合
	b)应采用密码技术保证重要数据在存储过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等。	通过 cat /etc/shadow 命令查看，服务器采用 SHA512 加盐加密技术将鉴别数据进行加密存储，实现鉴别数据在存储过程中的保密性，未采用密码技术实现配置数据在存储过程中的保密性。	部分符合
数据备份恢复	a)应提供重要数据的本地数据备份与恢复功能；	操作系统本身无需备份的业务数据和配置数据，此项不适用。	不适用
	b)应提供异地实时备份功能，利用通信网络将重要数据实时备份至备份场地；	操作系统本身无需备份的业务数据和配置数据，此项不适用。	不适用
	c)应提供重要数据处理系统的热冗余，保证系统的高可用性。	经访谈及核查，服务器为虚拟化集群部署，并配置了虚拟机资源的自动分配，能够提供系统的高可用性保障。	符合
剩余信息保护	a)应保证鉴别信息所在的存储空间被释放或重新分配前得到完	经查看，系统采用命令行方式进行管理，用户退出后会删除原来	符合

控制点	测评项	结果记录	符合情况
	全清除；	的用户目录，下次登录再重新生成，能够保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除。	符合
	b)应保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	经查看，系统采用命令行方式进行管理，操作生成的缓存文件关机自动删除，能够保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	
个人信息保护	a)应仅采集和保存业务必需的用户个人信息；	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
	b)应禁止未授权访问和非法使用用户个人信息。	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用

D.4.1.3.10 网站前台服务器

控制点	测评项	结果记录	符合情况
身份鉴别	a)应对登录的用户进行身份标识和鉴别，身份标识具有唯一性，身份鉴别信息具有复杂度要求并定期更换；	经核查，Linux 系统提供了登录模块，采用用户名和口令的方式对用户进行身份鉴别；通过 cat /etc/passwd 查看用户列表，用户名具有唯一性，系统用户使用 root 进行管理，通过/etc/login.defs 查看，口令策略如下：密码过期时间：90 天；最小密码长度：5 个字符；密码最短存留期：0 天；密码过期提示：7 天；通过 cat /etc/security/pwquality.conf 命令查看，minlen = 8、lcredit=-1、ucrcedit=-1、dcredit=-1、ocredit=-1，口令最小长度为 8 位，且口令至少包含一个大写字母、一个小写字母、一个数字、一个特殊字符，	符合

控制点	测评项	结果记录	符合情况
		已配置口令复杂度策略; 系统已禁用 chage 命令, 访谈系统管理员, 管理员已每 3 个月更换一次口令。	
	b)应具有登录失败处理功能, 应配置并启用结束会话、限制非法登录次数和当登录连接超时自动退出等相关措施;	经核查, 通过查看/etc/pam.d/system-auth 和/etc/pam.d/sshd 配置文件, auth required pam_tally2.so deny=3 unlock_time=300 even_deny_root root_unlock_time=300, 账户登录失败 3 次锁定 300 秒, 系统已配置登录失败处理策略; 通过 cat /etc/profile 命令查看, TMOUT=600, 系统已配置登录连接超时 600 秒自动退出策略。	符合
	c)当进行远程管理时, 应采取必要措施防止鉴别信息在网络传输过程中被窃听;	通过systemctl grep running 命令, 查看当前正在运行的服务, 系统未开启 Telnet 服务, 开启了 sshd.service 服务, 仅允许使用 SSH 协议进行远程管理, 服务器采用 AES_128_GCM 技术进行加密, 可实现鉴别信息在网络中加密传输。	符合
	d)应采用口令、密码技术、生物技术等两种或两种以上组合的鉴别技术对用户进行身份鉴别, 且其中一种鉴别技术至少应使用密码技术来实现。	经查看, 登录系统仅采用用户名和口令进行身份鉴别, 未采用双因子认证对用户身份进行鉴别。	不符合
访问控制	a)应对登录的用户分配账户和权限;	经核查/etc/passwd 和/etc/shadow 文件, 已对登录系统的用户分配了 root 等账户, 并分配了相应的权限。	符合
	b)应重命名或删除默认账户, 修改默认账户的默认口令;	经查看, 系统采用 root 账户进行管理, 未重命名默认账户, 但对默认账户自行设置了口令。	部分符合
	c)应及时删除或停用多余的、过期的账户, 避免共享账户的存	经核查/etc/shadow 文件, 系统账户中不存在多余的、过期的账	符合

控制点	测评项	结果记录	符合情况
	在；	户，账户由专人管理，不存在共享账户。	
	d)应授予管理用户所需的最小权限，实现管理用户的权限分离；	经查看，系统采用 root 账户进行管理，未配置安全管理员、审计管理员等账户，未实现管理用户的权限分离。	不符合
	e)应由授权主体配置访问控制策略，访问控制策略规定主体对客体的访问规则；	经查看，系统未配置安全管理员对访问控制策略进行配置。	不符合
	f)访问控制的粒度应达到主体为用户级或进程级，客体为文件、数据库表级；	经查看，服务器访问控制粒度可达到主体为用户级，客体为文件级别。	符合
	g)应对重要主体和客体设置安全标记，并控制主体对有安全标记信息资源的访问。	经核查，系统未采取技术措施实现基于安全标记的强制访问控制功能。	不符合
安全审计	a)应启用安全审计功能，审计覆盖到每个用户，对重要的用户行为和重要安全事件进行审计；	通过命令 service auditd status、service rsyslog status 查看审计功能状态，服务器系统本身已开启了 auditd 服务和 rsyslog 服务，为用户操作和重要安全事件提供审计，审计范围覆盖到所有系统账户。	符合
	b)审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息；	查看 var/logs 下的审计日志文件，审计记录内容包括用户操作时间、操作进程 ID、操作内容、操作结果等信息。	符合
	c)应对审计记录进行保护，定期备份，避免受到未预期的删除、修改或覆盖等；	经核查，服务器审计日志已通过配置上传至华为云云日志服务 LTS 中，可对审计记录进行保护，能够查看 2025 年 3 月 1 日到 2025 年 9 月 2 日的审计记录，日志保存时间为 6 个月以上，可避免审计记录受到未预期的删除、修改或覆盖等。	符合
	d)应对审计进程进行保护，防止	经查看，系统启未采取措施对 rs	不符合

控制点	测评项	结果记录	符合情况
	未经授权的中断。	yslog 进程进行保护,无法防止未经授权的中断。	
入侵防范	a)应遵循最小安装的原则，仅安装需要的组件和应用程序；	经查看，操作系统为 CentOS Linux release 7.4.1708 (Core)，通过 rpm -qa sort 命令查看，系统实现了最小化安装，仅安装了与业务相关的组件和应用程序。	符合
	b)应关闭不需要的系统服务、默认共享和高危端口；	通过 service 命令和 netstat -nltlp 命令查看，开启的服务和端口均为业务需要,通过 show mount -e 命令查看，Linux 无共享文件。	符合
	c)应通过设定终端接入方式或网络地址范围对通过网络进行管理的管理终端进行限制；	查看/etc/hosts.allow 和/etc/hosts.deny 系统配置文件，服务器本地未对接入方式或远程网络访问地址进行限制，但系统仅在内部可控网络进行管理。	不符合
	d)应提供数据有效性检验功能，保证通过人机接口输入或通过通信接口输入的内容符合系统设定要求；	依据 GB/T 28448-2019 《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
	e)应能发现可能存在的已知漏洞，并在经过充分测试评估后，及时修补漏洞；	经访谈和查看，租户购买了华为云企业主机安全 HSS 企业版，华为云提供了漏洞自动检测并提供了修复方案；租户已每天对系统进行漏洞扫描并修补了漏洞。当前提供了《漏洞扫描记录》，包括时间、漏洞等情况、检测结果和检测结果分析等内容。	符合
	f)应能够检测到对重要节点进行入侵的行为，并在发生严重入侵事件时提供报警。	经核查，当前已部署华为云企业主机安全 HSS 企业版，可对服务器入侵行为进行检测，该设备入侵防御特征库版本为最新版本，更新时间为 2025-09-02，更新维护由华为云负责，能够检测到对重要节点进行入侵的行为，并通过手机短信 (138****5671) 的方	符合

控制点	测评项	结果记录	符合情况
		式进行主动报警。	
恶意代码防范	应采用免受恶意代码攻击的技术措施或主动免疫可信验证机制及时识别入侵和病毒行为，并将其有效阻断。	经核查，当前已部署华为云企业主机安全 HSS 企业版，病毒库版本为最新版本，更新时间为 2025-09-02，更新维护由华为云负责，可及时发现入侵和病毒行为，并将其有效阻断。	符合
可信验证	可基于可信根对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行可信验证，并在应用程序的关键执行环节进行动态可信验证，在检测到其可信性受到破坏后进行报警，并将验证结果形成审计记录送至安全管理中心。	未采用可信计算技术对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。	不符合
数据完整性	a)应采用校验技术或密码技术保证重要数据在传输过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等；	经查看，服务器使用 SSH 协议进行加密传输，采用 hmac-sha2-256-ctm 技术，可以实现鉴别数据、重要配置数据在传输过程中的完整性。	符合
	b)应采用校验技术或密码技术保证重要数据在存储过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等。	经查看，系统未采用校验技术或密码技术实现鉴别数据、重要配置数据在存储过程中的完整性。	不符合
数据保密性	a)应采用密码技术保证重要数据在传输过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等；	经查看，服务器使用 SSH 协议进行加密传输，采用 AES_128_GCM 算法，可以实现鉴别数据、重要配置数据在传输过程中的保密性。	符合
	b)应采用密码技术保证重要数据在存储过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等。	通过 cat /etc/shadow 命令查看，服务器采用 SHA512 加盐加密技术将鉴别数据进行加密存储，实现鉴别数据在存储过程中的保	部分符合

控制点	测评项	结果记录	符合情况
		密性，未采用密码技术实现配置数据在存储过程中的保密性。	
数据备份恢复	a)应提供重要数据的本地数据备份与恢复功能；	操作系统本身无需备份的业务数据和配置数据，此项不适用。	不适用
	b)应提供异地实时备份功能，利用通信网络将重要数据实时备份至备份场地；	操作系统本身无需备份的业务数据和配置数据，此项不适用。	不适用
	c)应提供重要数据处理系统的热冗余，保证系统的高可用性。	经访谈及核查，服务器为虚拟化集群部署，并配置了虚拟机资源的自动分配，能够提供系统的高可用性保障。	符合
剩余信息保护	a)应保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除；	经查看，系统采用命令行方式进行管理，用户退出后会删除原来的用户目录，下次登录再重新生成，能够保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除。	符合
	b)应保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	经查看，系统采用命令行方式进行管理，操作生成的缓存文件关机自动删除，能够保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	符合
个人信息保护	a)应仅采集和保存业务必需的用户个人信息；	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
	b)应禁止未授权访问和非法使用用户个人信息。	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用

D.4.1.3.11 评标服务器

控制点	测评项	结果记录	符合情况
身份鉴	a)应对登录的用户进行身份标识	经核查，Linux 系统提供了登录	符合

控制点	测评项	结果记录	符合情况
别	和鉴别，身份标识具有唯一性，身份鉴别信息具有复杂度要求并定期更换；	模块，采用用户名和口令的方式对用户进行身份鉴别；通过 <code>cat /etc/passwd</code> 查看用户列表，用户名具有唯一性，系统用户使用 <code>root</code> 进行管理，通过 <code>/etc/login.defs</code> 查看，口令策略如下：密码过期时间：90 天；最小密码长度：5 个字符；密码最短存留期：0 天；密码过期提示：7 天；通过 <code>cat /etc/security/pwquality.conf</code> 命令查看， <code>minlen = 8</code> 、 <code>lcredit=-1</code> 、 <code>ucrcedit=-1</code> 、 <code>dcrcedit=-1</code> 、 <code>ocrcedit=-1</code> ，口令最小长度为 8 位，且口令至少包含一个大写字母、一个小写字母、一个数字、一个特殊字符，已配置口令复杂度策略；系统已禁用 <code>chage</code> 命令，访谈系统管理员，管理员已每 3 个月更换一次口令。	
	b)应具有登录失败处理功能，应配置并启用结束会话、限制非法登录次数和当登录连接超时自动退出等相关措施；	经核查，通过查看 <code>/etc/pam.d/system-auth</code> 和 <code>/etc/pam.d/sshd</code> 配置文件， <code>auth required pam_tally2.so deny=3 unlock_time=300 even_deny_root root_unlock_time=300</code> ，账户登录失败 3 次锁定 300 秒，系统已配置登录失败处理策略；通过 <code>cat /etc/profile</code> 命令查看， <code>TMOUT=600</code> ，系统已配置登录连接超时 600 秒自动退出策略。	符合
	c)当进行远程管理时，应采取必要措施防止鉴别信息在网络传输过程中被窃听；	通过 <code>systemctl grep running</code> 命令，查看当前正在运行的服务，系统未开启 <code>Telnet</code> 服务，开启了 <code>sshd.service</code> 服务，仅允许使用 <code>SSH</code> 协议进行远程管理，服务器采用 <code>AES_128_GCM</code> 技术进行加密，可实现鉴别信息在网络中加密传输。	符合
	d)应采用口令、密码技术、生物	经查看，登录系统仅采用用户名	不符合

控制点	测评项	结果记录	符合情况
	技术等两种或两种以上组合的鉴别技术对用户进行身份鉴别，且其中一种鉴别技术至少应使用密码技术来实现。	和口令进行身份鉴别，未采用双因子认证对用户身份进行鉴别。	
访问控制	a)应对登录的用户分配账户和权限；	经核查/etc/passwd 和/etc/shadow 文件，已对登录系统的用户分配了 root 等账户，并分配了相应的权限。	符合
	b)应重命名或删除默认账户，修改默认账户的默认口令；	经查看，系统采用 root 账户进行管理，未重命名默认账户，但对默认账户自行设置了口令。	部分符合
	c)应及时删除或停用多余的、过期的账户，避免共享账户的存在；	经核查/etc/shadow 文件，系统账户中不存在多余的、过期的账户，账户由专人管理，不存在共享账户。	符合
	d)应授予管理用户所需的最小权限，实现管理用户的权限分离；	经查看，系统采用 root 账户进行管理，未配置安全管理员、审计管理员等账户，未实现管理用户的权限分离。	不符合
	e)应由授权主体配置访问控制策略，访问控制策略规定主体对客体的访问规则；	经查看，系统未配置安全管理员对访问控制策略进行配置。	不符合
	f)访问控制的粒度应达到主体为用户级或进程级，客体为文件、数据库表级；	经查看，服务器访问控制粒度可达到主体为用户级，客体为文件级别。	符合
	g)应对重要主体和客体设置安全标记，并控制主体对有安全标记信息资源的访问。	经核查，系统未采取技术措施实现基于安全标记的强制访问控制功能。	不符合
安全审计	a)应启用安全审计功能，审计覆盖到每个用户，对重要的用户行为和重要安全事件进行审计；	通过命令 service auditd status、service rsyslog status 查看审计功能状态，服务器系统本身已开启了 auditd 服务和 rsyslog 服务，为用户操作和重要安全事件提供审计，审计范围覆盖到所有系统账户。	符合

控制点	测评项	结果记录	符合情况
	b)审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息；	查看 var/logs 下的审计日志文件，审计记录内容包括用户操作时间、操作进程 ID、操作内容、操作结果等信息。	符合
	c)应对审计记录进行保护，定期备份，避免受到未预期的删除、修改或覆盖等；	经核查，服务器审计日志已通过配置上传至华为云云日志服务 LTS 中，可对审计记录进行保护，能够查看 2025 年 3 月 1 日到 2025 年 9 月 2 日的审计记录，日志保存时间为 6 个月以上，可避免审计记录受到未预期的删除、修改或覆盖等。	符合
	d)应对审计进程进行保护，防止未经授权的中断。	经查看，系统启未采取措施对 rsyslog 进程进行保护，无法防止未经授权的中断。	不符合
入侵防范	a)应遵循最小安装的原则，仅安装需要的组件和应用程序；	经查看，操作系统为 CentOS Linux release 7.4.1708 (Core)，通过 rpm -qa sort 命令查看，系统实现了最小化安装，仅安装了与业务相关的组件和应用程序。	符合
	b)应关闭不需要的系统服务、默认共享和高危端口；	通过 service 命令和 netstat -nltp 命令查看，开启的服务和端口均为业务需要，通过 show mount -e 命令查看，Linux 无共享文件。	符合
	c)应通过设定终端接入方式或网络地址范围对通过网络进行管理的管理终端进行限制；	查看/etc/hosts.allow 和/etc/hosts.deny 系统配置文件，服务器本地未对接入方式或远程网络访问地址进行限制，但系统仅在内部可控网络进行管理。	不符合
	d)应提供数据有效性检验功能，保证通过人机接口输入或通过通信接口输入的内容符合系统设定要求；	依据 GB/T 28448-2019 《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
	e)应能发现可能存在的已知漏洞，并在经过充分测试评估后，	经访谈和查看，租户购买了华为云企业主机安全 HSS 企业版，华	符合

控制点	测评项	结果记录	符合情况
	及时修补漏洞；	为云提供了漏洞自动检测并提供了修复方案；租户已每天对系统进行漏洞扫描并修补了漏洞。当前提供了《漏洞扫描记录》，包括时间、漏洞等情况、检测结果和检测结果分析等内容。	符合
	f)应能够检测到对重要节点进行入侵的行为，并在发生严重入侵事件时提供报警。	经核查，当前已部署华为云企业主机安全 HSS 企业版，可对服务器入侵行为进行检测，该设备入侵防御特征库版本为最新版本，更新时间为 2025-09-02，更新维护由华为云负责，能够检测到对重要节点进行入侵的行为，并通过手机短信（138****5671）的方式进行主动报警。	
恶意代码防范	应采用免受恶意代码攻击的技术措施或主动免疫可信验证机制及时识别入侵和病毒行为，并将其有效阻断。	经核查，当前已部署华为云企业主机安全 HSS 企业版，病毒库版本为最新版本，更新时间为 2025-09-02，更新维护由华为云负责，可及时发现入侵和病毒行为，并将其有效阻断。	符合
可信验证	可基于可信根对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行可信验证，并在应用程序的关键执行环节进行动态可信验证，在检测到其可信性受到破坏后进行报警，并将验证结果形成审计记录送至安全管理中心。	未采用可信计算技术对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。	不符合
数据完整性	a)应采用校验技术或密码技术保证重要数据在传输过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等；	经查看，服务器使用 SSH 协议进行加密传输，采用 hmac-sha2-256-ctm 技术，可以实现鉴别数据、重要配置数据在传输过程中的完整性。	符合
	b)应采用校验技术或密码技术保证重要数据在存储过程中的完	经查看，系统未采用校验技术或密码技术实现鉴别数据、重要配	不符合

控制点	测评项	结果记录	符合情况
	整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等。	置数据在存储过程中的完整性。	
数据保密性	a)应采用密码技术保证重要数据在传输过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等；	经查看，服务器使用 SSH 协议进行加密传输，采用 AES_128_GCM 算法，可以实现鉴别数据、重要配置数据在传输过程中的保密性。	符合
	b)应采用密码技术保证重要数据在存储过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等。	通过 cat /etc/shadow 命令查看，服务器采用 SHA512 加盐加密技术将鉴别数据进行加密存储，实现鉴别数据在存储过程中的保密性，未采用密码技术实现配置数据在存储过程中的保密性。	部分符合
数据备份恢复	a)应提供重要数据的本地数据备份与恢复功能；	操作系统本身无需备份的业务数据和配置数据，此项不适用。	不适用
	b)应提供异地实时备份功能，利用通信网络将重要数据实时备份至备份场地；	操作系统本身无需备份的业务数据和配置数据，此项不适用。	不适用
	c)应提供重要数据处理系统的热冗余，保证系统的高可用性。	经访谈及核查，服务器为虚拟化集群部署，并配置了虚拟机资源的自动分配，能够提供系统的高可用性保障。	符合
剩余信息保护	a)应保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除；	经查看，系统采用命令行方式进行管理，用户退出后会删除原来的用户目录，下次登录再重新生成，能够保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除。	符合
	b)应保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	经查看，系统采用命令行方式进行管理，操作生成的缓存文件关机自动删除，能够保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	符合

控制点	测评项	结果记录	符合情况
个人信息保护	a)应仅采集和保存业务必需的用户个人信息；	依据 GB/T 28448-2019 《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
	b)应禁止未授权访问和非法使用用户个人信息。	依据 GB/T 28448-2019 《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用

D.4.1.3.12 智能设备与全文检索服务器

控制点	测评项	结果记录	符合情况
身份鉴别	a)应对登录的用户进行身份标识和鉴别，身份标识具有唯一性，身份鉴别信息具有复杂度要求并定期更换；	经核查，Linux 系统提供了登录模块，采用用户名和口令的方式对用户进行身份鉴别；通过 <code>cat /etc/passwd</code> 查看用户列表，用户名具有唯一性，系统用户使用 <code>root</code> 进行管理，通过 <code>/etc/login.defs</code> 查看，口令策略如下：密码过期时间：90 天；最小密码长度：5 个字符；密码最短存留期：0 天；密码过期提示：7 天；通过 <code>cat /etc/security/pwquality.conf</code> 命令查看， <code>minlen = 8、lcredit=-1、ucrcedit=-1、dcredit=-1、ocredit=-1</code> ，口令最小长度为 8 位，且口令至少包含一个大写字母、一个小写字母、一个数字、一个特殊字符，已配置口令复杂度策略；系统已禁用 <code>chage</code> 命令，访谈系统管理员，管理员已每 3 个月更换一次口令。	符合
	b)应具有登录失败处理功能，应配置并启用结束会话、限制非法登录次数和当登录连接超时自动退出等相关措施；	经核查，通过查看 <code>/etc/pam.d/system-auth</code> 和 <code>/etc/pam.d/ssh</code> 配置文件， <code>auth required pam_tally2.so deny=3 unlock_time=300 even_deny_root root_unlock_time=300</code> ，账户登录失败 3 次锁定 300 秒，	符合

控制点	测评项	结果记录	符合情况
		系统已配置登录失败处理策略； 通过 <code>cat /etc/profile</code> 命令查看， <code>TMOU=600</code> ，系统已配置登录连接超时 600 秒自动退出策略。	
	c)当进行远程管理时，应采取必要措施防止鉴别信息在网络传输过程中被窃听；	通过 <code>systemctl grep running</code> 命令，查看当前正在运行的服务，系统未开启 <code>Telnet</code> 服务，开启了 <code>sshd.service</code> 服务，仅允许使用 <code>SSH</code> 协议进行远程管理，服务器采用 <code>AES_128_GCM</code> 技术进行加密，可实现鉴别信息在网络中加密传输。	符合
	d)应采用口令、密码技术、生物技术等两种或两种以上组合的鉴别技术对用户进行身份鉴别，且其中一种鉴别技术至少应使用密码技术来实现。	经查看，登录系统仅采用用户名和口令进行身份鉴别，未采用双因子认证对用户身份进行鉴别。	不符合
访问控制	a)应对登录的用户分配账户和权限；	经核查 <code>/etc/passwd</code> 和 <code>/etc/shadow</code> 文件，已对登录系统的用户分配了 <code>root</code> 等账户，并分配了相应的权限。	符合
	b)应重命名或删除默认账户，修改默认账户的默认口令；	经查看，系统采用 <code>root</code> 账户进行管理，未重命名默认账户，但对默认账户自行设置了口令。	部分符合
	c)应及时删除或停用多余的、过期的账户，避免共享账户的存在；	经核查 <code>/etc/shadow</code> 文件，系统账户中不存在多余的、过期的账户，账户由专人管理，不存在共享账户。	符合
	d)应授予管理用户所需的最小权限，实现管理用户的权限分离；	经查看，系统采用 <code>root</code> 账户进行管理，未配置安全管理员、审计管理员等账户，未实现管理用户的权限分离。	不符合
	e)应由授权主体配置访问控制策略，访问控制策略规定主体对客体的访问规则；	经查看，系统未配置安全管理员对访问控制策略进行配置。	不符合

控制点	测评项	结果记录	符合情况
	f)访问控制的粒度应达到主体为用户级或进程级，客体为文件、数据库表级；	经查看，服务器访问控制粒度可达到主体为用户级，客体为文件级别。	符合
	g)应对重要主体和客体设置安全标记，并控制主体对有安全标记信息资源的访问。	经核查，系统未采取技术措施实现基于安全标记的强制访问控制功能。	不符合
安全审计	a)应启用安全审计功能，审计覆盖到每个用户，对重要的用户行为和重要安全事件进行审计；	通过命令 <code>service auditd status</code> 、 <code>service rsyslog status</code> 查看审计功能状态，服务器系统本身已开启了 <code>auditd</code> 服务和 <code>rsyslog</code> 服务，为用户操作和重要安全事件提供审计，审计范围覆盖到所有系统账户。	符合
	b)审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息；	查看 <code>var/logs</code> 下的审计日志文件，审计记录内容包括用户操作时间、操作进程 ID、操作内容、操作结果等信息。	符合
	c)应对审计记录进行保护，定期备份，避免受到未预期的删除、修改或覆盖等；	经核查，服务器审计日志已通过配置上传至华为云云日志服务 L TS 中，可对审计记录进行保护，能够查看 2025 年 3 月 1 日到 2025 年 9 月 2 日的审计记录，日志保存时间为 6 个月以上，可避免审计记录受到未预期的删除、修改或覆盖等。	符合
	d)应对审计进程进行保护，防止未经授权的中断。	经查看，系统启未采取措施对 <code>rsyslog</code> 进程进行保护，无法防止未经授权的中断。	不符合
入侵防范	a)应遵循最小安装的原则，仅安装需要的组件和应用程序；	经查看，操作系统为 CentOS Linux release 7.4.1708 (Core)，通过 <code>rpm -qa sort</code> 命令查看，系统实现了最小化安装，仅安装了与业务相关的组件和应用程序。	符合
	b)应关闭不需要的系统服务、默认共享和高危端口；	通过 <code>service</code> 命令和 <code>netstat -nltp</code> 命令查看，开启的服务和端口均	符合

控制点	测评项	结果记录	符合情况
		为业务需要，通过 show mount - e 命令查看，Linux 无共享文件。	
	c)应通过设定终端接入方式或网络地址范围对通过网络进行管理的管理终端进行限制；	查看/etc/hosts.allow 和/etc/hosts.deny 系统配置文件，服务器本地未对接入方式或远程网络访问地址进行限制，但系统仅在内部可控网络进行管理。	不符合
	d)应提供数据有效性检验功能，保证通过人机接口输入或通过通信接口输入的内容符合系统设定要求；	依据 GB/T 28448-2019 《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
	e)应能发现可能存在的已知漏洞，并在经过充分测试评估后，及时修补漏洞；	经访谈和查看，租户购买了华为云企业主机安全 HSS 企业版，华为云提供了漏洞自动检测并提供了修复方案；租户已每天对系统进行漏洞扫描并修补了漏洞。当前提供了《漏洞扫描记录》，包括时间、漏洞等情况、检测结果和检测结果分析等内容。	符合
	f)应能够检测到对重要节点进行入侵的行为，并在发生严重入侵事件时提供报警。	经核查，当前已部署华为云企业主机安全 HSS 企业版，可对服务器入侵行为进行检测，该设备入侵防御特征库版本为最新版本，更新时间为 2025-09-02，更新维护由华为云负责，能够检测到对重要节点进行入侵的行为，并通过手机短信（138****5671）的方式进行主动报警。	符合
恶意代码防范	应采用免受恶意代码攻击的技术措施或主动免疫可信验证机制及时识别入侵和病毒行为，并将其有效阻断。	经核查，当前已部署华为云企业主机安全 HSS 企业版，病毒库版本为最新版本，更新时间为 2025-09-02，更新维护由华为云负责，可及时发现入侵和病毒行为，并将其有效阻断。	符合
可信验证	可基于可信根对计算设备的系统引导程序、系统程序、重要配	未采用可信计算技术对计算设备的系统引导程序、系统程序、	不符合

控制点	测评项	结果记录	符合情况
	置参数和应用程序等进行可信验证，并在应用程序的关键执行环节进行动态可信验证，在检测到其可信性受到破坏后进行报警，并将验证结果形成审计记录送至安全管理中心。	重要配置参数和应用程序等进行动态可信验证。	
数据完整性	a)应采用校验技术或密码技术保证重要数据在传输过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等；	经查看，服务器使用 SSH 协议进行加密传输，采用 hmac-sha2-256-etm 技术，可以实现鉴别数据、重要配置数据在传输过程中的完整性。	符合
	b)应采用校验技术或密码技术保证重要数据在存储过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等。	经查看，系统未采用校验技术或密码技术实现鉴别数据、重要配置数据在存储过程中的完整性。	不符合
数据保密性	a)应采用密码技术保证重要数据在传输过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等；	经查看，服务器使用 SSH 协议进行加密传输，采用 AES_128_GCM 算法，可以实现鉴别数据、重要配置数据在传输过程中的保密性。	符合
	b)应采用密码技术保证重要数据在存储过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等。	通过 cat /etc/shadow 命令查看，服务器采用 SHA512 加盐加密技术将鉴别数据进行加密存储，实现鉴别数据在存储过程中的保密性，未采用密码技术实现配置数据在存储过程中的保密性。	部分符合
数据备份恢复	a)应提供重要数据的本地数据备份与恢复功能；	操作系统本身无需备份的业务数据和配置数据，此项不适用。	不适用
	b)应提供异地实时备份功能，利用通信网络将重要数据实时备份至备份场地；	操作系统本身无需备份的业务数据和配置数据，此项不适用。	不适用
	c)应提供重要数据处理系统的热	经访谈及核查，服务器为虚拟化	符合

控制点	测评项	结果记录	符合情况
	冗余，保证系统的高可用性。	集群部署，并配置了虚拟机资源的自动分配，能够提供系统的高可用性保障。	
剩余信息保护	a)应保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除；	经查看，系统采用命令行方式进行管理，用户退出后会删除原来的用户目录，下次登录再重新生成，能够保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除。	符合
	b)应保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	经查看，系统采用命令行方式进行管理，操作生成的缓存文件关机自动删除，能够保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	符合
个人信息保护	a)应仅采集和保存业务必需的用户个人信息；	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
	b)应禁止未授权访问和非法使用用户个人信息。	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用

D.4.1.3.13 限额会员端服务器

控制点	测评项	结果记录	符合情况
身份鉴别	a)应对登录的用户进行身份标识和鉴别，身份标识具有唯一性，身份鉴别信息具有复杂度要求并定期更换；	经核查，Linux 系统提供了登录模块，采用用户名和口令的方式对用户进行身份鉴别；通过 <code>cat /etc/passwd</code> 查看用户列表，用户名具有唯一性，系统用户使用 <code>root</code> 进行管理，通过 <code>/etc/login.defs</code> 查看，口令策略如下：密码过期时间：90 天；最小密码长度：5 个字符；密码最短存留期：0 天；密码过期提示：7 天；通过 <code>cat /etc/security/pwquality.conf</code> 命令查	符合

控制点	测评项	结果记录	符合情况
		看，minlen = 8、lcredit=-1、ucredit=-1、dcredit=-1、ocredit=-1，口令最小长度为 8 位，且口令至少包含一个大写字母、一个小写字母、一个数字、一个特殊字符，已配置口令复杂度策略；系统已禁用 chage 命令，访谈系统管理员，管理员已每 3 个月更换一次口令。	
	b)应具有登录失败处理功能，应配置并启用结束会话、限制非法登录次数和当登录连接超时自动退出等相关措施；	经核查，通过查看/etc/pam.d/system-auth 和/etc/pam.d/sshd 配置文件，auth required pam_tally2.sodeny=3 unlock_time=300 even_deny_root root_unlock_time=300，账户登录失败 3 次锁定 300 秒，系统已配置登录失败处理策略；通过 cat /etc/profile 命令查看，TMOUT=600，系统已配置登录连接超时 600 秒自动退出策略。	符合
	c)当进行远程管理时，应采取必要措施防止鉴别信息在网络传输过程中被窃听；	通过systemctl grep running 命令，查看当前正在运行的服务，系统未开启 Telnet 服务，开启了 sshd.service 服务，仅允许使用 SSH 协议进行远程管理,服务器采用 AES_128_GCM 技术进行加密，可实现鉴别信息在网络中加密传输。	符合
	d)应采用口令、密码技术、生物技术等两种或两种以上组合的鉴别技术对用户进行身份鉴别，且其中一种鉴别技术至少应使用密码技术来实现。	经查看，登录系统仅采用用户名和口令进行身份鉴别，未采用双因子认证对用户身份进行鉴别。	不符合
访问控制	a)应对登录的用户分配账户和权限；	经核查/etc/passwd 和/etc/shadow 文件，已对登录系统的用户分配了 root 等账户，并分配了相应的权限。	符合
	b)应重命名或删除默认账户，修	经查看，系统采用 root 账户进行	部分符合

控制点	测评项	结果记录	符合情况
	改默认账户的默认口令；	管理，未重命名默认账户，但对默认账户自行设置了口令。	
	c)应及时删除或停用多余的、过期的账户，避免共享账户的存在；	经核查/etc/shadow 文件，系统账户中不存在多余的、过期的账户，账户由专人管理，不存在共享账户。	符合
	d)应授予管理用户所需的最小权限，实现管理用户的权限分离；	经查看，系统采用 root 账户进行管理，未配置安全管理员、审计管理员等账户，未实现管理用户的权限分离。	不符合
	e)应由授权主体配置访问控制策略，访问控制策略规定主体对客体的访问规则；	经查看，系统未配置安全管理员对访问控制策略进行配置。	不符合
	f)访问控制的粒度应达到主体为用户级或进程级，客体为文件、数据库表级；	经查看，服务器访问控制粒度可达到主体为用户级，客体为文件级别。	符合
	g)应对重要主体和客体设置安全标记，并控制主体对有安全标记信息资源的访问。	经核查，系统未采取技术措施实现基于安全标记的强制访问控制功能。	不符合
安全审计	a)应启用安全审计功能，审计覆盖到每个用户，对重要的用户行为和重要安全事件进行审计；	通过命令 <code>service auditd status</code> 、 <code>service rsyslog status</code> 查看审计功能状态，服务器系统本身已开启了 <code>auditd</code> 服务和 <code>rsyslog</code> 服务，为用户操作和重要安全事件提供审计，审计范围覆盖到所有系统账户。	符合
	b)审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息；	查看 <code>var/logs</code> 下的审计日志文件，审计记录内容包括用户操作时间、操作进程 ID、操作内容、操作结果等信息。	符合
	c)应对审计记录进行保护，定期备份，避免受到未预期的删除、修改或覆盖等；	经核查，服务器审计日志已通过配置上传至华为云云日志服务 L TS 中，可对审计记录进行保护，能够查看 2025 年 3 月 1 日到 2025 年 9 月 2 日的审计记录，日志	符合

控制点	测评项	结果记录	符合情况
		保存时间为 6 个月以上，可避免审计记录受到未预期的删除、修改或覆盖等。	
	d)应对审计进程进行保护，防止未经授权的中断。	经查看，系统启未采取措施对 rsyslog 进程进行保护，无法防止未经授权的中断。	不符合
入侵防范	a)应遵循最小安装的原则，仅安装需要的组件和应用程序；	经查看，操作系统为 CentOS Linux release 7.4.1708 (Core)，通过 rpm -qa sort 命令查看，系统实现了最小化安装，仅安装了与业务相关的组件和应用程序。	符合
	b)应关闭不需要的系统服务、默认共享和高危端口；	通过 service 命令和 netstat -nltp 命令查看，开启的服务和端口均为业务需要，通过 show mount -e 命令查看，Linux 无共享文件。	符合
	c)应通过设定终端接入方式或网络地址范围对通过网络进行管理的管理终端进行限制；	查看/etc/hosts.allow 和/etc/hosts.deny 系统配置文件，服务器本地未对接入方式或远程网络访问地址进行限制，但系统仅在内部可控网络进行管理。	不符合
	d)应提供数据有效性检验功能，保证通过人机接口输入或通过通信接口输入的内容符合系统设定要求；	依据 GB/T 28448-2019 《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
	e)应能发现可能存在的已知漏洞，并在经过充分测试评估后，及时修补漏洞；	经访谈和查看，租户购买了华为云企业主机安全 HSS 企业版，华为云提供了漏洞自动检测并提供了修复方案；租户已每天对系统进行漏洞扫描并修补了漏洞。当前提供了《漏洞扫描记录》，包括时间、漏洞等情况、检测结果和检测结果分析等内容。	符合
	f)应能够检测到对重要节点进行入侵的行为，并在发生严重入侵事件时提供报警。	经核查，当前已部署华为云企业主机安全 HSS 企业版，可对服务器入侵行为进行检测，该设备入	符合

控制点	测评项	结果记录	符合情况
		侵防御特征库版本为最新版本，更新时间为 2025-09-02，更新维护由华为云负责，能够检测到对重要节点进行入侵的行为，并通过手机短信（138****5671）的方式进行主动报警。	
恶意代码防范	应采用免受恶意代码攻击的技术措施或主动免疫可信验证机制及时识别入侵和病毒行为，并将其有效阻断。	经核查，当前已部署华为云企业主机安全 HSS 企业版，病毒库版本为最新版本，更新时间为 2025-09-02，更新维护由华为云负责，可及时发现入侵和病毒行为，并将其有效阻断。	符合
可信验证	可基于可信根对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行可信验证，并在应用程序的关键执行环节进行动态可信验证，在检测到其可信性受到破坏后进行报警，并将验证结果形成审计记录送至安全管理中心。	未采用可信计算技术对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。	不符合
数据完整性	a)应采用校验技术或密码技术保证重要数据在传输过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等；	经查看，服务器使用 SSH 协议进行加密传输，采用 hmac-sha2-256-ctm 技术，可以实现鉴别数据、重要配置数据在传输过程中的完整性。	符合
	b)应采用校验技术或密码技术保证重要数据在存储过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等。	经查看，系统未采用校验技术或密码技术实现鉴别数据、重要配置数据在存储过程中的完整性。	不符合
数据保密性	a)应采用密码技术保证重要数据在传输过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等；	经查看，服务器使用 SSH 协议进行加密传输，采用 AES_128_GCM 算法，可以实现鉴别数据、重要配置数据在传输过程中的保密性。	符合

控制点	测评项	结果记录	符合情况
	b)应采用密码技术保证重要数据在存储过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等。	通过 cat /etc/shadow 命令查看，服务器采用 SHA512 加盐加密技术将鉴别数据进行加密存储，实现鉴别数据在存储过程中的保密性，未采用密码技术实现配置数据在存储过程中的保密性。	部分符合
数据备份恢复	a)应提供重要数据的本地数据备份与恢复功能；	操作系统本身无需备份的业务数据和配置数据，此项不适用。	不适用
	b)应提供异地实时备份功能，利用通信网络将重要数据实时备份至备份场地；	操作系统本身无需备份的业务数据和配置数据，此项不适用。	不适用
	c)应提供重要数据处理系统的热冗余，保证系统的高可用性。	经访谈及核查，服务器为虚拟化集群部署，并配置了虚拟机资源的自动分配，能够提供系统的高可用性保障。	符合
剩余信息保护	a)应保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除；	经查看，系统采用命令行方式进行管理，用户退出后会删除原来的用户目录，下次登录再重新生成，能够保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除。	符合
	b)应保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	经查看，系统采用命令行方式进行管理，操作生成的缓存文件关机自动删除，能够保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	符合
个人信息保护	a)应仅采集和保存业务必需的用户个人信息；	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
	b)应禁止未授权访问和非法使用用户个人信息。	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用

D.4.1.3.14 评标中间价与诚信库接口服务器

控制点	测评项	结果记录	符合情况
身份鉴别	a)应对登录的用户进行身份标识和鉴别，身份标识具有唯一性，身份鉴别信息具有复杂度要求并定期更换；	经核查，Linux 系统提供了登录模块，采用用户名和口令的方式对用户进行身份鉴别；通过 <code>cat /etc/passwd</code> 查看用户列表，用户名具有唯一性，系统用户使用 <code>root</code> 进行管理，通过 <code>/etc/login.defs</code> 查看，口令策略如下：密码过期时间：90 天；最小密码长度：5 个字符；密码最短存留期：0 天；密码过期提示：7 天；通过 <code>cat /etc/security/pwquality.conf</code> 命令查看， <code>minlen = 8、lcredit=-1、ucrcedit=-1、dcredit=-1、ocredit=-1</code> ，口令最小长度为 8 位，且口令至少包含一个大写字母、一个小写字母、一个数字、一个特殊字符，已配置口令复杂度策略；系统已禁用 <code>chage</code> 命令，访谈系统管理员，管理员已每 3 个月更换一次口令。	符合
	b)应具有登录失败处理功能，应配置并启用结束会话、限制非法登录次数和当登录连接超时自动退出等相关措施；	经核查，通过查看 <code>/etc/pam.d/system-auth</code> 和 <code>/etc/pam.d/sshd</code> 配置文件， <code>auth required pam_tally2.so deny=3 unlock_time=300 even_deny_root root_unlock_time=300</code> ，账户登录失败 3 次锁定 300 秒，系统已配置登录失败处理策略；通过 <code>cat /etc/profile</code> 命令查看， <code>TMOU=600</code> ，系统已配置登录连接超时 600 秒自动退出策略。	符合
	c)当进行远程管理时，应采取必要措施防止鉴别信息在网络传输过程中被窃听；	通过 <code>systemctl grep running</code> 命令，查看当前正在运行的服务，系统未开启 <code>Telnet</code> 服务，开启了 <code>sshd.service</code> 服务，仅允许使用 <code>SSH</code> 协议进行远程管理，服务器采用 <code>AES_128_GCM</code> 技术进行加密，可实现鉴别信息在网络中加密传输。	符合

控制点	测评项	结果记录	符合情况
	d)应采用口令、密码技术、生物技术等两种或两种以上组合的鉴别技术对用户进行身份鉴别,且其中一种鉴别技术至少应使用密码技术来实现。	经查看,登录系统仅采用用户名和口令进行身份鉴别,未采用双因子认证对用户身份进行鉴别。	不符合
访问控制	a)应对登录的用户分配账户和权限;	经核查/etc/passwd 和/etc/shadow 文件,已对登录系统的用户分配了 root 等账户,并分配了相应的权限。	符合
	b)应重命名或删除默认账户,修改默认账户的默认口令;	经查看,系统采用 root 账户进行管理,未重命名默认账户,但对默认账户自行设置了口令。	部分符合
	c)应及时删除或停用多余的、过期的账户,避免共享账户的存在;	经核查/etc/shadow 文件,系统账户中不存在多余的、过期的账户,账户由专人管理,不存在共享账户。	符合
	d)应授予管理用户所需的最小权限,实现管理用户的权限分离;	经查看,系统采用 root 账户进行管理,未配置安全管理员、审计管理员等账户,未实现管理用户的权限分离。	不符合
	e)应由授权主体配置访问控制策略,访问控制策略规定主体对客体的访问规则;	经查看,系统未配置安全管理员对访问控制策略进行配置。	不符合
	f)访问控制的粒度应达到主体为用户级或进程级,客体为文件、数据库表级;	经查看,服务器访问控制粒度可达到主体为用户级,客体为文件级别。	符合
	g)应对重要主体和客体设置安全标记,并控制主体对有安全标记信息资源的访问。	经核查,系统未采取技术措施实现基于安全标记的强制访问控制功能。	不符合
安全审计	a)应启用安全审计功能,审计覆盖到每个用户,对重要的用户行为和重要安全事件进行审计;	通过命令 service auditd status、service rsyslog status 查看审计功能状态,服务器系统本身已开启了 auditd 服务和 rsyslog 服务,为用户操作和重要安全事件提供审计,审计范围覆盖到所有系	符合

控制点	测评项	结果记录	符合情况
		统账户。	
	b)审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息；	查看 var/logs 下的审计日志文件，审计记录内容包括用户操作时间、操作进程 ID、操作内容、操作结果等信息。	符合
	c)应对审计记录进行保护，定期备份，避免受到未预期的删除、修改或覆盖等；	经核查，服务器审计日志已通过配置上传至华为云云日志服务 LTS 中，可对审计记录进行保护，能够查看 2025 年 3 月 1 日到 2025 年 9 月 2 日的审计记录，日志保存时间为 6 个月以上，可避免审计记录受到未预期的删除、修改或覆盖等。	符合
	d)应对审计进程进行保护，防止未经授权的中断。	经查看，系统启未采取措施对 rsyslog 进程进行保护，无法防止未经授权的中断。	不符合
入侵防范	a)应遵循最小安装的原则，仅安装需要的组件和应用程序；	经查看，操作系统为 CentOS Linux release 7.4.1708 (Core)，通过 rpm -qa sort 命令查看，系统实现了最小化安装，仅安装了与业务相关的组件和应用程序。	符合
	b)应关闭不需要的系统服务、默认共享和高危端口；	通过 service 命令和 netstat -nltp 命令查看，开启的服务和端口均为业务需要，通过 show mount -e 命令查看，Linux 无共享文件。	符合
	c)应通过设定终端接入方式或网络地址范围对通过网络进行管理的管理终端进行限制；	查看/etc/hosts.allow 和/etc/hosts.deny 系统配置文件，服务器本地未对接入方式或远程网络访问地址进行限制，但系统仅在内部可控网络进行管理。	不符合
	d)应提供数据有效性检验功能，保证通过人机接口输入或通过通信接口输入的内容符合系统设定要求；	依据 GB/T 28448-2019 《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
	e)应能发现可能存在的已知漏	经访谈和查看，租户购买了华为	符合

控制点	测评项	结果记录	符合情况
	洞，并在经过充分测试评估后，及时修补漏洞；	云企业主机安全 HSS 企业版，华为云提供了漏洞自动检测并提供了修复方案；租户已每天对系统进行漏洞扫描并修补了漏洞。当前提供了《漏洞扫描记录》，包括时间、漏洞等情况、检测结果和检测结果分析等内容。	
	f)应能够检测到对重要节点进行入侵的行为，并在发生严重入侵事件时提供报警。	经核查，当前已部署华为云企业主机安全 HSS 企业版，可对服务器入侵行为进行检测，该设备入侵防御特征库版本为最新版本，更新时间为 2025-09-02，更新维护由华为云负责，能够检测到对重要节点进行入侵的行为，并通过手机短信（138****5671）的方式进行主动报警。	符合
恶意代码防范	应采用免受恶意代码攻击的技术措施或主动免疫可信验证机制及时识别入侵和病毒行为，并将其有效阻断。	经核查，当前已部署华为云企业主机安全 HSS 企业版，病毒库版本为最新版本，更新时间为 2025-09-02，更新维护由华为云负责，可及时发现入侵和病毒行为，并将其有效阻断。	符合
可信验证	可基于可信根对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行可信验证，并在应用程序的关键执行环节进行动态可信验证，在检测到其可信性受到破坏后进行报警，并将验证结果形成审计记录送至安全管理中心。	未采用可信计算技术对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。	不符合
数据完整性	a)应采用校验技术或密码技术保证重要数据在传输过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等；	经查看，服务器使用 SSH 协议进行加密传输，采用 hmac-sha2-256-etm 技术，可以实现鉴别数据、重要配置数据在传输过程中的完整性。	符合
	b)应采用校验技术或密码技术保	经查看，系统未采用校验技术或	不符合

控制点	测评项	结果记录	符合情况
	证重要数据在存储过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等。	密码技术实现鉴别数据、重要配置数据在存储过程中的完整性。	
数据保密性	a)应采用密码技术保证重要数据在传输过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等；	经查看，服务器使用 SSH 协议进行加密传输，采用 AES_128_GCM 算法，可以实现鉴别数据、重要配置数据在传输过程中的保密性。	符合
	b)应采用密码技术保证重要数据在存储过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等。	通过 cat /etc/shadow 命令查看，服务器采用 SHA512 加盐加密技术将鉴别数据进行加密存储，实现鉴别数据在存储过程中的保密性，未采用密码技术实现配置数据在存储过程中的保密性。	部分符合
数据备份恢复	a)应提供重要数据的本地数据备份与恢复功能；	操作系统本身无需备份的业务数据和配置数据，此项不适用。	不适用
	b)应提供异地实时备份功能，利用通信网络将重要数据实时备份至备份场地；	操作系统本身无需备份的业务数据和配置数据，此项不适用。	不适用
	c)应提供重要数据处理系统的热冗余，保证系统的高可用性。	经访谈及核查，服务器为虚拟化集群部署，并配置了虚拟机资源的自动分配，能够提供系统的高可用性保障。	符合
剩余信息保护	a)应保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除；	经查看，系统采用命令行方式进行管理，用户退出后会删除原来的用户目录，下次登录再重新生成，能够保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除。	符合
	b)应保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	经查看，系统采用命令行方式进行管理，操作生成的缓存文件关机自动删除，能够保证存有敏感数据的存储空间被释放或重新	符合

控制点	测评项	结果记录	符合情况
		分配前得到完全清除。	
个人信息保护	a)应仅采集和保存业务必需的用户个人信息；	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
	b)应禁止未授权访问和非法使用用户个人信息。	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用

D.4.1.3.15 诚信库部署服务器

控制点	测评项	结果记录	符合情况
身份鉴别	a)应对登录的用户进行身份标识和鉴别，身份标识具有唯一性，身份鉴别信息具有复杂度要求并定期更换；	经核查，Linux 系统提供了登录模块，采用用户名和口令的方式对用户进行身份鉴别；通过 cat /etc/passwd 查看用户列表，用户名具有唯一性，系统用户使用 root 进行管理，通过/etc/login.defs 查看，口令策略如下：密码过期时间：90 天；最小密码长度：5 个字符；密码最短存留期：0 天；密码过期提示：7 天；通过 cat /etc/security/pwquality.conf 命令查看，minlen = 8、lcredit=-1、ucredit=-1、dcredit=-1、ocredit=-1，口令最小长度为 8 位，且口令至少包含一个大写字母、一个小写字母、一个数字、一个特殊字符，已配置口令复杂度策略；系统已禁用 chage 命令，访谈系统管理员，管理员已每 3 个月更换一次口令。	符合
	b)应具有登录失败处理功能，应配置并启用结束会话、限制非法登录次数和当登录连接超时自动退出等相关措施；	经核查，通过查看/etc/pam.d/system-auth 和/etc/pam.d/sshd 配置文件，auth required pam_tally2.sodeny=3 unlock_time=300 even_d	符合

控制点	测评项	结果记录	符合情况
		eny_root root_unlock_time=300, 账户登录失败 3 次锁定 300 秒, 系统已配置登录失败处理策略; 通过 cat /etc/profile 命令查看, TMOUT=600, 系统已配置登录连接超时 600 秒自动退出策略。	
	c)当进行远程管理时,应采取必要措施防止鉴别信息在网络传输过程中被窃听;	通过systemctl grep running 命令,查看当前正在运行的服务,系统未开启 Telnet 服务,开启了 sshd.service 服务,仅允许使用 SSH 协议进行远程管理,服务器采用 AES_128_GCM 技术进行加密,可实现鉴别信息在网络中加密传输。	符合
	d)应采用口令、密码技术、生物技术等两种或两种以上组合的鉴别技术对用户进行身份鉴别,且其中一种鉴别技术至少应使用密码技术来实现。	经查看,登录系统仅采用用户名和口令进行身份鉴别,未采用双因子认证对用户身份进行鉴别。	不符合
访问控制	a)应对登录的用户分配账户和权限;	经核查/etc/passwd 和/etc/shadow 文件,已对登录系统的用户分配了 root 等账户,并分配了相应的权限。	符合
	b)应重命名或删除默认账户,修改默认账户的默认口令;	经查看,系统采用 root 账户进行管理,未重命名默认账户,但对默认账户自行设置了口令。	部分符合
	c)应及时删除或停用多余的、过期的账户,避免共享账户的存在;	经核查/etc/shadow 文件,系统账户中不存在多余的、过期的账户,账户由专人管理,不存在共享账户。	符合
	d)应授予管理用户所需的最小权限,实现管理用户的权限分离;	经查看,系统采用 root 账户进行管理,未配置安全管理员、审计管理员等账户,未实现管理用户的权限分离。	不符合
	e)应由授权主体配置访问控制策	经查看,系统未配置安全管理员	不符合

控制点	测评项	结果记录	符合情况
	略，访问控制策略规定主体对客体的访问规则；	对访问控制策略进行配置。	
	f)访问控制的粒度应达到主体为用户级或进程级，客体为文件、数据库表级；	经查看，服务器访问控制粒度可达到主体为用户级，客体为文件级别。	符合
	g)应对重要主体和客体设置安全标记，并控制主体对有安全标记信息资源的访问。	经核查，系统未采取技术措施实现基于安全标记的强制访问控制功能。	不符合
安全审计	a)应启用安全审计功能，审计覆盖到每个用户，对重要的用户行为和重要安全事件进行审计；	通过命令 <code>service auditd status</code> 、 <code>service rsyslog status</code> 查看审计功能状态，服务器系统本身已开启了 <code>auditd</code> 服务和 <code>rsyslog</code> 服务，为用户操作和重要安全事件提供审计，审计范围覆盖到所有系统账户。	符合
	b)审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息；	查看 <code>var/logs</code> 下的审计日志文件，审计记录内容包括用户操作时间、操作进程 ID、操作内容、操作结果等信息。	符合
	c)应对审计记录进行保护，定期备份，避免受到未预期的删除、修改或覆盖等；	经核查，服务器审计日志已通过配置上传至华为云云日志服务 L TS 中，可对审计记录进行保护，能够查看 2025 年 3 月 1 日到 2025 年 9 月 2 日的审计记录，日志保存时间为 6 个月以上，可避免审计记录受到未预期的删除、修改或覆盖等。	符合
	d)应对审计进程进行保护，防止未经授权的中断。	经查看，系统启未采取措施对 <code>rsyslog</code> 进程进行保护，无法防止未经授权的中断。	不符合
入侵防范	a)应遵循最小安装的原则，仅安装需要的组件和应用程序；	经查看，操作系统为 CentOS Linux release 7.4.1708 (Core)，通过 <code>rpm -qa sort</code> 命令查看，系统实现了最小化安装，仅安装了与业务相关的组件和应用程序。	符合

控制点	测评项	结果记录	符合情况
	b)应关闭不需要的系统服务、默认共享和高危端口；	通过 service 命令和 netstat -nltp 命令查看，开启的服务和端口均为业务需要，通过 show mount -e 命令查看，Linux 无共享文件。	符合
	c)应通过设定终端接入方式或网络地址范围对通过网络进行管理的管理终端进行限制；	查看/etc/hosts.allow 和/etc/hosts.deny 系统配置文件，服务器本地未对接入方式或远程网络访问地址进行限制，但系统仅在内部可控网络进行管理。	不符合
	d)应提供数据有效性检验功能，保证通过人机接口输入或通过通信接口输入的内容符合系统设定要求；	依据 GB/T 28448-2019 《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
	e)应能发现可能存在的已知漏洞，并在经过充分测试评估后，及时修补漏洞；	经访谈和查看，租户购买了华为云企业主机安全 HSS 企业版，华为云提供了漏洞自动检测并提供了修复方案；租户已每天对系统进行漏洞扫描并修补了漏洞。当前提供了《漏洞扫描记录》，包括时间、漏洞等情况、检测结果和检测结果分析等内容。	符合
	f)应能够检测到对重要节点进行入侵的行为，并在发生严重入侵事件时提供报警。	经核查，当前已部署华为云企业主机安全 HSS 企业版，可对服务器入侵行为进行检测，该设备入侵防御特征库版本为最新版本，更新时间为 2025-09-02，更新维护由华为云负责，能够检测到对重要节点进行入侵的行为，并通过手机短信 (138****5671) 的方式进行主动报警。	符合
恶意代码防范	应采用免受恶意代码攻击的技术措施或主动免疫可信验证机制及时识别入侵和病毒行为，并将其有效阻断。	经核查，当前已部署华为云企业主机安全 HSS 企业版，病毒库版本为最新版本，更新时间为 2025-09-02，更新维护由华为云负责，可及时发现入侵和病毒行为，并将其有效阻断。	符合

控制点	测评项	结果记录	符合情况
可信验证	可基于可信根对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行可信验证，并在应用程序的关键执行环节进行动态可信验证，在检测到其可信性受到破坏后进行报警，并将验证结果形成审计记录送至安全管理中心。	未采用可信计算技术对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。	不符合
数据完整性	a)应采用校验技术或密码技术保证重要数据在传输过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等；	经查看，服务器使用 SSH 协议进行加密传输，采用 hmac-sha2-256-ctm 技术，可以实现鉴别数据、重要配置数据在传输过程中的完整性。	符合
	b)应采用校验技术或密码技术保证重要数据在存储过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等。	经查看，系统未采用校验技术或密码技术实现鉴别数据、重要配置数据在存储过程中的完整性。	不符合
数据保密性	a)应采用密码技术保证重要数据在传输过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等；	经查看，服务器使用 SSH 协议进行加密传输，采用 AES_128_GCM 算法，可以实现鉴别数据、重要配置数据在传输过程中的保密性。	符合
	b)应采用密码技术保证重要数据在存储过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等。	通过 cat /etc/shadow 命令查看，服务器采用 SHA512 加盐加密技术将鉴别数据进行加密存储，实现鉴别数据在存储过程中的保密性，未采用密码技术实现配置数据在存储过程中的保密性。	部分符合
数据备份恢复	a)应提供重要数据的本地数据备份与恢复功能；	操作系统本身无需备份的业务数据和配置数据，此项不适用。	不适用
	b)应提供异地实时备份功能，利用通信网络将重要数据实时备份至备份场地；	操作系统本身无需备份的业务数据和配置数据，此项不适用。	不适用

控制点	测评项	结果记录	符合情况
	c)应提供重要数据处理系统的热冗余，保证系统的高可用性。	经访谈及核查，服务器为虚拟化集群部署，并配置了虚拟机资源的自动分配，能够提供系统的高可用性保障。	符合
剩余信息保护	a)应保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除；	经查看，系统采用命令行方式进行管理，用户退出后会删除原来的用户目录，下次登录再重新生成，能够保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除。	符合
	b)应保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	经查看，系统采用命令行方式进行管理，操作生成的缓存文件关机自动删除，能够保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	符合
个人信息保护	a)应仅采集和保存业务必需的用户个人信息；	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
	b)应禁止未授权访问和非法使用用户个人信息。	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用

D.4.1.3.16 新点限额集群服务器

控制点	测评项	结果记录	符合情况
身份鉴别	a)应对登录的用户进行身份标识和鉴别，身份标识具有唯一性，身份鉴别信息具有复杂度要求并定期更换；	经核查，Linux 系统提供了登录模块，采用用户名和口令的方式对用户进行身份鉴别；通过 cat /etc/passwd 查看用户列表，用户名具有唯一性，系统用户使用 ro ot 进行管理，通过/etc/login.defs 查看，口令策略如下：密码过期时间：90 天；最小密码长度：5 个字符；密码最短存留期：0 天；密码过期提示：7 天；通过 cat /	符合

控制点	测评项	结果记录	符合情况
		etc/security/pwquality.conf 命令查看，minlen = 8、lcredit=-1、ucrcedit=-1、dcredit=-1、ocredit=-1，口令最小长度为 8 位，且口令至少包含一个大写字母、一个小写字母、一个数字、一个特殊字符，已配置口令复杂度策略；系统已禁用 chage 命令，访谈系统管理员，管理员已每 3 个月更换一次口令。	
	b)应具有登录失败处理功能，应配置并启用结束会话、限制非法登录次数和当登录连接超时自动退出等相关措施；	经核查，通过查看/etc/pam.d/system-auth 和/etc/pam.d/sshd 配置文件，auth required pam_tally2.sodeny=3 unlock_time=300 even_deny_root root_unlock_time=300，账户登录失败 3 次锁定 300 秒，系统已配置登录失败处理策略；通过 cat /etc/profile 命令查看，TMOUT=600，系统已配置登录连接超时 600 秒自动退出策略。	符合
	c)当进行远程管理时，应采取必要措施防止鉴别信息在网络传输过程中被窃听；	通过systemctl grep running 命令，查看当前正在运行的服务，系统未开启 Telnet 服务，开启了sshd.service 服务，仅允许使用SSH 协议进行远程管理,服务器采用 AES_128_GCM 技术进行加密，可实现鉴别信息在网络中加密传输。	符合
	d)应采用口令、密码技术、生物技术等两种或两种以上组合的鉴别技术对用户进行身份鉴别，且其中一种鉴别技术至少应使用密码技术来实现。	经查看，登录系统仅采用用户名和口令进行身份鉴别，未采用双因子认证对用户身份进行鉴别。	不符合
访问控制	a)应对登录的用户分配账户和权限；	经核查/etc/passwd 和/etc/shadow 文件，已对登录系统的用户分配了 root 等账户，并分配了相应的权限。	符合

控制点	测评项	结果记录	符合情况
	b)应重命名或删除默认账户，修改默认账户的默认口令；	经查看，系统采用 root 账户进行管理，未重命名默认账户，但对默认账户自行设置了口令。	部分符合
	c)应及时删除或停用多余的、过期的账户，避免共享账户的存在；	经核查/etc/shadow 文件，系统账户中不存在多余的、过期的账户，账户由专人管理，不存在共享账户。	符合
	d)应授予管理用户所需的最小权限，实现管理用户的权限分离；	经查看，系统采用 root 账户进行管理，未配置安全管理员、审计管理员等账户，未实现管理用户的权限分离。	不符合
	e)应由授权主体配置访问控制策略，访问控制策略规定主体对客体的访问规则；	经查看，系统未配置安全管理员对访问控制策略进行配置。	不符合
	f)访问控制的粒度应达到主体为用户级或进程级，客体为文件、数据库表级；	经查看，服务器访问控制粒度可达到主体为用户级，客体为文件级别。	符合
	g)应对重要主体和客体设置安全标记，并控制主体对有安全标记信息资源的访问。	经核查，系统未采取技术措施实现基于安全标记的强制访问控制功能。	不符合
安全审计	a)应启用安全审计功能，审计覆盖到每个用户，对重要的用户行为和重要安全事件进行审计；	通过命令 service auditd status、service rsyslog status 查看审计功能状态，服务器系统本身已开启了 auditd 服务和 rsyslog 服务，为用户操作和重要安全事件提供审计，审计范围覆盖到所有系统账户。	符合
	b)审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息；	查看 var/logs 下的审计日志文件，审计记录内容包括用户操作时间、操作进程 ID、操作内容、操作结果等信息。	符合
	c)应对审计记录进行保护，定期备份，避免受到未预期的删除、修改或覆盖等；	经核查，服务器审计日志已通过配置上传至华为云云日志服务 L TS 中，可对审计记录进行保护，能够查看 2025 年 3 月 1 日到 20	符合

控制点	测评项	结果记录	符合情况
		25 年 9 月 2 日的审计记录，日志保存时间为 6 个月以上，可避免审计记录受到未预期的删除、修改或覆盖等。	
	d)应对审计进程进行保护，防止未经授权的中断。	经查看，系统启未采取措施对 rsyslog 进程进行保护，无法防止未经授权的中断。	不符合
入侵防范	a)应遵循最小安装的原则，仅安装需要的组件和应用程序；	经查看，操作系统为 CentOS Linux release 7.4.1708 (Core)，通过 rpm -qa sort 命令查看，系统实现了最小化安装，仅安装了与业务相关的组件和应用程序。	符合
	b)应关闭不需要的系统服务、默认共享和高危端口；	通过 service 命令和 netstat -nltp 命令查看，开启的服务和端口均为业务需要，通过 show mount -e 命令查看，Linux 无共享文件。	符合
	c)应通过设定终端接入方式或网络地址范围对通过网络进行管理的管理终端进行限制；	查看/etc/hosts.allow 和/etc/hosts.deny 系统配置文件，服务器本地未对接入方式或远程网络访问地址进行限制，但系统仅在内部可控网络进行管理。	不符合
	d)应提供数据有效性检验功能，保证通过人机接口输入或通过通信接口输入的内容符合系统设定要求；	依据 GB/T 28448-2019 《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
	e)应能发现可能存在的已知漏洞，并在经过充分测试评估后，及时修补漏洞；	经访谈和查看，租户购买了华为云企业主机安全 HSS 企业版，华为云提供了漏洞自动检测并提供了修复方案；租户已每天对系统进行漏洞扫描并修补了漏洞。当前提供了《漏洞扫描记录》，包括时间、漏洞等情况、检测结果和检测结果分析等内容。	符合
	f)应能够检测到对重要节点进行入侵的行为，并在发生严重入侵	经核查，当前已部署华为云企业主机安全 HSS 企业版，可对服务	符合

控制点	测评项	结果记录	符合情况
	事件时提供报警。	器入侵行为进行检测，该设备入侵防御特征库版本为最新版本，更新时间为 2025-09-02，更新维护由华为云负责，能够检测到对重要节点进行入侵的行为，并通过手机短信（138****5671）的方式进行主动报警。	
恶意代码防范	应采用免受恶意代码攻击的技术措施或主动免疫可信验证机制及时识别入侵和病毒行为，并将其有效阻断。	经核查，当前已部署华为云企业主机安全 HSS 企业版，病毒库版本为最新版本，更新时间为 2025-09-02，更新维护由华为云负责，可及时发现入侵和病毒行为，并将其有效阻断。	符合
可信验证	可基于可信根对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行可信验证，并在应用程序的关键执行环节进行动态可信验证，在检测到其可信性受到破坏后进行报警，并将验证结果形成审计记录送至安全管理中心。	未采用可信计算技术对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。	不符合
数据完整性	a)应采用校验技术或密码技术保证重要数据在传输过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等；	经查看，服务器使用 SSH 协议进行加密传输，采用 hmac-sha2-256-etm 技术，可以实现鉴别数据、重要配置数据在传输过程中的完整性。	符合
	b)应采用校验技术或密码技术保证重要数据在存储过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等。	经查看，系统未采用校验技术或密码技术实现鉴别数据、重要配置数据在存储过程中的完整性。	不符合
数据保密性	a)应采用密码技术保证重要数据在传输过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等；	经查看，服务器使用 SSH 协议进行加密传输，采用 AES_128_GCM 算法，可以实现鉴别数据、重要配置数据在传输过程中的保	符合

控制点	测评项	结果记录	符合情况
		密性。	
	b)应采用密码技术保证重要数据在存储过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等。	通过 cat /etc/shadow 命令查看，服务器采用 SHA512 加盐加密技术将鉴别数据进行加密存储，实现鉴别数据在存储过程中的保密性，未采用密码技术实现配置数据在存储过程中的保密性。	部分符合
数据备份恢复	a)应提供重要数据的本地数据备份与恢复功能；	操作系统本身无需备份的业务数据和配置数据，此项不适用。	不适用
	b)应提供异地实时备份功能，利用通信网络将重要数据实时备份至备份场地；	操作系统本身无需备份的业务数据和配置数据，此项不适用。	不适用
	c)应提供重要数据处理系统的热冗余，保证系统的高可用性。	经访谈及核查，服务器为虚拟化集群部署，并配置了虚拟机资源的自动分配，能够提供系统的高可用性保障。	符合
剩余信息保护	a)应保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除；	经查看，系统采用命令行方式进行管理，用户退出后会删除原来的用户目录，下次登录再重新生成，能够保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除。	符合
	b)应保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	经查看，系统采用命令行方式进行管理，操作生成的缓存文件关机自动删除，能够保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	符合
个人信息保护	a)应仅采集和保存业务必需的用户个人信息；	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
	b)应禁止未授权访问和非法使用用户个人信息。	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用

D.4.1.3.17 江苏限额集群服务器

控制点	测评项	结果记录	符合情况
身份鉴别	a)应对登录的用户进行身份标识和鉴别，身份标识具有唯一性，身份鉴别信息具有复杂度要求并定期更换；	经核查，Linux 系统提供了登录模块，采用用户名和口令的方式对用户进行身份鉴别；通过 cat /etc/passwd 查看用户列表，用户名具有唯一性，系统用户使用 root 进行管理，通过/etc/login.defs 查看，口令策略如下：密码过期时间：90 天；最小密码长度：5 个字符；密码最短存留期：0 天；密码过期提示：7 天；通过 cat /etc/security/pwquality.conf 命令查看，minlen = 8、lcredit=-1、ucrcedit=-1、dcredit=-1、ocredit=-1，口令最小长度为 8 位，且口令至少包含一个大写字母、一个小写字母、一个数字、一个特殊字符，已配置口令复杂度策略；系统已禁用 chage 命令，访谈系统管理员，管理员已每 3 个月更换一次口令。	符合
	b)应具有登录失败处理功能，应配置并启用结束会话、限制非法登录次数和当登录连接超时自动退出等相关措施；	经核查，通过查看/etc/pam.d/system-auth 和/etc/pam.d/sshd 配置文件，auth required pam_tally2.sodeny=3 unlock_time=300 even_denyr_root root_unlock_time=300，账户登录失败 3 次锁定 300 秒，系统已配置登录失败处理策略；通过 cat /etc/profile 命令查看，TMOUT=600，系统已配置登录连接超时 600 秒自动退出策略。	符合
	c)当进行远程管理时，应采取必要措施防止鉴别信息在网络传输过程中被窃听；	通过systemctl grep running 命令，查看当前正在运行的服务，系统未开启 Telnet 服务，开启了sshd.service 服务，仅允许使用SSH 协议进行远程管理,服务器采用 AES_128_GCM 技术进行加	符合

控制点	测评项	结果记录	符合情况
		密, 可实现鉴别信息在网络中加密传输。	
	d)应采用口令、密码技术、生物技术等两种或两种以上组合的鉴别技术对用户进行身份鉴别, 且其中一种鉴别技术至少应使用密码技术来实现。	经查看, 登录系统仅采用用户名和口令进行身份鉴别, 未采用双因子认证对用户身份进行鉴别。	不符合
访问控制	a)应对登录的用户分配账户和权限;	经核查/etc/passwd 和/etc/shadow 文件, 已对登录系统的用户分配了 root 等账户, 并分配了相应的权限。	符合
	b)应重命名或删除默认账户, 修改默认账户的默认口令;	经查看, 系统采用 root 账户进行管理, 未重命名默认账户, 但对默认账户自行设置了口令。	部分符合
	c)应及时删除或停用多余的、过期的账户, 避免共享账户的存在;	经核查/etc/shadow 文件, 系统账户中不存在多余的、过期的账户, 账户由专人管理, 不存在共享账户。	符合
	d)应授予管理用户所需的最小权限, 实现管理用户的权限分离;	经查看, 系统采用 root 账户进行管理, 未配置安全管理员、审计管理员等账户, 未实现管理用户的权限分离。	不符合
	e)应由授权主体配置访问控制策略, 访问控制策略规定主体对客体的访问规则;	经查看, 系统未配置安全管理员对访问控制策略进行配置。	不符合
	f)访问控制的粒度应达到主体为用户级或进程级, 客体为文件、数据库表级;	经查看, 服务器访问控制粒度可达到主体为用户级, 客体为文件级别。	符合
	g)应对重要主体和客体设置安全标记, 并控制主体对有安全标记信息资源的访问。	经核查, 系统未采取技术措施实现基于安全标记的强制访问控制功能。	不符合
安全审计	a)应启用安全审计功能, 审计覆盖到每个用户, 对重要的用户行为和重要安全事件进行审计;	通过命令 service auditd status、service rsyslog status 查看审计功能状态, 服务器系统本身已开	符合

控制点	测评项	结果记录	符合情况
		启了 auditd 服务和 rsyslog 服务，为用户操作和重要安全事件提供审计，审计范围覆盖到所有系统账户。	
	b)审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息；	查看 var/logs 下的审计日志文件，审计记录内容包括用户操作时间、操作进程 ID、操作内容、操作结果等信息。	符合
	c)应对审计记录进行保护，定期备份，避免受到未预期的删除、修改或覆盖等；	经核查，服务器审计日志已通过配置上传至华为云云日志服务 LTS 中，可对审计记录进行保护，能够查看 2025 年 3 月 1 日到 2025 年 9 月 2 日的审计记录，日志保存时间为 6 个月以上，可避免审计记录受到未预期的删除、修改或覆盖等。	符合
	d)应对审计进程进行保护，防止未经授权的中断。	经查看，系统启未采取措施对 rsyslog 进程进行保护，无法防止未经授权的中断。	不符合
入侵防范	a)应遵循最小安装的原则，仅安装需要的组件和应用程序；	经查看，操作系统为 CentOS Linux release 7.4.1708 (Core)，通过 rpm -qa sort 命令查看，系统实现了最小化安装，仅安装了与业务相关的组件和应用程序。	符合
	b)应关闭不需要的系统服务、默认共享和高危端口；	通过 service 命令和 netstat -nltp 命令查看，开启的服务和端口均为业务需要，通过 show mount -e 命令查看，Linux 无共享文件。	符合
	c)应通过设定终端接入方式或网络地址范围对通过网络进行管理的管理终端进行限制；	查看/etc/hosts.allow 和/etc/hosts.deny 系统配置文件，服务器本地未对接入方式或远程网络访问地址进行限制，但系统仅在内部可控网络进行管理。	不符合
	d)应提供数据有效性检验功能，保证通过人机接口输入或通过	依据 GB/T 28448-2019 《信息安全技术网络安全等级保护测评	不适用

控制点	测评项	结果记录	符合情况
	通信接口输入的内容符合系统设定要求；	要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	
	e)应能发现可能存在的已知漏洞，并在经过充分测试评估后，及时修补漏洞；	经访谈和查看，租户购买了华为云企业主机安全 HSS 企业版，华为云提供了漏洞自动检测并提供了修复方案；租户已每天对系统进行漏洞扫描并修补了漏洞。当前提供了《漏洞扫描记录》，包括时间、漏洞等情况、检测结果和检测结果分析等内容。	符合
	f)应能够检测到对重要节点进行入侵的行为，并在发生严重入侵事件时提供报警。	经核查，当前已部署华为云企业主机安全 HSS 企业版，可对服务器入侵行为进行检测，该设备入侵防御特征库版本为最新版本，更新时间为 2025-09-02，更新维护由华为云负责，能够检测到对重要节点进行入侵的行为，并通过手机短信（138****5671）的方式进行主动报警。	符合
恶意代码防范	应采用免受恶意代码攻击的技术措施或主动免疫可信验证机制及时识别入侵和病毒行为，并将其有效阻断。	经核查，当前已部署华为云企业主机安全 HSS 企业版，病毒库版本为最新版本，更新时间为 2025-09-02，更新维护由华为云负责，可及时发现入侵和病毒行为，并将其有效阻断。	符合
可信验证	可基于可信根对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行可信验证，并在应用程序的关键执行环节进行动态可信验证，在检测到其可信性受到破坏后进行报警，并将验证结果形成审计记录送至安全管理中心。	未采用可信计算技术对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。	不符合
数据完整性	a)应采用校验技术或密码技术保证重要数据在传输过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、	经查看，服务器使用 SSH 协议进行加密传输，采用 hmac-sha2-256-ctm 技术，可以实现鉴别数据、重要配置数据在传输过程中的	符合

控制点	测评项	结果记录	符合情况
	重要配置数据、重要视频数据和重要个人信息等；	完整性。	
	b)应采用校验技术或密码技术保证重要数据在存储过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等。	经查看，系统未采用校验技术或密码技术实现鉴别数据、重要配置数据在存储过程中的完整性。	不符合
数据保密性	a)应采用密码技术保证重要数据在传输过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等；	经查看，服务器使用 SSH 协议进行加密传输，采用 AES_128_GCM 算法，可以实现鉴别数据、重要配置数据在传输过程中的保密性。	符合
	b)应采用密码技术保证重要数据在存储过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等。	通过 cat /etc/shadow 命令查看，服务器采用 SHA512 加盐加密技术将鉴别数据进行加密存储，实现鉴别数据在存储过程中的保密性，未采用密码技术实现配置数据在存储过程中的保密性。	部分符合
数据备份恢复	a)应提供重要数据的本地数据备份与恢复功能；	操作系统本身无需备份的业务数据和配置数据，此项不适用。	不适用
	b)应提供异地实时备份功能，利用通信网络将重要数据实时备份至备份场地；	操作系统本身无需备份的业务数据和配置数据，此项不适用。	不适用
	c)应提供重要数据处理系统的冗余，保证系统的高可用性。	经访谈及核查，服务器为虚拟化集群部署，并配置了虚拟机资源的自动分配，能够提供系统的高可用性保障。	符合
剩余信息保护	a)应保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除；	经查看，系统采用命令行方式进行管理，用户退出后会删除原来的用户目录，下次登录再重新生成，能够保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除。	符合
	b)应保证存有敏感数据的存储空	经查看，系统采用命令行方式进	符合

控制点	测评项	结果记录	符合情况
	间被释放或重新分配前得到完全清除。	行管理，操作生成的缓存文件关机自动删除，能够保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	
个人信息保护	a)应仅采集和保存业务必需的用户个人信息；	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
	b)应禁止未授权访问和非法使用用户个人信息。	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用

D.4.1.3.18 评标中间服务器

控制点	测评项	结果记录	符合情况
身份鉴别	a)应对登录的用户进行身份标识和鉴别，身份标识具有唯一性，身份鉴别信息具有复杂度要求并定期更换；	经核查，Linux 系统提供了登录模块，采用用户名和口令的方式对用户进行身份鉴别；通过 cat /etc/passwd 查看用户列表，用户名具有唯一性，系统用户使用 root 进行管理，通过/etc/login.defs 查看，口令策略如下：密码过期时间：90 天；最小密码长度：5 个字符；密码最短存留期：0 天；密码过期提示：7 天；通过 cat /etc/security/pwquality.conf 命令查看，minlen = 8、lcredit=-1、ucrcedit=-1、dcredit=-1、ocredit=-1，口令最小长度为 8 位，且口令至少包含一个大写字母、一个小写字母、一个数字、一个特殊字符，已配置口令复杂度策略；系统已禁用 chage 命令，访谈系统管理员，管理员已每 3 个月更换一次口令。	符合
	b)应具有登录失败处理功能，应	经核查，通过查看/etc/pam.d/syst	符合

控制点	测评项	结果记录	符合情况
	配置并启用结束会话、限制非法登录次数和当登录连接超时自动退出等相关措施;	em-auth 和/etc/pam.d/sshd 配置文件, auth required pam_tally2.so deny=3 unlock_time=300 even_deny_root root_unlock_time=300, 账户登录失败 3 次锁定 300 秒, 系统已配置登录失败处理策略; 通过 cat /etc/profile 命令查看, TMOUT=600, 系统已配置登录连接超时 600 秒自动退出策略。	
	c)当进行远程管理时, 应采取必要措施防止鉴别信息在网络传输过程中被窃听;	通过systemctl grep running 命令, 查看当前正在运行的服务, 系统未开启 Telnet 服务, 开启了 sshd.service 服务, 仅允许使用 SSH 协议进行远程管理, 服务器采用 AES_128_GCM 技术进行加密, 可实现鉴别信息在网络中加密传输。	符合
	d)应采用口令、密码技术、生物技术等两种或两种以上组合的鉴别技术对用户进行身份鉴别, 且其中一种鉴别技术至少应使用密码技术来实现。	经查看, 登录系统仅采用用户名和口令进行身份鉴别, 未采用双因子认证对用户身份进行鉴别。	不符合
访问控制	a)应对登录的用户分配账户和权限;	经核查/etc/passwd 和/etc/shadow 文件, 已对登录系统的用户分配了 root 等账户, 并分配了相应的权限。	符合
	b)应重命名或删除默认账户, 修改默认账户的默认口令;	经查看, 系统采用 root 账户进行管理, 未重命名默认账户, 但对默认账户自行设置了口令。	部分符合
	c)应及时删除或停用多余的、过期的账户, 避免共享账户的存在;	经核查/etc/shadow 文件, 系统账户中不存在多余的、过期的账户, 账户由专人管理, 不存在共享账户。	符合
	d)应授予管理用户所需的最小权限, 实现管理用户的权限分离;	经查看, 系统采用 root 账户进行管理, 未配置安全管理员、审计管理员等账户, 未实现管理用户	不符合

控制点	测评项	结果记录	符合情况
		的权限分离。	
	e)应由授权主体配置访问控制策略，访问控制策略规定主体对客体的访问规则；	经查看，系统未配置安全管理员对访问控制策略进行配置。	不符合
	f)访问控制的粒度应达到主体为用户级或进程级，客体为文件、数据库表级；	经查看，服务器访问控制粒度可达到主体为用户级，客体为文件级别。	符合
	g)应对重要主体和客体设置安全标记，并控制主体对有安全标记信息资源的访问。	经核查，系统未采取技术措施实现基于安全标记的强制访问控制功能。	不符合
安全审计	a)应启用安全审计功能，审计覆盖到每个用户，对重要的用户行为和重要安全事件进行审计；	通过命令 <code>service auditd status</code> 、 <code>service rsyslog status</code> 查看审计功能状态，服务器系统本身已开启了 <code>auditd</code> 服务和 <code>rsyslog</code> 服务，为用户操作和重要安全事件提供审计，审计范围覆盖到所有系统账户。	符合
	b)审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息；	查看 <code>var/logs</code> 下的审计日志文件，审计记录内容包括用户操作时间、操作进程 ID、操作内容、操作结果等信息。	符合
	c)应对审计记录进行保护，定期备份，避免受到未预期的删除、修改或覆盖等；	经核查，服务器审计日志已通过配置上传至华为云云日志服务 L TS 中，可对审计记录进行保护，能够查看 2025 年 3 月 1 日到 2025 年 9 月 2 日的审计记录，日志保存时间为 6 个月以上，可避免审计记录受到未预期的删除、修改或覆盖等。	符合
	d)应对审计进程进行保护，防止未经授权的中断。	经查看，系统启未采取措施对 <code>rsyslog</code> 进程进行保护，无法防止未经授权的中断。	不符合
入侵防范	a)应遵循最小安装的原则，仅安装需要的组件和应用程序；	经查看，操作系统为 CentOS Linux release 7.4.1708 (Core)，通过 <code>rpm -qa sort</code> 命令查看，系统	符合

控制点	测评项	结果记录	符合情况
		实现了最小化安装，仅安装了与业务相关的组件和应用程序。	
	b)应关闭不需要的系统服务、默认共享和高危端口；	通过 service 命令和 netstat -nltp 命令查看，开启的服务和端口均为业务需要，通过 show mount -e 命令查看，Linux 无共享文件。	符合
	c)应通过设定终端接入方式或网络地址范围对通过网络进行管理的管理终端进行限制；	查看/etc/hosts.allow 和/etc/hosts.deny 系统配置文件，服务器本地未对接入方式或远程网络访问地址进行限制，但系统仅在内部可控网络进行管理。	不符合
	d)应提供数据有效性检验功能，保证通过人机接口输入或通过通信接口输入的内容符合系统设定要求；	依据 GB/T 28448-2019 《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
	e)应能发现可能存在的已知漏洞，并在经过充分测试评估后，及时修补漏洞；	经访谈和查看，租户购买了华为云企业主机安全 HSS 企业版，华为云提供了漏洞自动检测并提供了修复方案；租户已每天对系统进行漏洞扫描并修补了漏洞。当前提供了《漏洞扫描记录》，包括时间、漏洞等情况、检测结果和检测结果分析等内容。	符合
	f)应能够检测到对重要节点进行入侵的行为，并在发生严重入侵事件时提供报警。	经核查，当前已部署华为云企业主机安全 HSS 企业版，可对服务器入侵行为进行检测，该设备入侵防御特征库版本为最新版本，更新时间为 2025-09-02，更新维护由华为云负责，能够检测到对重要节点进行入侵的行为，并通过手机短信（138****5671）的方式进行主动报警。	符合
恶意代码防范	应采用免受恶意代码攻击的技术措施或主动免疫可信验证机制及时识别入侵和病毒行为，并将其有效阻断。	经核查，当前已部署华为云企业主机安全 HSS 企业版，病毒库版本为最新版本，更新时间为 2025-09-02，更新维护由华为云负责，	符合

控制点	测评项	结果记录	符合情况
		可及时发现入侵和病毒行为，并将其有效阻断。	
可信验证	可基于可信根对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行可信验证，并在应用程序的关键执行环节进行动态可信验证，在检测到其可信性受到破坏后进行报警，并将验证结果形成审计记录送至安全管理中心。	未采用可信计算技术对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。	不符合
数据完整性	a)应采用校验技术或密码技术保证重要数据在传输过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等；	经查看，服务器使用 SSH 协议进行加密传输，采用 hmac-sha2-256-ctm 技术，可以实现鉴别数据、重要配置数据在传输过程中的完整性。	符合
	b)应采用校验技术或密码技术保证重要数据在存储过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等。	经查看，系统未采用校验技术或密码技术实现鉴别数据、重要配置数据在存储过程中的完整性。	不符合
数据保密性	a)应采用密码技术保证重要数据在传输过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等；	经查看，服务器使用 SSH 协议进行加密传输，采用 AES_128_GCM 算法，可以实现鉴别数据、重要配置数据在传输过程中的保密性。	符合
	b)应采用密码技术保证重要数据在存储过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等。	通过 cat /etc/shadow 命令查看，服务器采用 SHA512 加盐加密技术将鉴别数据进行加密存储，实现鉴别数据在存储过程中的保密性，未采用密码技术实现配置数据在存储过程中的保密性。	部分符合
数据备份恢复	a)应提供重要数据的本地数据备份与恢复功能；	操作系统本身无需备份的业务数据和配置数据，此项不适用。	不适用

控制点	测评项	结果记录	符合情况
	b)应提供异地实时备份功能，利用通信网络将重要数据实时备份至备份场地；	操作系统本身无需备份的业务数据和配置数据，此项不适用。	不适用
	c)应提供重要数据处理系统的热冗余，保证系统的高可用性。	经访谈及核查，服务器为虚拟化集群部署，并配置了虚拟机资源的自动分配，能够提供系统的高可用性保障。	符合
剩余信息保护	a)应保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除；	经查看，系统采用命令行方式进行管理，用户退出后会删除原来的用户目录，下次登录再重新生成，能够保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除。	符合
	b)应保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	经查看，系统采用命令行方式进行管理，操作生成的缓存文件关机自动删除，能够保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	符合
个人信息保护	a)应仅采集和保存业务必需的用户个人信息；	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
	b)应禁止未授权访问和非法使用用户个人信息。	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用

D.4.1.3.19 项目 1-不见面大厅服务器

控制点	测评项	结果记录	符合情况
身份鉴别	a)应对登录的用户进行身份标识和鉴别，身份标识具有唯一性，身份鉴别信息具有复杂度要求并定期更换；	经核查，Linux 系统提供了登录模块，采用用户名和口令的方式对用户进行身份鉴别；通过 cat /etc/passwd 查看用户列表，用户名具有唯一性，系统用户使用 root 进行管理，通过/etc/login.defs	符合

控制点	测评项	结果记录	符合情况
		查看，口令策略如下：密码过期时间：90 天；最小密码长度：5 个字符；密码最短存留期：0 天；密码过期提示：7 天；通过 cat /etc/security/pwquality.conf 命令查看，minlen = 8、lcredit=-1、ucrcedit=-1、dcredit=-1、ocredit=-1，口令最小长度为 8 位，且口令至少包含一个大写字母、一个小写字母、一个数字、一个特殊字符，已配置口令复杂度策略；系统已禁用 chage 命令，访谈系统管理员，管理员已每 3 个月更换一次口令。	
	b)应具有登录失败处理功能，应配置并启用结束会话、限制非法登录次数和当登录连接超时自动退出等相关措施；	经核查，通过查看/etc/pam.d/system-auth 和/etc/pam.d/sshd 配置文件，auth required pam_tally2.so deny=3 unlock_time=300 even_deny_root root_unlock_time=300，账户登录失败 3 次锁定 300 秒，系统已配置登录失败处理策略；通过 cat /etc/profile 命令查看，TMOUT=600，系统已配置登录连接超时 600 秒自动退出策略。	符合
	c)当进行远程管理时，应采取必要措施防止鉴别信息在网络传输过程中被窃听；	通过systemctl grep running 命令，查看当前正在运行的服务，系统未开启 Telnet 服务，开启了 sshd.service 服务，仅允许使用 SSH 协议进行远程管理,服务器采用 AES_128_GCM 技术进行加密，可实现鉴别信息在网络中加密传输。	符合
	d)应采用口令、密码技术、生物技术等两种或两种以上组合的鉴别技术对用户进行身份鉴别，且其中一种鉴别技术至少应使用密码技术来实现。	经查看，登录系统仅采用用户名和口令进行身份鉴别，未采用双因子认证对用户身份进行鉴别。	不符合

控制点	测评项	结果记录	符合情况
访问控制	a)应对登录的用户分配账户和权限；	经核查/etc/passwd 和/etc/shadow 文件，已对登录系统的用户分配了 root 等账户，并分配了相应的权限。	符合
	b)应重命名或删除默认账户，修改默认账户的默认口令；	经查看，系统采用 root 账户进行管理，未重命名默认账户，但对默认账户自行设置了口令。	部分符合
	c)应及时删除或停用多余的、过期的账户，避免共享账户的存在；	经核查/etc/shadow 文件，系统账户中不存在多余的、过期的账户，账户由专人管理，不存在共享账户。	符合
	d)应授予管理用户所需的最小权限，实现管理用户的权限分离；	经查看，系统采用 root 账户进行管理，未配置安全管理员、审计管理员等账户，未实现管理用户的权限分离。	不符合
	e)应由授权主体配置访问控制策略，访问控制策略规定主体对客体的访问规则；	经查看，系统未配置安全管理员对访问控制策略进行配置。	不符合
	f)访问控制的粒度应达到主体为用户级或进程级，客体为文件、数据库表级；	经查看，服务器访问控制粒度可达到主体为用户级，客体为文件级别。	符合
	g)应对重要主体和客体设置安全标记，并控制主体对有安全标记信息资源的访问。	经核查，系统未采取技术措施实现基于安全标记的强制访问控制功能。	不符合
安全审计	a)应启用安全审计功能，审计覆盖到每个用户，对重要的用户行为和重要安全事件进行审计；	通过命令 service auditd status、service rsyslog status 查看审计功能状态，服务器系统本身已开启了 auditd 服务和 rsyslog 服务，为用户操作和重要安全事件提供审计，审计范围覆盖到所有系统账户。	符合
	b)审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息；	查看 var/logs 下的审计日志文件，审计记录内容包括用户操作时间、操作进程 ID、操作内容、操作结果等信息。	符合

控制点	测评项	结果记录	符合情况
	c)应对审计记录进行保护，定期备份，避免受到未预期的删除、修改或覆盖等；	经核查，服务器审计日志已通过配置上传至华为云云日志服务 LTS 中，可对审计记录进行保护，能够查看 2025 年 3 月 1 日到 2025 年 9 月 2 日的审计记录，日志保存时间为 6 个月以上，可避免审计记录受到未预期的删除、修改或覆盖等。	符合
	d)应对审计进程进行保护，防止未经授权的中断。	经查看，系统启未采取措施对 rsyslog 进程进行保护，无法防止未经授权的中断。	不符合
入侵防范	a)应遵循最小安装的原则，仅安装需要的组件和应用程序；	经查看，操作系统为 CentOS Linux release 7.4.1708 (Core)，通过 rpm -qa sort 命令查看，系统实现了最小化安装，仅安装了与业务相关的组件和应用程序。	符合
	b)应关闭不需要的系统服务、默认共享和高危端口；	通过 service 命令和 netstat -nltp 命令查看，开启的服务和端口均为业务需要，通过 show mount -e 命令查看，Linux 无共享文件。	符合
	c)应通过设定终端接入方式或网络地址范围对通过网络进行管理的管理终端进行限制；	查看/etc/hosts.allow 和/etc/hosts.deny 系统配置文件，服务器本地未对接入方式或远程网络访问地址进行限制，但系统仅在内部可控网络进行管理。	不符合
	d)应提供数据有效性检验功能，保证通过人机接口输入或通过通信接口输入的内容符合系统设定要求；	依据 GB/T 28448-2019 《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
	e)应能发现可能存在的已知漏洞，并在经过充分测试评估后，及时修补漏洞；	经访谈和查看，租户购买了华为云企业主机安全 HSS 企业版，华为云提供了漏洞自动检测并提供了修复方案；租户已每天对系统进行漏洞扫描并修补了漏洞。当前提供了《漏洞扫描记录》，包括时间、漏洞等情况、检测结果	符合

控制点	测评项	结果记录	符合情况
		和检测结果分析等内容。	
	f)应能够检测到对重要节点进行入侵的行为，并在发生严重入侵事件时提供报警。	经核查，当前已部署华为云企业主机安全 HSS 企业版，可对服务器入侵行为进行检测，该设备入侵防御特征库版本为最新版本，更新时间为 2025-09-02，更新维护由华为云负责，能够检测到对重要节点进行入侵的行为，并通过手机短信（138****5671）的方式进行主动报警。	符合
恶意代码防范	应采用免受恶意代码攻击的技术措施或主动免疫可信验证机制及时识别入侵和病毒行为，并将其有效阻断。	经核查，当前已部署华为云企业主机安全 HSS 企业版，病毒库版本为最新版本，更新时间为 2025-09-02，更新维护由华为云负责，可及时发现入侵和病毒行为，并将其有效阻断。	符合
可信验证	可基于可信根对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行可信验证，并在应用程序的关键执行环节进行动态可信验证，在检测到其可信性受到破坏后进行报警，并将验证结果形成审计记录送至安全管理中心。	未采用可信计算技术对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。	不符合
数据完整性	a)应采用校验技术或密码技术保证重要数据在传输过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等；	经查看，服务器使用 SSH 协议进行加密传输，采用 hmac-sha2-256-etm 技术，可以实现鉴别数据、重要配置数据在传输过程中的完整性。	符合
	b)应采用校验技术或密码技术保证重要数据在存储过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等。	经查看，系统未采用校验技术或密码技术实现鉴别数据、重要配置数据在存储过程中的完整性。	不符合

控制点	测评项	结果记录	符合情况
数据保密性	a)应采用密码技术保证重要数据在传输过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等；	经查看，服务器使用 SSH 协议进行加密传输，采用 AES_128_GCM 算法，可以实现鉴别数据、重要配置数据在传输过程中的保密性。	符合
	b)应采用密码技术保证重要数据在存储过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等。	通过 cat /etc/shadow 命令查看，服务器采用 SHA512 加盐加密技术将鉴别数据进行加密存储，实现鉴别数据在存储过程中的保密性，未采用密码技术实现配置数据在存储过程中的保密性。	部分符合
数据备份恢复	a)应提供重要数据的本地数据备份与恢复功能；	操作系统本身无需备份的业务数据和配置数据，此项不适用。	不适用
	b)应提供异地实时备份功能，利用通信网络将重要数据实时备份至备份场地；	操作系统本身无需备份的业务数据和配置数据，此项不适用。	不适用
	c)应提供重要数据处理系统的热冗余，保证系统的高可用性。	经访谈及核查，服务器为虚拟化集群部署，并配置了虚拟机资源的自动分配，能够提供系统的高可用性保障。	符合
剩余信息保护	a)应保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除；	经查看，系统采用命令行方式进行管理，用户退出后会删除原来的用户目录，下次登录再重新生成，能够保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除。	符合
	b)应保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	经查看，系统采用命令行方式进行管理，操作生成的缓存文件关机自动删除，能够保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	符合
个人信息保护	a)应仅采集和保存业务必需的用户个人信息；	依据 GB/T 28448-2019 《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用

控制点	测评项	结果记录	符合情况
	b)应禁止未授权访问和非法使用用户个人信息。	依据 GB/T 28448-2019 《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用

D.4.1.3.20 项目 1-新点 e 交易推送服务 2.0 前置机

控制点	测评项	结果记录	符合情况
身份鉴别	a)应对登录的用户进行身份标识和鉴别，身份标识具有唯一性，身份鉴别信息具有复杂度要求并定期更换；	经核查，Linux 系统提供了登录模块，采用用户名和口令的方式对用户进行身份鉴别；通过 cat /etc/passwd 查看用户列表，用户名具有唯一性，系统用户使用 root 进行管理，通过/etc/login.defs 查看，口令策略如下：密码过期时间：90 天；最小密码长度：5 个字符；密码最短存留期：0 天；密码过期提示：7 天；通过 cat /etc/security/pwquality.conf 命令查看，minlen = 8、lcredit=-1、ucrcedit=-1、dcredit=-1、ocredit=-1，口令最小长度为 8 位，且口令至少包含一个大写字母、一个小写字母、一个数字、一个特殊字符，已配置口令复杂度策略；系统已禁用 chage 命令，访谈系统管理员，管理员已每 3 个月更换一次口令。	符合
	b)应具有登录失败处理功能，应配置并启用结束会话、限制非法登录次数和当登录连接超时自动退出等相关措施；	经核查，通过查看/etc/pam.d/system-auth 和/etc/pam.d/sshd 配置文件，auth required pam_tally2.sodeny=3 unlock_time=300 even_deny_root root_unlock_time=300，账户登录失败 3 次锁定 300 秒，系统已配置登录失败处理策略；通过 cat /etc/profile 命令查看，TMOUT=600，系统已配置登录连接超时 600 秒自动退出策略。	符合

控制点	测评项	结果记录	符合情况
	c)当进行远程管理时，应采取必要措施防止鉴别信息在网络传输过程中被窃听；	通过systemctl grep running 命令，查看当前正在运行的服务，系统未开启 Telnet 服务，开启了 sshd.service 服务，仅允许使用 SSH 协议进行远程管理,服务器采用 AES_128_GCM 技术进行加密，可实现鉴别信息在网络中加密传输。	符合
	d)应采用口令、密码技术、生物技术等两种或两种以上组合的鉴别技术对用户进行身份鉴别，且其中一种鉴别技术至少应使用密码技术来实现。	经查看，登录系统仅采用用户名和口令进行身份鉴别，未采用双因子认证对用户身份进行鉴别。	不符合
访问控制	a)应对登录的用户分配账户和权限；	经核查/etc/passwd 和/etc/shadow 文件，已对登录系统的用户分配了 root 等账户，并分配了相应的权限。	符合
	b)应重命名或删除默认账户，修改默认账户的默认口令；	经查看，系统采用 root 账户进行管理，未重命名默认账户，但对默认账户自行设置了口令。	部分符合
	c)应及时删除或停用多余的、过期的账户，避免共享账户的存在；	经核查/etc/shadow 文件，系统账户中不存在多余的、过期的账户，账户由专人管理，不存在共享账户。	符合
	d)应授予管理用户所需的最小权限，实现管理用户的权限分离；	经查看，系统采用 root 账户进行管理，未配置安全管理员、审计管理员等账户，未实现管理用户的权限分离。	不符合
	e)应由授权主体配置访问控制策略，访问控制策略规定主体对客体的访问规则；	经查看，系统未配置安全管理员对访问控制策略进行配置。	不符合
	f)访问控制的粒度应达到主体为用户级或进程级，客体为文件、数据库表级；	经查看，服务器访问控制粒度可达到主体为用户级，客体为文件级别。	符合
	g)应对重要主体和客体设置安全	经核查，系统未采取技术措施实	不符合

控制点	测评项	结果记录	符合情况
	标记，并控制主体对有安全标记信息资源的访问。	现基于安全标记的强制访问控制功能。	
安全审计	a)应启用安全审计功能，审计覆盖到每个用户，对重要的用户行为和重要安全事件进行审计；	通过命令 <code>service auditd status</code> 、 <code>service rsyslog status</code> 查看审计功能状态，服务器系统本身已开启了 <code>auditd</code> 服务和 <code>rsyslog</code> 服务，为用户操作和重要安全事件提供审计，审计范围覆盖到所有系统账户。	符合
	b)审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息；	查看 <code>var/logs</code> 下的审计日志文件，审计记录内容包括用户操作时间、操作进程 ID、操作内容、操作结果等信息。	符合
	c)应对审计记录进行保护，定期备份，避免受到未预期的删除、修改或覆盖等；	经核查，服务器审计日志已通过配置上传至华为云云日志服务 L TS 中，可对审计记录进行保护，能够查看 2025 年 3 月 1 日到 2025 年 9 月 2 日的审计记录，日志保存时间为 6 个月以上，可避免审计记录受到未预期的删除、修改或覆盖等。	符合
	d)应对审计进程进行保护，防止未经授权的中断。	经查看，系统启未采取措施对 <code>rsyslog</code> 进程进行保护，无法防止未经授权的中断。	不符合
入侵防范	a)应遵循最小安装的原则，仅安装需要的组件和应用程序；	经查看，操作系统为 CentOS Linux release 7.4.1708 (Core)，通过 <code>rpm -qa sort</code> 命令查看，系统实现了最小化安装，仅安装了与业务相关的组件和应用程序。	符合
	b)应关闭不需要的系统服务、默认共享和高危端口；	通过 <code>service</code> 命令和 <code>netstat -nltp</code> 命令查看，开启的服务和端口均为业务需要，通过 <code>show mount -e</code> 命令查看，Linux 无共享文件。	符合
	c)应通过设定终端接入方式或网络地址范围对通过网络进行管	查看 <code>/etc/hosts.allow</code> 和 <code>/etc/hosts.deny</code> 系统配置文件，服务器本地	不符合

控制点	测评项	结果记录	符合情况
	理的管理终端进行限制；	未对接入方式或远程网络访问地址进行限制，但系统仅在内部可控网络进行管理。	
	d)应提供数据有效性检验功能，保证通过人机接口输入或通过通信接口输入的内容符合系统设定要求；	依据 GB/T 28448-2019 《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
	e)应能发现可能存在的已知漏洞，并在经过充分测试评估后，及时修补漏洞；	经访谈和查看，租户购买了华为云企业主机安全 HSS 企业版，华为云提供了漏洞自动检测并提供了修复方案；租户已每天对系统进行漏洞扫描并修补了漏洞。当前提供了《漏洞扫描记录》，包括时间、漏洞等情况、检测结果和检测结果分析等内容。	符合
	f)应能够检测到对重要节点进行入侵的行为，并在发生严重入侵事件时提供报警。	经核查，当前已部署华为云企业主机安全 HSS 企业版，可对服务器入侵行为进行检测，该设备入侵防御特征库版本为最新版本，更新时间为 2025-09-02，更新维护由华为云负责，能够检测到对重要节点进行入侵的行为，并通过手机短信 (138****5671) 的方式进行主动报警。	符合
恶意代码防范	应采用免受恶意代码攻击的技术措施或主动免疫可信验证机制及时识别入侵和病毒行为，并将其有效阻断。	经核查，当前已部署华为云企业主机安全 HSS 企业版，病毒库版本为最新版本，更新时间为 2025-09-02，更新维护由华为云负责，可及时发现入侵和病毒行为，并将其有效阻断。	符合
可信验证	可基于可信根对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行可信验证，并在应用程序的关键执行环节进行动态可信验证，在检测到其可信性受到破坏后进行报警，并将验证结果形成审计记录	未采用可信计算技术对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。	不符合

控制点	测评项	结果记录	符合情况
	送至安全管理中心。		
数据完整性	a)应采用校验技术或密码技术保证重要数据在传输过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等；	经查看，服务器使用 SSH 协议进行加密传输，采用 hmac-sha2-256-ctm 技术，可以实现鉴别数据、重要配置数据在传输过程中的完整性。	符合
	b)应采用校验技术或密码技术保证重要数据在存储过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等。	经查看，系统未采用校验技术或密码技术实现鉴别数据、重要配置数据在存储过程中的完整性。	不符合
数据保密性	a)应采用密码技术保证重要数据在传输过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等；	经查看，服务器使用 SSH 协议进行加密传输，采用 AES_128_GCM 算法，可以实现鉴别数据、重要配置数据在传输过程中的保密性。	符合
	b)应采用密码技术保证重要数据在存储过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等。	通过 cat /etc/shadow 命令查看，服务器采用 SHA512 加盐加密技术将鉴别数据进行加密存储，实现鉴别数据在存储过程中的保密性，未采用密码技术实现配置数据在存储过程中的保密性。	部分符合
数据备份恢复	a)应提供重要数据的本地数据备份与恢复功能；	操作系统本身无需备份的业务数据和配置数据，此项不适用。	不适用
	b)应提供异地实时备份功能，利用通信网络将重要数据实时备份至备份场地；	操作系统本身无需备份的业务数据和配置数据，此项不适用。	不适用
	c)应提供重要数据处理系统的热冗余，保证系统的高可用性。	经访谈及核查，服务器为虚拟化集群部署，并配置了虚拟机资源的自动分配，能够提供系统的高可用性保障。	符合
剩余信息保护	a)应保证鉴别信息所在的存储空间被释放或重新分配前得到完	经查看，系统采用命令行方式进行管理，用户退出后会删除原来	符合

控制点	测评项	结果记录	符合情况
	全清除；	的用户目录，下次登录再重新生成，能够保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除。	符合
	b)应保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	经查看，系统采用命令行方式进行管理，操作生成的缓存文件关机自动删除，能够保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	
个人信息保护	a)应仅采集和保存业务必需的用户个人信息；	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
	b)应禁止未授权访问和非法使用用户个人信息。	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用

D.4.1.3.21 项目 1-开标大厅服务器

控制点	测评项	结果记录	符合情况
身份鉴别	a)应对登录的用户进行身份标识和鉴别，身份标识具有唯一性，身份鉴别信息具有复杂度要求并定期更换；	经核查，Linux 系统提供了登录模块，采用用户名和口令的方式对用户进行身份鉴别；通过 cat /etc/passwd 查看用户列表，用户名具有唯一性，系统用户使用 root 进行管理，通过/etc/login.defs 查看，口令策略如下：密码过期时间：90 天；最小密码长度：5 个字符；密码最短存留期：0 天；密码过期提示：7 天；通过 cat /etc/security/pwquality.conf 命令查看，minlen = 8、lcredit=-1、ucrcedit=-1、dcredit=-1、ocredit=-1，口令最小长度为 8 位，且口令至少包含一个大写字母、一个小写字母、一个数字、一个特殊字符，	符合

控制点	测评项	结果记录	符合情况
		已配置口令复杂度策略；系统已禁用 chage 命令，访谈系统管理员，管理员已每 3 个月更换一次口令。	
	b)应具有登录失败处理功能，应配置并启用结束会话、限制非法登录次数和当登录连接超时自动退出等相关措施；	经核查，通过查看/etc/pam.d/system-auth 和/etc/pam.d/sshd 配置文件，auth required pam_tally2.so deny=3 unlock_time=300 even_deny_root root_unlock_time=300，账户登录失败 3 次锁定 300 秒，系统已配置登录失败处理策略；通过 cat /etc/profile 命令查看，TMOUT=600，系统已配置登录连接超时 600 秒自动退出策略。	符合
	c)当进行远程管理时，应采取必要措施防止鉴别信息在网络传输过程中被窃听；	通过systemctl grep running 命令，查看当前正在运行的服务，系统未开启 Telnet 服务，开启了 sshd.service 服务，仅允许使用 SSH 协议进行远程管理，服务器采用 AES_128_GCM 技术进行加密，可实现鉴别信息在网络中加密传输。	符合
	d)应采用口令、密码技术、生物技术等两种或两种以上组合的鉴别技术对用户进行身份鉴别，且其中一种鉴别技术至少应使用密码技术来实现。	经查看，登录系统仅采用用户名和口令进行身份鉴别，未采用双因子认证对用户身份进行鉴别。	不符合
访问控制	a)应对登录的用户分配账户和权限；	经核查/etc/passwd 和/etc/shadow 文件，已对登录系统的用户分配了 root 等账户，并分配了相应的权限。	符合
	b)应重命名或删除默认账户，修改默认账户的默认口令；	经查看，系统采用 root 账户进行管理，未重命名默认账户，但对默认账户自行设置了口令。	部分符合
	c)应及时删除或停用多余的、过期的账户，避免共享账户的存	经核查/etc/shadow 文件，系统账户中不存在多余的、过期的账	符合

控制点	测评项	结果记录	符合情况
	在；	户，账户由专人管理，不存在共享账户。	
	d)应授予管理用户所需的最小权限，实现管理用户的权限分离；	经查看，系统采用 root 账户进行管理，未配置安全管理员、审计管理员等账户，未实现管理用户的权限分离。	不符合
	e)应由授权主体配置访问控制策略，访问控制策略规定主体对客体的访问规则；	经查看，系统未配置安全管理员对访问控制策略进行配置。	不符合
	f)访问控制的粒度应达到主体为用户级或进程级，客体为文件、数据库表级；	经查看，服务器访问控制粒度可达到主体为用户级，客体为文件级别。	符合
	g)应对重要主体和客体设置安全标记，并控制主体对有安全标记信息资源的访问。	经核查，系统未采取技术措施实现基于安全标记的强制访问控制功能。	不符合
安全审计	a)应启用安全审计功能，审计覆盖到每个用户，对重要的用户行为和重要安全事件进行审计；	通过命令 service auditd status、service rsyslog status 查看审计功能状态，服务器系统本身已开启了 auditd 服务和 rsyslog 服务，为用户操作和重要安全事件提供审计，审计范围覆盖到所有系统账户。	符合
	b)审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息；	查看 var/logs 下的审计日志文件，审计记录内容包括用户操作时间、操作进程 ID、操作内容、操作结果等信息。	符合
	c)应对审计记录进行保护，定期备份，避免受到未预期的删除、修改或覆盖等；	经核查，服务器审计日志已通过配置上传至华为云云日志服务 LTS 中，可对审计记录进行保护，能够查看 2025 年 3 月 1 日到 2025 年 9 月 2 日的审计记录，日志保存时间为 6 个月以上，可避免审计记录受到未预期的删除、修改或覆盖等。	符合
	d)应对审计进程进行保护，防止	经查看，系统启未采取措施对 rs	不符合

控制点	测评项	结果记录	符合情况
	未经授权的中断。	yslog 进程进行保护,无法防止未经授权的中断。	
入侵防范	a)应遵循最小安装的原则，仅安装需要的组件和应用程序；	经查看，操作系统为 CentOS Linux release 7.4.1708 (Core)，通过 rpm -qa sort 命令查看，系统实现了最小化安装，仅安装了与业务相关的组件和应用程序。	符合
	b)应关闭不需要的系统服务、默认共享和高危端口；	通过 service 命令和 netstat -nltp 命令查看，开启的服务和端口均为业务需要,通过 show mount -e 命令查看，Linux 无共享文件。	符合
	c)应通过设定终端接入方式或网络地址范围对通过网络进行管理的管理终端进行限制；	查看/etc/hosts.allow 和/etc/hosts.deny 系统配置文件，服务器本地未对接入方式或远程网络访问地址进行限制，但系统仅在内部可控网络进行管理。	不符合
	d)应提供数据有效性检验功能，保证通过人机接口输入或通过通信接口输入的内容符合系统设定要求；	依据 GB/T 28448-2019 《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
	e)应能发现可能存在的已知漏洞，并在经过充分测试评估后，及时修补漏洞；	经访谈和查看，租户购买了华为云企业主机安全 HSS 企业版，华为云提供了漏洞自动检测并提供了修复方案；租户已每天对系统进行漏洞扫描并修补了漏洞。当前提供了《漏洞扫描记录》，包括时间、漏洞等情况、检测结果和检测结果分析等内容。	符合
	f)应能够检测到对重要节点进行入侵的行为，并在发生严重入侵事件时提供报警。	经核查，当前已部署华为云企业主机安全 HSS 企业版，可对服务器入侵行为进行检测，该设备入侵防御特征库版本为最新版本，更新时间为 2025-09-02，更新维护由华为云负责，能够检测到对重要节点进行入侵的行为，并通过手机短信 (138****5671) 的方	符合

控制点	测评项	结果记录	符合情况
		式进行主动报警。	
恶意代码防范	应采用免受恶意代码攻击的技术措施或主动免疫可信验证机制及时识别入侵和病毒行为，并将其有效阻断。	经核查，当前已部署华为云企业主机安全 HSS 企业版，病毒库版本为最新版本，更新时间为 2025-09-02，更新维护由华为云负责，可及时发现入侵和病毒行为，并将其有效阻断。	符合
可信验证	可基于可信根对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行可信验证，并在应用程序的关键执行环节进行动态可信验证，在检测到其可信性受到破坏后进行报警，并将验证结果形成审计记录送至安全管理中心。	未采用可信计算技术对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。	不符合
数据完整性	a)应采用校验技术或密码技术保证重要数据在传输过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等；	经查看，服务器使用 SSH 协议进行加密传输，采用 hmac-sha2-256-ctm 技术，可以实现鉴别数据、重要配置数据在传输过程中的完整性。	符合
	b)应采用校验技术或密码技术保证重要数据在存储过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等。	经查看，系统未采用校验技术或密码技术实现鉴别数据、重要配置数据在存储过程中的完整性。	不符合
数据保密性	a)应采用密码技术保证重要数据在传输过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等；	经查看，服务器使用 SSH 协议进行加密传输，采用 AES_128_GCM 算法，可以实现鉴别数据、重要配置数据在传输过程中的保密性。	符合
	b)应采用密码技术保证重要数据在存储过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等。	通过 cat /etc/shadow 命令查看，服务器采用 SHA512 加盐加密技术将鉴别数据进行加密存储，实现鉴别数据在存储过程中的保	部分符合

控制点	测评项	结果记录	符合情况
		密性，未采用密码技术实现配置数据在存储过程中的保密性。	
数据备份恢复	a)应提供重要数据的本地数据备份与恢复功能；	操作系统本身无需备份的业务数据和配置数据，此项不适用。	不适用
	b)应提供异地实时备份功能，利用通信网络将重要数据实时备份至备份场地；	操作系统本身无需备份的业务数据和配置数据，此项不适用。	不适用
	c)应提供重要数据处理系统的热冗余，保证系统的高可用性。	经访谈及核查，服务器为虚拟化集群部署，并配置了虚拟机资源的自动分配，能够提供系统的高可用性保障。	符合
剩余信息保护	a)应保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除；	经查看，系统采用命令行方式进行管理，用户退出后会删除原来的用户目录，下次登录再重新生成，能够保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除。	符合
	b)应保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	经查看，系统采用命令行方式进行管理，操作生成的缓存文件关机自动删除，能够保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	符合
个人信息保护	a)应仅采集和保存业务必需的用户个人信息；	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
	b)应禁止未授权访问和非法使用用户个人信息。	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用

D.4.1.3.22 档案服务器

控制点	测评项	结果记录	符合情况
身份鉴	a)应对登录的用户进行身份标识	经核查，Linux 系统提供了登录	符合

控制点	测评项	结果记录	符合情况
别	和鉴别，身份标识具有唯一性，身份鉴别信息具有复杂度要求并定期更换；	模块，采用用户名和口令的方式对用户进行身份鉴别；通过 <code>cat /etc/passwd</code> 查看用户列表，用户名具有唯一性，系统用户使用 <code>root</code> 进行管理，通过 <code>/etc/login.defs</code> 查看，口令策略如下：密码过期时间：90 天；最小密码长度：5 个字符；密码最短存留期：0 天；密码过期提示：7 天；通过 <code>cat /etc/security/pwquality.conf</code> 命令查看， <code>minlen = 8</code> 、 <code>lcredit=-1</code> 、 <code>ucrcedit=-1</code> 、 <code>dcrcedit=-1</code> 、 <code>ocredit=-1</code> ，口令最小长度为 8 位，且口令至少包含一个大写字母、一个小写字母、一个数字、一个特殊字符，已配置口令复杂度策略；系统已禁用 <code>chage</code> 命令，访谈系统管理员，管理员已每 3 个月更换一次口令。	
	b)应具有登录失败处理功能，应配置并启用结束会话、限制非法登录次数和当登录连接超时自动退出等相关措施；	经核查，通过查看 <code>/etc/pam.d/system-auth</code> 和 <code>/etc/pam.d/sshd</code> 配置文件， <code>auth required pam_tally2.so deny=3 unlock_time=300 even_deny_root root_unlock_time=300</code> ，账户登录失败 3 次锁定 300 秒，系统已配置登录失败处理策略；通过 <code>cat /etc/profile</code> 命令查看， <code>TMOU=600</code> ，系统已配置登录连接超时 600 秒自动退出策略。	符合
	c)当进行远程管理时，应采取必要措施防止鉴别信息在网络传输过程中被窃听；	通过 <code>systemctl grep running</code> 命令，查看当前正在运行的服务，系统未开启 <code>Telnet</code> 服务，开启了 <code>sshd.service</code> 服务，仅允许使用 <code>SSH</code> 协议进行远程管理，服务器采用 <code>AES_128_GCM</code> 技术进行加密，可实现鉴别信息在网络中加密传输。	符合
	d)应采用口令、密码技术、生物	经查看，登录系统仅采用用户名	不符合

控制点	测评项	结果记录	符合情况
	技术等两种或两种以上组合的鉴别技术对用户进行身份鉴别,且其中一种鉴别技术至少应使用密码技术来实现。	和口令进行身份鉴别,未采用双因子认证对用户身份进行鉴别。	
访问控制	a)应对登录的用户分配账户和权限;	经核查/etc/passwd 和/etc/shadow 文件,已对登录系统的用户分配了 root 等账户,并分配了相应的权限。	符合
	b)应重命名或删除默认账户,修改默认账户的默认口令;	经查看,系统采用 root 账户进行管理,未重命名默认账户,但对默认账户自行设置了口令。	部分符合
	c)应及时删除或停用多余的、过期的账户,避免共享账户的存在;	经核查/etc/shadow 文件,系统账户中不存在多余的、过期的账户,账户由专人管理,不存在共享账户。	符合
	d)应授予管理用户所需的最小权限,实现管理用户的权限分离;	经查看,系统采用 root 账户进行管理,未配置安全管理员、审计管理员等账户,未实现管理用户的权限分离。	不符合
	e)应由授权主体配置访问控制策略,访问控制策略规定主体对客体的访问规则;	经查看,系统未配置安全管理员对访问控制策略进行配置。	不符合
	f)访问控制的粒度应达到主体为用户级或进程级,客体为文件、数据库表级;	经查看,服务器访问控制粒度可达到主体为用户级,客体为文件级别。	符合
	g)应对重要主体和客体设置安全标记,并控制主体对有安全标记信息资源的访问。	经核查,系统未采取技术措施实现基于安全标记的强制访问控制功能。	不符合
安全审计	a)应启用安全审计功能,审计覆盖到每个用户,对重要的用户行为和重要安全事件进行审计;	通过命令 service auditd status、service rsyslog status 查看审计功能状态,服务器系统本身已开启了 auditd 服务和 rsyslog 服务,为用户操作和重要安全事件提供审计,审计范围覆盖到所有系统账户。	符合

控制点	测评项	结果记录	符合情况
	b)审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息；	查看 var/logs 下的审计日志文件，审计记录内容包括用户操作时间、操作进程 ID、操作内容、操作结果等信息。	符合
	c)应对审计记录进行保护，定期备份，避免受到未预期的删除、修改或覆盖等；	经核查，服务器审计日志已通过配置上传至华为云云日志服务 LTS 中，可对审计记录进行保护，能够查看 2025 年 3 月 1 日到 2025 年 9 月 2 日的审计记录，日志保存时间为 6 个月以上，可避免审计记录受到未预期的删除、修改或覆盖等。	符合
	d)应对审计进程进行保护，防止未经授权的中断。	经查看，系统启未采取措施对 rsyslog 进程进行保护，无法防止未经授权的中断。	不符合
入侵防范	a)应遵循最小安装的原则，仅安装需要的组件和应用程序；	经查看，操作系统为 CentOS Linux release 7.4.1708 (Core)，通过 rpm -qa sort 命令查看，系统实现了最小化安装，仅安装了与业务相关的组件和应用程序。	符合
	b)应关闭不需要的系统服务、默认共享和高危端口；	通过 service 命令和 netstat -nltp 命令查看，开启的服务和端口均为业务需要，通过 show mount -e 命令查看，Linux 无共享文件。	符合
	c)应通过设定终端接入方式或网络地址范围对通过网络进行管理的管理终端进行限制；	查看/etc/hosts.allow 和/etc/hosts.deny 系统配置文件，服务器本地未对接入方式或远程网络访问地址进行限制，但系统仅在内部可控网络进行管理。	不符合
	d)应提供数据有效性检验功能，保证通过人机接口输入或通过通信接口输入的内容符合系统设定要求；	依据 GB/T 28448-2019 《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
	e)应能发现可能存在的已知漏洞，并在经过充分测试评估后，	经访谈和查看，租户购买了华为云企业主机安全 HSS 企业版，华	符合

控制点	测评项	结果记录	符合情况
	及时修补漏洞；	为云提供了漏洞自动检测并提供了修复方案；租户已每天对系统进行漏洞扫描并修补了漏洞。 当前提供了《漏洞扫描记录》，包括时间、漏洞等情况、检测结果和检测结果分析等内容。	符合
	f)应能够检测到对重要节点进行入侵的行为，并在发生严重入侵事件时提供报警。	经核查，当前已部署华为云企业主机安全 HSS 企业版，可对服务器入侵行为进行检测，该设备入侵防御特征库版本为最新版本，更新时间为 2025-09-02，更新维护由华为云负责，能够检测到对重要节点进行入侵的行为，并通过手机短信（138****5671）的方式进行主动报警。	
恶意代码防范	应采用免受恶意代码攻击的技术措施或主动免疫可信验证机制及时识别入侵和病毒行为，并将其有效阻断。	经核查，当前已部署华为云企业主机安全 HSS 企业版，病毒库版本为最新版本，更新时间为 2025-09-02，更新维护由华为云负责，可及时发现入侵和病毒行为，并将其有效阻断。	符合
可信验证	可基于可信根对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行可信验证，并在应用程序的关键执行环节进行动态可信验证，在检测到其可信性受到破坏后进行报警，并将验证结果形成审计记录送至安全管理中心。	未采用可信计算技术对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。	不符合
数据完整性	a)应采用校验技术或密码技术保证重要数据在传输过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等；	经查看，服务器使用 SSH 协议进行加密传输，采用 hmac-sha2-256-etm 技术，可以实现鉴别数据、重要配置数据在传输过程中的完整性。	符合
	b)应采用校验技术或密码技术保证重要数据在存储过程中的完	经查看，系统未采用校验技术或密码技术实现鉴别数据、重要配	不符合

控制点	测评项	结果记录	符合情况
	整性,包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等。	置数据在存储过程中的完整性。	
数据保密性	a)应采用密码技术保证重要数据在传输过程中的保密性,包括但不限于鉴别数据、重要业务数据和重要个人信息等;	经查看,服务器使用 SSH 协议进行加密传输,采用 AES_128_GCM 算法,可以实现鉴别数据、重要配置数据在传输过程中的保密性。	符合
	b)应采用密码技术保证重要数据在存储过程中的保密性,包括但不限于鉴别数据、重要业务数据和重要个人信息等。	通过 cat /etc/shadow 命令查看,服务器采用 SHA512 加盐加密技术将鉴别数据进行加密存储,实现鉴别数据在存储过程中的保密性,未采用密码技术实现配置数据在存储过程中的保密性。	部分符合
数据备份恢复	a)应提供重要数据的本地数据备份与恢复功能;	操作系统本身无需备份的业务数据和配置数据,此项不适用。	不适用
	b)应提供异地实时备份功能,利用通信网络将重要数据实时备份至备份场地;	操作系统本身无需备份的业务数据和配置数据,此项不适用。	不适用
	c)应提供重要数据处理系统的热冗余,保证系统的高可用性。	经访谈及核查,服务器为虚拟化集群部署,并配置了虚拟机资源的自动分配,能够提供系统的高可用性保障。	符合
剩余信息保护	a)应保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除;	经查看,系统采用命令行方式进行管理,用户退出后会删除原来的用户目录,下次登录再重新生成,能够保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除。	符合
	b)应保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	经查看,系统采用命令行方式进行管理,操作生成的缓存文件关机自动删除,能够保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	符合

控制点	测评项	结果记录	符合情况
个人信息保护	a)应仅采集和保存业务必需的用户个人信息；	依据 GB/T 28448-2019 《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
	b)应禁止未授权访问和非法使用用户个人信息。	依据 GB/T 28448-2019 《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用

D.4.1.3.23 运维终端-1

控制点	测评项	结果记录	符合情况
身份鉴别	a)应对登录的用户进行身份标识和鉴别，身份标识具有唯一性，身份鉴别信息具有复杂度要求并定期更换；	经核查，终端提供了登录模块对用户进行身份鉴别，身份鉴别方式为用户名和口令；系统无法新建同名账户，身份标识具有唯一性；查看本地安全策略，密码策略配置如下：密码必须符合复杂性要求：已禁用，密码长度最小值：0 个字符，密码最短使用期限：0 天，密码最长使用期限：42 天，强制密码历史：0 个记住的密码，账户属性中已勾选密码永不过期，未配置口令复杂度策略和口令定期更换策略；经访谈，当前管理用户口令长度超过 8 位，由数字、大写字母、小写字母和特殊符号组成。	部分符合
	b)应具有登录失败处理功能，应配置并启用结束会话、限制非法登录次数和当登录连接超时自动退出等相关措施；	经核查，查看本地安全策略-账户策略-账户锁定策略及个性化-锁屏界面-屏幕保护程序，终端未配置登录失败锁定策略及登录连接超时自动退出策略。	不符合
	c)当进行远程管理时，应采取必要措施防止鉴别信息在网络传输过程中被窃听；	终端未开启远程管理功能，仅本地可进行管理，此项不适用。	不适用
	d)应采用口令、密码技术、生物	经核查，终端仅采用用户名+口	不符合

控制点	测评项	结果记录	符合情况
	技术等两种或两种以上组合的鉴别技术对用户进行身份鉴别，且其中一种鉴别技术至少应使用密码技术来实现。	令方式进行登录管理，未采用两种或两种以上组合的鉴别技术对用户进行身份鉴别。	
访问控制	a)应对登录的用户分配账户和权限；	经核查，查看系统本地用户和组，系统采用 Administrator 账户进行统一管理，账户隶属于 Administrators 组，拥有管理员权限，登录用户和账户一一对应。	符合
	b)应重命名或删除默认账户，修改默认账户的默认口令；	经核查，终端存在默认账户 Administrator 未重命名或删除，但用户自行设置了口令，已禁用 guest 来宾账户。	部分符合
	c)应及时删除或停用多余的、过期的账户，避免共享账户的存在；	经核查，查看系统本地用户和组，终端配置了 Administrator 账户进行管理，不存在多余或过期账户，无共享账户。	符合
	d)应授予管理用户所需的最小权限，实现管理用户的权限分离；	经查看，终端采用 Administrator 账户进行统一管理，未限制 Administrator 账户的管理权限，未建立系统管理员、审计管理员和安全管理员账户，未实现管理用户的权限分离。	不符合
	e)应由授权主体配置访问控制策略，访问控制策略规定主体对客体的访问规则；	经核查，终端采用 Administrator 账户进行管理，未配置安全管理员账户对访问控制策略进行配置。	不符合
	f)访问控制的粒度应达到主体为用户级或进程级，客体为文件、数据库表级；	经核查，终端由管理员依据具体业务需求配置用户对文件的访问规则，关键系统文件夹权限设置合理，访问控制的粒度主体达到用户级，客体达到文件级。	符合
	g)应对重要主体和客体设置安全标记，并控制主体对有安全标记信息资源的访问。	经核查，终端未对重要主体和客体设置安全标记，未实现通过安全标记控制主体对客体的访问。	不符合

控制点	测评项	结果记录	符合情况
安全审计	a)应启用安全审计功能，审计覆盖到每个用户，对重要的用户行为和重要安全事件进行审计；	经核查，终端默认开启了安全审计功能，查看事件查看器-Windows 日志，审计范围覆盖到所有系统用户，终端组策略中审核策略如下：审核策略更改：无审核；审核对象访问：无审核；审核目录服务器访问：无审核；审核特权使用：无审核；审核系统事件：无审核；审核账户管理：无审核；审核过程追踪：无审核；审核登录事件：无审核；审核账户登录事件：无审核；系统仅开启了默认审核策略，对 windows 日志、应用程序和服务日志进行审计，但未完善组策略的审核策略，部分审核策略不完善。	部分符合
	b)审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息；	经核查，查看事件查看器-Windows 日志，终端审计记录包括：来源、记录时间、事件 ID、任务类别、级别、关键字、用户、计算机、操作代码等内容。	符合
	c)应对审计记录进行保护，定期备份，避免受到未预期的删除、修改或覆盖等；	经核查，终端审计记录仅在本地保存，查看日志属性，已勾选“按需要覆盖事件”；日志大小 20.00MB，可以对日志进行清除，且未配置日志审计系统或日志服务器将日志文件单独备份保存，无法避免受到未预期的删除、修改或覆盖等。	不符合
	d)应对审计进程进行保护，防止未经授权的中断。	经核查，终端为 Windows 系统，默认保护审计进程，无法直接中断该进程。	符合
入侵防范	a)应遵循最小安装的原则，仅安装需要的组件和应用程序；	经核查，查看操作系统属性，终端当前系统为 Windows 7 旗舰版（内部版本 7601: Service Pack 1），查看控制面板-程序和功能，操作系统实现最小化安装原	符合

控制点	测评项	结果记录	符合情况
		则，未安装其他与业务无关的组件或应用程序。	
	b)应关闭不需要的系统服务、默认共享和高危端口；	经核查，终端存在 C 盘、D 盘和 E 盘等不必要的默认共享，未关闭 135 和 445 等端口，未关闭 Remote Registry、Server 等不必要的服务。	不符合
	c)应通过设定终端接入方式或网络地址范围对通过网络进行管理的管理终端进行限制；	终端未开启远程管理功能，仅本地可进行管理，此项不适用。	不适用
	d)应提供数据有效性检验功能，保证通过人机接口输入或通过通信接口输入的内容符合系统设定要求；	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项目不适用。	不适用
	e)应能发现可能存在的已知漏洞，并在经过充分测试评估后，及时修补漏洞；	经访谈与查看，终端系统未定期进行漏洞扫描，无法及时发现可能存在的漏洞。	不符合
	f)应能够检测到对重要节点进行入侵的行为，并在发生严重入侵事件时提供报警。	经查看，系统安装了火绒安全软件，程序版本：6.0.6.6，特征库联网自动更新，最新更新时间：2025-08-13，更新时间在最近一个月，能够及时检测到对重要节点进行入侵的行为，并通过弹窗进行报警。	符合
恶意代码防范	应采用免受恶意代码攻击的技术措施或主动免疫可信验证机制及时识别入侵和病毒行为，并将其有效阻断。	经查看，系统安装了火绒安全软件，程序版本：6.0.6.6，病毒库联网自动更新，最新更新时间：2025-08-13，更新时间在最近一个月，能够及时识别入侵和病毒行为，并将其有效阻断。	符合
可信验证	可基于可信根对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行可信验证，并在应用程序的关键执行环节进行动态可信验证，在检测	未采用可信计算技术对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。	不符合

控制点	测评项	结果记录	符合情况
	到其可信性受到破坏后进行报警，并将验证结果形成审计记录送至安全管理中心。		
数据完整性	a)应采用校验技术或密码技术保证重要数据在传输过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等；	终端未开启远程管理功能，仅本地可进行管理，此项不适用。	不适用
	b)应采用校验技术或密码技术保证重要数据在存储过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等。	经核查，终端未采用校验技术或密码技术保证重要配置数据和鉴别数据在存储过程中的完整性。	不符合
数据保密性	a)应采用密码技术保证重要数据在传输过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等；	终端未开启远程管理功能，仅本地可进行管理，此项不适用。	不适用
	b)应采用密码技术保证重要数据在存储过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等。	经核查，终端仅对系统鉴别数据（口令）加密存储至 SAM 文件，采用 CNG BCrypt AES-256 算法进行加密存储，密码文件被窃取后无法显示明文密码，但未采用密码技术保证重要配置数据在存储过程中的保密性。	部分符合
数据备份恢复	a)应提供重要数据的本地数据备份与恢复功能；	操作系统中无需保存的业务信息和配置信息，此项不适用。	不适用
	b)应提供异地实时备份功能，利用通信网络将重要数据实时备份至备份场地；	操作系统中无需保存的业务信息和配置信息，此项不适用。	不适用
	c)应提供重要数据处理系统的热冗余，保证系统的高可用性。	该项要求一般针对服务器、交换机等重要数据处理系统，终端此项不适用。	不适用
剩余信	a)应保证鉴别信息所在的存储空	经核查，查看本地组策略，安全	符合

控制点	测评项	结果记录	符合情况
息保护	间被释放或重新分配前得到完全清除；	设置-本地策略-安全选项中“交互式登录：不显示上次登录 已启用”；开机不显示上次登录过的用户名信息，已对鉴别信息进行清除。	
	b)应保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	经核查，查看本地组策略，安全设置-本地策略-安全选项中“关机：清除虚拟内存页面 已启用”；可以保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	符合
个人信息保护	a)应仅采集和保存业务必需的用户个人信息；	因《信息安全技术 网络安全等级保护测评要求》（GB/T 28448-2019）中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
	b)应禁止未授权访问和非法使用用户个人信息。	因《信息安全技术 网络安全等级保护测评要求》（GB/T 28448-2019）中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用

D.4.1.3.24 运维终端-2

控制点	测评项	结果记录	符合情况
身份鉴别	a)应对登录的用户进行身份标识和鉴别，身份标识具有唯一性，身份鉴别信息具有复杂度要求并定期更换；	经核查，终端提供了登录模块对用户进行身份鉴别，身份鉴别方式为用户名和口令；系统无法新建同名账户，身份标识具有唯一性；查看本地安全策略，密码策略配置如下：密码必须符合复杂性要求：已禁用，密码长度最小值：0 个字符，密码最短使用期限：0 天，密码最长使用期限：4 2 天，强制密码历史：0 个记住的密码，账户属性中已勾选密码永不过期，未配置口令复杂度策略和口令定期更换策略；经访谈，当前管理用户口令长度超过 8	部分符合

控制点	测评项	结果记录	符合情况
		位, 由数字、大写字母、小写字母和特殊符号组成。	
	b)应具有登录失败处理功能, 应配置并启用结束会话、限制非法登录次数和当登录连接超时自动退出等相关措施;	经核查, 查看本地安全策略-账户策略-账户锁定策略及个性化-锁屏界面-屏幕保护程序, 终端未配置登录失败锁定策略及登录连接超时自动退出策略。	不符合
	c)当进行远程管理时, 应采取必要措施防止鉴别信息在网络传输过程中被窃听;	终端未开启远程管理功能, 仅本地可进行管理, 此项不适用。	不适用
	d)应采用口令、密码技术、生物技术等两种或两种以上组合的鉴别技术对用户进行身份鉴别, 且其中一种鉴别技术至少应使用密码技术来实现。	经核查, 终端仅采用用户名+口令方式进行登录管理, 未采用两种或两种以上组合的鉴别技术对用户进行身份鉴别。	不符合
访问控制	a)应对登录的用户分配账户和权限;	经核查, 查看系统本地用户和组, 系统采用 Administrator 账户进行统一管理, 账户隶属于 Administrators 组, 拥有管理员权限, 登录用户和账户一一对应。	符合
	b)应重命名或删除默认账户, 修改默认账户的默认口令;	经核查, 终端存在默认账户 Administrator 未重命名或删除, 但用户自行设置了口令, 已禁用 guest 来宾账户。	部分符合
	c)应及时删除或停用多余的、过期的账户, 避免共享账户的存在;	经核查, 查看系统本地用户和组, 终端配置了 Administrator 账户进行管理, 不存在多余或过期账户, 无共享账户。	符合
	d)应授予管理用户所需的最小权限, 实现管理用户的权限分离;	经查看, 终端采用 Administrator 账户进行统一管理, 未限制 Administrator 账户的管理权限, 未建立系统管理员、审计管理员和安全管理员账户, 未实现管理用户的权限分离。	不符合
	e)应由授权主体配置访问控制策	经核查, 终端采用 Administrator	不符合

控制点	测评项	结果记录	符合情况
	略，访问控制策略规定主体对客体的访问规则；	账户进行管理，未配置安全管理员账户对访问控制策略进行配置。	
	f)访问控制的粒度应达到主体为用户级或进程级，客体为文件、数据库表级；	经核查，终端由管理员依据具体业务需求配置用户对文件的访问规则，关键系统文件夹权限设置合理，访问控制的粒度主体达到用户级，客体达到文件级。	符合
	g)应对重要主体和客体设置安全标记，并控制主体对有安全标记信息资源的访问。	经核查，终端未对重要主体和客体设置安全标记，未实现通过安全标记控制主体对客体的访问。	不符合
安全审计	a)应启用安全审计功能，审计覆盖到每个用户，对重要的用户行为和重要安全事件进行审计；	经核查，终端默认开启了安全审计功能，查看事件查看器-Windows 日志，审计范围覆盖到所有系统用户，终端组策略中审核策略如下：审核策略更改：无审核；审核对象访问：无审核；审核目录服务器访问：无审核；审核特权使用：无审核；审核系统事件：无审核；审核账户管理：无审核；审核过程追踪：无审核；审核登录事件：无审核；审核账户登录事件：无审核；系统仅开启了默认审核策略，对 windows 日志、应用程序和服务日志进行审计，但未完善组策略的审核策略，部分审核策略不完善。	部分符合
	b)审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息；	经核查，查看事件查看器-Windows 日志，终端审计记录包括：来源、记录时间、事件 ID、任务类别、级别、关键字、用户、计算机、操作代码等内容。	符合
	c)应对审计记录进行保护，定期备份，避免受到未预期的删除、修改或覆盖等；	经核查，终端审计记录仅在本地保存，查看日志属性，已勾选“按需要覆盖事件”；日志大小 20.00MB，可以对日志进行清除，且未配置日志审计系统或日志服务器	不符合

控制点	测评项	结果记录	符合情况
		将日志文件单独备份保存，无法避免受到未预期的删除、修改或覆盖等。	
	d)应对审计进程进行保护，防止未经授权的中断。	经核查，终端为 Windows 系统，默认保护审计进程，无法直接中断该进程。	符合
入侵防范	a)应遵循最小安装的原则，仅安装需要的组件和应用程序；	经核查，查看操作系统属性，终端当前系统为 Windows 7 旗舰版（内部版本 7601: Service Pack 1），查看控制面板-程序和功能，操作系统实现最小化安装原则，未安装其他与业务无关的组件或应用程序。	符合
	b)应关闭不需要的系统服务、默认共享和高危端口；	经核查，终端存在 C 盘、D 盘和 E 盘等不必要的默认共享，未关闭 135 和 445 等端口，未关闭 Remote Registry、Server 等不必要的服务。	不符合
	c)应通过设定终端接入方式或网络地址范围对通过网络进行管理的管理终端进行限制；	终端未开启远程管理功能，仅本地可进行管理，此项不适用。	不适用
	d)应提供数据有效性检验功能，保证通过人机接口输入或通过通信接口输入的内容符合系统设定要求；	因《信息安全技术 网络安全等级保护测评要求》（GB/T 28448-2019）中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
	e)应能发现可能存在的已知漏洞，并在经过充分测试评估后，及时修补漏洞；	经访谈与查看，终端系统未定期进行漏洞扫描，无法及时发现可能存在的漏洞。	不符合
	f)应能够检测到对重要节点进行入侵的行为，并在发生严重入侵事件时提供报警。	经查看，系统安装了火绒安全软件，程序版本：6.0.6.6，特征库联网自动更新，最新更新时间：2025-08-13，更新时间在最近一个月，能够及时检测到对重要节点进行入侵的行为，并通过弹窗进行报警。	符合

控制点	测评项	结果记录	符合情况
恶意代码防范	应采用免受恶意代码攻击的技术措施或主动免疫可信验证机制及时识别入侵和病毒行为，并将其有效阻断。	经查看，系统安装了火绒安全软件，程序版本：6.0.6.6，病毒库联网自动更新，最新更新时间：2025-08-13，更新时间在最近一个月，能够及时识别入侵和病毒行为，并将其有效阻断。	符合
可信验证	可基于可信根对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行可信验证，并在应用程序的关键执行环节进行动态可信验证，在检测到其可信性受到破坏后进行报警，并将验证结果形成审计记录送至安全管理中心。	未采用可信计算技术对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。	不符合
数据完整性	a)应采用校验技术或密码技术保证重要数据在传输过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等；	终端未开启远程管理功能，仅本地可进行管理，此项不适用。	不适用
	b)应采用校验技术或密码技术保证重要数据在存储过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等。	经核查，终端未采用校验技术或密码技术保证重要配置数据和鉴别数据在存储过程中的完整性。	不符合
数据保密性	a)应采用密码技术保证重要数据在传输过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等；	终端未开启远程管理功能，仅本地可进行管理，此项不适用。	不适用
	b)应采用密码技术保证重要数据在存储过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等。	经核查，终端仅对系统鉴别数据（口令）加密存储至 SAM 文件，采用 CNG BCrypt AES-256 算法进行加密存储，密码文件被窃取后无法显示明文密码，但未采用密码技术保证重要配置数据在存储过程中的保密性。	部分符合

控制点	测评项	结果记录	符合情况
数据备份恢复	a)应提供重要数据的本地数据备份与恢复功能；	操作系统中无需保存的业务信息和配置信息，此项不适用。	不适用
	b)应提供异地实时备份功能，利用通信网络将重要数据实时备份至备份场地；	操作系统中无需保存的业务信息和配置信息，此项不适用。	不适用
	c)应提供重要数据处理系统的热冗余，保证系统的高可用性。	该项要求一般针对服务器、交换机等重要数据处理系统，终端此项不适用。	不适用
剩余信息保护	a)应保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除；	经核查，查看本地组策略，安全设置-本地策略-安全选项中“交互式登录：不显示上次登录 已启用”；开机不显示上次登录过的用户名信息，已对鉴别信息进行清除。	符合
	b)应保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	经核查，查看本地组策略，安全设置-本地策略-安全选项中“关机：清除虚拟内存页面 已启用”；可以保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	符合
个人信息保护	a)应仅采集和保存业务必需的用户个人信息；	因《信息安全技术 网络安全等级保护测评要求》（GB/T 28448-2019）中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
	b)应禁止未授权访问和非法使用用户个人信息。	因《信息安全技术 网络安全等级保护测评要求》（GB/T 28448-2019）中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用

D.4.1.3.25 业务终端-1

控制点	测评项	结果记录	符合情况
身份鉴别	a)应对登录的用户进行身份标识和鉴别，身份标识具有唯一性，身份鉴别信息具有复杂度要求	经核查，终端提供了登录模块对用户进行身份鉴别，身份鉴别方式为用户名和口令；系统无法新	部分符合

控制点	测评项	结果记录	符合情况
	并定期更换；	建同名账户，身份标识具有唯一性；查看本地安全策略，密码策略配置如下：密码必须符合复杂性要求：已禁用，密码长度最小值：0 个字符，密码最短使用期限：0 天，密码最长使用期限：42 天，强制密码历史：0 个记住的密码，账户属性中已勾选密码永不过期，未配置口令复杂度策略和口令定期更换策略；经访谈，当前管理用户口令长度超过 8 位，由数字、大写字母、小写字母和特殊符号组成。	
	b)应具有登录失败处理功能，应配置并启用结束会话、限制非法登录次数和当登录连接超时自动退出等相关措施；	经核查，查看本地安全策略-账户策略-账户锁定策略及个性化-锁屏界面-屏幕保护程序，终端未配置登录失败锁定策略及登录连接超时自动退出策略。	不符合
	c)当进行远程管理时，应采取必要措施防止鉴别信息在网络传输过程中被窃听；	终端未开启远程管理功能，仅本地可进行管理，此项不适用。	不适用
	d)应采用口令、密码技术、生物技术等两种或两种以上组合的鉴别技术对用户进行身份鉴别，且其中一种鉴别技术至少应使用密码技术来实现。	经核查，终端仅采用用户名+口令方式进行登录管理，未采用两种或两种以上组合的鉴别技术对用户进行身份鉴别。	不符合
访问控制	a)应对登录的用户分配账户和权限；	经核查，查看系统本地用户和组，系统采用 Administrator 账户进行统一管理，账户隶属于 Administrators 组，拥有管理员权限，登录用户和账户一一对应。	符合
	b)应重命名或删除默认账户，修改默认账户的默认口令；	经核查，终端存在默认账户 Administrator 未重命名或删除，但用户自行设置了口令，已禁用 guest 来宾账户。	部分符合
	c)应及时删除或停用多余的、过	经核查，查看系统本地用户和	符合

控制点	测评项	结果记录	符合情况
	期的账户，避免共享账户的存在；	组，终端配置了 Administrator 账户进行管理，不存在多余或过期账户，无共享账户。	
	d)应授予管理用户所需的最小权限，实现管理用户的权限分离；	经查看，终端采用 Administrator 账户进行统一管理，未限制 Administrator 账户的管理权限，未建立系统管理员、审计管理员和安全管理员账户，未实现管理用户的权限分离。	不符合
	e)应由授权主体配置访问控制策略，访问控制策略规定主体对客体的访问规则；	经核查，终端采用 Administrator 账户进行管理，未配置安全管理员账户对访问控制策略进行配置。	不符合
	f)访问控制的粒度应达到主体为用户级或进程级，客体为文件、数据库表级；	经核查，终端由管理员依据具体业务需求配置用户对文件的访问规则，关键系统文件夹权限设置合理，访问控制的粒度主体达到用户级，客体达到文件级。	符合
	g)应对重要主体和客体设置安全标记，并控制主体对有安全标记信息资源的访问。	经核查，终端未对重要主体和客体设置安全标记，未实现通过安全标记控制主体对客体的访问。	不符合
安全审计	a)应启用安全审计功能，审计覆盖到每个用户，对重要的用户行为和重要安全事件进行审计；	经核查，终端默认开启了安全审计功能，查看事件查看器-Windows 日志，审计范围覆盖到所有系统用户，终端组策略中审核策略如下：审核策略更改：无审核；审核对象访问：无审核；审核目录服务器访问：无审核；审核特权使用：无审核；审核系统事件：无审核；审核账户管理：无审核；审核过程追踪：无审核；审核登录事件：无审核；审核账户登录事件：无审核；系统仅开启了默认审核策略，对 windows 日志、应用程序和服务日志进行审计，但未完善组策略的审核策略，部分审核策略不完善。	部分符合

控制点	测评项	结果记录	符合情况
	b)审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息；	经核查，查看事件查看器-Windows 日志，终端审计记录包括：来源、记录时间、事件 ID、任务类别、级别、关键字、用户、计算机、操作代码等内容。	符合
	c)应对审计记录进行保护，定期备份，避免受到未预期的删除、修改或覆盖等；	经核查，终端审计记录仅在本地保存，查看日志属性，已勾选“按需要覆盖事件”；日志大小 20.00MB，可以对日志进行清除，且未配置日志审计系统或日志服务器将日志文件单独备份保存，无法避免受到未预期的删除、修改或覆盖等。	不符合
	d)应对审计进程进行保护，防止未经授权的中断。	经核查，终端为 Windows 系统，默认保护审计进程，无法直接中断该进程。	符合
入侵防范	a)应遵循最小安装的原则，仅安装需要的组件和应用程序；	经核查，查看操作系统属性，终端当前系统为 Windows 7 旗舰版（内部版本 7601: Service Pack 1），查看控制面板-程序和功能，操作系统实现最小化安装原则，未安装其他与业务无关的组件或应用程序。	符合
	b)应关闭不需要的系统服务、默认共享和高危端口；	经核查，终端存在 C 盘、D 盘和 E 盘等不必要的默认共享，未关闭 135 和 445 等端口，未关闭 Remote Registry、Server 等不必要的服务。	不符合
	c)应通过设定终端接入方式或网络地址范围对通过网络进行管理的管理终端进行限制；	终端未开启远程管理功能，仅本地可进行管理，此项不适用。	不适用
	d)应提供数据有效性检验功能，保证通过人机接口输入或通过通信接口输入的内容符合系统设定要求；	因《信息安全技术 网络安全等级保护测评要求》（GB/T 28448-2019）中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用

控制点	测评项	结果记录	符合情况
	e)应能发现可能存在的已知漏洞，并在经过充分测试评估后，及时修补漏洞；	经访谈与查看，终端系统未定期进行漏洞扫描，无法及时发现可能存在的漏洞。	不符合
	f)应能够检测到对重要节点进行入侵的行为，并在发生严重入侵事件时提供报警。	经查看，系统安装了火绒安全软件，程序版本：6.0.6.6，特征库联网自动更新，最新更新时间：2025-08-13，更新时间在最近一个月，能够及时检测到对重要节点进行入侵的行为，并通过弹窗进行报警。	符合
恶意代码防范	应采用免受恶意代码攻击的技术措施或主动免疫可信验证机制及时识别入侵和病毒行为，并将其有效阻断。	经查看，系统安装了火绒安全软件，程序版本：6.0.6.6，病毒库联网自动更新，最新更新时间：2025-08-13，更新时间在最近一个月，能够及时识别入侵和病毒行为，并将其有效阻断。	符合
可信验证	可基于可信根对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行可信验证，并在应用程序的关键执行环节进行动态可信验证，在检测到其可信性受到破坏后进行报警，并将验证结果形成审计记录送至安全管理中心。	未采用可信计算技术对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。	不符合
数据完整性	a)应采用校验技术或密码技术保证重要数据在传输过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等；	终端未开启远程管理功能，仅本地可进行管理，此项不适用。	不适用
	b)应采用校验技术或密码技术保证重要数据在存储过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等。	经核查，终端未采用校验技术或密码技术保证重要配置数据和鉴别数据在存储过程中的完整性。	不符合

控制点	测评项	结果记录	符合情况
数据保密性	a)应采用密码技术保证重要数据在传输过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等；	终端未开启远程管理功能，仅本地可进行管理，此项不适用。	不适用
	b)应采用密码技术保证重要数据在存储过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等。	经核查，终端仅对系统鉴别数据（口令）加密存储至 SAM 文件，采用 CNG BCrypt AES-256 算法进行加密存储，密码文件被窃取后无法显示明文密码，但未采用密码技术保证重要配置数据在存储过程中的保密性。	部分符合
数据备份恢复	a)应提供重要数据的本地数据备份与恢复功能；	操作系统中无需保存的业务信息和配置信息，此项不适用。	不适用
	b)应提供异地实时备份功能，利用通信网络将重要数据实时备份至备份场地；	操作系统中无需保存的业务信息和配置信息，此项不适用。	不适用
	c)应提供重要数据处理系统的热冗余，保证系统的高可用性。	该项要求一般针对服务器、交换机等重要数据处理系统，终端此项不适用。	不适用
剩余信息保护	a)应保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除；	经核查，查看本地组策略，安全设置-本地策略-安全选项中“交互式登录：不显示上次登录 已启用”，开机不显示上次登录过的用户名信息，已对鉴别信息进行清除。	符合
	b)应保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	经核查，查看本地组策略，安全设置-本地策略-安全选项中“关机：清除虚拟内存页面 已启用”，可以保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	符合
个人信息保护	a)应仅采集和保存业务必需的用户个人信息；	因《信息安全技术 网络安全等级保护测评要求》（GB/T 28448-2019）中该项测评对象的选择不涉及当前系统，故此项目不适用。	不适用

控制点	测评项	结果记录	符合情况
	b)应禁止未授权访问和非法使用用户个人信息。	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用

D.4.1.3.26 业务终端-2

控制点	测评项	结果记录	符合情况
身份鉴别	a)应对登录的用户进行身份标识和鉴别，身份标识具有唯一性，身份鉴别信息具有复杂度要求并定期更换；	经核查，终端提供了登录模块对用户进行身份鉴别，身份鉴别方式为用户名和口令；系统无法新建同名账户，身份标识具有唯一性；查看本地安全策略，密码策略配置如下：密码必须符合复杂性要求：已禁用，密码长度最小值：0 个字符，密码最短使用期限：0 天，密码最长使用期限：4 2 天，强制密码历史：0 个记住的密码，账户属性中已勾选密码永不过期，未配置口令复杂度策略和口令定期更换策略；经访谈，当前管理用户口令长度超过 8 位，由数字、大写字母、小写字母和特殊符号组成。	部分符合
	b)应具有登录失败处理功能，应配置并启用结束会话、限制非法登录次数和当登录连接超时自动退出等相关措施；	经核查，查看本地安全策略-账户策略-账户锁定策略及个性化-锁屏界面-屏幕保护程序，终端未配置登录失败锁定策略及登录连接超时自动退出策略。	不符合
	c)当进行远程管理时，应采取必要措施防止鉴别信息在网络传输过程中被窃听；	终端未开启远程管理功能，仅本地可进行管理，此项不适用。	不适用
	d)应采用口令、密码技术、生物技术等两种或两种以上组合的鉴别技术对用户进行身份鉴别，且其中一种鉴别技术至少应使用密码技术来实现。	经核查，终端仅采用用户名+口令方式进行登录管理，未采用两种或两种以上组合的鉴别技术对用户进行身份鉴别。	不符合

控制点	测评项	结果记录	符合情况
访问控制	a)应对登录的用户分配账户和权限；	经核查，查看系统本地用户和组，系统采用 Administrator 账户进行统一管理，账户隶属于 Administrators 组，拥有管理员权限，登录用户和账户一一对应。	符合
	b)应重命名或删除默认账户，修改默认账户的默认口令；	经核查，终端存在默认账户 Administrator 未重命名或删除，但用户自行设置了口令，已禁用 guest 来宾账户。	部分符合
	c)应及时删除或停用多余的、过期的账户，避免共享账户的存在；	经核查，查看系统本地用户和组，终端配置了 Administrator 账户进行管理，不存在多余或过期账户，无共享账户。	符合
	d)应授予管理用户所需的最小权限，实现管理用户的权限分离；	经查看，终端采用 Administrator 账户进行统一管理，未限制 Administrator 账户的管理权限，未建立系统管理员、审计管理员和安全管理员账户，未实现管理用户的权限分离。	不符合
	e)应由授权主体配置访问控制策略，访问控制策略规定主体对客体的访问规则；	经核查，终端采用 Administrator 账户进行管理，未配置安全管理员账户对访问控制策略进行配置。	不符合
	f)访问控制的粒度应达到主体为用户级或进程级，客体为文件、数据库表级；	经核查，终端由管理员依据具体业务需求配置用户对文件的访问规则，关键系统文件夹权限设置合理，访问控制的粒度主体达到用户级，客体达到文件级。	符合
	g)应对重要主体和客体设置安全标记，并控制主体对有安全标记信息资源的访问。	经核查，终端未对重要主体和客体设置安全标记，未实现通过安全标记控制主体对客体的访问。	不符合
安全审计	a)应启用安全审计功能，审计覆盖到每个用户，对重要的用户行为和重要安全事件进行审计；	经核查，终端默认开启了安全审计功能，查看事件查看器-Windows 日志，审计范围覆盖到所有系统用户，终端组策略中审核策略	部分符合

控制点	测评项	结果记录	符合情况
		如下：审核策略更改：无审核；审核对象访问：无审核；审核目录服务器访问：无审核；审核特权使用：无审核；审核系统事件：无审核；审核账户管理：无审核；审核过程追踪：无审核；审核登录事件：无审核；审核账户登录事件：无审核；系统仅开启了默认审核策略，对 windows 日志、应用程序和服务日志进行审计，但未完善组策略的审核策略，部分审核策略不完善。	
	b)审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息；	经核查，查看事件查看器-Windows 日志，终端审计记录包括：来源、记录时间、事件 ID、任务类别、级别、关键字、用户、计算机、操作代码等内容。	符合
	c)应对审计记录进行保护，定期备份，避免受到未预期的删除、修改或覆盖等；	经核查，终端审计记录仅在本地保存，查看日志属性，已勾选“按需要覆盖事件”；日志大小 20.00MB，可以对日志进行清除，且未配置日志审计系统或日志服务器将日志文件单独备份保存，无法避免受到未预期的删除、修改或覆盖等。	不符合
	d)应对审计进程进行保护，防止未经授权的中断。	经核查，终端为 Windows 系统，默认保护审计进程，无法直接中断该进程。	符合
入侵防范	a)应遵循最小安装的原则，仅安装需要的组件和应用程序；	经核查，查看操作系统属性，终端当前系统为 Windows 7 旗舰版（内部版本 7601: Service Pack 1），查看控制面板-程序和功能，操作系统实现最小化安装原则，未安装其他与业务无关的组件或应用程序。	符合
	b)应关闭不需要的系统服务、默认共享和高危端口；	经核查，终端存在 C 盘、D 盘和 E 盘等不必要的默认共享，未关	不符合

控制点	测评项	结果记录	符合情况
		闭 135 和 445 等端口，未关闭 Remote Registry、Server 等不必要的服务。	
	c)应通过设定终端接入方式或网络地址范围对通过网络进行管理的管理终端进行限制；	终端未开启远程管理功能，仅本地可进行管理，此项不适用。	不适用
	d)应提供数据有效性检验功能，保证通过人机接口输入或通过通信接口输入的内容符合系统设定要求；	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
	e)应能发现可能存在的已知漏洞，并在经过充分测试评估后，及时修补漏洞；	经访谈与查看，终端系统未定期进行漏洞扫描，无法及时发现可能存在的漏洞。	不符合
	f)应能够检测到对重要节点进行入侵的行为，并在发生严重入侵事件时提供报警。	经查看，系统安装了火绒安全软件，程序版本：6.0.6.6，特征库联网自动更新，最新更新时间：2025-08-13，更新时间在最近一个月，能够及时检测到对重要节点进行入侵的行为，并通过弹窗进行报警。	符合
恶意代码防范	应采用免受恶意代码攻击的技术措施或主动免疫可信验证机制及时识别入侵和病毒行为，并将其有效阻断。	经查看，系统安装了火绒安全软件，程序版本：6.0.6.6，病毒库联网自动更新，最新更新时间：2025-08-13，更新时间在最近一个月，能够及时识别入侵和病毒行为，并将其有效阻断。	符合
可信验证	可基于可信根对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行可信验证，并在应用程序的关键执行环节进行动态可信验证，在检测到其可信性受到破坏后进行报警，并将验证结果形成审计记录送至安全管理中心。	未采用可信计算技术对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。	不符合
数据完	a)应采用校验技术或密码技术保	终端未开启远程管理功能，仅本	不适用

控制点	测评项	结果记录	符合情况
完整性	证重要数据在传输过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等；	地可进行管理，此项不适用。	
	b)应采用校验技术或密码技术保证重要数据在存储过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等。	经核查，终端未采用校验技术或密码技术保证重要配置数据和鉴别数据在存储过程中的完整性。	不符合
数据保密性	a)应采用密码技术保证重要数据在传输过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等；	终端未开启远程管理功能，仅本地可进行管理，此项不适用。	不适用
	b)应采用密码技术保证重要数据在存储过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等。	经核查，终端仅对系统鉴别数据（口令）加密存储至 SAM 文件，采用 CNG BCrypt AES-256 算法进行加密存储，密码文件被窃取后无法显示明文密码，但未采用密码技术保证重要配置数据在存储过程中的保密性。	部分符合
数据备份恢复	a)应提供重要数据的本地数据备份与恢复功能；	操作系统中无需保存的业务信息和配置信息，此项不适用。	不适用
	b)应提供异地实时备份功能，利用通信网络将重要数据实时备份至备份场地；	操作系统中无需保存的业务信息和配置信息，此项不适用。	不适用
	c)应提供重要数据处理系统的热冗余，保证系统的高可用性。	该项要求一般针对服务器、交换机等重要数据处理系统，终端此项不适用。	不适用
剩余信息保护	a)应保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除；	经核查，查看本地组策略，安全设置-本地策略-安全选项中“交互式登录：不显示上次登录 已启用”；开机不显示上次登录过的用户名信息，已对鉴别信息进行	符合

控制点	测评项	结果记录	符合情况
		清除。	
	b)应保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	经核查，查看本地组策略，安全设置-本地策略-安全选项中“关机：清除虚拟内存页面 已启用”；可以保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	符合
个人信息保护	a)应仅采集和保存业务必需的用户个人信息；	因《信息安全技术 网络安全等级保护测评要求》（GB/T 28448-2019）中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
	b)应禁止未授权访问和非法使用用户个人信息。	因《信息安全技术 网络安全等级保护测评要求》（GB/T 28448-2019）中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用

D.4.1.4其他系统或设备

本次测评不包含本安全层面检测项。

D.4.1.5系统管理软件/平台

D.4.1.5.1 华为云管理控制台

控制点	测评项	结果记录	符合情况
身份鉴别	a)应对登录的用户进行身份标识和鉴别，身份标识具有唯一性，身份鉴别信息具有复杂度要求并定期更换；	经查看，华为云管理控制台登录需要输入用户名和口令+手机短信验证码的方式进行身份鉴别，用户标识具有唯一性，查看访问管理-安全设置-密码安全策略，当前配置策略账户口令长度为 8 个字符及以上，且包含大写字母、小写字母、数字和特殊符号 4 种，当前口令配置与系统配置策略一致，满足口令复杂度要求，口令有效期 30 天。	符合
	b)应具有登录失败处理功能，应	经查看，系统配置了登录失败处	部分符合

控制点	测评项	结果记录	符合情况
	配置并启用结束会话、限制非法登录次数和当登录连接超时自动退出等相关措施；	理功能和网络登录连接超时自动退出功能,查看访问管理-安全设置-登录验证策略,15分钟内登录失败5次,账户锁定15分钟,网络登录连接超时60分钟自动退出,但登录连接超时过长。	
	c)当进行远程管理时,应采取必要措施防止鉴别信息在网络传输过程中被窃听；	经查看,远程管理系统采用https协议,使用ECDHE-RSA-WITH-AES-128-GCM-SHA256进行数据传输加密,鉴别信息在网络中加密传输,能够防止鉴别信息在传输过程中被窃听和篡改。	符合
	d)应采用口令、密码技术、生物技术等两种或两种以上组合的鉴别技术对用户进行身份鉴别,且其中一种鉴别技术至少应使用密码技术来实现。	经查看,华为云管理控制台登录系统时采用用户名和口令,同时通过手机验证码进行身份鉴别,但系统未采用密码技术对用户进行身份鉴别。	部分符合
访问控制	a)应对登录的用户分配账户和权限；	经查看,查看华为云管理控制台-统一身份认证服务-用户,系统对登录的用户分配了账户 zhangxin 系统管理员、admin_shenji 审计管理员、admin_safe 安全管理员,并为每个登录的账户分配了相应的系统管理权限。	符合
	b)应重命名或删除默认账户,修改默认账户的默认口令；	经查看,查看华为云管理控制台-统一身份认证服务-用户,系统对登录的用户分配了账户 zhangxin 系统管理员、admin_shenji 审计管理员、admin_safe 安全管理员,系统中无默认账户,所有账户均为手动创建,口令满足复杂度要求。	符合
	c)应及时删除或停用多余的、过期的账户,避免共享账户的存在；	经查看,系统对登录的用户分配了账户 zhangxin 系统管理员、admin_shenji 审计管理员、admin_safe 安全管理员,不存在其他多	符合

控制点	测评项	结果记录	符合情况
		余、过期和共享账户。	
	d)应授予管理用户所需的最小权限，实现管理用户的权限分离；	经查看，查看华为云管理控制台-统一身份认证服务-用户，系统对登录的用户分配了账户 zhang xin 系统管理员、admin_shenji 审计管理员、admin_safe 安全管理员，实现了管理用户的权限分离和用户所需的最小化权限。	符合
	e)应由授权主体配置访问控制策略，访问控制策略规定主体对客体的访问规则；	经查看，系统配置了安全管理员对访问控制策略进行配置。	符合
	f)访问控制的粒度应达到主体为用户级或进程级，客体为文件、数据库表级；	经查看，设备的访问控制粒度可达到主体为用户级，客体为功能级。	符合
	g)应对重要主体和客体设置安全标记，并控制主体对有安全标记信息资源的访问。	经查看，系统不支持基于安全标记的访问控制。	不符合
安全审计	a)应启用安全审计功能，审计覆盖到每个用户，对重要的用户行为和重要安全事件进行审计；	经查看，华为云管理控制台开启了华为云云日志服务 LTS，审计范围覆盖所有用户，可对用户的操作行为、系统运行状态等进行审计记录。	符合
	b)审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息；	经查看，审计记录的主要内容包括：操作时间、操作者、事件名称、资源类型、资源名称等相关信息。	符合
	c)应对审计记录进行保护，定期备份，避免受到未预期的删除、修改或覆盖等；	经查看，华为云管理控制台通过华为云云日志服务 LTS 进行审计，当前配置策略已创建跟踪列表，并通过本地网络实时保存至华为云对象存储服务 OBS 中,可查询最早日志时间为 2025.3.1-2025.9.2,日志保存时间在 6 个月以上，能够对审计记录进行收集、保存、分析，可避免受到未预期	符合

控制点	测评项	结果记录	符合情况
		的删除、修改或覆盖等。	
	d)应对审计进程进行保护，防止未经授权的中断。	经查看，华为云管理控制台未提供审计进程关闭功能，用户无法通过登录界面对审计进程进行关闭。	符合
入侵防范	a)应遵循最小安装的原则，仅安装需要的组件和应用程序；	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019)中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
	b)应关闭不需要的系统服务、默认共享和高危端口；	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019)中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
	c)应通过设定终端接入方式或网络地址范围对通过网络进行管理的管理终端进行限制；	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019)中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
	d)应提供数据有效性检验功能，保证通过人机接口输入或通过通信接口输入的内容符合系统设定要求；	经查看，系统不存在 SQL 注入和跨站脚本编制等漏洞，华为云管理控制台对人机接口输入的数据做了有效性校验。	符合
	e)应能发现可能存在的已知漏洞，并在经过充分测试评估后，及时修补漏洞；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
	f)应能够检测到对重要节点进行入侵的行为，并在发生严重入侵事件时提供报警。	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019)中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
恶意代码防范	应采用免受恶意代码攻击的技术措施或主动免疫可信验证机制及时识别入侵和病毒行为，并将其有效阻断。	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019)中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
可信验证	可基于可信根对计算设备的系统引导程序、系统程序、重要配	未采用可信计算技术对计算设备的系统引导程序、系统程序、	不符合

控制点	测评项	结果记录	符合情况
	置参数和应用程序等进行可信验证，并在应用程序的关键执行环节进行动态可信验证，在检测到其可信性受到破坏后进行报警，并将验证结果形成审计记录送至安全管理中心。	重要配置参数和应用程序等进行动态可信验证。	
数据完整性	a)应采用校验技术或密码技术保证重要数据在传输过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等；	经查看，远程管理系统采用 https 协议，采用 ECDHE-RSA-WITH-AES-128-GCM-SHA256 进行数据传输加密，可对鉴别信息和配置数据在网络传输过程中的完整性进行校验。	符合
	b)应采用校验技术或密码技术保证重要数据在存储过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等。	经查看，系统未采用校验技术或密码技术实现鉴别数据、重要配置数据在存储过程中的完整性。	不符合
数据保密性	a)应采用密码技术保证重要数据在传输过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等；	经查看，远程管理系统采用 https 协议，使用 ECDHE-RSA-WITH-AES-128-GCM-SHA256 进行数据传输加密，可对鉴别信息和配置数据在网络传输过程中进行数据传输加密。	符合
	b)应采用密码技术保证重要数据在存储过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等。	经查看，系统未采用密码技术保证鉴别数据、重要配置数据在存储过程中的保密性。	不符合
数据备份恢复	a)应提供重要数据的本地数据备份与恢复功能；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
	b)应提供异地实时备份功能，利用通信网络将重要数据实时备份至备份场地；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
	c)应提供重要数据处理系统的热	因《信息安全技术 网络安全等	不适用

控制点	测评项	结果记录	符合情况
	冗余，保证系统的高可用性。	级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	
剩余信息保护	a)应保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除；	经查看，华为云管理控制台的鉴别信息保存在本地 Cookie 中, 用户关闭页面或长时间无数据请求，Cookie 自动失效，且服务器自动删除对应的 Session 信息。	符合
	b)应保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
个人信息保护	a)应仅采集和保存业务必需的用户个人信息；	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
	b)应禁止未授权访问和非法使用用户个人信息。	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用

D.4.1.5.2 Nginx 中间件

控制点	测评项	结果记录	符合情况
身份鉴别	a)应对登录的用户进行身份标识和鉴别，身份标识具有唯一性，身份鉴别信息具有复杂度要求并定期更换；	中间件未配置身份鉴别功能，通过服务器对配置文件修改进行管理，此项不适用。	不适用
	b)应具有登录失败处理功能，应配置并启用结束会话、限制非法登录次数和当登录连接超时自动退出等相关措施；	中间件未配置身份鉴别功能，通过服务器对配置文件修改进行管理，此项不适用。	不适用
	c)当进行远程管理时，应采取必要措施防止鉴别信息在网络传输过程中被窃听；	中间件未配置身份鉴别功能，通过服务器对配置文件修改进行管理，此项不适用。	不适用

控制点	测评项	结果记录	符合情况
	d)应采用口令、密码技术、生物技术等两种或两种以上组合的鉴别技术对用户进行身份鉴别，且其中一种鉴别技术至少应使用密码技术来实现。	中间件未配置身份鉴别功能，通过服务器对配置文件修改进行管理，此项不适用。	不适用
访问控制	a)应对登录的用户分配账户和权限；	中间件未配置访问控制功能，通过服务器对配置文件修改进行管理，此项不适用。	不适用
	b)应重命名或删除默认账户，修改默认账户的默认口令；	中间件未配置访问控制功能，通过服务器对配置文件修改进行管理，此项不适用。	不适用
	c)应及时删除或停用多余的、过期的账户，避免共享账户的存在；	中间件未配置访问控制功能，通过服务器对配置文件修改进行管理，此项不适用。	不适用
	d)应授予管理用户所需的最小权限，实现管理用户的权限分离；	中间件未配置访问控制功能，通过服务器对配置文件修改进行管理，此项不适用。	不适用
	e)应由授权主体配置访问控制策略，访问控制策略规定主体对客体的访问规则；	中间件未配置访问控制功能，通过服务器对配置文件修改进行管理，此项不适用。	不适用
	f)访问控制的粒度应达到主体为用户级或进程级，客体为文件、数据库表级；	中间件未配置访问控制功能，通过服务器对配置文件修改进行管理，此项不适用。	不适用
	g)应对重要主体和客体设置安全标记，并控制主体对有安全标记信息资源的访问。	中间件未配置访问控制功能，通过服务器对配置文件修改进行管理，此项不适用。	不适用
安全审计	a)应启用安全审计功能，审计覆盖到每个用户，对重要的用户行为和重要安全事件进行审计；	经核查，查看 <code>nginx.conf</code> 文件可知，Nginx 中间件开启了日志功能，包含 <code>access.log</code> 日志以及 <code>error.log</code> 日志，可对重要行为和事件进行审计。	符合
	b)审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信	经核查，Nginx 中间件的审计内容包括客户端 IP 地址、客户端用户名、请求的 URL 和 HTTP 协	符合

控制点	测评项	结果记录	符合情况
	息；	议、请求状态、发送给客户端的字节数、连接的序列号、当前通过一个连接获得的请求数量、日志写入的时间、请求是否通过 HTTP 流水线 (pipelined) 发送、从哪个页面链接访问过来的、客户端浏览器相关信息、请求的长度、请求处理时间、通用日志格式下的本地时间等。	
	c)应对审计记录进行保护，定期备份，避免受到未预期的删除、修改或覆盖等；	经核查，中间件审计日志已通过配置上传至华为云云日志服务 LTS 中，可对审计记录进行保护，能够查看 2025 年 3 月 1 日到 2025 年 9 月 2 日的审计记录，日志保存时间为 6 个月以上，可避免审计记录受到未预期的删除、修改或覆盖等。	符合
	d)应对审计进程进行保护，防止未经授权的中断。	经核查，Nginx 中间件的审计进程与其主进程相关联，无法单独中断审计进程。	符合
入侵防范	a)应遵循最小安装的原则，仅安装需要的组件和应用程序；	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
	b)应关闭不需要的系统服务、默认共享和高危端口；	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
	c)应通过设定终端接入方式或网络地址范围对通过网络进行管理的管理终端进行限制；	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
	d)应提供数据有效性检验功能，保证通过人机接口输入或通过通信接口输入的内容符合系统设定要求；	经核查，系统对人机接口或通信接口输入的内容提供了数据有效性检验功能，经漏洞扫描未发现 SQL 注入、跨站脚本、远程命	符合

控制点	测评项	结果记录	符合情况
		令执行等漏洞。	
	e)应能发现可能存在的已知漏洞，并在经过充分测试评估后，及时修补漏洞；	经访谈和查看，租户购买了华为云企业主机安全 HSS 企业版，华为云提供了漏洞自动检测并提供了修复方案；租户已每天对系统进行漏洞扫描并修补了漏洞。当前提供了《漏洞扫描记录》，包括时间、漏洞等情况、检测结果和检测结果分析等内容。	符合
	f)应能够检测到对重要节点进行入侵的行为，并在发生严重入侵事件时提供报警。	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
恶意代码防范	应采用免受恶意代码攻击的技术措施或主动免疫可信验证机制及时识别入侵和病毒行为，并将其有效阻断。	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
可信验证	可基于可信根对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行可信验证，并在应用程序的关键执行环节进行动态可信验证，在检测到其可信性受到破坏后进行报警，并将验证结果形成审计记录送至安全管理中心。	未采用可信计算技术对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。	不符合
数据完整性	a)应采用校验技术或密码技术保证重要数据在传输过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等；	中间件未开启远程管理功能，此项不适用。	不适用
	b)应采用校验技术或密码技术保证重要数据在存储过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和	经核查，中间件未采用校验技术或密码技术保证重要配置数据在存储过程中的完整性。	不符合

控制点	测评项	结果记录	符合情况
	重要个人信息等。		
数据保密性	a)应采用密码技术保证重要数据在传输过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等；	中间件未开启远程管理功能，此项不适用。	不适用
	b)应采用密码技术保证重要数据在存储过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等。	经核查，中间件未采用密码技术保证重要配置数据在存储过程中的保密性。	不符合
数据备份恢复	a)应提供重要数据的本地数据备份与恢复功能；	中间件系统本身无需要备份的业务数据和配置数据，此项不适用。	不适用
	b)应提供异地实时备份功能，利用通信网络将重要数据实时备份至备份场地；	中间件系统本身无需要备份的业务数据和配置数据，此项不适用。	不适用
	c)应提供重要数据处理系统的热冗余，保证系统的高可用性。	因《信息安全技术 网络安全等级保护测评要求》（GB/T 28448-2019）中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
剩余信息保护	a)应保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除；	中间件未配置身份鉴别功能，通过服务器对配置文件修改进行管理，此项不适用。	不适用
	b)应保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	经核查，系统除访问必须的框架文件外，不保存业务相关的敏感信息。	符合
个人信息保护	a)应仅采集和保存业务必需的用户个人信息；	因《信息安全技术 网络安全等级保护测评要求》（GB/T 28448-2019）中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用
	b)应禁止未授权访问和非法使用用户个人信息。	因《信息安全技术 网络安全等级保护测评要求》（GB/T 28448-2019）中该项测评对象的选择不涉及当前系统，故此项不适用。	不适用

D.4.1.5.3 MySQL 数据库

控制点	测评项	结果记录	符合情况
身份鉴别	a)应对登录的用户进行身份标识和鉴别，身份标识具有唯一性，身份鉴别信息具有复杂度要求并定期更换；	经查看,MySQL 数据库采用用户名和口令进行身份鉴别，不可新建同名账户；通过 show variables like '%validate_password%'命令查看，validate_password_length:8、validate_password_mixed_case_count:1、validate_password_number_count:1、validate_password_special_char_count:1，口令长度至少 8 位，包含 1 个大小写字母、1 个数字、1 个特殊字符，已配置口令复杂度策略；通过 show global variables like 'default_password_lifetime'命令查看，default_password_lifetime 的值为 0，未配置口令定期更换策略；经访谈，当前口令长度超过 8 位，包含大小写字母、数字、特殊字符，满足口令复杂度要求，未定期更换口令。	部分符合
	b)应具有登录失败处理功能，应配置并启用结束会话、限制非法登录次数和当登录连接超时自动退出等相关措施；	经核查，通过 show variables like '%connection_control%';命令查看，未配置登录失败处理功能；通过 show variables like "%time_out%"命令查看空闲会话超时 interactive_timeout 值为 10 秒，空闲会话超时等待 wait_timeout 值为 1800 秒。	不符合
	c)当进行远程管理时，应采取必要措施防止鉴别信息在网络传输过程中被窃听；	经核查，通过 show variables like ""'%have_ssl%'""以及 show variables like ""'%have_openssl%'"";命令查看 Value 值为 YES，数据库开启了 SSL，采用 AES_128_GCM 技术进行加密，可防止鉴别信息在网络传输过程中被窃听。	符合

控制点	测评项	结果记录	符合情况
	d)应采用口令、密码技术、生物技术等两种或两种以上组合的鉴别技术对用户进行身份鉴别，且其中一种鉴别技术至少应使用密码技术来实现。	经查看，系统采用用户名和口令进行身份鉴别，未采用两种以上身份鉴别技术，但系统仅在内部可控网络中使用。	不符合
访问控制	a)应对登录的用户分配账户和权限；	经核查，通过 <code>select * from mysql.user</code> 命令查看用户列表，数据库系统采用 <code>root</code> 账户进行统一管理，根据业务需求建立了 <code>monitor</code> 、 <code>sjjc</code> 等账号，并对账户划分了相应的权限。	符合
	b)应重命名或删除默认账户，修改默认账户的默认口令；	经查看，系统采用 <code>root</code> 账户进行管理，未重命名系统默认账户，但对默认账户自行设置了口令。	部分符合
	c)应及时删除或停用多余的、过期的账户，避免共享账户的存在；	经查看和访谈，数据库采用 <code>root</code> 账户进行管理，根据业务需求建立了 <code>monitor</code> 、 <code>sjjc</code> 等账号，不存在多余的、过期的账户，无共享账户。	符合
	d)应授予管理用户所需的最小权限，实现管理用户的权限分离；	经查看，系统采用 <code>root</code> 账户进行统一管理，根据业务需求建立了 <code>monitor</code> 、 <code>sjjc</code> 等账号，未建立审计管理员、安全管理员等账户，未实现管理用户的权限分离。	不符合
	e)应由授权主体配置访问控制策略，访问控制策略规定主体对客体的访问规则；	经查看，系统未配置安全管理员对访问控制策略进行配置。	不符合
	f)访问控制的粒度应达到主体为用户级或进程级，客体为文件、数据库表级；	经查看，数据库访问控制粒度可达到主体为用户级，客体为数据库表级。	符合
	g)应对重要主体和客体设置安全标记，并控制主体对有安全标记信息资源的访问。	经核查，系统未采取技术措施实现基于安全标记的强制访问控制功能。	不符合
安全审计	a)应启用安全审计功能，审计覆盖到每个用户，对重要的用户行	经核查，通过 <code>show variables like '%log%'</code> 命令查看数据库日志	符合

控制点	测评项	结果记录	符合情况
	为和重要安全事件进行审计；	配置，数据库开启了错误日志 <code>log_error</code> 、二进制日志 <code>log_bin</code> 和通用查询日志 <code>general_log</code> ，可以对所有重要用户行为和重要的安全事件进行审计。	
	b)审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息；	通过日志查看用户操作记录，审计内容包括：日期、时间、用户名、登录主机名、事件和结果等。	符合
	c)应对审计记录进行保护，定期备份，避免受到未预期的删除、修改或覆盖等；	经核查，数据库审计日志已通过配置上传至华为云云日志服务 <code>LTS</code> 中，可对审计记录进行保护，能够查看 2025 年 3 月 1 日到 2025 年 9 月 2 日的审计记录，日志保存时间为 6 个月以上，可避免审计记录受到未预期的删除、修改或覆盖等。	符合
	d)应对审计进程进行保护，防止未经授权的中断。	经询问和查看，未对审计进程进行相应的保护，无法防止未经授权的中断。	不符合
入侵防范	a)应遵循最小安装的原则，仅安装需要的组件和应用程序；	依据 <code>GB/T 28448-2019</code> 《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
	b)应关闭不需要的系统服务、默认共享和高危端口；	依据 <code>GB/T 28448-2019</code> 《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
	c)应通过设定终端接入方式或网络地址范围对通过网络进行管理的管理终端进行限制；	通过 <code>select user, host from user;</code> 命令查看， <code>root</code> 用户 <code>HOST</code> 列的值为%，未在系统层面对终端地址范围进行限制，但系统仅在内部可控网络中使用。	不符合
	d)应提供数据有效性检验功能，保证通过人机接口输入或通过	依据 <code>GB/T 28448-2019</code> 《信息安全技术网络安全等级保护测评	不适用

控制点	测评项	结果记录	符合情况
	通信接口输入的内容符合系统设定要求；	要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	
	e)应能发现可能存在的已知漏洞，并在经过充分测试评估后，及时修补漏洞；	经访谈和查看，租户购买了华为云企业主机安全 HSS 企业版，华为云提供了漏洞自动检测并提供了修复方案；租户已每天对系统进行漏洞扫描并修补了漏洞。当前提供了《漏洞扫描记录》，包括时间、漏洞等情况、检测结果和检测结果分析等内容。	符合
	f)应能够检测到对重要节点进行入侵的行为，并在发生严重入侵事件时提供报警。	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
恶意代码防范	应采用免受恶意代码攻击的技术措施或主动免疫可信验证机制及时识别入侵和病毒行为，并将其有效阻断。	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
可信验证	可基于可信根对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行可信验证，并在应用程序的关键执行环节进行动态可信验证，在检测到其可信性受到破坏后进行报警，并将验证结果形成审计记录送至安全管理中心。	未采用可信计算技术对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。	不符合
数据完整性	a)应采用校验技术或密码技术保证重要数据在传输过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等；	经查看，数据库采用 SSL 协议进行管理，采用 AES_128_GCM 技术进行加密，能够实现鉴别数据、重要配置数据在传输过程中的完整性。	符合
	b)应采用校验技术或密码技术保证重要数据在存储过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、	经查看，未采用校验技术或密码技术保证鉴别数据、重要配置数据在存储过程中的完整性。	不符合

控制点	测评项	结果记录	符合情况
	重要配置数据、重要视频数据和重要个人信息等。		
数据保密性	a)应采用密码技术保证重要数据在传输过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等；	经查看，数据库采用 SSL 协议进行管理，采用 AES_128_GCM 技术进行加密，能够保证鉴别数据、重要配置数据在传输过程中的保密性。	符合
	b)应采用密码技术保证重要数据在存储过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等。	经访谈和查看，数据库未采取密码技术实现配置数据在存储过程中的保密性，通过 sha256 加盐算法对鉴别数据进行加密存储，实现鉴别数据在存储过程中的保密性。	部分符合
数据备份恢复	a)应提供重要数据的本地数据备份与恢复功能；	数据库系统本身配置文件无备份需要；业务数据备份在业务数据对象中独立核查，此处不做重复测评，此项不适用。	不适用
	b)应提供异地实时备份功能，利用通信网络将重要数据实时备份至备份场地；	数据库系统本身配置文件无备份需要；业务数据备份在业务数据对象中独立核查，此处不做重复测评，此项不适用。	不适用
	c)应提供重要数据处理系统的热冗余，保证系统的高可用性。	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
剩余信息保护	a)应保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除；	经查看，数据库通过服务器命令行方式管理，用户退出后会删除原来的用户目录，下次登录再重新生成，能够保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除。	符合
	b)应保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	经查看，数据库管理通过服务器命令行方式进行管理，操作生成的缓存文件，关机自动删除保证存有敏感数据的存储空间被释	符合

控制点	测评项	结果记录	符合情况
		放或重新分配前得到完全清除。	
个人信息保护	a)应仅采集和保存业务必需的用户个人信息；	系统未收集和保存用户的个人信息，此项不适用。	不适用
	b)应禁止未授权访问和非法使用用户个人信息。	系统未收集和保存用户的个人信息，此项不适用。	不适用

D.4.1.6业务应用系统/平台

D.4.1.6.1 “新点 e 交易”电子交易平台

控制点	测评项	结果记录	符合情况
身份鉴别	a)应对登录的用户进行身份标识和鉴别，身份标识具有唯一性，身份鉴别信息具有复杂度要求并定期更换；	经核查，应用系统为 B/S 架构，系统已启用登录模块，登录系统可通过新点标证通 app 扫码或 ca 登录或用户登录（用户名+账号密码）这 3 种方式进行身份鉴别，经查看，系统不可设置相同的账户名，用户标识具有唯一性；经测试，系统已配置口令复杂度校验功能，要求口令长度必须在 8 位以上，且口令至少是大小写字母和特殊字符的组合，当前口令长度 8 位以上，口令包含大写字母、小写字母、数字、特殊符号，当前口令复杂度符合要求；未配置口令有效期功能，未定期对登录口令进行更换。	部分符合
	b)应具有登录失败处理功能，应配置并启用结束会话、限制非法登录次数和当登录连接超时自动退出等相关措施；	经查看，系统已提供登录失败处理功能，限制了连续口令错误 5 次，账户锁定 1 分钟；已配置登录连接超时自动退出时长为 30 分钟。	符合
	c)当进行远程管理时，应采取必要措施防止鉴别信息在网络传输过程中被窃听；	经查看，系统远程管理采用 HTTP 协议，具有 ECDHE-RSA-WITH-AES-256-GCM-SHA256 加密算法，用户鉴别信息以加密方式进行传输。	符合

控制点	测评项	结果记录	符合情况
	d)应采用口令、密码技术、生物技术等两种或两种以上组合的鉴别技术对用户进行身份鉴别,且其中一种鉴别技术至少应使用密码技术来实现。	经核查,应用系统采用可通过新点标证通 app 扫码或 ca 登录或用户登录(用户名+账号密码)这 3 种方式进行身份鉴别,未采用两种或两种以上身份鉴别技术。	不符合
访问控制	a)应对登录的用户分配账户和权限;	经核查,应用系统的用户管理,系统通过权限分配模块对登录的用户分配所需的登录账户和相应的权限。	符合
	b)应重命名或删除默认账户,修改默认账户的默认口令;	经核查,应用系统用户管理,系统采用管理员账户进行统一管理,系统均为自行创建用户,无默认用户。	符合
	c)应及时删除或停用多余的、过期的账户,避免共享账户的存在;	经查看与访谈,系统内账户均为在用账户,不存在共享账户,不存在多余的、过期的账户。	符合
	d)应授予管理用户所需的最小权限,实现管理用户的权限分离;	经查看,系统采用管理员账户进行统一管理,未限制管理员账户的管理权限,未建立审计管理员、安全管理员、系统管理员,未实现管理用户的权限分离。	不符合
	e)应由授权主体配置访问控制策略,访问控制策略规定主体对客体的访问规则;	经核查,系统未配置专职安全管理员配置访问控制策略,经渗透测试未发现越权访问漏洞。	部分符合
	f)访问控制的粒度应达到主体为用户级或进程级,客体为文件、数据库表级;	经查看,应用系统的访问控制粒度可达到主体为用户级,可以实现客体为功能模块级、菜单级或 API 级。	符合
	g)应对重要主体和客体设置安全标记,并控制主体对有安全标记信息资源的访问。	经访谈,系统中未采取技术措施实现基于安全标记的强制访问控制功能。	不符合
安全审计	a)应启用安全审计功能,审计覆盖到每个用户,对重要的用户行为和重要安全事件进行审计;	通过系统设置-系统日志查看,系统已启用安全审计功能,对用户的重要行为进行了审计与记录,审计范围覆盖所有的用户。	符合

控制点	测评项	结果记录	符合情况
	b)审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息；	经核查，系统日志审计记录包括操作人员、日期、IP、时间、模块名称、操作结果等信息。	符合
	c)应对审计记录进行保护，定期备份，避免受到未预期的删除、修改或覆盖等；	经查看，系统不能对日志进行删除或修改操作，对数据操作的每条记录均保存在数据库内，数据库每日全量备份，本地保存并创建跟踪列表保存至华为云对象存储服务 OBS，保存周期大于 6 个月,可查询 2025 年 03 月 01 日-2025 年 09 月 02 日的日志信息，可对审计记录进行保护。	符合
	d)应对审计进程进行保护，防止未经授权的中断。	经查看和验证，审计进程作为应用系统的功能模块，无独立进程，无法单独中断，审计功能无法关闭。	符合
入侵防范	a)应遵循最小安装的原则，仅安装需要的组件和应用程序；	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
	b)应关闭不需要的系统服务、默认共享和高危端口；	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
	c)应通过设定终端接入方式或网络地址范围对通过网络进行管理的管理终端进行限制；	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
	d)应提供数据有效性检验功能，保证通过人机接口输入或通过通信接口输入的内容符合系统设定要求；	经验证，系统已对人机接口和通信接口进行了规范，对输入的数据类型、格式、长度（如 SQL 注入的特殊字符、文件格式等）进行符合性校验，系统已提供了数据有效性的校验功能，未发现 SQL 注入、跨站脚本、远程命令执	符合

控制点	测评项	结果记录	符合情况
		行等漏洞。	
	e)应能发现可能存在的已知漏洞，并在经过充分测试评估后，及时修补漏洞；	经访谈和查看，租户购买了华为云企业主机安全 HSS 企业版，华为云提供了漏洞自动检测并提供了修复方案；租户已每天对系统进行漏洞扫描并修补了漏洞。当前提供了《漏洞扫描记录》，包括时间、漏洞等情况、检测结果和检测结果分析等内容。	符合
	f)应能够检测到对重要节点进行入侵的行为，并在发生严重入侵事件时提供报警。	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
恶意代码防范	应采用免受恶意代码攻击的技术措施或主动免疫可信验证机制及时识别入侵和病毒行为，并将其有效阻断。	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
可信验证	可基于可信根对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行可信验证，并在应用程序的关键执行环节进行动态可信验证，在检测到其可信性受到破坏后进行报警，并将验证结果形成审计记录送至安全管理中心。	未采用可信计算技术对计算设备的系统引导程序、系统程序、重要配置参数和应用程序等进行动态可信验证。	不符合
数据完整性	a)应采用校验技术或密码技术保证重要数据在传输过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等；	经查看，系统采用 HTTPS 进行传输，使用 ECDHE-RSA-WITH-AES-256-GCM-SHA256 加密算法对鉴别数据、配置数据进行完整性校验，能够保证通信传输过程中鉴别数据、配置数据的完整性。	符合
	b)应采用校验技术或密码技术保证重要数据在存储过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、	经核查，当前针对鉴别数据和配置数据采用 SM4 算法，可防止重要配置数据和鉴别数据在存储过程中被篡改，但未提供数据存	部分符合

控制点	测评项	结果记录	符合情况
	重要配置数据、重要视频数据和重要个人信息等。	储完整性被破坏时的检查和报警机制。	
数据保密性	a)应采用密码技术保证重要数据在传输过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等；	经查看，系统采用 HTTPS 进行传输，使用 ECDHE-RSA-WITH-AES-256-GCM-SHA256 加密算法对鉴别数据、配置数据进行加密，能够保证通信传输过程中鉴别数据、配置数据的保密性。	符合
	b)应采用密码技术保证重要数据在存储过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等。	经核查，当前针对鉴别数据和配置数据采用 SM4 算法，可保证重要配置数据和鉴别数据在存储过程中的保密性。	符合
数据备份恢复	a)应提供重要数据的本地数据备份与恢复功能；	应用系统本身配置文件无备份需要；业务数据备份在业务数据对象中独立核查，此处不做重复测评，此项不适用。	不适用
	b)应提供异地实时备份功能，利用通信网络将重要数据实时备份至备份场地；	应用系统本身配置文件无备份需要；业务数据备份在业务数据对象中独立核查，此处不做重复测评，此项不适用。	不适用
	c)应提供重要数据处理系统的热冗余，保证系统的高可用性。	依据 GB/T 28448-2019《信息安全技术网络安全等级保护测评要求》，该项的测评对象选择不涉及当前对象，故此项不适用。	不适用
剩余信息保护	a)应保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除；	经查看，鉴别信息保存在本地 Cookie 中，用户关闭页面或长时间无数据请求，Cookie 自动失效，且服务器自动删除对应的 Session 信息。	符合
	b)应保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	经查看，系统访问采用 WEB 方式，本地除访问必须的框架文件（如 html, js, css, img 等）外，不保存业务相关的敏感数据。	符合
个人信息保护	a)应仅采集和保存业务必需的用户个人信息；	该项在个人信息对象中独立评估，此处不重复测评，此项不适	不适用

控制点	测评项	结果记录	符合情况
		用。	
	b)应禁止未授权访问和非法使用用户个人信息。	该项在个人信息对象中独立评估，此处不重复测评，此项不适用。	不适用

D.4.1.7数据资源

D.4.1.7.1 重要业务数据

控制点	测评项	结果记录	符合情况
数据完整性	a)应采用校验技术或密码技术保证重要数据在传输过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等；	经核查，系统远程管理采用 https 协议进行传输，采用 ECDHE-RS A-WITH-AES-256-GCM-SHA256 加密算法进行加密和身份验证，可以保证重要业务数据在传输过程中的完整性。	符合
	b)应采用校验技术或密码技术保证重要数据在存储过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等。	经核查，当前针对重要业务数据采用 SM4 算法，可防止重要业务数据在存储过程中被篡改，但未提供数据存储完整性被破坏时的检查和报警机制。	部分符合
数据保密性	a)应采用密码技术保证重要数据在传输过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等；	经核查，系统远程管理采用 https 协议进行传输，采用 ECDHE-RS A-WITH-AES-256-GCM-SHA256 加密算法进行加密和身份验证，可以保证重要业务数据在传输过程中的保密性。	符合
	b)应采用密码技术保证重要数据在存储过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等。	经核查，当前针对重要业务数据采用 SM4 算法，可保证重要业务数据在存储过程中的保密性。	符合
数据备份恢复	a)应提供重要数据的本地数据备份与恢复功能；	经核查，系统的重要业务数据保存在数据库中，按照数据库备份策略，每天凌晨 6 点通过自研脚本 obs-backup.sh，将前一天的数	符合

控制点	测评项	结果记录	符合情况
		数据库备份，备份到华为云对象存储服务 OBS，在系统进行重大升级时对备份文件进行备份恢复测试，具备《数据备份恢复测试记录》，包括备份恢复数据名称、备份恢复人员、备份恢复结果等内容。	
	b)应提供异地实时备份功能，利用通信网络将重要数据实时备份至备份场地；	经核查，云服务客户每月通过手动备份方式将系统重要业务数据备份至运维终端-1 的 D:\备份文件夹中，未利用通信网络将关键数据实时传送至备用场地。	不符合
	c)应提供重要数据处理系统的热冗余，保证系统的高可用性。	因《信息安全技术 网络安全等级保护测评要求》(GB/T 28448-2019) 中该项测评对象的选择不涉及重要业务数据，故此项不适用。	不适用
剩余信息保护	a)应保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除；	鉴别信息的释放措施在操作系统、应用系统、数据库、中间件等对象中独立评估，此处不重复测评，此项不适用。	不适用
	b)应保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	敏感数据的释放措施在操作系统、应用系统、数据库、中间件等对象中独立评估，此处不重复测评，此项不适用。	不适用
个人信息保护	a)应仅采集和保存业务必需的用户个人信息；	该项在个人信息对象中独立评估，此处不重复测评，此项不适用。	不适用
	b)应禁止未授权访问和非法使用用户个人信息。	该项在个人信息对象中独立评估，此处不重复测评，此项不适用。	不适用

D.4.1.7.2 重要个人信息

控制点	测评项	结果记录	符合情况
数据完整性	a)应采用校验技术或密码技术保证重要数据在传输过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等；	经核查，系统远程管理采用 https 协议进行传输，采用 ECDHE-RS A-WITH-AES-256-GCM-SHA256 加密算法进行加密和身份验证，可以保证重要个人信息在传输过程中的完整性。	符合
	b)应采用校验技术或密码技术保证重要数据在存储过程中的完整性，包括但不限于鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要视频数据和重要个人信息等。	经核查，当前针对个人信息采用 SM4 算法，可防止重要个人信息在存储过程中被篡改，但未提供数据存储完整性被破坏时的检查和报警机制。	部分符合
数据保密性	a)应采用密码技术保证重要数据在传输过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等；	经核查，系统远程管理采用 https 协议进行传输，采用 ECDHE-RS A-WITH-AES-256-GCM-SHA256 加密算法进行加密和身份验证，可以保证重要个人信息在传输过程中的保密性。	符合
	b)应采用密码技术保证重要数据在存储过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等。	经核查，当前针对重要个人信息采用 SM4 算法，可保证重要个人信息在存储过程中的保密性。	符合
数据备份恢复	a)应提供重要数据的本地数据备份与恢复功能；	经核查，系统的重要个人信息保存在数据库中，按照数据库备份策略，每天凌晨 6 点通过自研脚本 obs-backup.sh，将前一天的数据库备份，备份到华为云对象存储服务 OBS，在系统进行重大升级时对备份文件进行备份恢复测试，具备《数据备份恢复测试记录》，包括备份恢复数据名称、备份恢复人员、备份恢复结果等内容。	符合
	b)应提供异地实时备份功能，利用通信网络将重要数据实时备份至备份场地；	经核查，云服务客户每月通过手动备份方式将系统重要个人信息备份至运维终端-1 的 D:\备份文件夹中，未利用通信网络将关	不符合

控制点	测评项	结果记录	符合情况
		键数据实时传送至备用场地。	
	c)应提供重要数据处理系统的热冗余，保证系统的高可用性。	因《信息安全技术 网络安全等级保护测评要求》（GB/T 28448-2019）中该项测评对象的选择不涉及重要个人信息，故此项不适用。	不适用
剩余信息保护	a)应保证鉴别信息所在的存储空间被释放或重新分配前得到完全清除；	鉴别信息的释放措施在操作系统、应用系统、数据库、中间件等对象中独立评估，此处不重复测评，此项不适用。	不适用
	b)应保证存有敏感数据的存储空间被释放或重新分配前得到完全清除。	敏感数据的释放措施在操作系统、应用系统、数据库、中间件等对象中独立评估，此处不重复测评，此项不适用。	不适用
个人信息保护	a)应仅采集和保存业务必需的用户个人信息；	经核查，系统采集的用户个人信息包括姓名、身份证号、手机号等，均为业务所需的个人信息，未发现超范围采集情况；且被测单位已具备个人信息保护的相关管理要求和流程规定。	符合
	b)应禁止未授权访问和非法使用用户个人信息。	经核查，系统中保存的个人信息仅授权用户可访问，非授权用户无法访问及使用，且具备个人信息保护的相关管理要求和流程规定，且通过华为云数据库安全服务 DBSS 对数据进行安全审计，防止非法查询操作。	符合

D.4.2 安全扩展要求部分

D.4.2.1云租户安全扩展要求

测评指标	控制点	测评项	结果记录	符合情况
云计算安全扩展要求	身份鉴别	当远程管理云计算平台中设备时，管理终端和	经查看，当对云计算平台设备进行远程管理时，未采用任何	不符合

测评指标	控制点	测评项	结果记录	符合情况
	访问控制	云计算平台之间应建立双向身份验证机制。	机制对管理终端及云平台之间进行双向身份验证。	
		a)应保证当虚拟机迁移时，访问控制策略随其迁移；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
		b)应允许云服务客户设置不同虚拟机之间的访问控制策略。	经查看，云服务客户可通过华为云安全组设置不同虚拟机之间的访问控制策略，且访问控制策略可生效。	符合
	入侵防范	a)应能检测虚拟机之间的资源隔离失效，并进行告警；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
		b)应能检测非授权新建虚拟机或者重新启用虚拟机，并进行告警；	经查看，云计算平台部署华为云企业主机安全服务 HSS，可对非授权新建虚拟机或者重新启用虚拟机进行检测，并通过手机短信（138****5671）的方式进行告警。	符合
		c)应能够检测恶意代码感染及在虚拟机间蔓延的情况，并进行告警。	经查看，云计算平台部署华为云企业主机安全服务 HSS，可对恶意代码感染及在虚拟机间蔓延的情况进行检测，并通过手机短信（138****5671）的方式进行告警。	符合
	镜像和快照保护	a)应针对重要业务系统提供加固的操作系统镜像或操作系统安全加固服务；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
		b)应提供虚拟机镜像、快照完整性校验功能，防止虚拟机镜像被恶意篡改；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
		c)应采取密码技术或其他技术手段防止虚拟机	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云	不适用

测评指标	控制点	测评项	结果记录	符合情况
	数据完整性和保密性	镜像、快照中可能存在的敏感资源被非法访问。	负责，此项标准不适用。	
		a)应确保云服务客户数据、用户个人信息等存储于中国境内，如需出境应遵循国家相关规定；	经查看与访谈，被测系统部署于华为云平台，系统服务器、数据库等设备均放置于华为云机房，机房位于华北-北京一区，属于中国境内。	符合
		b)应确保只有在云服务客户授权下，云服务商或第三方才具有云服务客户数据的管理权限；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
		c)应使用校验码或密码技术确保虚拟机迁移过程中重要数据的完整性，并在检测到完整性受到破坏时采取必要的恢复措施；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
		d)应支持云服务客户部署密钥管理解决方案，保证云服务客户自行实现数据的加解密过程。	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
	数据备份恢复	a)云服务客户应在本地保存其业务数据的备份；	经核查，云服务客户每月通过手动备份方式将系统重要数据备份至运维终端-1 的 D:\备份文件夹中。	符合
		b)应提供查询云服务客户数据及备份存储位置的能力；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
		c)云服务商的云存储服务应保证云服务客户数据存在若干个可用的副本，各副本之间的内容应保持一致；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用

测评指标	控制点	测评项	结果记录	符合情况
	剩余信息保护	d)应为云服务客户将业务系统及数据迁移到其他云计算平台和本地系统提供技术手段，并协助完成迁移过程。	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
		a)应保证虚拟机所使用的内存和存储空间回收时得到完全清除；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
		b)云服务客户删除业务应用数据时，云计算平台应将云存储中所有副本删除。	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用

D.5 安全管理中心

D.5.1 安全通用要求部分

D.5.1.1安全管理中心

控制点	测评项	结果记录	符合情况
系统管理	a)应对系统管理员进行身份鉴别，只允许其通过特定的命令或操作界面进行系统管理操作，并对这些操作进行审计；	经查看，系统部署在华为云上，查看华为云管理控制台，系统管理员通过华为云管理控制台（用户名和口令+手机短信验证码）和皓迪堡垒机（用户名和口令）提供的登录模块进行身份鉴别并登录系统，可对全网资源进行统一管理，系统开启事件审核策略，可对系统管理员的操作进行审计。	符合
	b)应通过系统管理员对系统的资源和运行进行配置、控制和管理，包括用户身份、系统资源配置、系统加载和启动、系统运行的异常处理、数据和设备的备份与	经查看，系统部署在华为云上，查看华为云管理控制台，系统管理员通过华为云管理控制台和皓迪堡垒机提供的管理功能模块对全网的资源和运行进行配置、控制和管理，包括用户身份、系统资源配置、系统加载和	符合

控制点	测评项	结果记录	符合情况
	恢复等。	启动、系统运行的异常处理、数据和设备的备份与恢复等。	
审计管理	a)应对审计管理员进行身份鉴别,只允许其通过特定的命令或操作界面进行安全审计操作,并对这些操作进行审计;	经查看,审计管理员通过用户名口令+手机短信验证码的方式登录华为云管理控制台,通过华为云管理控制台的华为云对象存储服务 OBS 和华为云云日志服务 LTS 能够进行安全审计操作,并对审计管理员的行为进行审计记录。	符合
	b)应通过审计管理员对审计记录应进行分析,并根据分析结果进行处理,包括根据安全审计策略对审计记录进行存储、管理和查询等。	经查看,系统部署了华为云对象存储服务 OBS 和华为云云日志服务 LTS 对各个节点的日志记录进行集中收集,审计管理员登录日志审计平台可以对收集的审计记录进行统一查询、管理和分析,可对审计数据完整性进行保护。	符合
安全管理	a)应对安全管理员进行身份鉴别,只允许其通过特定的命令或操作界面进行安全管理操作,并对这些操作进行审计;	经查看,系统部署在华为云上,查看华为云管理控制台-RAM 访问控制-身份管理,安全管理员可通过华为云管理控制台(用户名和口令+手机短信验证码)提供的登录模块进行身份鉴别,登录系统后可限制其通过特定的命令或操作界面进行系统管理操作。	符合
	b)应通过安全管理员对系统中的安全策略进行配置,包括安全参数的设置,主体、客体进行统一安全标记,对主体进行授权,配置可信验证策略等。	经查看,系统部署在华为云上,查看访问管理-安全设置,安全管理员可通过华为云管理控制台对系统中的安全策略进行统一配置,并包括安全参数的设置,主体、客体进行统一安全标记,对主体进行授权,配置可信验证策略等。	符合
集中管控	a)应划分出特定的管理区域,对分布在网络中的安全设备或安全组件进行管控;	经查看,系统部署在华为云上,网络中已划分出单独的安全组件区用于部署安全设备及安全组件。	符合
	b)应能够建立一条安全的	经查看,系统部署在华为云上,系统	符合

控制点	测评项	结果记录	符合情况
	信息传输路径,对网络中的安全设备或安全组件进行管理;	的主要设备可通过华为云管理控制台采用 https 等协议进行远程管理,主要设备管理均通过华为云管理控制台进行操作管理。	
	c)应对网络链路、安全设备、网络设备和服务器等的运行状况进行集中监测;	经核查,系统部署在华为云,云租户开通了华为云企业主机安全 HSS,可对网络链路、服务器、安全组件的运行状况进行集中监测。	符合
	d)应对分散在各个设备上的审计数据进行收集汇总和集中分析,并保证审计记录的留存时间符合法律法规要求;	经查看,系统部署在华为云上,华为云管理控制台当前配置策略已创建跟踪列表(华为云云日志服务 LTS、华为云数据库安全服务 DBSS),并通过本地网络实时保存至华为云对象存储服务 OBS 中,可以对各类设备的审计记录进行实时统一收集、汇总、分析、查询等,查询 2025 年 3 月 1 日-2025 年 9 月 2 日的日志信息,日志保存时间 6 个月以上,可对审计记录的完整性进行保护,避免受到未预期的删除、修改和覆盖等。	符合
	e)应对安全策略、恶意代码、补丁升级等安全相关事项进行集中管理;	经查看,租户已购买华为云企业主机安全 HSS 企业版功能,能够对主机漏洞进行统一检测和修复;在华为云企业主机安全 HSS 的设置模块中能对云环境的安全策略进行统一管理,包括 IP 白名单、访问控制防护模式、主动防御模式等,同时华为云企业主机安全 HSS 企业版提供了恶意代码查杀功能。	符合
	f)应能对网络中发生的各类安全事件进行识别、报警和分析。	经查看,系统部署在华为云上,查看华为云管理控制台,配置了深信服 Web 应用云防火墙和华为云企业主机安全 HSS,其具有流量分析功能,能够对各类安全事件进行分析,并通并通过手机短信(138****5671)的方式进行报警。	符合

D.5.2 安全扩展要求部分

D.5.2.1 云租户安全扩展要求

测评指标	控制点	测评项	结果记录	符合情况
云计算安全扩展要求	集中管控	a)应能对物理资源和虚拟资源按照策略做统一管理调度与分配；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
		b)应保证云计算平台管理流量与云服务客户业务流量分离；	被测系统采用 IaaS 服务，针对此项的安全保护责任由华为云负责，此项标准不适用。	不适用
		c)应根据云服务商和云服务客户的职责划分，收集各自控制部分的审计数据并实现各自的集中审计；	经查看，云服务客户的审计记录通过华为云日志服务 LTS 进行收集，可根据云服务商和云服务客户的职责划分，分别收集各自控制部分审计记录，并实现各自的集中审计。	符合
		d)应根据云服务商和云服务客户的职责划分，实现各自控制部分，包括虚拟化网络、虚拟机、虚拟化安全设备等的运行状况的集中监测。	经查看，通过华为云管理控制台对虚拟化网络、虚拟机、虚拟化安全设备的运行状况的集中监测，云服务商和云服务客户根据职责划分，对各自控制部分进行集中监测。	符合

D.6 安全管理制度

D.6.1 安全通用要求部分

控制点	测评项	结果记录	符合情况
安全策略	应制定网络安全工作的总体方针和安全策略,阐明机构安全工作的总体目标、范围、原则和安全框架等。	经核查，单位提供了《信息安全管理办法》，内容包含有总则、信息安全方针和目标、信息安全管理策略等内容，阐明了网络信息系统安全管理工作的总体目标、范围、原则和安全框架等。	符合
管理制度	a)应对安全管理活动中的	经核查，提供了《岗位建设管理	符合

控制点	测评项	结果记录	符合情况
	各类管理内容建立安全管理制度；	制度》、《授权和审批管理制度》、《安全检查和通报管理制度》、《人员安全管理制度》、《安全教育和培训管理制度》、《外部人员管理制度》、《产品采购管理制度》、《软件开发管理制度》、《项目实施管理制度》、《测试验收管理制度》、《办公环境管理制度》、《资产管理制度》、《介质安全管理制度》、《设备安全管理制度》、《网络安全管理制度》、《信息系统安全管理制度》、《恶意代码防范管理制度》、《密码管理制度》、《信息系统变更管理制度》、《备份与恢复管理制度》、《安全事件报告与处置管理制度》、《应急响应预案》；对安全管理活动中的各类管理内容建立了安全的管理制度。	
	b)应对管理人员或操作人员执行的日常管理操作建立操作规程；	经核查，提供了《信息安全管理策略》其中对每个岗位管理员的日常操作进行了规范，并对系统建设管理和系统运维管理的相关内容进行了规范，建立具体的建设、运维操作规程。	符合
	c)应形成由安全策略、管理制度、操作规程、记录表单等构成的全面的的安全管理制度体系。	经核查，已形成由信息安全管理办法、信息安全管理策略、信息安全各项操作规程、记录表单等构成的全面的的安全管理制度体系。	符合
制定和发布	a)应指定或授权专门的部门或人员负责安全管理制度的制定；	经核查，指定信息安全工作小组负责安全管理制度的制定。	符合
	b)安全管理制度应通过正式、有效的方式发布，并进行版本控制。	经核查，安全管理制度通过 OA 系统进行正式、有效的发布，当前版本为 V1.4，进行了版本控	符合

控制点	测评项	结果记录	符合情况
		制。	
评审和修订	应定期对安全管理制度的合理性和适用性进行论证和审定,对存在不足或需要改进的安全管理制度进行修订。	经核查,《信息安全管理办法》明确说明信息安全管理组织需要定期(至少每年一次)开展信息安全管理体制度和安全管理制度的评审工作,以确保整个信息安全管理体制度和安全管理制度的合理性、适用性和有效性;当前已提供了《安全管理制度评审沟通会议记录》和《安全管理制度修订记录》,修订记录包括文件名称、发文部门、修改内容和修改时间等;会议记录包括会议时间、会议地点、主要人员和会议内容等内容。	符合

D.7 安全管理机构

D.7.1 安全通用要求部分

控制点	测评项	结果记录	符合情况
岗位设置	a)应成立指导和管理网络安全工作的委员会或领导小组,其最高领导由单位主管领导担任或授权;	经核查,当前成立了信息安全领导小组,提供了《信息安全领导小组职责》文件,文件里明确说明其最高领导由信息安全部经理担任。	符合
	b)应设立网络安全管理工作的职能部门,设立安全主管、安全管理各个方面的负责人岗位,并定义各负责人的职责;	经访谈,苏州国泰新点软件有限公司已指定由信息安全部担任网络安全管理工作的职能部门,且具备人员职责划分文档,文档中明确了部门及各工作岗位的职责。	符合
	c)应设立系统管理员、审计管理员和安全管理员等岗位,并定义部门及各工作岗位	经核查,提供的《安全组织机构》,在安全管理机构管理职责中定义了信息安全部作为单位	符合

控制点	测评项	结果记录	符合情况
	岗位的职责。	信息安全管理工作的职能部门，并说明了部门职责；提供的《岗位建设管理制度》其中在信息安全岗位职责中，明确设立了安全管理员、审计管理员、系统管理员、网络管理员等岗位并定义了各岗位职责。	
人员配备	a)应配备一定数量的系统管理员、审计管理员和安全管理员等；	经核查，当前配备了网络管理员、安全管理员、系统管理员和审计管理员等管理员，可以满足业务需求，并建立了《岗位建设管理制度》对各负责人的职责进行了书面定义。	符合
	b)应配备专职安全管理员，不可兼任。	经核查，当前由张鑫担任安全管理员，未兼任其他管理员职务。	符合
授权和审批	a)应根据各个部门和岗位的职责明确授权审批事项、审批部门和批准人等；	经核查，提供的《授权和审批管理制度》，其中一般信息安全管理活动审批和授权流程明确了“信息安全工作小组组长审阅后，在其授权审批职责范围内进行审批并签字；当其不在办公现场而副组长具有相应审批权时，应提交副组长进行授权和审批，副组长审阅后，在其授权审批职责范围内进行审批、签字”；重要信息安全管理活动审批和授权流程明确了“信息安全领导小组组长审阅后，在其授权审批职责范围内进行审批并签字；当其不在办公现场而副组长具有相应审批权时，应提交副组长进行授权和审批；信息安全领导小组组长或副组长审批签字后，应提交信息安全工作小组组长进行授权和审批，并签字盖章；当组长不在办公现场而副组长具有相应审批权时，应提交副组长进行授	符合

控制点	测评项	结果记录	符合情况
		权和审批”；规定了比较完善的授权审批流程，其中审批事项需通过书面申请，并由信息安全领导小组组长、信息安全工作小组组长、上级人员等逐级进行审批。	
	b)应针对系统变更、重要操作、物理访问和系统接入等事项建立审批程序,按照审批程序执行审批过程,对重要活动建立逐级审批制度；	经核查，提供了《授权与审批管理制度》，其中重要信息安全管理活动审批和授权流程明确了“(1)当所需审批事项属于关键或重要管理活动，安全管理活动当事人或负责人填写审批申请，写明审批事项内容、审批事项原因等事项，提交信息安全领导小组组长；(2)信息安全领导小组组长审阅后，在其授权审批职责范围内进行审批并签字；当其不在办公现场而副组长具有相应审批权时，应提交副组长进行授权和审批；(3)经过信息安全领导小组及信息安全工作小组负责人双重审批后，安全活动发起人在授权审批范围内执行相应的安全管理操作，并适时将实施进展报告给上级；(4)安全管理活动结束后，应及时告知上级，并按要求汇报实施结果。对重要安全管理活动，须由信息安全领导小组及信息安全工作小组负责人进行双重审批”。提供了《关键活动审批过程表》，其中包含了事件编号、事件类型、事件描述、生效时间、申请部门、申请人以及审批意见。	符合
	c)应定期审查审批事项，及时更新需授权和审批的项目、审批部门和审批人等信息。	经核查，提供的《授权和审批管理制度》中，明确了“应根据实际情况的变化，每月对各审批事项进行检查和审定，以便对审批事项、审批人或审批流程等进行相	符合

控制点	测评项	结果记录	符合情况
		应的更新”；并提供了《信息安全管理活动授权和审批表》，包括申请人、所属部门、申请时间、审批事项、审批内容、审批事项具体内容及原因描述、信息安全工作小组审批意见等内容。	
沟通和合作	a)应加强各类管理人员、组织内部机构和网络安全管理部门之间的合作与沟通，定期召开协调会议，共同协作处理网络安全问题；	经核查，提供的《安全意识教育和培训制度》中，内部沟通明确了“部门主管或信息安全管理将员工的意见分类后向信息安全工作小组反映，信息安全工作小组联同各部门进行跟进，最长不超过两天进行有关调查；原则上每月召开一次信息沟通会议，由信息安全工作小组组织，各部门负责人参加，记录《信息沟通会议记录》。信息安全工作小组每月对各种建议、意见进行汇总分析，向信息领导小组报告。”为各类管理人员之间保持着沟通合作关系，共同协作处理信息安全问题，规定了相应的信息沟通和合作要求；当前每月召开网络安全会议商讨网络安全方面工作，并提供了《信息沟通会议记录》，记录包括会议时间、地点、名称、主要人员和会议内容。	符合
	b)应加强与网络安全职能部门、各类供应商、业界专家及安全组织的合作与沟通；	经核查，提供的《安全意识教育和培训制度》中，外部沟通明确了“信息安全工作小组接收来自主管部门、政府等有关信息安全方面的意见、法律法规规范及规定，接受来自安全研究机构或组织的安全评测、安全管理要求和建议等信息，接受来自第三方安全服务商提供的各种咨询建议和安全预警信息等；对信息进行	符合

控制点	测评项	结果记录	符合情况
		预处理后，进行进一步的分发处理”；“根据与外部用户沟通交换内容的敏感程度，签订保密协议”；同设备厂商、系统集成商、安全服务供应商及公安机关有积极的沟通、合作，并提供的合作合同和保密协议。当前积极通过电话、邮件等方式与网信办等单位进行沟通与合作。	
	c)应建立外联单位联系列表，包括外联单位名称、合作内容、联系人和联系方式等信息。	经核查，当前已提供《外联单位联系列表》，包括单位名称、地址、联系人、联系方式和合作内容等。	符合
审核和检查	a)应定期进行常规安全检查，检查内容包括系统日常运行、系统漏洞和数据备份等情况；	经访谈及核查，由信息安全部每天对系统进行常规安全检查，提供了《日常安全检查记录表》，内容包括联网情况、系统运行情况、系统漏洞等。	符合
	b)应定期进行全面安全检查，检查内容包括现有安全技术措施的有效性、安全配置与安全策略的一致性、安全管理制度的执行情况等；	经核查，信息安全部已每半年对现有安全技术措施的有效性、安全配置与安全策略的一致性、安全管理制度的执行情况进行检查和记录，并提供了《网络信息安全管理检查表》。	符合
	c)应制定安全检查表格实施安全检查，汇总安全检查数据，形成安全检查报告，并对安全检查结果进行通报。	经核查，提供了《年度信息安全检查情况报告表》，表格中包含了部门基本情况、信息系统基本情况、日常信息安全管理情况、信息安全防护管理情况、信息安全应急管理情况、信息技术产品应用情况、信息安全教育培训情况、信息系统安全建设整改、信息安全经费保障、本年度信息安全事件情况等内容，对相关结果进行信息安全部内部通告。	符合

D.8 安全管理人员

D.8.1 安全通用要求部分

控制点	测评项	结果记录	符合情况
人员录用	a)应指定或授权专门的部门或人员负责人员录用；	经访谈，由苏州国泰新点软件有限公司人力资源部负责人员的录用工作。	符合
	b)应对被录用人员的身份、安全背景、专业资格或资质等进行审查，对其所具有的技术技能进行考核；	经访谈和查看，在人员录用前均会对其作严格的身份背景、技能掌握程度等相关的考核，特别对于关键岗位、关键职务人员，以及其他会大量接触敏感信息的人员会重点审查；相关审查记录保存在人力资源部。	符合
	c)应与被录用人员签署保密协议，与关键岗位人员签署岗位责任协议。	经核查，当前与被录用人员签署《保密协议》，同时提供了与关键岗位人员签署的《岗位责任协议》。	符合
人员离岗	a)应及时终止离岗人员的所有访问权限，取回各种身份证件、钥匙、徽章等以及机构提供的软硬件设备；	经访谈及核查，提供的《人员安全管理制度》中，人员转岗和离职明确了“4.人员离职时，应按照离职流程，由部门负责人及时通知网络管理员，由网络管理员删除用户的账号、邮件，即时取消其计算机涉密信息系统的访问授权，取回各种身份证件、钥匙、徽章以及机构提供的软硬件设备。5.如果保留设备中的信息以留给新入职的员工使用，在设备重用时由重用人对设备中的信息进行确认。信息处理方式包括：信息删除、保留信息给他人使用、将信息拷贝出来另行存储等”。当前单位暂无人员离岗。	符合
	b)应办理严格的调离手续，并承诺调离后的保密义务后方可离开。	经核查，提供的《人员安全管理制度》，人员转岗和离职明确了“6.接触较多单位机密或更高级别信息资产或特殊工种的人员在离岗离职时需要签订离岗离职相关保密协议，不得私自泄露单位秘密信息。”当前单位暂无人员离岗。	符合
安全意识教育和培训	a)应对各类人员进行安全意识教育和岗位技能培训，	经核查，提供的《安全教育和培训管理制度》中，明确了“对在职人员进	符合

控制点	测评项	结果记录	符合情况
	并告知相关的安全责任和惩戒措施;	行必要的信息安全意识教育和培训,让工作人员了解和掌握基本的信息安全法律法规,加强全体工作人员的信息安全意识;信息安全培训内容包括安全意识培训、安全技能培训和安全专业技术培训;且提供的《人员安全管理制度》制度对相关的安全责任和惩戒措施进行了明确,当前提供了安全培训记录《信息安全培训汇总登记表》,包括时间、地点、培训内容和培训人员等内容。	
	b)应针对不同岗位制定不同的培训计划,对安全基础知识、岗位操作规程等进行培训;	经核查,针对不同岗位的培训计划在年初已制定。《培训计划》包括培训内容、培训次数、培训地点、培训时间等内容。	符合
	c)应定期对不同岗位的人员进行技能考核。	经核查,已每月对不同岗位的人员进行技能考核,并提供了《人员考核记录》。	符合
外部人员访问管理	a)应在外部人员物理访问受控区域前先提出书面申请,批准后由专人全程陪同,并登记备案;	经核查,提供了《外部人员管理制度》,其中来访登记控制明确了“(1)所有到单位访问的外来人员必须依据来访登记表进行登记预约,未经单位相关人员确定的访客一律谢绝进入办公区域。登记表必须明确记录时间、姓名、证件名称(号码)、受访部门或人员名称、事由、来访值班员、离开时间和离开时值班员等相关信息,并在备注中说明其他需要明确或记录的事项。(2)与单位业务有关但不确定具体情况的人员来访时,必须及时询问来访客人身份、目的、需要咨询了解事项认真登记后,再与相关部门办公人员核实处理。(3)到访单位的外来人员实行谁接待谁负责的安全控制方式,需要进入办公区域的必须由受访部门安排人员陪同并控制范围,机房、财务室、档案室等重	符合

控制点	测评项	结果记录	符合情况
		点部位非检查单位人员一律禁止入内”；提供了《关键区域出入申请表》，其中详细记录了申请人姓名、申请部门、申请日期、外部人员姓名及单位、申请部门陪同人员姓名、携带设备、工作内容描述等内容。	
	b)应在外部人员接入受控网络访问系统前先提出书面申请,批准后由专人开设账户、分配权限,并登记备案;	经核查,提供了《外部人员管理制度》,其中外部人员的安全操作明确了“不允许外部人员进行远程网络访问。如确因维护需要远程访问,必须报分管领导批准”提供了《系统外联申请表》,详细记录了申请部门、申请人、申请事项、审核申请事项等内容。提供了《外部人员接入受控网络访问系统的登记记录》,其中包含了人员信息、接入网络、账户分配、访问权限等内容。	符合
	c)外部人员离场后应及时清除其所有的访问权限;	经查看,建立了《外部人员管理制度》,规定外部人员离场后及时清除其所有的访问权限;测评机构人员访问系统均由本单位人员操作,故无清除外部人员访问权限记录。	符合
	d)获得系统访问授权的外部人员应签署保密协议,不得进行非授权操作,不得复制和泄露任何敏感信息。	经核查,提供了《第三方人员保密协议》,对获得系统访问权限的人员签署保密内容,规定双方责任等。	符合

D.9 安全建设管理

D.9.1 安全通用要求部分

控制点	测评项	结果记录	符合情况
定级和备案	a)应以书面的形式说明保护对象的安全保护等级及确定等级的方法和理由;	经核查,在定级报告中详细描述了定级过程,详细描述定级的依据、方法和理由,明确分析了系统被破坏后对国家安全、社会秩	符合

控制点	测评项	结果记录	符合情况
		序与公共利益、公民、法人和其他组织的合法权益造成的影响程度。	
	b)应组织相关部门和有关安全技术专家对定级结果的合理性和正确性进行论证和审定；	经访谈，组织了信息安全部和安全专家对定级结果进行论证和审定，并提供了《专家评审意见表》，包括评审人员姓名、评审时间、评审对象、评审意见等内容。	符合
	c)应保证定级结果经过相关部门的批准；	经访谈及核查，系统定级结果已经过信息安全部经理的批准，并提供了《系统定级领导意见审批表》，包括定级系统名称、系统等级、审核内容、审核人员和审核结果等内容。	符合
	d)应将备案材料报主管部门和相应公安机关备案。	经访谈及核查，系统等级备案表、定级报告等备案材料已经报信息安全部和苏州市公安局备案，具备公安机关反馈的备案证明。	符合
安全方案设计	a)应根据安全保护等级选择基本安全措施，依据风险分析的结果补充和调整安全措施；	经核查，当前已制定《系统总体安全建设规划书》，已明确须根据等级保护等级的要求对系统实施安全防护。	符合
	b)应根据保护对象的安全保护等级及与其他级别保护对象的关系进行安全整体规划和安全方案设计，设计内容应包含密码技术相关内容，并形成配套文件；	经访谈及核查，提供了《安全设计方案》，根据安全保护等级进行安全整体规划，对风险分析、数据安全需求、运行安全需求、系统结构及部署、系统安全设计和密码技术相关内容进行了详细规划，形成了配套文件。	符合
	c)应组织相关部门和有关安全专家对安全整体规划及其配套文件的合理性和正确性进行论证和审定，经过批准后才能正式实施。	经访谈，未组织相关部门和有关安全专家对安全方案的合理性和正确性进行论证和审定。	不符合

控制点	测评项	结果记录	符合情况
产品采购和使用	a)应确保网络安全产品采购和使用符合国家的有关规定；	经查看，建立了《产品采购管理制度》，对安全产品的采购原则、采购程序等进行了规定，其中采购程序中要求：供应商必须证照齐全，具有相关资质；采购的网络和安全产品均具备销售许可证。	符合
	b)应确保密码产品与服务的采购和使用符合国家密码管理主管部门的要求；	单位未采购和使用密码产品，无该需求，此项不适用。	不适用
	c)应预先对产品进行选型测试，确定产品的候选范围，并定期审定和更新候选产品名单。	经访谈及核查，业务部门或个人需要购买计算机设备或软件，首先须由本部门领导审批同意，然后向单位领导提出申请，由单位领导统一规划和综合评估后，如确实需要购买，由采购部门在向供货商询价后，申请部门或个人根据此价格完成财务审批手续，并提供了《产品采购清单》。每年均会审定和更新候选产品名单。	符合
自行软件开发	a)应将开发环境与实际运行环境物理分开，测试数据和测试结果受到控制；	经核查，苏州国泰新点软件有限公司部署有独立的开发、测试环境完成编码和调试工作，与生产运行环境完全物理隔离；测试部门拥有独立的测试库、测试文档服务器，均设置了访问权限可以实现测试数据和结果受控使用。	符合
	b)应制定软件开发管理制度，明确说明开发过程的控制方法和人员行为准则；	经核查，当前已制定《软件开发管理制度》，制度中包括软件设计、开发、测试和验收过程的控制流程，以及开发人员的行为准则等内容。	符合
	c)应制定代码编写安全规范，要求开发人员参照规范编写代码；	经核查，当前已制定《代码编写安全规范》，对代码排版要求、注释规范、方法(函数)注释规范以及变量使用等部分进行规范要求，已要求开发人员参照规范学	符合

控制点	测评项	结果记录	符合情况
		习、执行。	
	d)应具备软件设计的相关文档和使用指南，并对文档使用进行控制；	经核查，已提供软件设备文档和使用指南，包括《系统概要设计说明文档》、《用户手册》和《系统使用指南》，由信息安全部保存。	符合
	e)应保证在软件开发过程中对安全性进行测试，在软件安装前对可能存在的恶意代码进行检测；	经核查，软件开发过程中已进行安全性测试，同时已采取措施在软件安装前对可能存在的恶意代码进行检测，当前提供了《系统安全性测试报告》。	符合
	f)应对程序资源库的修改、更新、发布进行授权和批准，并严格进行版本控制；	经核查，开发人员对程序资源库的修改、更新、发布等均需向上级领导提交申请，并通过审批后才能进行操作，提供了《信息系统开发程序库修改登记表》，登记表包括变更内容、时间、修改人和批准人等内容。	符合
	g)应保证开发人员为专职人员，开发人员的开发活动受到控制、监视和审查。	经核查，所有开发人员均为专职人员，均已签署劳动合同；员工办公电脑为单位统一配发，且仅能通过公司内部网络访问开发环境。	符合
外包软件开发	a)应在软件交付前检测其中可能存在的恶意代码；	系统不涉及外包软件开发，故此项不适用。	不适用
	b)应保证开发单位提供软件设计文档和使用指南；	系统不涉及外包软件开发，故此项不适用。	不适用
	c)应保证开发单位提供软件源代码，并审查软件中可能存在的后门和隐蔽信道。	系统不涉及外包软件开发，故此项不适用。	不适用
工程实施	a)应指定或授权专门的部门或人员负责工程实施过程的管理；	经访谈，指定信息安全部负责工程实施过程的管理，对工程实施的质量和进度进行管理。	符合
	b)应制定安全工程实施方案控制	经访谈和查看，提供了《系统建	符合

控制点	测评项	结果记录	符合情况
	工程实施过程；	设项目实施方案》，方案中已对工程的实施过程进行控制与管理，方案内容包含项目概述、建设依据、组织部署、实施计划、人员安排等。	
	c)应通过第三方工程监理控制项目的实施过程。	经访谈，公司未聘请第三方工程监理控制项目的实施过程。	不符合
测试验收	a)应制订测试验收方案，并依据测试验收方案实施测试验收，形成测试验收报告；	经核查，当前单位已提供《系统测试验收方案》，内容包括：性能测试背景、性能测试目标、性能测试环境、性能测试计划、测试场景、风险分析等，并提供了《系统测试验收报告》。	符合
	b)应进行上线前的安全性测试，并出具安全测试报告，安全测试报告应包含密码应用安全性测试相关内容。	经核查，上线前已进行安全性测试，当前提供了《系统安全性测试报告》。	符合
系统交付	a)应制定交付清单，并根据交付清单对所交接的设备、软件和文档等进行清点；	经核查，系统交付时，已提供交付清单，内容包括产品软件、用户使用操作手册，网络设备清单、安全设备清单和服务器清单等文档，包括《系统概要设计说明文档》、《用户手册》、《系统使用指南》等文档。	符合
	b)应对负责运行维护的技术人员进行相应的技能培训；	经访谈及核查，信息安全部对系统使用人员和维护人员进行技能培训，提供了《培训记录》，内容包括：培训时间、培训内容、培训人员、培训地点等。	符合
	c)应提供建设过程文档和运行维护文档。	经核查，提供了系统建设过程中的交付清单、交付结果合格单以及用户手册等相关文档。	符合
等级测评	a)应定期进行等级测评，发现不符合相应等级保护标准要求的及时整改；	经核查，该系统已每年至少进行一次等级保护测评工作，并提供了 2024 年度的测评报告,前次测	符合

控制点	测评项	结果记录	符合情况
		评由苏州如意云网络科技有限公司负责，系统等级测评结论为良，综合得分为 87.18 分，报告编号为 32050013019-24004-24-0105-01，遵循 3 级系统每年至少进行一次等级保护测评安全工作的要求，提供了前次系统测评报告和问题整改记录。	
	b)应在发生重大变更或级别发生变化时进行等级测评；	经访谈及核查，在确定该信息系统的安全保护等级后，并未发生较大变更，未调整安全保护级别，且已在《变更管理制度》中规定系统发生重大变更或级别发生变化时及时进行等级测评。	符合
	c)应确保测评机构的选择符合国家有关规定。	经核查，前次选择的测评单位为苏州如意云网络科技有限公司，可在“网络安全等级保护测评机构服务认证获证机构名录”查看到该公司名称，该名录的发布单位是“公安部第三研究所(认证中心)”；符合国家有关规定。	符合
服务供应商选择	a)应确保服务供应商的选择符合国家的有关规定；	经核查，当前选择苏州如意云网络科技有限公司作为测评认证服务商，选择华为云计算技术有限公司作为云服务商，选择的安全服务商具备相应的安全资质，符合国家的有关规定。	符合
	b)应与选定的服务供应商签订相关协议，明确整个服务供应链各方需履行的网络安全相关义务；	经查看，与华为云计算技术有限公司和苏州如意云网络科技有限公司签署服务合同，明确了服务内容、服务期限和服务承诺等内容。	符合
	c)应定期监督、评审和审核服务供应商提供的服务，并对其变更服务内容加以控制。	经核查，公司具备每年的安全服务报告交付物，目前安全服务商未发起服务变更申请，无需对变更进行审核；已在《技术维护服务供应商管理》中要求一旦服务	符合

控制点	测评项	结果记录	符合情况
		供应商变更服务内容，须评价其变更是否符合规范要求，并出具服务审核报告，且具备《供应商评价审核制度》，制度中明确了评价指标、考核内容、进入及退出机制等。	

D.9.2 安全扩展要求部分

D.9.2.1云租户安全扩展要求

测评指标	控制点	测评项	结果记录	符合情况
云计算安全扩展要求	云服务商选择	a)应选择安全合规的云服务商，其所提供的云计算平台应为其所承载的业务应用系统提供相应等级的安全保护能力；	经访谈及核查，选择的云服务商为华为云计算技术有限公司，其具备相关服务资质，且此次测评系统托管的华为公有云服务(IaaS)系统已通过三级等保测评，提供了等保测评报告，云服务商所提供的云计算平台能够为其所承载的业务应用系统提供相应等级的安全保护能力。	符合
		b)应在服务水平协议中规定云服务的各项服务内容和具体技术指标；	经查看，当前单位与云服务商-华为云计算技术有限公司签署了《服务水平协议》，在合同中规定了云服务的各项服务内容和具体技术指标。	符合
		c)应在服务水平协议中规定云服务商的权限与责任，包括管理范围、职责划分、访问授权、隐私保护、行为准则、违约责任等；	经查看，当前单位与云服务商-华为云计算技术有限公司签署了《服务水平协议》，协议明确了服务商的权限与责任，包括管理的范围、人员职责划分、访问授权、隐私保护、行为准则、违约责任等。	符合
		d)应在服务水平协议中规定服务合约到期时，	经查看，当前单位与云服务商-华为云计算技术有限公司签署	符合

测评指标	控制点	测评项	结果记录	符合情况
		完整提供云服务客户数据，并承诺相关数据在云计算平台上清除；	了《服务水平协议》，合同明确说明服务水平协议中规定服务合约到期时，云服务商要完整提供云服务客户数据，并承诺相关数据在云计算平台上清除。	
		e)应与选定的云服务商签署保密协议，要求其不得泄露云服务客户数据。	经查看，当前单位与云服务商-华为云计算技术有限公司签署了《服务水平协议》，合同明确说明云服务商对云服务客户数据的保密规定。	符合
	供应链管理	a)应确保供应商的选择符合国家有关规定；	该服务由云平台提供，云租户不适用。	不适用
		b)应将供应链安全事件信息或安全威胁信息及时传达到云服务客户；	该服务由云平台提供，云租户不适用。	不适用
		c)应将供应商的重要变更及时传达到云服务客户，并评估变更带来的安全风险，采取措施对风险进行控制。	该服务由云平台提供，云租户不适用。	不适用

D.10安全运维管理

D.10.1 安全通用要求部分

控制点	测评项	结果记录	符合情况
环境管理	a)应指定专门的部门或人员负责机房安全，对机房出入进行管理，定期对机房供配电、空调、温湿度控制、消防等设施进行维护管理；	系统部署在华为云，机房物理环境管理由华为云负责，此项不适用。	不适用
	b)应建立机房安全管理制度，对有关物理访问、物品带进出和环境安全等方面的管理作出规定；	系统部署在华为云，机房物理环境管理由华为云负责，此项不适用。	不适用

控制点	测评项	结果记录	符合情况
	c)应不在重要区域接待来访人员，不随意放置含有敏感信息的纸档文件和移动介质等。	经查看，单位建立了《办公环境管理制度》，对办公室人员的相关行为作出了规定，内容包括不在办公区接待来访人员、工作人员离开座位应确保终端计算机退出登录状态和桌面上没有包含敏感信息的纸档文件等；现场观察办公桌面及终端屏幕保护情况符合管理制度规定。	符合
资产管理	a)应编制并保存与保护对象相关的资产清单，包括资产责任部门、重要程度和所处位置等内容；	经核查，建立了《资产清单》，清单内容包括资产的责任人、所属部门、资产的名称和资产数量等。	符合
	b)应根据资产的重要程度对资产进行标识管理，根据资产的价值选择相应的管理措施；	经核查，提供的《资产管理制度》中，资产分类与分级中明确了“1. 与信息系统相关的信息资产主要分为以下几类：(1) 网络及安全设备：路由器、交换机、负载均衡、防篡改、防火墙、IDS/IPS 等构成信息系统传输环境和安全环境的设备、软件和传输介质。(2) 服务器：各类承载业务系统和软件的计算机系统及其操作系统，包括安装在服务器上各类应用系统以及构建系统的平台软件（数据库，各软件平台等）。(3) 存储设备：NAS、SAN、磁带机、磁带库、磁盘阵列等构成信息系统存储环境的设备和软件。(4) 终端资产：包括工作站和普通办公终端。工作站指监控终端，即用于管理服务器上的服务的终端，例如网管终端等。普通办公终端包括一般用途的笔记本和 PC。(5) 其他资产：除上述资产之外的其他信息资产，如数据、文档等。2. 为便于对资产实行分级别保护，信息系统资	符合

控制点	测评项	结果记录	符合情况
		产分级将资产划分为：超核心资产、核心资产、高级资产、中级资产、一般资产五个级别。”已根据资产重要性对资产进行标识工作，并根据资产的价值选择相应的管理措施。	
	c)应对信息分类与标识方法作出规定，并对信息的使用、传输和存储等进行规范化管理。	经核查，提供的《资产管理制度》中，资产赋值和标识中明确了“3.应对所有已进行识别并分类的信息资产进行标识，标识方法可以采用标签、文档标识、数据标识等。4.对信息资产进行标识时，应标识出信息资产的名称、型号、版本、分类、资产编号、资产管理员、重要级别、所处物理位置等相关信息。根据不同的信息资产类别，标识的内容和方法可以有所不同。5.资产管理者要维护好自己所负责的资产分类清单，并定期进行检查和更新。6.当信息资产的管理者、物理位置、重要级别等信息发生变更时，需要及时对相应的标识进行变更”；同时对信息的使用、传输和存储进行说明。	符合
介质管理	a)应将介质存放在安全的环境中，对各类介质进行控制和保护，实行存储环境专人管理，并根据存档介质的目录清单定期盘点；	经核查，提供了《介质安全管理制度》，其中设备管理明确了“4、建立统一的移动存储设备资料库，记录设备的密级、用途、硬件特征码、管理部门、责任人等信息备查；5、建立移动存储设备发放流程，由专人负责设备发放工作，需要使用移动存储设备的部门或者个人需提出申请，并说明用途，到信息安全管理处领用”。信息安全部每半年对介质进行盘点，并提供了《介质盘点清单》，包括介质名称、存储位置、	符合

控制点	测评项	结果记录	符合情况
		盘点人员（部门）等内容。	
	b)应对介质在物理传输过程中的人员选择、打包、交付等情况进行控制，并对介质的归档和查询等进行登记记录。	经核查，提供了《介质安全管理制度》，其中设备外带明确了“1、移动存储设备原则上不得带离单位使用，如确因工作需要需带离单位的，须经单位领导批准，并确保涉密移动存储介质始终处于携带责任人的有效控制之下；2、携带涉密移动存储介质外出，需向信息安全管理员申请，备案本次外出携带的资料内容样本，设定有效使用期限，到期处理方式等；3、严禁以明文的形式将资料存储在移动存储设备中，应配备资料使用口令或钥匙，口令设置应满足安全需要，不得过于简单和容易猜测，禁止将解密钥匙与资料同时存放在同一个移动存储介质中；4、严禁携带涉密移动存储介质出境，确因工作需要携带出境的，应当按照有关保密规定办理特殊批准和携带手续；5、如因工作需要需携带笔记本电脑或者 PC 机离开单位，必须确保计算机移动存储访问受保护，重要敏感数据需经过加密处理，安装防拷贝系统防止非法访；6、设备带回后应交由信息安全管理人员确认介质序列号，并作病毒木马扫描等日常处理，方可实行联机操作，接入单位内部使用；7、从外单位通过移动存储设备带回本单位的数据必须经过安全验证，确保符合单位数据管理规定方可拷入单位内部使用”。当前提供了《介质使用记录表》，内容包含介质名称、借用人、借用时间、归还时间、借用原因等。	符合

控制点	测评项	结果记录	符合情况
设备维护管理	a)应对各种设备（包括备份和冗余设备）、线路等指定专门的部门或人员定期进行维护管理；	经核查，当前系统部署在华为云上，信息系统相关的设备及线路等由云服务商负责，由信息安全部每月对各办公室设备进行维护管理。	符合
	b)应建立配套设施、软硬件维护方面的管理制度，对其维护进行有效的管理，包括明确维护人员的责任、维修和服务的审批、维修过程的监督控制等；	经核查，提供的《设备安全管理制度》中，设备运维管理明确了“管理员须对设备使用人员进行必要的培训或指导，设备使用员须依照设备使用规范和操作手册要求，合理使用计算机设备，不得擅自拆装设备及更换设备部件。3.管理人员负责督促设备使用部门按时提交设备使用情况，对于设备闲置或资源使用效率持续低下的情况，管理人员应及时予以合理调整。4.设备使用人员不得自行变更设备使用用途，放置地点，须经管理人员审批通过并备案后方可实施。5.管理人员须做好计算机设备的维护管理工作，具体包括：日常监控、巡检、保养、健康检查、维护修理、扩容升级、停机管理等内容。6.管理人员根据不同种类计算机设备的使用情况，做好计算机设备硬件维护服务的管理工作。7.对于未购买日常硬件维护服务的计算机设备，日常硬件维护服务工作原则上由管理人员承担；该类设备出现故障，而管理人员无法修复的，可通过购买维修备件或计次服务方式解决”	符合
	c)信息处理设备应经过审批才能带离机房或办公地点，含有存储介质的设备带出工作环境时其中重要数据应加密；	经核查，建立了《设备安全管理制度》，规定了信息处理的设备必须经过审批才能带离机房或办公地点，提供《设备带离审批	符合

控制点	测评项	结果记录	符合情况
		记录》，包括设备名称、带离事由、审批人等内容。	
	d)含有存储介质的设备在报废或重用前，应进行完全清除或被安全覆盖，保证该设备上的敏感数据和授权软件无法被恢复重用。	经核查，提供的《设备安全管理制度》中，盘点处理明确了“3.管理人员须对退还计算机设备进行全面检查，清理数据、审核设备配置，确定设备当前状态，保证设备上的敏感数据和授权软件无法被恢复重用。4.管理人员应组织做好停用闲置设备的检修和维护管理工作，根据使用部门需求情况，合理调配使用闲置设备，最大限度发挥设备使用效益。5.对于有严重故障、无法修复或修复成本高于价值总和的设备，经设备管理部门鉴定，可以申请报废。6.设备的报废由设备管理部门统一组织实施，并按照相关制度规定执行。7.报废设备的处理须在确保相关设备存储信息安全处置前提下进行，并符合国家电子类设备处置的相关法律法规”	符合
漏洞和风险管理	a)应采取必要的措施识别安全漏洞和隐患，对发现的安全漏洞和隐患及时进行修补或评估可能的影响后进行修补；	经访谈和查看，租户购买了华为云企业主机安全 HSS 企业版，华为云提供了漏洞自动检测并提供了修复方案；租户已每天对系统进行漏洞扫描并修补了漏洞。当前提供了《漏洞扫描记录》，包括时间、漏洞等情况、检测结果和检测结果分析等内容。	符合
	b)应定期开展安全测评，形成安全测评报告，采取措施应对发现的安全问题。	经核查，该系统已每年至少进行一次等级保护测评工作，并提供了 2024 年度的测评报告,前次测评由苏州如意云网络科技有限公司负责，系统等级测评结论为良，综合得分为 87.18 分，报告编号为 32050013019-24004-24-0	符合

控制点	测评项	结果记录	符合情况
		105-01，同时已根据发现的问题进行了加固，有整改记录。	
网络和系统安全管理	a)应划分不同的管理员角色进行网络和系统的运维管理，明确各个角色的责任和权限；	经核查，划分了网络管理员、系统管理员、审计管理员和安全管理员等职务，并在《岗位建设管理制度》中明确了各个管理员的岗位职责。	符合
	b)应指定专门的部门或人员进行账户管理，对申请账户、建立账户、删除账户等进行控制；	经核查，系统的账号管理由信息安全部负责，包括账户的删除和创建等。	符合
	c)应建立网络和系统安全管理制度，对安全策略、账户管理、配置管理、日志管理、日常操作、升级与打补丁、口令更新周期等方面作出规定；	经核查，提供了《设备安全管理制度》、《网络安全管理制度》、《信息系统安全管理制度》、《恶意代码防范管理制度》、《密码管理制度》、《备份与恢复管理制度》等文件，对相关配置、网络运行、变更管理、补丁管理、版本升级等内容作出明确规定。	符合
	d)应制定重要设备的配置和操作手册，依据手册对设备进行安全配置和优化配置等；	经核查，提供了《设备操作手册》，内容包括：设备名称及型号、配置描述、安装说明、维护、设备操作、参数设置等，对重要设备的配置和操作进行了规定。	符合
	e)应详细记录运维操作日志，包括日常巡检工作、运行维护记录、参数的设置和修改等内容；	经核查，当前提供了《系统运维巡检记录表》，包括日常巡检记录、运行维护记录、参数的设置和修改等内容。	符合
	f)应指定专门的部门或人员对日志、监测和报警数据等进行分析、统计，及时发现可疑行为；	经核查和访谈，未组织相关人员或部门对监测和报警记录进行分析、统计。	不符合
	g)应严格控制变更性运维，经过审批后才可改变连接、安装系统组件或调整配置参数，操作过程中应保留不可更改的审计日志，操作结束后应同步更新配置信	经访谈和查看，系统连接、安装系统组件等事项需经信息安全部审批后方可进行，提供了系统连接、系统更新组件、调整配置参数等变更运维工作的《变更审	符合

控制点	测评项	结果记录	符合情况
	息库；	批记录》，且操作过程中保留了不可更改的审计日志。《变更审批记录》包括变更类型、申报流程、审批部门、批准人等方面内容。	
	h)应严格控制运维工具的使用，经过审批后才可接入进行操作，操作过程中应保留不可更改的审计日志，操作结束后应删除工具中的敏感数据；	经访谈，运维人员使用运维工具接入系统时需经过信息安全部通过 OA 系统审批通过后方可接入系统，结束后需删除工具中的敏感数据，且操作过程中保留了不可更改的审计日志。	符合
	i)应严格控制远程运维的开通，经过审批后才可开通远程运维接口或通道，操作过程中应保留不可更改的审计日志，操作结束后立即关闭接口或通道；	经访谈及核查，远程运维权限的开通需向信息安全部进行申请，由管理员负责远程工具账号和权限的开通，操作结束后对账户进行权限删除或禁用，且操作过程中保留了不可更改的审计日志。	符合
	j)应保证所有与外部的连接均得到授权和批准，应定期检查违反规定无线上网及其他违反网络安全策略的行为。	经访谈及核查，制定了《网络安全管理制度》，网络外联需提交《系统外联申请表》，详细记录了申请部门、申请人、申请事项、审核申请事项等内容，同时提供了检查用户违反网络安全策略行为的工作记录（每年一次）。	符合
恶意代码防范管理	a)应提高所有用户的防恶意代码意识，对外来计算机或存储设备接入系统前进行恶意代码检查等；	经核查，提供的《恶意代码防范管理制度》中，明确了“所有计算设备用户应保证使用的计算设备，按照单位要求安装了相应的病毒防护软件或采用了相应的病毒防护手段，如果自己无法对病毒防护措施的有效性进行判断，应及时通知进行解决”并在员工安全意识培训中对防恶意代码知识进行了宣讲，宣讲内容包括防病毒相关知识和防恶意代码的方法等，并提供了《恶意	符合

控制点	测评项	结果记录	符合情况
		代码培训记录表》，内容包括培训名称、培训类别、培训人数、培训地点等。	
	b)应定期验证防范恶意代码攻击的技术措施的有效性。	经核查，提供了《恶意代码防范管理制度》，其中安全要求明确了“管理员要每月验证防范恶意代码攻击的有效性，保证这些措施的可用性”。提供了《恶意代码查杀表》和《恶意代码库升级记录》，详细记录了恶意代码检测记录、恶意代码库升级记录等内容。	符合
配置管理	a)应记录和保存基本配置信息，包括网络拓扑结构、各个设备安装的软件组件、软件组件的版本和补丁信息、各个设备或软件组件的配置参数等；	经访谈，网络管理员对网络拓扑结构、软件组件版本和补丁信息等基本配置信息进行了记录和保存。	符合
	b)应将基本配置信息改变纳入变更范畴，实施对配置信息改变的控制，并及时更新基本配置信息库。	经核查，提供的《网络安全管理制度》中，网络变更明确了“1. 网络变更包括：网络设备更换、网络线路调整、网络配置修改、网络系统升级等的所有网络变更行为。2. 网络变更都须经过申请，禁止在没有通过审批流程的情况下私自进行网络变更或网络结构调整。3. 针对网络设备的任何配置变更，都应在变更前和变更后做好配置文件的备份工作，并且制定详细可行的回退方案，以应对变更失败时的变更回退操作。4. 所有的网络变更操作都应记录，并且做好网络变更的记录保存工作。”目前配置信息暂未发生变更。	符合
密码管理	a)应遵循密码相关国家标准和行业标准；	当前测评对象未涉及密码产品，无密码产品相关要求，故此项不适用。	不适用

控制点	测评项	结果记录	符合情况
	b)应使用国家密码管理主管部门认证核准的密码技术和产品。	当前测评对象未涉及密码产品，无密码产品相关要求，故此项不适用。	不适用
变更管理	a)应明确变更需求，变更前根据变更需求制定变更方案，变更方案经过评审、审批后方可实施；	经核查，提供的《信息系统变更管理制度》已规定系统发生变更时应制定变更方案，方案内容包括变更类型，变更原因，变更过程、变更前评估等内容。提供了《系统变更申请表》，申请表包括变更缘由、变更时间、变更结果等内容。	符合
	b)应建立变更的申报和审批控制程序，依据程序控制所有的变更，记录变更实施过程；	经核查，提供的《信息系统变更管理制度》中，变更审批明确了“1.系统变更由信息安全部进行审批，如涉及多个部门，由各个部门共同审批。2.变更实施人员填写实施计划时，应明确变更的风险，并由系统负责人审批。3.对于技术方案或审批过程存在异议的变更，由变更实施部门组织协调，必要时提请本部门最终审批人裁定。4.对于未被批准的变更，由变更实施部门负责将变更未被批准的具体原因通知变更申请单位。5.对业务有可能造成影响的变更，需要在变更实施前通知相关业务部门”提供了《变更审批记录》，包括变更类型、申报流程、审批部门、批准人等方面内容。	符合
	c)应建立中止变更并从失败变更中恢复的程序，明确过程控制方法和人员职责，必要时对恢复过程进行演练。	经核查，提供的《信息系统变更管理制度》中，明确了“变更实施人员需要对变更实施计划进行确认，做好实施前的准备工作，包括有关操作流程制定、操作日志修改、技术文档整理和操作人员培训等工作；根据变更的受理情况，协调相关技术支持人员进	符合

控制点	测评项	结果记录	符合情况
		行验证。变更实施过程中，按照变更实施计划的执行时间、环境、顺序、条件等要求执行变更实施计划，严格监控变更实施过程；变更实施过程必须保证双人操作；变更实施完成，认真检查现场执行结果，根据变更验证方案对变更后情况进行验证，并将变更实施结果反馈相关部门。变更实施过程中，如果发生与变更实施计划不相符的意外情况时，在没有找到原因和排除错误的方法时，变更实施人员必须立即报告，由该变更审批人决定是否终止变更，恢复变更实施前的运行环境，并详细记录信息。明确过程控制方法和人员职责。	
备份与恢复管理	a)应识别需要定期备份的重要业务信息、系统数据及软件系统等；	经核查，提供了《备份与恢复管理制度》，其中总则明确了严格按照“对于重要系统和数据的备份周期及备份保存期限应遵循以下原则：(1)至少要保留一份全系统备份。(2)每日运行中发生变更的文件，都应进行备份。(3)生产系统程序库要定期做备份，每月至少做一次。(4)生产系统有变更时，须对变更前后的程序库进行备份。(5)批加工若有对主文件的更新操作，则应进行批加工前备份。(6)对批加工生成的报表也要有相应的备份手段，并按规定的保留期限进行保留。(7)各重要业务系统的月末、半年末、年末以及计息日等特殊日的数据备份须永久保留。(8)定期将生产系统的数据进行删减压缩，并将删减的数据备份上磁带，永久保留。(9)以上未明确保存期限的各项备份的保存至少应保存一周”。	符合

控制点	测评项	结果记录	符合情况
		当前提供了《数据备份清单》，内容包括备份方式及备份周期等。	
	b)应规定备份信息的备份方式、备份频度、存储介质、保存期等；	经核查，提供的《备份与恢复管理制度》中，明确了“对于重要系统和数据的备份周期及备份保存期限应遵循，至少要保留一份全系统备份；每日运行中发生变更的文件，都应进行备份；系统程序库要定期做备份，每月至少做一次；系统有变更时，须对变更前后的程序库进行备份；各重要业务系统的月末、半年末、年末以及计息日等特殊日的数据备份须永久保留”	符合
	c)应根据数据的重要性和数据对系统运行的影响，制定数据的备份策略和恢复策略、备份程序和恢复程序等。	经核查，在《备份与恢复管理制度》中，对数据的备份策略和恢复策略、备份程序和恢复程序等方面做出规定。	符合
安全事件处置	a)应及时向安全管理部门报告所发现的安全弱点和可疑事件；	经核查，提供的《安全事件报告与处置管理制度》中，明确了“信息系统相关人员一旦发现严重信息安全事件发生，必须在一小时以内向上级部门和领导小组报告”；目前尚无安全事件发生。	符合
	b)应制定安全事件报告和处置管理制度，明确不同安全事件的报告、处置和响应流程，规定安全事件的现场处理、事件报告和后期恢复的管理职责等；	经核查，提供的《安全事件报告与处置管理制度》中，明确了“根据信息安全事件对业务可能造成的影响或已经造成影响的严重程度并结合信息安全事件的紧急程度将信息安全事件分为一般、严重和重大三个级别；”并明确了故障类信息安全事件处理流程和泄密类信息安全事件处理流程，对事件的现场与事后报告记录、后期恢复等内容进行明确规定。	符合

控制点	测评项	结果记录	符合情况
	c)应在安全事件报告和响应处理过程中，分析和鉴定事件产生的原因，收集证据，记录处理过程，总结经验教训；	经核查，提供的《安全事件报告与处置管理制度》已规定在安全事件处理过程中及时做好处置记录，分析和鉴定事件产生的原因，总结经验教训，防止安全事件发生；目前未发生安全事件。	符合
	d)对造成系统中断和造成信息泄漏的重大安全事件应采用不同的处理程序和报告程序。	经核查，提供的《安全事件报告与处置管理制度》中，已对泄密类信息安全事件和故障类信息安全事件建立了不同的处理程序；处理流程主要包括现场保护、防止扩散、应急恢复处理、分析事件原因、制定解决方案、实施解决方案、实施检查、总结反馈。	符合
应急预案管理	a)应规定统一的应急预案框架，包括启动预案的条件、应急组织构成、应急资源保障、事后教育和培训等内容；	经核查，提供的《应急响应预案》中，已统一了应急预案框架，内容包括信息系统应急响应策略、基本原则、组织指挥和职责、应急响应的流程、不同事件的应急预案、应急处置演练制度、应急响应总结制度等。	符合
	b)应制定重要事件的应急预案，包括应急处理流程、系统恢复流程等内容；	经核查，提供的《应急响应预案》中，已根据统一的应急预案框架制定重要事件的应急预案；包括组织指挥和职责、应急响应的流程、不同事件的应急预案、应急处置演练制度、应急响应总结制度、系统恢复流程等内容。	符合
	c)应定期对系统相关的人员进行应急预案培训，并进行应急预案的演练；	经核查，当前已每年对系统相关的人员进行一次应急预案培训和一次应急预案演练，并提供了《应急预案培训记录》和《应急预案演练记录》，培训和演练记录包括时间、地址、人员和应急预案培训内容、应急预案演练内容等。	符合

控制点	测评项	结果记录	符合情况
	d)应定期对原有的应急预案重新评估，修订完善。	经核查，每年对原有的应急预案进行评估和修订，提供了《应急预案评审修订记录》和《应急预案评审记录》，《应急预案评审修订记录》内容包括：应急预案名称、编制人、修订日期、适用单位及地点、层次结构、编制程序、修改意见等；《应急预案评审记录》内容包括：应急预案名称、评审人、评审方式、预案评审、评审意见等。	符合
外包运维管理	a)应确保外包运维服务商的选择符合国家的有关规定；	系统未涉及外包运维服务，此项不适用。	不适用
	b)应与选定的外包运维服务商签订相关的协议，明确约定外包运维的范围、工作内容；	系统未涉及外包运维服务，此项不适用。	不适用
	c)应保证选择的外包运维服务商在技术和管理方面均应具有按照等级保护要求开展安全运维工作的能力，并将能力要求在签订的协议中明确；	系统未涉及外包运维服务，此项不适用。	不适用
	d)应在与外包运维服务商签订的协议中明确所有相关的安全要求，如可能涉及对敏感信息的访问、处理、存储要求，对 IT 基础设施中断服务的应急保障要求等。	系统未涉及外包运维服务，此项不适用。	不适用

D.10.2 安全扩展要求部分

D.10.2.1 云租户安全扩展要求

测评指标	控制点	测评项	结果记录	符合情况
云计算安全扩展要求	云计算环境管理	云计算平台的运维地点应位于中国境内，境外对境内云计算平台实施	该服务由云平台提供，云租户不适用。	不适用

测评指标	控制点	测评项	结果记录	符合情况
		运维操作应遵循国家相关规定。		

D.11其他安全要求

本次测评不包含其他安全要求。

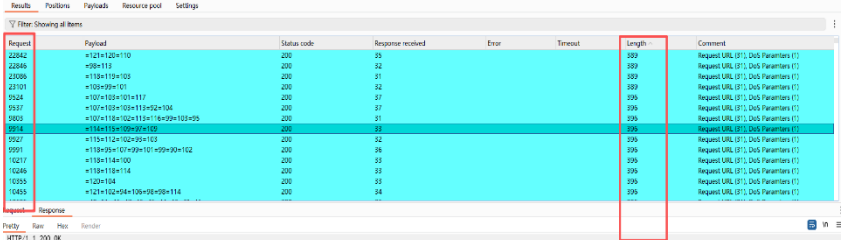
附录E 漏洞扫描结果记录

附录 E 表-1 漏洞扫描主要安全漏洞

序号	安全漏洞名称	关联资产/域名	严重程度
本次漏扫未发现安全漏洞			

附录F 渗透测试结果记录

F.1 暴力破解

截图	系统不存在验证码机制，可直接进行暴力破解 
漏洞类别	身份认证漏洞
漏洞位置	https://www.etrading.cn/HXTPFrame/rest/customframe4bid/loginaction/login?isCommondto=true
风险等级	中风险
漏洞说明及危害	暴力破解（Brute Force Attack）是一种尝试所有可能的组合来找到正确密码或密钥的攻击方法。攻击者通常使用自动化工具，通过不断猜测用户名和密码的组合，直到找到正确的配对为止。这种攻击方式虽然效率较低，但当密码较弱时，可以非常有效。 暴力破解攻击可以针对各种系统和服务，包括但不限于：登录界面（如

	Web 应用、SSH、FTP 等)、加密文件、无线网络。 一旦成功，攻击者可以获得未经授权的访问权限，并可能进行进一步的恶意活动，如数据窃取、系统破坏或安装恶意软件。
解决方法	1.使用多因素认证 (MFA)：引入第二层身份验证机制，例如短信验证码、生物识别或硬件令牌，即使密码被猜中，也需要额外的身份验证信息才能登录。 2.增强密码复杂度要求： 强制用户设置足够复杂的密码，包括大小写字母、数字及特殊字符。定期更新密码，并禁止使用常见的弱口令。 3.引入 CAPTCHA 机制： 在登录表单中添加 CAPTCHA（完全自动化的公共图灵测试以区分计算机和人类),增加自动化工具执行暴力破解的难度。 4.采用慢速哈希算法： 对于存储在数据库中的密码，使用慢速哈希算法（如 bcrypt, scrypt, Argon2）进行加密，这样即使数据库泄露，攻击者也难以快速破解密码。 5.使用专门的安全工具和服务： 利用专业的安全解决方案，如 Web 应用防火墙(WAF)、入侵检测系统(IDS)等，它们能够帮助识别并阻止暴力破解尝试。

附录G 重大风险隐患触发项参照表

网络安全等级保护测评过程中，针对等级测评结果中存在的所有安全问题，应采用风险分析的方法进行危害分析和重大风险隐患评估,分析所产生的安全问题被威胁利用的可能性,判断其被威胁利用后对业务信息安全和系统服务安全造成影响的程度，综合评价对定级对象造成的重大风险隐患。

基于以下判定原则，同时符合下列所有条件的安全问题应当判定为重大风险隐患：

——相关性原则：基于网络安全等级保护测评中发现的、可能导致系统面临高风险的安全问题，且针对该问题未采取任一缓解措施；

——严重性原则：安全事件一旦发生后将造成严重后果,包括导致业务中断、重要数据泄露或被篡改，获得系统管理权限或业务权限等；

——高发性原则：在实际运行中由该问题导致的安全事件发生概率较大。

附录 G 表-1 重大风险隐患触发项参照表

序号	安全类	安全子类	测评项	重大风险隐患触发项	安全问题描述
1	安全物理环境	物理访问控制	机房出入口应配置电子门禁系统，控制、鉴别和记录进入的人员。	机房出入口访问控制措施缺失	1) 机房出入口无任何访问控制措施，例如未安装电子或机械门锁（包括机房大门处于未上锁状态），且机房门口无专人值守等； 2) 其他。
2		室外控制设备物理防护	室外控制设备应放置于采用铁板或其他防火材料制作的箱体或装置中并紧固；箱体或装置具有透风、散热、防盗、防雨和防火能力等。	室外控制设备防护缺失	1) 室外控制设备裸露放置、无固定措施，无法做到防水、防盗和防火； 2) 放置控制设备的箱体或装置不具有相关检测验收报告，不具有透风、散热、防盗、防雨和防火能力； 3) 其他。
3	安全通信网络	网络架构	应保证网络设备的业务处理能力满足业务高峰期需要。	网络设备业务处理能力不足	1) 网络设备、安全设备等网络链路上的关键设备性能无法满足高峰期需求； 2) 其他。
4		网络架构	应实现不同云服务客户虚拟网络之间的隔离。	云计算平台虚拟网络隔离措施缺失	1) 云计算平台未采取网络隔离技术实现不同云服务客户虚拟网络之间的隔离；

序号	安全类	安全子类	测评项	重大风险隐患触发项	安全问题描述
					2) 其他。
5		网络架构	应具有根据云服务客户业务需求提供通信传输、边界防护、入侵防范等安全机制的能力。	云计算平台未提供安全防护能力	1) 云计算平台无法提供满足云服务客户业务需要的通信传输、边界防护、入侵防范等安全机制； 2) 其他。
6		网络架构	工业控制系统与企业其他系统之间应划分为两个区域，区域间应采用单向的技术隔离手段。	工业控制系统网络隔离措施缺失	1) 工业控制系统与企业其他系统之间未划分单独的网络区域； 2) 数据交互未采用单向隔离装置或单向隔离装置未配置有效的访问控制策略； 3) 其他。
7		网络架构	工业控制系统内部应根据业务特点划分为不同的安全域，安全域之间应采用技术隔离手段。	工业控制系统所在网络区域划分不当，访问控制措施缺失	1) 工业控制系统所在的生产网络未根据不同工业控制系统业务特点划分不同安全域； 2) 不同安全域之间无任何访问控制措施或访问控制措施无效； 3) 其他。
8		通信传输	在工业控制系统内使用广域网进行控制指令或相关数据交换的应采用加密认证技术手段实现身份	工业控制系统广域网传输控制指令防护措施缺失	1) 未使用基于密码技术的身份鉴别技术； 2) 未使用密码技术保证数据传输

序号	安全类	安全子类	测评项	重大风险隐患触发项	安全问题描述
			认证、访问控制和数据加密传输。		过程中的完整性和保密性； 3) 其他。
9	安全区域边界	边界防护	应保证跨越边界的访问和数据流通过边界设备提供的受控接口进行通信。	网络边界接入设备或端口不可控	1) 网络边界链路接入设备未配置明确的上联链路端口； 2) 网络边界链路接入设备端口 IP 及路由策略不明确； 3) 网络边界链路接入设备未关闭不使用的端口； 4) 其他。
10		边界防护	应限制无线网络的使用，保证无线网络通过受控的边界设备接入内部网络。	无线网络管控措施缺失	1) 内部重要网络与无线网络互联，且不通过任何受控的边界设备或边界设备访问控制策略设置不当； 2) 其他。
11		访问控制	应在网络边界或区域之间根据访问控制策略设置访问控制规则，默认情况下除允许通信外受控接口拒绝所有通信。	重要网络区域边界访问控制措施缺失或配置不当	1) 重要网络区域与其他网络区域之间（包括内部区域边界和外部区域边界）访问控制设备缺失或访问控制措施失效； 2) 其他。
12		访问控制	应在工业控制系统与企业其他系	工业控制系统与企业其他系统之	1) 工业控制系统与企业其他系统

序号	安全类	安全子类	测评项	重大风险隐患触发项	安全问题描述
			统之间部署访问控制设备，配置访问控制策略，禁止任何穿越区域边界的 E-Mail、Web、Telnet、Rlogin、FTP 等通用网络服务。	间未对通用网络服务进行限制	之间未部署访问控制设备； 2) 工业控制系统与企业其他系统之间未对任何通用的网络服务如 E-Mail、WEB、Telnet、Rlogin、FTP 等进行限制； 3) 其他。
13		入侵防范	应在关键网络节点处检测、防止或限制从外部发起的网络攻击行为。	外部网络攻击防御措施缺失	1) 关键网络节点无任何网络攻击行为检测手段和防护手段； 2) 网络攻击行为检测措施的策略库/规则库半年及以上未更新； 3) 其他。
14		入侵防范	应在关键网络节点处检测、防止或限制从内部发起的网络攻击行为。	内部网络攻击防御措施缺失	1) 关键网络节点无任何网络攻击行为检测手段和防护手段； 2) 网络攻击行为检测措施的策略库/规则库半年及以上未更新； 3) 其他。
15		入侵防范	应采取技术措施对网络行为进行分析，实现对网络攻击特别是新型网络攻击行为的分析。	网络行为分析措施缺失	1) 关键网络节点对新型网络攻击行为网络访问行为无任何分析手段，例如未部署抗 APT 系统、全流量分析系统、沙箱系统、具备行为分析功能的态势感知系统、

序号	安全类	安全子类	测评项	重大风险隐患触发项	安全问题描述
	安全计算环境				威胁情报系统等； 2) 基于威胁情报、行为分析模型进行行为分析的安全措施，半年及以上未更新威胁情报库、事件分析模型，无法满足防护需求； 3) 其他。
16		入侵防范	应能检测到云服务客户发起的网络攻击行为，并能记录攻击类型、攻击时间、攻击流量等。	云计算平台网络攻击防御措施缺失	1) 云计算平台对云服务客户发起的网络攻击行为无任何检测手段； 2) 网络攻击行为检测措施的策略库/规则库半年及以上未更新； 3) 其他。
17		接入控制	应保证只有授权的感知节点可以接入。	非授权感知节点设备能够接入网络中	1) 感知节点设备（例如感知节点接入网关、传感器等设备）未经授权可以接入网络； 2) 其他。
18	安全计算环境	身份鉴别	应对登录的用户进行身份标识和鉴别，身份标识具有唯一性，身份鉴别信息具有复杂度要求并定期更换。	存在空口令、弱口令、通用口令或无身份鉴别措施	1) 存在可登录的空口令账户、无身份鉴别措施或身份鉴别措施可被绕过等； 2) 存在可登录的弱口令账户，如长度在 6 位以下，或存在单个、

序号	安全类	安全子类	测评项	重大风险隐患触发项	安全问题描述
					相同、连续数字/字母/字符及常见字典等易猜测的口令； 3) 多个不同被测对象的管理账户口令相同、或同一被测对象中多个不同管理账户口令相同； 4) 其他。
19		身份鉴别	应采用口令、密码技术、生物技术等两种或两种以上组合的鉴别技术对用户进行身份鉴别，且其中一种鉴别技术至少应使用密码技术来实现。	未采用两种或两种以上组合身份鉴别技术	1) 未采用两种或两种以上组合鉴别技术对用户进行身份鉴别； 2) 其他。
20		访问控制	应由授权主体配置访问控制策略，访问控制策略规定主体对客体的访问规则。	访问控制策略存在缺陷或不完善，存在越权访问可能	1) 业务应用系统/平台访问控制策略存在缺陷或不完善，可非授权访问系统功能模块或查看、操作其他用户的数据； 2) 数据库管理系统访问控制策略存在缺陷或不完善，存在数据库的超级管理员权限被授予非数据库管理员用户、或数据库的默认超级管理员账户被用于非数据库管理用途；

序号	安全类	安全子类	测评项	重大风险隐患触发项	安全问题描述
					3) 操作系统访问控制策略存在缺陷或不完善。存在以操作系统超级管理员权限运行的数据库、中间件、应用程序等非操作系统级进程或服务； 4) 其他。
21		入侵防范	应关闭不需要的系统服务、默认共享和高危端口。	开启多余的系统服务、默认共享和高危端口	1) 开启多余的系统服务、默认共享和高危端口，且可被远程访问； 2) 其他。
22		入侵防范	应能发现可能存在的已知漏洞，并在经过充分测试评估后，及时修补漏洞。	存在可被利用的高危安全漏洞	1) 通过互联网管理或访问的系统或设备，存在外界披露的可被利用的高危安全漏洞； 2) 通过非互联网等公共通信网络管理或访问的系统或设备，经测试验证确认存在缓冲区溢出、越权访问、远程代码执行等可被利用的高危安全漏洞； 3) 其他。
23		恶意代码防范	应采用免受恶意代码攻击的技术措施或主动免疫可信验证机制及	恶意代码防范措施缺失	1) 未采取恶意代码检测和清除措施；

序号	安全类	安全子类	测评项	重大风险隐患触发项	安全问题描述
			时识别入侵和病毒行为，并将其有效阻断。		2) 恶意代码防范产品授权已过期； 3) 恶意代码特征库、规则库等一个月以上未更新； 4) 其他。
24		数据保密性	应采用密码技术保证重要数据在传输过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等。	重要数据明文传输	1) 鉴别信息、重要个人信息或重要业务数据等以明文的方式在网络环境中传输； 2) 其他。
25		数据保密性	应采用密码技术保证重要数据在存储过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等。	重要数据明文存储	1) 鉴别信息、重要个人信息、具有保密性需求的重要业务数据以明文的方式存储； 2) 其他。
26		数据备份恢复	应提供重要数据的本地数据备份与恢复功能。	重要数据无本地备份措施	1) 重要数据未提供任何数据备份措施； 2) 重要数据备份到互联网网盘或相关存储环境； 3) 其他。
27	综合类	——	——	获取被测系统关联系统权限	1) 获取了最高管理员权限或子管理员权限或普通用户权限；

序号	安全类	安全子类	测评项	重大风险隐患触发项	安全问题描述
					2) 其他。
28		——	——	获取被测系统权限	1) 获取了被测系统权限； 2) 其他。
29		——	——	互联网暴露面过宽	1) 大型专网未能有效收口； 2) 移动应用后台接口成为新的暴露点； 3) 应用私搭乱建，管理不到位，存在防护盲区； 4) 违规打通内网与互联网连接； 5) 第三方接入缺乏安全管理与整体管控； 6) 其他。
30		——	——	数据管理不规范	1) 违背最小化原则信息量泄露过多； 2) 数据传输、存储、备份不规范； 3) 其他。
31		——	——	“神经中枢”系统缺乏重点加固	1) 集权系统鉴别机制存在缺陷； 2) 管理后台自身架构存在漏洞； 3) 集权系统支撑环境存在漏洞；

序号	安全类	安全子类	测评项	重大风险隐患触发项	安全问题描述
					4) 域控系统缺乏重点防护措施； 5) 其他。
32		——	——	安全管理运维水平不足	1) 供应链管控不力，成为迂回攻击跳板； 2) 网络资产底数不清晰，老旧资产、测试系统未下线； 3) 基层单位安全防护能力薄弱，极易成为攻击突破口； 4) 员工安全意识不足，易被社工攻击利用； 5) 公开漏洞未修复； 6) 0Day 漏洞攻击难以监测发现； 7) 网络安全监测存在盲点导致难以及时发现隐蔽入侵行为，缺乏对攻击监测数据的分析； 8) 其他。

附录H 重大风险隐患及整改情况

经过单项测评结果判定和整体测评，未发现“新点 e 交易”电子交易平台存在重大风险隐患。

附录I 威胁列表

附录 I 表-1 威胁列表

序号	威胁分（子）类	威胁描述
1	恶意攻击	利用工具和技术对信息系统进行攻击和入侵。
2	软硬件故障	对业务实施或系统运行产生影响的设备硬件故障、通讯链路中断、系统本身或软件缺陷等问题。
3	管理不到位	由于制度缺失、不完善等原因导致安全管理无法落实或者不到位。
4	无作为或操作失误	应该执行而没有执行相应的操作，或者无意执行了错误的操作。
5	敏感信息泄露	敏感信息泄露给不应了解的他人。
6	物理环境影响	对信息系统正常运行造成影响的物理环境问题和自然灾害。
7	越权或滥用	越权访问本来无权访问的资源，或者滥用自己的权限破坏信息系统。
8	物理攻击	通过物理的接触造成对软件、硬件和数据的破坏。
9	篡改	非法修改信息，破坏信息的完整性使系统的安全性降低或信息不可用。
10	抵赖	否认所做的操作。
11	物理损害	对业务实施或系统运行产生影响的物理损害。
12	自然灾害	自然界中所发生的异常现象，且对业务开展或者系统运行会造成危害的现象和事件。
13	信息损害	对系统或资产中的信息产生破坏、篡改、丢失、盗取等行为。
14	技术失效	信息系统所依赖的软硬件设备不可用。

序号	威胁分（子）类	威胁描述
15	未授权行为	超出权限设置或授权进行操作或者使用的行为。
16	功能损害	造成业务或系统运行的部分功能不可用或者损害。
17	供应链失效	业务或系统所依赖的供应商、接口等不可用。

附录J 云计算平台测评及整改情况

云计算平台测评报告内容如下：



报告编号: 44030002840-25001-25-0162-01
文档编号: DB-20250530-F0204-01R1



华为公有云服务 (IaaS) 系统

网络安全等级保护测评报告

被测单位: 华为云计算技术有限公司

测评单位: 深圳市网安计算机安全检测技术有限公司

报告时间: 2025 年 10 月 08 日

报告编号：44030002840-25001-25-0162-01

【2025 版】

网络安全等级测评基本信息表

被测对象				
被测对象名称	华为公有云服务（IaaS）系统		安全保护等级	第三级（S3A3）
备案证明编号	440300-02840-25001		统一社会信用代码	91520900MA6J6CBN9Q
被测单位				
单位名称	华为云计算技术有限公司			
单位地址	深圳市龙岗区华为基地		邮政编码	518000
联系人	姓 名	金培松	职务/职称	主任工程师
	所属部门	华为云计算安全与隐私保护办公室	办公电话	0755-23656083
	移动电话	15899856730	电子邮件	jinpeisong@huawei.com
测评单位				
单位名称	深圳市网安计算机安全检测技术有限公司		机构代码	SC202127130010162
单位地址	深圳市南山区学苑大道 1001 号南山智园 C1 栋 13 楼		邮政编码	518055
联系人	姓 名	石松奇	职务/职称	副总经理
	所属部门	行政部	办公电话	0755-83764999
	移动电话	13714833734	电子邮件	root@szcert.org
审核批准	编 制 人	黄光平	编制日期	2025.10.8
	审 核 人	牛建红	审核日期	2025.10.8
	批 准 人	张 强	批准日期	2025.10.8

报告编号：44030002840-25001-25-0162-01

【2025 版】

声明

本报告是华为公有云服务（IaaS）系统（备案证明编号：440300-02840-25001）的等级测评报告。

本报告是对华为公有云服务（IaaS）系统的整体安全性进行检测分析，针对等级测评过程中发现的安全问题，结合风险分析，提出合理化建议。

本报告测评结论的有效性建立在被测评单位提供相关证据的真实性基础之上。

本报告在测评师现场测评被测对象的个人信息合法采集、保存、访问、使用的检测过程中，仅对被测对象当前已检测内容和检测范围情况进行符合性判断。如因被测对象相关人员采取隐匿、欺骗等方式违法违规处理个人信息，致使测评师无法客观作出测评结论，本报告不再适用。

本报告中给出的测评结论仅对被测信息系统当时的安全状态有效，并仅适用于此次测评过程中所抽样设备及系统。当测评工作完成后，由于信息系统发生变更而涉及到的系统构成组件（或子系统）都应重新进行等级测评，本报告不再适用。

本报告中给出的测评结论不能作为对信息系统内部部署的相关系统构成组件（或产品）的测评结论。

在任何情况下，若需引用本报告中的测评结果或结论都应保持其原有的意义，不得对相关内容擅自进行增加、修改和伪造或掩盖事实。未经本机构批准，任何情况下不得复制（全文复制除外）报告。

深圳市网安计算机安全检测技术有限公司
2025 年 10 月 08 日

声明

II

报告编号：44030002840-25001-25-0162-01

【2025 版】

等级测评结论

测评结论和重大风险隐患			
被测对象名称	华为公有云服务（IaaS）系统	安全保护等级	第三级（S3A3）
扩展要求应用情况	☒ 云计算 ☐ 移动互联 ☐ 物联网 ☐ 工业控制系统 ☐ 大数据 ☐ 其他_____		
被测对象描述	（一）华为公有云服务(IaaS)系统主要面向泛互联网、政府、金融、大中型企业提供包括计算（弹性云服务器、GPU 加速云服务器、FPGA 加速云服务器、裸金属服务器 BMS、云手机、专属主机、弹性伸缩、镜像服务、华为云云耀云服务器、Huawei Cloud EulerOS）、容器（云容器引擎、云容器实例、容器镜像服务、华为云 UCS）、存储（对象存储服务、云硬盘、云备份、专属分布式存储服务、云硬盘备份、云服务器备份、存储容灾服务、弹性文件服务、数据工坊、数据快递服务、云存储网关、地图数据服务）、网络（虚拟私有云、VPC 终端节点、弹性负载均衡、NAT 网关、弹性公网 IP、云专线、云连接、企业连接、全球加速、企业交换机、企业路由器、虚拟专用网络）、CDN 与智能边缘（内容分发网络、全站加速、智能边缘云、智能边缘小站、智能边缘平台）、企业应用（域名注册服务、云解析服务、企业邮箱、网站备案、资源专属服务、全栈专属服务、云桌面、移动业务加速服务、云管理网络、SD-WAN 云服务、边缘数据中心管理、云客服、专属计算集群服务）、管理与监管（云监控服务、资源编排服务（原应用编排服务）、消息通知服务、应用身份管理服务 OneAccess、资源访问管理、组织、资源管理服务、优化顾问）、开发与运维（研发安全服务）、开天 aPaaS（企业搜索服务）、华为云 Stack 等业务，系统安全方案按照等级保护标准要求设计和建设，结合华为优秀实践，实现多层次纵深防护体系。（二）华为公有云服务(IaaS)系统覆盖多个节点，包括北京汇天数据中心、廊坊基地数据中心、廊坊润泽数据中心、廊坊万国数据中心（万国平安园区 M1）、廊坊万国数据中心（万国创新产业中心）、乌兰察布 B 区数据中心、乌兰察布 C 区数据中心、乌兰察布 D 区数据中心、北京中金机房、和林格尔 CDC（云谷西区 A01）、和林格尔 CDC（云谷南区 B01）、和林格尔 CDC（云谷北区 C01）、上海宝信蓝川数据中心（四期）、上海宝信蓝川数据中心（二期）、上海万国数据中心、上海光环数据中心、上海周浦数据中心、上海移动数据中心、苏州吴江数据中心、苏州国科数据中心、苏州桑田岛机房、昆山坤汇机房、青岛数据中心、青岛 CDC（胶州卡奥斯）、青岛 CDC（黄岛联通）、芜湖北区数据中心、芜湖职教园数据中心、芜湖三山数据中心、广州加速器数据中心、东莞松湖 CDC、深圳观澜机房、深圳奕峰机房、广州联通化龙数据中心、广州联通名美数据中心、广州云埔数据中心、贵阳电信机房、贵阳 CDC、贵阳高端园数据中心、贵阳马场 CDC 等。		

等级测评结论

III

报告编号：44030002840-25001-25-0162-01

【2025 版】

安全状况描述	被测系统的物理布局、网络结构和业务逻辑等在整体结构上合理安全。在物理上，被测系统的重要设备均固定在机柜中，机房具有严格访问控制、防火、防水防潮、防破坏等能力，并严格限制了外部人员的物理访问。在网络上，被系统网络边界采取防火墙隔离，实施边界防护和访问控制。操作系统、应用系统、数据库等各种业务应用平台都采取了基本的身份鉴别、访问控制、审计、资源控制等安全措施，在入侵防范和恶意代码防护上，采用防火墙、防病毒软件等安全指施；总体来看，安全技术方面具有基本安全保障能力。在安全管理方面，被测系统所属单位已经建立了基本的信息安全管理体系，建立了相应的安全组织，设置了相应的安全部门和岗位，制订了安全管理制度，并在日常管理中依照制度要求执行，信息系统日常运行维护，如外来人员访问管理系统，安全管理和网络安全管理等方面，拥有较完善的流程和规范。总体来看，安全管理方面具有安全保障能力。 本次安全等级测评共发现华为公有云服务（IaaS）系统存在高风险问题 0 个，中风险问题 0 个，低风险问题 16 个。华为公有云服务（IaaS）系统技术方面尚有一些问题需要整改和完善，信息安全管理体系执行情况还可以进一步提高。		
等级测评结论	符合	重大风险隐患数量	0

等级测评结论

IV

报告编号：44030002840-25001-25-0162-01

【2025 版】

重大风险隐患及整改建议

经过单项测评结果判定和整体测评，未发现华为公有云服务（IaaS）系统存在重大风险隐患。



重大风险隐患及整改建议

V

报告编号：44030002840-25001-25-0162-01

【2025 版】

等级测评结论扩展表（云计算安全）

等级测评结论扩展表（云计算安全）		
被测对象 云计算形态	☒ 云计算平台 ☐ 云服务客户业务应用系统（平台报告编号：）	
云计算平台 名称	华为公有云服务（IaaS）系统	被测对象采用的 云计算服务模式 ☒ IaaS ☐ PaaS ☐ SaaS
云计算平台服务能力描述		
云计算安全扩展主要要求		符合情况
基础设施位置	a) 应保证云计算基础设施位于中国境内。	符合
网络架构	a) 应保证云计算平台不承载高于其安全保护等级的业务应用系统；	符合
	b) 应实现不同云服务客户虚拟网络之间的隔离；	符合
	c) 应具有根据云服务客户业务需求提供通信传输、边界防护、入侵防范等安全机制的能力；	符合
	d) 应具有根据云服务客户业务需求自主设置安全策略的能力，包括定义访问路径、选择安全组件、配置安全策略；	符合
	e) 应提供开放接口或开放性安全服务，允许云服务客户接入第三方安全产品或在云计算平台选择第三方安全服务。	符合
访问控制	a) 应在虚拟化网络边界部署访问控制机制，并设置访问控制规则；	符合
	b) 应在不同等级的网络区域边界部署访问控制机制，设置访问控制规则。	符合
入侵防范	a) 应能检测到云服务客户发起的网络攻击行为，并能记录攻击类型、攻击时间、攻击流量等；	符合
	b) 应能检测到对虚拟网络节点的网络攻击行为，并能记录攻击类型、攻击时间、攻击流量等；	符合
	c) 应能检测到虚拟机与宿主机、虚拟机与虚拟机之间的异常流量；	符合
	d) 应在检测到网络攻击行为、异常流量情况进行告警。	符合
安全审计	a) 应对云服务商和云服务客户在远程管理时执行的特权命令进行审计，至少包括虚拟机删除、虚拟机重启；	符合

等级测评结论扩展表（云计算安全）

VI

报告编号：44030002840-25001-25-0162-01		【2025 版】
	b) 应保证云服务商对云服务客户系统和数据的操作可被云服务客户审计。	符合
身份鉴别	a) 当远程管理云计算平台中设备时，管理终端和云计算平台之间应建立双向身份验证机制。	符合
访问控制	a) 应保证当虚拟机迁移时，访问控制策略随其迁移；	符合
	b) 应允许云服务客户设置不同虚拟机之间的访问控制策略。	符合
入侵防范	a) 应能检测虚拟机之间的资源隔离失效，并进行告警；	符合
	b) 应能检测非授权新建虚拟机或者重新启用虚拟机，并进行告警；	符合
	c) 应能够检测恶意代码感染及在虚拟机间蔓延的情况，并进行告警。	符合
镜像和快照保护	a) 应针对重要业务系统提供加固的操作系统镜像或操作系统安全加固服务；	符合
	b) 应提供虚拟机镜像、快照完整性校验功能，防止虚拟机镜像被恶意篡改；	符合
	c) 应采取密码技术或其他技术手段防止虚拟机镜像、快照中可能存在的敏感资源被非法访问。	符合
数据完整性和保密性	a) 应确保云服务客户数据、用户个人信息等存储于中国境内，如需出境应遵循国家相关规定；	符合
	b) 应确保只有在云服务客户授权下，云服务商或第三方才具有云服务客户数据的管理权限；	符合
	c) 应使用校验技术或密码技术确保虚拟机迁移过程中重要数据的完整性，并在检测到完整性受到破坏时采取必要的恢复措施；	符合
	d) 应支持云服务客户部署密钥管理解决方案，保证云服务客户自行实现数据的加解密过程。	符合
数据备份恢复	a) 云服务客户应在本地保存其业务数据的备份；	符合
	b) 应提供查询云服务客户数据及备份存储位置的能力。	符合
	c) 云服务商的云存储服务应保证云服务客户数据存在若干个可用的副本，各副本之间的内容应保持一致；	符合
	d) 应为云服务客户将业务系统及数据迁移到其他云计算平台和本地系统提供技术手段，并协助完成迁移过程。	符合

等保测评结论扩展表（云计算安全）

VII

报告编号：44030002840-25001-25-0162-01		【2025 版】	
剩余信息保护	a) 应保证虚拟机所使用的内存和存储空间回收时得到完全清除；	符合	
	b) 云服务客户删除业务应用数据时，云计算平台应将云存储中所有副本删除。	符合	
集中管控	a) 应对物理资源和虚拟资源按照策略做统一管理调度与分配；	符合	
	b) 应保证云计算平台管理流量与云服务客户业务流量分离；	符合	
	c) 应根据云服务商和云服务客户的职责划分，收集各自控制部分的审计数据并实现各自的集中审计；	符合	
	d) 应根据云服务商和云服务客户的职责划分，实现各自控制部分，包括虚拟化网络、虚拟机、虚拟化安全设备等的运行状况的集中监测。	符合	
云服务商选择	a) 应选择安全合规的云服务商，其所提供的云平台应为其所承载的业务应用系统提供相应等级的安全保护能力；	符合	
	b) 应在服务水平协议中规定云服务的各项服务内容和具体技术指标；	符合	
	c) 应在服务水平协议中规定云服务商的权限与责任，包括管理范围、职责划分、访问授权、隐私保护、行为准则、违约责任等；	符合	
	d) 应在服务水平协议中规定服务合约到期时，完整提供云服务客户数据，并承诺相关数据在云计算平台上清除；	符合	
	e) 应与选定的云服务商签署保密协议，要求其不得泄露云服务客户数据。	符合	
供应链管理	a) 应确保供应商的选择符合国家有关规定；	符合	
	b) 应将供应链安全事件信息或安全威胁信息及时传达到云服务客户；	符合	
	c) 应将供应商的重要变更及时传达到云服务客户，并评估变更带来的安全风险，采取措施对风险进行控制。	符合	
云计算环境管理	a) 云计算平台的运维地点应位于中国境内，境外对境内云计算平台实施运维操作应遵循国家相关规定。	符合	
云计算平台等级测评结论	符合	云计算平台重大风险隐患数量	0

等保测评结论扩展表（云计算安全）

VIII

【全文结束】